

江苏省第四届数据安全技 术应用职业技能竞赛公开 题（1806 题）

"Q1、修订后的《中华人民共和国网络安全法》自
（ ）起施行。

- A、2025-10-28
- B、2025-12-01
- C、2026-01-01
- D、2026-06-01

答案:C"

Q2、数据合规培训对象应包括全体员工，而非仅限
技术和管理人员。（正确）

"Q3、某企业数据资产识别工具将""内部员工工号""
误标为公开数据。应？

- A、修正分类规则，工号属内部标识需限制访问
- B、维持误标
- C、删除工号字段
- D、仅内部使用即可

答案:A"

"Q4、在数据出境安全评估中，若境外接收方拟将接
收的数据再转移给第三方，最应关注的是（ ）。

- A、转移条件、边界、控制措施与责任链条是否已被
约束
- B、接收方办公楼层高
- C、接收方品牌 Logo
- D、终端硬件资产管理配置

答案:A"

"Q5、Oracle 中的三种核心系统文件分别是？

- A、数据文件 DBF
- B、控制文件 CTL
- C、日志文件 LOG
- D、归档文件 ARC

答案:ABC"

"Q6、主体通常是什么？

- A、文件
- B、用户
- C、应用服务
- D、数据

答案:B"

"Q7、在云计算中，多租户隔离问题主要与以下哪方
面安全有关（ ）。

- A、网络带宽
- B、操作系统更新
- C、数据访问控制和虚拟化安全
- D、用户界面优化

答案:C"

"Q8、在 RSA 算法中，取 $p=3$ ， $q=11$ ， $e=3$ ，则 d
等于多少？（ ）

- A、33
- B、20
- C、7
- D、14

答案:C"

"Q9、某企业应急处置中“补丁已打完”但未验证攻
击面是否真正关闭。该处置缺陷在于（ ）。

- A、缺少修复有效性验证
- B、补丁数量不足

- C、日志太多
- D、告警阈值过高

答案:A"

"Q10、有 A 和 B 二人互相比收入，在双方互不泄露自己收入的场景下，那种隐私计算技术能比较出二人收入高低（ ）？

- A、零知识证明
- B、联邦学习
- C、安全多方计算
- D、数据脱敏

答案:C"

"Q11、以下哪种做法不能保护隐私数据（ ）

- A、将年龄值 30 岁的个体泛化为年龄段为 30-40 岁
- B、将原始数据中的薪资值加上一个随机的偏移量
- C、将原始数据集中两个不同个体的出生日期进行交换
- D、将增加原始数据集的数据量

答案:D"

"Q12、根据《数据安全法》的规定，重要数据的处理者应当按照规定对其数据处理活动定期开展风险评估，并向有关主管部门报送风险评估报告。风险评估报告应当包括哪些内容？

- A、重要数据的种类
- B、重要数据的数量
- C、开展数据处理活动的情况
- D、面临的数据安全风险及其应对措施

答案:ABCD"

"Q13、以下哪些是身份认证系统必需的组成部分？

- A、认证服务器
- B、认证系统客户端
- C、物理认证设备（如指纹仪）

- D、认证协议
- E、认证数据库

答案:ABDE"

"Q14、在安全测试报告中，仅列出漏洞列表而不提供“复现路径、影响范围、修复建议”，最大的缺陷是（ ）。

- A、无法有效支撑整改落地与优先级管理
- B、会提升系统吞吐量
- C、会降低日志留存需求
- D、会自动修复漏洞

答案:A"

"Q15、以下哪些是访问控制主要产品的技术特点？

- A、利用网络数据包信息和安全威胁特征库进行访问控制
- B、通过物理隔离来保护系统资源
- C、提供用户账号管理和权限分配功能
- D、支持数据库访问控制
- E、实现端到端加密通信

答案:ACD"

"Q16、某企业数据资产识别工具对非结构化数据（如合同 PDF）解析失败。应？

- A、放弃合同数据治理
- B、要求员工全部转为 Excel
- C、引入 NLP/OCR 技术提升非结构化数据识别能力
- D、仅处理结构化数据

答案:C"

Q17、根据《中华人民共和国个人信息保护法》的规定，个人信息处理者共同处理个人信息，侵害个人信息权益造成损害的，应当依法承担连带责任。（正确）

"Q18、利用""网络爬虫技术""获取公开信息时，应（ ）。

- A、注意目标网站的 Robots 协议的具体内容和限制
- B、使用过程中不需要甄别""网络爬虫""收集的信息的权属
- C、严格管控数据采集的范围，不超范围采集
- D、涉及个人信息的需慎重评价

答案:ACD"

"Q19、角色基础访问控制模型（RBAC）是基于什么来确定用户的访问权限？

- A、用户属性
- B、资源属性
- C、用户角色
- D、环境属性

答案:C"

Q20、脱敏后的数据可能会对数据的可用性造成影响。（正确）

"Q21、《网络数据安全条例》共有多少章、多少条？

- A、7 章，50 条
- B、8 章，60 条
- C、9 章，64 条
- D、10 章，70 条

答案:C"

"Q22、某企业数据资产目录中，某数据表无业务责任人标注。治理要求应？

- A、默认归 IT 部门
- B、交由外部审计指定
- C、明确数据 Owner 与 Steward，落实管理责任
- D、不标注不影响使用

答案:C"

Q23、Oracle 数据库中，Truncate 命令可以删除整个表中的数据，并且无法回滚。（正确）

"Q24、以下哪些是用户访问管理的主要内容？

- A、用户登记和认证
- B、用户权限分配和授权
- C、访问记录和审计
- D、权限监测和修改
- E、用户培训和教育

答案:ABCD"

Q25、仅影响组织自身或者公民个体的数据一般不作为重要数据。（正确）

"Q26、在存储用户个人信息时，以下哪种做法是合规的？

- A、存储用户的全名和地址
- B、存储用户的敏感信息，但不加密
- C、只存储业务所必需的信息
- D、存储所有用户信息，包括敏感信息

答案:C"

"Q27、访问控制包含哪三个要素？

- A、主体、客体、控制策略
- B、服务器、数据库、客户端
- C、用户名、密码、验证码
- D、IP 地址、端口号、协议类型

答案:A"

Q28、数据交易应当遵循自愿原则。（正确）

"Q29、根据《个人信息保护合规审计管理办法》，处理超过多少人个人信息的个人信息处理者，应当每两年至少开展一次个人信息保护合规审计？

- A、100 万人
- B、500 万人
- C、1000 万人
- D、5000 万人

答案:C"

"Q30、区块链最早应用于下列哪个领域？

- A、金融和数字货币
- B、社交媒体
- C、游戏开发
- D、医疗保健

答案:A"

Q31、《人工智能生成合成内容标识办法》要求服务提供者对 AI 生成内容仅需添加显式标识，不需要隐式标识。（错误）

Q32、当发生数据出境活动存在较大风险或者发生数据安全事件时，数据处理者应当采取补救措施，并及时向省级以上网信部门报告。（正确）

"Q33、某互联网平台数据资产识别发现某数据库含大量明文密码。治理团队应？

- A、忽略，内部系统安全
- B、立即推动密码哈希化改造，开展漏洞修复
- C、仅更新管理制度
- D、交由 DBA 处理

答案:B"

"Q34、违反《中华人民共和国数据安全法》关于配合数据调取的规定，拒不配合数据调取的，由有关主管部门责令改正，给予警告，并处五万元以上五十万元以下罚款，对直接负责的主管人员和其他直接责任人员处（ ）罚款。

- A、五千元以上一万元以下
- B、一万元以上十万元以下
- C、五万元以上五十万元以下
- D、二十万元以上一百万元以下

答案:B"

"Q35、有关部门组织开展关键信息基础设施安全检测评估，可采取下列措施（ ）。

- A、要求运营者相关人员就检测评估事项作出说明

- B、查阅、调取、复制与安全保护有关的文档、记录
- C、经运营者同意的其他必要方式
- D、查看网络安全管理制度制订、落实情况以及网络安全技术措施规划、建设、运行情况

答案:ABCD"

"Q36、数据安全应急复盘的主要目标包括哪些？

- A、识别根因
- B、验证响应流程缺陷
- C、形成预防性改进措施
- D、回避责任讨论，尽快结案

答案:ABC"

"Q37、若一条数据血缘链条缺失“外部共享”节点信息，最直接影响的是（ ）。

- A、无法准确回溯数据对外流转路径
- B、系统 CPU 占用率升高
- C、数据库索引自动失效
- D、网络带宽自动降低

答案:A"

"Q38、一个人的面部特征是属于（ ）的个人信息。

- A、重要
- B、敏感
- C、公开
- D、隐私

答案:B"

"Q39、某企业安全开发生命周期（SDL）缺失，导致上线系统含已知漏洞。应？

- A、仅上线前测试
- B、交由运维修补
- C、忽略已知漏洞
- D、将安全需求、代码扫描、渗透测试嵌入研发全流程

答案:D"

"Q40、当发生数据出境活动存在较大风险或者发生数据安全事件时，数据处理者应当采取什么措施？

- A、无需采取任何措施
- B、立即停止所有数据出境活动
- C、自行决定如何处理
- D、采取补救措施，并及时向省级以上网信部门报告

答案:D"

"Q41、下列说法正确的是：

- A、处理个人信息应当遵循公开、透明原则，公开个人信息处理规则，明示处理的目的、方式和范围
- B、处理个人信息不用保证个人信息的质量，个人信息不准确、不完整不会对个人权益造成不利影响
- C、收集个人信息，可以不限于实现处理目的的最小范围，可以过度收集个人信息
- D、个人信息处理者应当对其个人信息处理活动负责，并采取必要措施保障所处理的个人信息的安全

答案:AD"

"Q42、POS 是指（ ）。

- A、工作量证明
- B、零知识证明
- C、权益证明
- D、以上都不是

答案:C"

"Q43、工业和信息化领域数据处理者应当根据传输的数据（ ），制定安全策略并采取保护措施。传输重要数据和核心数据的，应当采取校验技术、密码技术、安全传输通道或者安全传输协议等措施。

- A、级别
- B、类型
- C、条件
- D、应用场景

答案:ABD"

"Q44、《人工智能生成合成内容标识办法》规定，人工智能生成合成内容是指利用人工智能技术生成、合成的哪些类型的信息？

- A、仅文本和图片
- B、仅视频和音频
- C、文本、图片、音频、视频、虚拟场景等信息
- D、仅文本、图片和视频

答案:C"

"Q45、开展数据处理活动应当加强风险监测，发现数据安全缺陷、漏洞等风险时下列做法错误的是：

- A、立即采取补救措施
- B、偷偷修复缺陷
- C、等有时间再修复缺陷
- D、不处理

答案:BCD"

"Q46、违反《个人信息保护法》规定处理个人信息，或者处理个人信息未履行本法规定的个人信息保护义务的，履行个人信息保护职责的部门可做出（ ）决定。

- A、责令改正
- B、对违法处理个人信息的应用程序，责令暂停或终止提供服务
- C、没收违法所得
- D、给予警告

答案:ABCD"

"Q47、个人信息处理者可以采取下列措施确保个人信息处理活动符合法律、行政法规的规定，并防止未经授权的访问以及个人信息泄露、篡改、丢失。

- A、对个人信息实行分类管理
- B、采取相应的加密、去标识化等安全技术措施
- C、制定内部管理制度和操作规程

D、合理确定个人信息处理的操作权限，并定期对从业人员进行安全教育和培训

答案:ABCD"

"Q48、2020 年微盟的离职人员心怀不满，利用远程登录方式销毁了在线电商数据，对微盟的业务与营收造成了严重影响，这件事情警示大家，对账号的管理也应当从严，以下哪些属于账号生命周期管理。

A、账号创建

B、岗位变动后账号权限变更

C、离职人员账号关停审计

D、账号口令强度要求，最好是大小写字母结合数字与特殊字符的复杂口令

答案:ABC"

"Q49、ISMS 是基于组织的（ ）风险角度建立的。

A、财务部门

B、资产安全

C、信息部门

D、整体业务

答案:D"

"Q50、个人信息处理规则或隐私政策中，通常应明确说明哪些与个人信息存储和处理相关的事项？

A、个人信息保存期限或者确定方法

B、保存期限届满后的处理方式

C、个人信息存储地域或涉及出境的安排

D、个人行使查阅、更正、删除等权利的方式和途径

答案:ABCD"

Q51、国家对与维护国家安全和利益、履行国际义务相关的属于管制物项的数据依法实施出口管制。（正确）

"Q52、某交付团队希望验证“同一用户在不同角色下访问同一数据对象是否受到限制”，最优先的测试方法是（ ）。

A、基于不同角色身份进行权限矩阵测试

B、只检查用户界面显示

C、只跑压力测试

D、只比对服务器时间

答案:A"

"Q53、在无线网络安全威胁中不属于对传递信息的威胁的是（ ）。

A、侦听

B、篡改

C、抵赖

D、屏蔽

答案:D"

"Q54、根据《人脸识别技术应用安全管理办法》，提供人脸识别技术服务的供应商，在出现数据泄露时应如何处理？

A、自行处置，无需上报

B、立即采取补救措施，按规定及时通知用户并向有关主管部门报告

C、在 72 小时内仅向公安机关报告

D、仅向企业内部汇报

答案:B"

"Q55、重要数据的处理者应当明确（ ）和管理机构，落实数据安全保护责任。

A、数据用途

B、数据处理时间

C、数据使用人

D、数据安全负责人

答案:D"

"Q56、《中华人民共和国个人信息保护法》的制定是为了保护（ ）权益。

A、个人信息

B、公民利益

C、个人健康

D、集体财富

答案:A"

"Q57、以下不属于数据库软件的是（ ）。

A、MSSQL

B、SQLite

C、Apache

D、Oracle

答案:C"

"Q58、依据 ISO 27001，信息分类方案的目的是？

A、划分信息的数据型，如供销数据、生产数据、开发测试数据，以便于应用大数据技术对其分析

B、划分信息载体所属的职能以便于明确管理责任

C、划分信息载体的不同介质以便于存储和处理，如纸张、光盘、磁盘

D、划分信息对于组织业务的关键性和敏感性分类，按此分类确定信息存储、处理、处置的原则

答案:D"

"Q59、《数据安全法》中的""数据""是指（ ）。

A、任何电子或者其他方式对信息的记录

B、进行各种统计、计算、科学研究或技术设计等所依据的数值

C、网络数据

D、只包括电子形式的信息记录

答案:A"

"Q60、来路不明的服务供应商发来的电子邮件、即时通讯消息，我们应该采取哪些措施？

A、正常打开

B、确认发送者的身份

C、回拨电话确认

D、向 IT 部门求助

E、先点开再确认其真实性

答案:BCD"

"Q61、以下关系（ ）的数据属于国家核心数据

A、国家安全

B、国民经济命脉

C、重要民生

D、重大公共利益

答案:ABCD"

"Q62、防范 SQL 注入攻击的最佳方式是（ ）。

A、使用防火墙

B、输入验证与参数化查询

C、禁用数据库日志

D、限制网络带宽

答案:B"

"Q63、区块链中的零知识证明（Zero-Knowledge Proof）用于解决什么问题？

A、隐私保护

B、数据完整性验证

C、交易速度优化

D、分布式网络安全

答案:A"

Q64、国家建立数据安全审查制度，对影响或者可能影响国家安全的数据处理活动进行国家安全审查。依法作出的安全审查决定为最终决定。（正确）

Q65、数据完整性校验（如 MD5）可替代数据加密保护敏感信息。（错误）

"Q66、关键信息基础设施和网络安全等级保护之间的关系？

A、网络安全等级保护第三级的系统一定是关键信息基础设施

B、关键信息基础设施同时也必须通过网络安全等级保护第二级

C、基于等保而高于等保，关键信息基础设施需在等级保护第三级及以上对象中确定

D、关键信息基础设施保护和网络安全等级保护各自独立，互不相关

答案:C"

"Q67、VLAN 技术用于实现什么目的？

A、增强系统安全性

B、提高网络带宽

C、实现网络隔离

D、加速数据传输速度

答案:C"

"Q68、某企业以""数据处理委托""为名向境外合作方传输大量用户数据，但实际上该合作方对数据有完整控制权。依据《数据安全法》，该行为的定性是？

A、合规的数据处理委托

B、实质上属于数据出境，须履行相应出境合规义务

C、属于数据共享，无需监管

D、属于技术服务，无需审批

答案:B"

"Q69、某评估团队为提高效率，打算跳过对管理制度执行情况的访谈，只保留技术扫描。该做法的最大问题是（ ）。"

A、会漏掉流程控制、职责分工、培训落地等非技术性风险

B、技术扫描足以覆盖一切

C、访谈会必然泄露商业秘密

D、法规不要求管理评估

答案:A"

"Q70、唐朝年间，科举基本上被五姓七家把控，武则天于是决定采用糊名制度，""暗考以定其等级""，

糊名制度在个人信息处理上是什么措施（ ）？

A、隔离

B、身份验证

C、去标识化

D、差分隐私

答案:C"

"Q71、日本安全研究员与密歇根大学利用激光攻击知名厂商的智能音响与语音识别软件，从5米到110米范围上述设备与软件无一幸免，这种攻击（ ）？

A、属于物理攻击

B、证明了目前的语音识别设备其实存在很大安全隐患

C、利用了波的特性，波的特征可以被模仿

D、目前没有很好的防御手段

答案:ABC"

"Q72、通道劫持是指攻击者通过什么方式获取受害者的通信信息？

A、中间人代理攻击

B、恶意软件感染用户设备后监控通信

C、网络钓鱼诈骗

D、盗取用户的登录凭据

答案:B"

"Q73、以下哪些是区块链的特点。"

A、不可篡改

B、去中心化

C、匿名性

D、透明性

答案:ABCD"

"Q74、媒体欺骗是指攻击者通过伪造以下哪种内容来引导目标执行操作？

A、文字内容

- B、图像、视频或音频材料
- C、网络流量
- D、加密算法

答案:B"

"Q75、大数据发展应当全面实施国家大数据战略，坚持（ ）、依法管理、保障安全原则。

- A、统筹规划、创新引领
- B、数据赋能、繁荣业态
- C、互联互通、共享开放
- D、以上都正确

答案:D"

"Q76、某企业风险评估报告只给出了“高、中、低”结论，没有解释评分方法和依据。该报告的主要问题是（ ）。

- A、缺少风险评级方法透明度和可复核性
- B、可读性更高，因此更合规
- C、等级结论足够，无需方法
- D、只影响外观排版

答案:A"

"Q77、某企业希望从大量访问日志中自动发现“与日常模式显著不同的数据查询行为”，最适合加强的是（ ）。

- A、用户行为基线建模与异常检测
- B、删除所有旧日志
- C、关闭查询接口
- D、只加强门禁

答案:A"

"Q78、某组织在开展数据安全风险评估时，仅识别了资产和漏洞，没有评定风险程度。该评估最主要缺失的是（ ）。

- A、风险等级判定与处置建议环节
- B、网络拓扑图

- C、员工工龄信息
- D、服务器数量统计

答案:A"

"Q79、侵权行为危及他人人身、财产安全的，被侵权人有权请求侵权人承担（ ）等侵权责任。

- A、停止侵害
- B、排除妨碍
- C、消除危险
- D、损失赔偿

答案:ABC"

"Q80、若数据处理者未按照相应监管要求进行数据跨境传输，视情节轻重可能收到下列哪些处罚？

- A、警告
- B、罚款
- C、停业整顿
- D、吊销相关业务许可证或吊销营业执照

答案:ABCD"

"Q81、以下哪种做法通常不会增加浏览网页时个人信息泄露的风险？

- A、开启“请勿跟踪（DNT）”功能
- B、访问来源不明的网站
- C、点击可疑链接
- D、在公共网络下输入敏感账号信息

答案:A"

Q82、隐私政策以单独成文的形式发布，而不是作为用户协议、用户说明等文件中的一部分存在。（正确）

"Q83、合规评估报告通常应包含哪些核心输出？

- A、评估范围与方法
- B、发现的问题和证据
- C、整改建议与优化方案

D、评估对象员工个人家庭住址

答案:ABC"

"Q84、根据《网络数据安全条例》，未被相关地区、部门告知或者公开发布为重要数据的，网络数据处理者是否需要将其作为重要数据申报数据出境安全评估？

A、必须申报

B、不需要将其作为重要数据申报

C、由企业自行判断

D、需要向国家网信部门咨询

答案:B"

"Q85、在数据出境整改方案中，若发现某项出境活动缺少合法依据，最稳妥的措施通常是（ ）。

A、暂停相关出境活动，补足合法依据或调整业务模式后再评估恢复

B、先继续传输，等待监管问询

C、只补充口头说明

D、只修改隐私政策版本号

答案:A"

Q86、数字证书应由政府机构签发。（错误）

Q87、在国家网信部门统筹协调下，国务院电信主管部门负责指导监督关键信息基础设施安全保护工作。（错误）

"Q88、某政务系统日志集中管理平台未设置异常访问告警阈值。该缺陷导致？

A、安全事件发现延迟，无法及时响应

B、日志存储空间增加

C、网络带宽占用

D、系统响应变快

答案:A"

"Q89、关于无线网络（WiFi）的安全使用，以下哪个说法是正确的（ ）。

A、无线网络可以通过接入点名称来判定是否可靠

B、无线网络如果接入需要密码都是安全的

C、无线网络的设置都必须经过严格的认证，因此所有无线网络都是安全可靠的

D、所有外部的无线局域网都属于不可控网络，传输敏感数据都应谨慎

答案:D"

"Q90、认证服务器在单点登录（SSO）过程中的主要职责是什么？

A、生成访问票据并存放在 Cookie 中

B、验证用户的登录请求并确认其合法性

C、建立安全访问通道与应用系统通信

D、检查 Cookie 的有效性并进行验证

答案:B"

"Q91、关于数据，下列说法错误的是：

A、使用纸质记录的文字等信息不是数据，因此不适用《中华人民共和国数据安全法》

B、电子记录的文字等信息是数据，因此适用《中华人民共和国数据安全法》

C、数据处理是指数据的收集、存储、使用、加工、传输、提供、公开等

D、数据安全是指通过采取必要措施，确保数据处于有效保护和合法利用的状态，以及具备保障持续安全状态的能力

答案:A"

"Q92、《三国演义》中描述曹操每天更换营中口令，一日口令为""鸡肋""。在数据安全保护体系中，这种方式体现了什么思想？（ ）

A、舆情检测

B、动态口令（定期更换口令）

C、内容分析

D、动态风控

答案:B"

"Q93、API 网关核心能力需包含：

- A、动态速率限制
- B、字段级数据脱敏
- C、数据库直连查询
- D、JWT 身份验证
- E、SSL 证书生成

答案:ABD"

"Q94、根据《生成式人工智能服务管理暂行办法》，提供者对用户输入信息和使用记录应当如何处理？

- A、依法履行保护义务，不得将用户输入的个人信息用于生成式人工智能服务之外的目的
- B、可以用于改进算法且无需告知用户
- C、须实时上报监管部门存档
- D、保留 30 年供监管查阅

答案:A"

"Q95、如果你需要检测某社交 APP 是否存在违规收集用户敏感信息的行为。以下哪些技术方法可以有效检测该 APP 实际获取的敏感数据类型？

- A、使用 Android SDK 中的 adb shell dumpsys package <package_name>命令，分析应用的权限声明
- B、通过 Frida 框架动态 Hook 应用对 getDeviceId()、getLocation()等敏感 API 的调用
- C、使用 Wireshark 抓取 APP 的网络流量，分析 HTTP/HTTPS 请求中是否包含用户个人信息
- D、检查 APP 的隐私政策文档，确认其声明的数据收集范围

答案:ABC"

"Q96、根据《工业和信息化领域数据安全事件应急预案》，电信领域数据遭到篡改、破坏、泄露或者非法获取、非法利用，导致相关网络设施和信息系统运行中断或严重异常，持续时间 8 小时以上的属于什么级别的数据安全事件？

- A、特别重大数据安全事件
- B、重大数据安全事件
- C、较大数据安全事件
- D、一般数据安全事件

答案:C"

"Q97、验证一个系统是否传输加密，一般采用（ ）获取其传输的数据包，查看是否有加密措施或其他手段保障传输保密性。

- A、SSH 登录客户端
- B、嗅探工具
- C、以上都有
- D、以上都不对

答案:B"

"Q98、在访问控制中，RBAC（Role-Based Access Control）的核心思想是（ ）。

- A、基于用户的身份验证进行访问控制
- B、基于角色的权限分配进行访问控制
- C、基于资源的分类进行访问控制
- D、基于审计日志进行访问控制

答案:B"

"Q99、访问控制决定用户什么？

- A、是否能够访问网络资源
- B、是否能够使用网络资源
- C、是否能够修改网络资源
- D、是否能够删除网络资源

答案:A"

"Q100、根据《密码法》的规定，在有线、无线通信中传递的国家秘密信息，以及存储、处理国家秘密信息的信息系统，应当依照法律、行政法规和国家有关规定使用核心密码、普通密码进行（ ）？

- A、加密保护

B、绝对保护

C、安全认证

D、强制认证

答案:AC"

"Q101、重要涉密部门的人员选配，应当坚持（ ）的原则，并定期进行考核，不适合的应及时调整。

A、谁选配谁负责

B、先审后用

C、先选后训

D、边审边用

答案:B"

"Q102、零信任安全模型的目标是什么？

A、减少网络带宽使用

B、实施精细化的访问控制策略

C、保护用户和数据安全

D、支持开放的网络连接

E、最大限度地提高网络性能

答案:BC"

"Q103、MFA 疲劳是指什么？

A、攻击者拦截 MFA 推送通知

B、攻击者反复发送 MFA 推送通知，使用户因疲惫而误点同意

C、攻击者通过社会工程欺骗用户提供登录凭据

D、用户忘记了 MFA 代码

答案:B"

"Q104、根据 GB/T 43697-2024，以下哪类数据应定为最高安全级别（4 级）？

A、企业内部公告

B、关系国家安全和重大公共利益、泄露后对国家和社会造成严重危害的数据

C、普通员工个人联系方式

D、产品用户手册

答案:B"

"Q105、维护数据安全，应当坚持（ ），建立健全数据安全治理体系，提高数据安全保障能力。

A、国家安全观

B、社会安全观

C、总体国家安全观

D、总体社会安全观

答案:C"

"Q106、以下哪些情形下，企业可以不经用户同意处理个人信息？

A、履行法定职责或义务所必需

B、与个人订立或履行合同所必需

C、紧急情况下为保护生命健康

D、基于商业创新需要

答案:ABC"

Q107、访问控制的目标有两个：防止非法用户进入系统和阻止合法用户的越权访问。（正确）

"Q108、对于发现存在较大安全风险的数据处理活动，行业监管部门可以采取以下哪种措施？

A、给予奖励

B、发出警告信函

C、进行约谈并要求整改

D、暂停行政审批程序

答案:C"

"Q109、下面对""零日（Zero-Day）漏洞""的理解中，正确的是（ ）。

A、指一个特定的漏洞，该漏洞每年 1 月 1 日零点发作，可以被攻击者用来远程攻击

B、指通过漏洞扫描系统发现但是还没有被通告给监管机构的漏洞

C、指一类漏洞，即特别好被利用，一旦成功利用该

类漏洞，可以在 1 天内完成攻击

D、指一类漏洞，即刚被发现后立即被恶意利用的安全漏洞，一般已经被小部分人发现，但还未公开、也不存在安全补丁的漏洞

答案:D"

"Q110、关键信息基础设施运营者采购网络产品和服务的，应当预判该产品和服务投入使用后可能带来的国家安全风险。影响或者可能影响国家安全的，应当向（ ）申报网络安全审查。

A、网络安全审查办公室

B、公安部

C、国家保密局

D、国家安全部

答案:A"

"Q111、社交工程学攻击者主要利用以下哪个因素来欺骗目标？

A、技术手段

B、社交技巧和人际交往

C、网络协议

D、数字证书

答案:B"

"Q112、电信业务经营者、互联网信息服务提供者应当对用户个人信息保护情况每年至少进行（ ）自查，记录自查情况，及时消除自查中发现的安全隐患。

A、一次

B、二次

C、三次

D、四次

答案:A"

"Q113、若某接口既面向内部系统又面向外部合作伙伴，安全架构设计中最合理的思路是（ ）。

A、按调用主体类别实施差异化认证、授权和审计

B、对所有调用者开放同一权限

C、只做网络层白名单

D、关闭全部日志

答案:A"

"Q114、访问控制列表可实现下列哪些要求？

A、允许 202.38.0.0/16 网段的主机可以使用协议 HTTP 访问 129.10.10.1

B、不让任何机器使用 Telnet 登录

C、使某个用户能从外部远程登录

D、允许在晚上 8:00 到晚上 12:00 访问网络

答案:ABD"

Q115、Windows 系统中，用户的身份标识包含在访问令牌中。（正确）

"Q116、关于数据脱敏，下列说法正确的是

A、数据脱敏要满足单向性

B、数据脱敏要满足无残留

C、数据脱敏一般要容易实现

D、数据脱敏很容易影响数据分析结果的准确性，一般不采用

答案:ABC"

"Q117、在应急演练中，如果恢复时间目标（RTO）反复不达标，应优先考虑（ ）。

A、优化恢复流程与资源保障，必要时调整容灾架构

B、取消后续演练

C、降低日志留存时间

D、只增加宣传培训

答案:A"

Q118、《人工智能生成合成内容标识办法》以国家互联网信息办公室第 17 号令形式发布，属于部门规章。（正确）

Q119、钓鱼攻击常利用虚假的电子邮件、短信或其他通信形式来诱使受害者揭示个人信息。（正确）

"Q120、国家网信部门统筹建立关键信息基础设施网络安全监测预警体系和信息通报制度，组织指导有关机构开展（ ）。

- A、网络安全信息汇总
- B、分析研判
- C、通报工作
- D、安全服务的社会影响及收益分析

答案:ABC"

Q121、根据《网络安全法》的规定，任何个人和组织不得提供专门用于从事侵入网络、干扰网络正常功能等危害网络安全活动的程序。（正确）

"Q122、《关于促进数据安全产业发展的指导意见》提出，数据安全产业应如何发展？

- A、深化产学研用合作
- B、推动数据安全技术创新
- C、强化基础设施建设
- D、加强国际合作与交流

答案:ABCD"

"Q123、国家建立数据（ ）制度，根据数据在经济社会发展中的重要程度，以及一旦遭到篡改、破坏、泄露或者非法获取、非法利用，对国家安全、公共利益或者个人、组织合法权益造成的危害程度，对数据实行分类分级保护。

- A、分类分级备案
- B、分级访问权限
- C、分级实时备份
- D、分类分级保护

答案:D"

"Q124、某金融机构数据治理发现""客户联系方式""字段存在大量无效/过期号码。应？

- A、保留所有数据

B、仅通知客户更新

C、交由客服处理

D、建立数据质量校验与定期清洗机制

答案:D"

"Q125、某金融机构数据安全监测发现某核心系统CPU使用率长期100%。该现象可能关联？

- A、数据泄露或恶意挖矿程序驻留
- B、系统优化良好
- C、网络延迟正常
- D、磁盘读写正常

答案:A"

"Q126、个人信息处理者应当公开个人信息保护负责人的（ ），并将个人信息保护负责人的姓名、联系方式等报送履行个人信息保护职责的部门。

- A、身份证号
- B、联系方式
- C、家庭住址
- D、工作地点

答案:B"

Q127、身份认证是证实实体与其所声称的身份是否相符的过程。（正确）

"Q128、某跨境电商平台的境外消费者向企业提出查阅其个人信息的请求，企业以""境外用户不适用《个人信息保护法》""为由拒绝。该拒绝理由是否成立？

- A、成立，个保法仅保护境内自然人
- B、不成立，在境内处理的个人信息均受保护，与信息主体是否在境内无关
- C、是否成立取决于双边协定
- D、只有中国公民才受个保法保护

答案:B"

Q129、数字签名可以保证数据的保密性。（错误）

"Q130、某团队在代码审计中发现：开发者把用户身

份证号写入测试日志，且测试日志会同步到集中日志平台。该问题应判定为（ ）。

- A、敏感个人信息在测试链路中发生不必要扩散
- B、正常调试行为
- C、仅影响系统性能
- D、与数据安全无关

答案:A"

"Q131、某企业拟建设“统一数据开放门户”，最需
要先完成的工作是（ ）。

- A、开放数据目录梳理与数据可开放边界判断
- B、前端颜色选型
- C、办公楼无线覆盖优化
- D、打印配额控制

答案:A"

Q132、按照数据对国家安全、公共利益或者个人、
组织合法权益的影响和重要程度，将数据分为一般
数据、重要数据、核心数据，不同级别的数据采取
不同的保护措施。（正确）

"Q133、关于数据库恢复技术，下列说法不正确的是
（ ）。

- A、数据库恢复技术的实现主要依靠各种数据的冗余
和恢复机制技术来解决，当数据库中数据被破坏
时，可以利用冗余数据来进行修复
- B、数据库管理员定期地将整个数据库或部分数据库
文件备份到磁带或另一个磁盘上保存起来，是数据
库恢复中采用的基本技术
- C、日志文件在数据库恢复中起着非常重要的作用，
可以用来进行事务故障恢复和系统故障恢复，并协
助后备副本进行介质故障恢复
- D、计算机系统发生故障导致数据未存储到固定存储
器上，利用日志文件中故障发生前数据的循环，将
数据库恢复到故障发生前的完整状态，这一对事务
的操作称为提交

答案:D"

"Q134、某项目采用水印技术保护导出文档。该控制
项最主要服务于（ ）。

- A、事后泄露溯源与责任追踪
- B、提升压缩率
- C、替代加密存储
- D、减少接口调用次数

答案:A"

Q135、网络安全等级保护第三级的系统一定是关键
信息基础设施。（错误）

"Q136、《中华人民共和国民法典》规定，网络用户
利用网络服务实施侵权行为的，权利人有权通知网
络服务提供者采取屏蔽、（ ）、断开链接等必要措
施。通知应当包括构成侵权的初步证据及权利人的
真实身份信息。

- A、过滤
- B、删除
- C、加密
- D、拉黑

答案:B"

"Q137、根据《密码法》的规定，下列哪些商用密码
产品，无需依法列入网络关键设备和网络安全专用
产品目录？

- A、涉及国家安全的商用密码产品
- B、涉及国计民生的商用密码产品
- C、涉及社会公共利益的商用密码产品
- D、涉及个人利益的商用密码产品

答案:D"

Q138、个人信息的认定难点在于具有"间接可识别性
"的数据，即与其他信息结合能够识别出特定个人的
数据范围的不确定性，例如常用设备数据、位置数
据等，各法域对间接识别性的解释也存在差异。（正
确）

"Q139、修订后的《网络安全法》对关键信息基础设

施运营者造成特别严重危害网络安全后果的，最高罚款上限为（ ）。

- A、一百万元
- B、五百万元
- C、一千万元
- D、五千万元

答案:C"

Q140、重要数据的处理者应当按照规定对其数据处理活动定期开展风险评估，并向有关主管部门报送风险评估报告。（正确）

"Q141、零信任安全模型中，以下哪些技术可以用于实施细粒度的访问控制？

- A、双因素身份验证
- B、代理服务器
- C、角色基础访问控制
- D、防火墙
- E、强制访问控制

答案:ACE"

Q142、征信机构明确告知信息主体提供收入、存款、有价证券、商业保险、不动产的信息和纳税数额信息可能产生的不利后果，并取得其书面同意的，可以采集上述信息。（正确）

Q143、核心密码、普通密码用于保护国家秘密信息，核心密码保护信息的最高密级为绝密级，普通密码保护信息的最高密级为机密级。（正确）

"Q144、数据分类和保护的目的是什么？

- A、限制员工的数据访问权限
- B、降低数据存储成本
- C、简化数据管理过程
- D、保护敏感信息的安全和隐私

答案:D"

"Q145、4A 系统指的是以下哪些功能的集合？

- A、认证（Authentication）
- B、授权（Authorization）
- C、账号管理（Account）
- D、审计（Audit）

答案:ABCD"

"Q146、根据现行《促进和规范数据跨境流动规定》，下列哪些情形应当申报数据出境安全评估？

- A、关键信息基础设施运营者向境外提供个人信息
- B、数据处理者向境外提供重要数据
- C、关键信息基础设施运营者以外的数据处理者，自当年 1 月 1 日起累计向境外提供 100 万人以上个人信息（不含敏感个人信息）
- D、关键信息基础设施运营者以外的数据处理者，自当年 1 月 1 日起累计向境外提供 1 万人以上敏感个人信息

答案:ABCD"

"Q147、在访问控制产品的选择过程中，以下哪个因素应该是最重要的考虑因素？

- A、产品的售价
- B、产品的品牌知名度
- C、产品的功能和特性是否满足需求
- D、产品的外观设计和用户界面

答案:C"

"Q148、国家金融监督管理总局消费者权益保护局持续加大监管力度，重点推动银行业保险业落实下列哪一部法律，提升个人信息使用的规范性，保护消费者信息安全权？

- A、《个人信息保护法》
- B、《民法典》
- C、《网络安全法》
- D、《数据安全法》

答案:A"

"Q149、目录级安全控制主要用于控制用户对以下哪些资源的访问？

- A、文件
- B、目录
- C、设备
- D、系统管理员权限
- E、网络服务器

答案:AB"

"Q150、个人信息处理者因业务等需要，确需向中华人民共和国境外提供个人信息的，应当具备下列条件之一：

- A、依照本法相关规定通过国家网信部门组织的安全评估
- B、按照国家网信部门制定的标准合同与境外接收方订立合同，约定双方的权利和义务
- C、按照国家网信部门的规定经专业机构进行个人信息保护认证
- D、法律、行政法规或者国家网信部门规定的其他条件

答案:ABCD"

"Q151、根据《个人信息保护法》，以下哪类信息属于敏感个人信息？

- A、姓名和工作单位
- B、普通邮政地址
- C、生物识别、宗教信仰、特定身份、医疗健康、金融账户、行踪轨迹等
- D、公开发表的职业信息

答案:C"

"Q152、国家大力推进电子政务建设，提高政务数据的科学性、（ ）、时效性，提升运用数据服务经济社会发展的能力。

- A、公平性
- B、创新性

C、便民性

D、准确性

答案:D"

"Q153、为确保个人信息处理活动符合法律、行政法规的规定，应采取下列哪些措施？

- A、最小化采集
- B、内部制定管理制度，确保个人信息处理合规
- C、采取加密、去标识等措施
- D、APP 设计开发时采用默认采集默认授权的模式

答案:ABC"

Q154、App 应提供注销账号的途径（如在线功能界面、客服电话等），并在用户注销账号后，及时删除其个人信息或进行匿名化处理。（正确）

"Q155、银行保险监督管理机构应当按照县级以上人民政府及法定授权部门对突发事件的应对要求，审慎评估突发事件对银行保险机构造成的影响，依法履行的职责不包括下列哪一项内容？

- A、加强对突发事件引发的区域性、系统性风险的监测、分析和预警
- B、督促银行保险机构按照突发事件应对预案，保障基本金融服务功能持续安全运转
- C、配合银行保险机构提供突发事件应急处置金融服务
- D、引导银行保险机构积极承担社会责任

答案:C"

"Q156、区块链环境下的数据分级面临的核心矛盾是？

- A、存储成本过高
- B、不可篡改性与其"被遗忘权"冲突
- C、节点同步延迟
- D、加密密钥管理

答案:B"

"Q157、隐私政策应对（）进行明确说明。

- A、应用功能
- B、存储期限
- C、超期处理方式
- D、个人信息存放地域

答案:BCD"

"Q158、下列哪一规定的颁布被誉为数据领域""哥白尼革命""式的立法，特别注重""数据权利保护""与""数据自由流通""之间的平衡？

- A、《加州隐私权利法》
- B、《通用数据保护条例》（GDPR）
- C、《弗吉尼亚州消费者数据保护法》
- D、《科罗拉多州隐私法案》

答案:B"

Q159、《网络数据安全条例》通过数据出境安全评估后，数据处理者可以超出评估时明确的数据出境目的、方式、范围和种类、规模等进行数据出境。（错误）

Q160、口令安全管理是访问控制中不重要的一部分，可以使用简单的口令来保护系统。（错误）

"Q161、结合法律法规的要求、相关行业标准，形成数据跨境合规管控关键管控点，下列哪一项不属于关键管控点？

- A、数据跨境前的评估
- B、数据跨境中的执行
- C、数据跨境后的管理
- D、数据跨境后的检查

答案:D"

"Q162、区块链的核心特点包括（）。

- A、去中心化
- B、不可篡改
- C、可逆性

D、低效率

答案:AB"

"Q163、对称加密算法的特点是（）。

- A、加密解密使用相同密钥
- B、加密解密使用不同密钥
- C、仅用于数字签名
- D、仅用于身份认证

答案:A"

"Q164、没有公开收集使用规则的情形有哪些？

- A、没有隐私政策、用户协议，或者隐私政策、用户协议中没有相关收集使用规则的内容
- B、在 App 安装、使用等过程中均未通过弹窗、链接等方式提示用户阅读隐私政策，或隐私政策链接无效、文本无法正常显示
- C、进入 App 主功能界面后，多于 4 次点击、滑动才能访问到隐私政策
- D、使用 App 前需要勾选同意隐私政策和用户协议

答案:ABC"

"Q165、从爬虫运行的环节分析爬虫技术的刑事违法性，下列分析正确的有（）。

- A、利用爬虫技术窃取国家秘密的，可能构成《刑法》第二百八十二条规定的非法获取国家秘密罪
- B、利用爬虫技术侵入除国家事务、国防建设、尖端科学技术领域以外的计算机信息系统，获取该计算机信息系统中存储、处理或者传输的数据，可能构成《刑法》第二百八十五条第二款规定的非法获取计算机信息系统数据罪
- C、利用爬虫技术非法获取商业秘密的，可能构成《刑法》第二百一十九条规定的侵犯商业秘密罪
- D、行为人若利用爬虫爬取公民个人信息，不仅获取了公民个人信息，也侵入了被害单位的计算机信息系统，属于法条竞合，应按照刑法的原则择一重罪处罚

答案:ABCD"

"Q166、履行个人信息保护职责的部门履行下列哪些职责？

- A、开展个人信息保护宣传教育，指导、监督个人信息处理者开展个人信息保护工作
- B、接受、处理与个人信息保护有关的投诉、举报
- C、组织对应用程序等个人信息保护情况进行测评，并公布测评结果
- D、调查、处理违法个人信息处理活动

答案:ABCD"

"Q167、某企业需要保护其 API 接口的安全，以下哪项措施是错误的？

- A、对 API 接口进行身份验证
- B、对 API 接口进行访问频率限制
- C、将 API 接口的密钥硬编码在代码中
- D、对 API 接口的响应数据进行加密

答案:C"

"Q168、下列说法正确的有：

- A、敏感个人信息是一旦泄露或者非法使用，容易导致自然人的人格尊严受到侵害或者人身、财产安全受到危害的个人信息
- B、只要有具有特定的目的和充分的必要性，不采取严格保护措施的情形下，个人信息处理者也可处理敏感个人信息
- C、个人信息处理者处理不满十四周岁未成年人个人信息的，不用取得未成年人的父母或者其他监护人的同意
- D、处理敏感个人信息应当取得个人的单独同意；法律、行政法规规定处理敏感个人信息应当取得书面同意的，从其规定

答案:AD"

"Q169、智能卡身份验证需要什么？

- A、需要智能卡读卡器和智能卡
- B、需要指纹识别设备和智能卡

C、需要面部识别设备和智能卡

D、需要虹膜扫描设备和智能卡

答案:A"

"Q170、某企业实施数据分类分级后，发现部分业务系统权限未同步调整。下一步应？

- A、分级完成即止
- B、将分级结果映射至访问控制策略
- C、重新进行分类
- D、仅更新文档不调整系统

答案:B"

"Q171、在访问控制中，RBAC 模型中的用户角色关系是（ ）。

- A、一对一关系
- B、一对多关系
- C、多对多关系
- D、多对一关系

答案:C"

"Q172、根据《电子签名法》的规定，以下哪类文书当事人不得约定使用或者不使用电子签名、数据电文？

- A、婚姻证明
- B、收养协议书
- C、遗赠协议书
- D、电子发票

答案:ABC"

Q173、只要是合法收集的数据，都可以随意使用。（错误）

"Q174、在大数据环境中，（ ）不是隐私保护的挑战之一。

- A、数据集成和共享
- B、数据存储和处理能力

C、跨组织数据交换

D、网络攻击和入侵

答案:D"

"Q175、大数据时代，可以从哪几个方面加强数据安全与隐私保护

A、数据安全与隐私工作，与个人无关，全部需要依赖国家层面进行管控

B、提高个人意识，应用安全技术

C、从企业端源头进行遏制

D、从国家法制层面进行管控

答案:BCD"

"Q176、根据《个人信息保护合规审计管理办法》，同一专业机构及其关联机构不得连续多少次以上对同一审计对象开展个人信息保护合规审计？

A、两次

B、三次

C、五次

D、不限次数

答案:B"

"Q177、以下哪些内容是数据出境标准合同的核心条款？

A、数据处理者和境外接收方各自的权利义务

B、境外接收方所在国家的数据保护水平说明

C、个人信息主体在跨境场景下行使权利的路径

D、境外接收方与数据处理者的商务合作条款

答案:ABC"

Q178、修订后的《网络安全法》要求有关主管部门依据职责制定相应的行政处罚裁量基准，规范行使行政处罚裁量权。（正确）

Q179、《个人信息出境标准合同》正文不可以增加、删除、修改任何条款，只可在需要填空处填写适当内容。（正确）

Q180、VLAN 是一种网络访问控制技术，用于将网络划分为不同的子网以实现隔离。（正确）

Q181、双因素认证中的“你知道什么”因素一定比“你拥有什么”因素更安全。（错误）

"Q182、数据完整性指的是（ ）。

A、保护网络中各系统之间交换的数据，防止因数据被截获而造成泄密

B、提供连接实体身份的鉴别

C、防止非法实体对用户的主动攻击，保证数据接受方收到的信息与发送方发送的信息完全一致

D、确保数据数据是由合法实体发出的

答案:C"

"Q183、单点登录（SSO）的优势包括。

A、用户只需登录一次即可访问多个应用系统

B、管理和维护成本较低

C、提供统一的身份认证和访问控制

D、提高系统的安全性

E、加速应用系统的响应速度

答案:ABC"

"Q184、根据《关键信息基础设施安全保护条例》第十七条，运营者应当自行或者委托网络安全服务机构对关键信息基础设施每年（ ）进行网络安全检测和风险评估，并按照保护工作部门要求报送情况。

A、至少进行一次

B、至少进行两次

C、至少进行四次

D、至少进行十二次

答案:A"

"Q185、制定关键信息基础设施安全保护条例的认定规则应当主要考虑下列因素（ ）。

A、网络设施、信息系统等对于本行业、本领域关键核心业务的重要程度

B、网络设施、信息系统等一旦遭到破坏、丧失功能或者数据泄露可能带来的危害程度

C、对其他行业和领域的关联性影响

D、网络设施、信息系统应确保可以直接从境外访问
答案:ABC"

Q186、APP 运营商应规范网页推荐下载行为。在用户浏览页面内容时，未经用户同意或主动选择，自动下载 APP 的行为违反相关规定。（正确）

"Q187、以下哪些是 UNIX/Linux 系统访问控制的应用参考？

A、文件读写访问控制

B、进程访问控制

C、内存访问控制

D、用户账户认证

E、IP 地址限制

答案:ABCD"

Q188、区块链技术中的侧信道攻击（Side-channel Attack）是指利用共识算法的漏洞进行攻击。（错误）

"Q189、经济合作与发展组织（OECD）在下列哪一年发布《隐私保护和跨境个人数据流动指南》？

A、1967 年

B、1968 年

C、1990 年

D、1980 年

答案:D"

"Q190、ZigBee 技术是一种_____技术。

A、长距离双向无线通信

B、短距离单向无线通信

C、短距离双向无线通信

D、短距离双向有线通信

答案:C"

"Q191、根据《人脸识别技术应用安全管理办法》，以下哪些行为被明确禁止？

A、未经同意收集、存储或传输人脸信息

B、滥用人脸识别技术分析、预测个人宗教信仰、政治观点等特征

C、将人脸数据用于出生日期验证

D、强迫当事人同意人脸识别作为服务唯一条件

答案:ABD"

"Q192、定级对象受到破坏时所侵害的客体中，侵害国家安全的事项不包括以下哪些方面？

A、影响国家政权稳固和领土主权、海洋权益完整

B、影响国家统一、民族团结和社会稳定

C、影响社会成员获取公开数据资源

D、影响国家社会主义市场经济秩序和文化实力

答案:C"

"Q193、以下哪种情形属于个人信息出境，但可以免于申报数据出境安全评估、订立个人信息出境标准合同、通过个人信息保护认证？

A、关键信息基础设施运营者向境外提供个人信息

B、自当年 1 月 1 日起累计向境外提供 100 万人以上个人信息（不含敏感个人信息）

C、为订立、履行个人作为一方当事人的合同，确需向境外提供个人信息

D、向境外提供重要数据

答案:C"

"Q194、根据《数据安全法》第四十六条第一款，违规向境外提供重要数据的，由有关主管部门责令改正、给予警告，可以并处的罚款金额范围（对机构）为？

A、1 万元以上 10 万元以下

B、10 万元以上 100 万元以下

C、100 万元以上 500 万元以下

D、500 万元以上 1000 万元以下

答案:B"

Q195、跨行业领域数据是指某个行业领域收集或产生的数据流转到另一个行业领域，以及两个或两个以上行业领域的数据融合加工产生的数据。（正确）

Q196、国家坚持保障数据开发与利用并重，鼓励研发数据安全保护技术，积极推进数据资源开发利用，保障数据依法有序自由流动。（错误）

"Q197、某开发团队希望通过“灰盒测试”验证接口授权逻辑，灰盒测试的特点更接近（ ）。

A、测试者掌握部分内部信息并结合外部攻击视角验证系统

B、完全不了解系统

C、只做源代码静态检查

D、只做功能回归

答案:A"

"Q198、需求分析阶段若忽略内部人员越权访问这一威胁，最可能导致什么后果？

A、访问控制策略设计不完整

B、服务器功耗升高

C、容灾等级自动下降

D、代码风格不统一

答案:A"

Q199、掌握超过 100 万用户个人信息的网络平台运营者赴国外上市，必须向网络安全审查办公室申报网络安全审查。（正确）

"Q200、根据 GB/T 43697-2024，数据分类的核心依据是？

A、数据的存储格式（结构化/非结构化）

B、数据内容的属性与特征

C、数据的文件大小

D、数据的创建时间

答案:B"

"Q201、建立良好的沟通渠道可以帮助组织做什么？

A、降低网络流量分析风险

B、加强身份验证措施

C、促进员工报告可疑活动或攻击

D、提高数据隐私保护水平

答案:C"

"Q202、业务连续性设计中，RPO 的含义是（ ）。

A、系统恢复所需的最长时间目标

B、可接受的数据丢失时间窗口目标

C、日志压缩比例目标

D、带宽利用率目标

答案:B"

"Q203、根据 ISO/IEC 27001 等相关网络安全标准，访问控制的目的是什么？

A、保护网络免受未经授权的访问

B、加密网络通信

C、监控网络流量

D、提高网络性能

答案:A"

Q204、电子文档的安全管理，涉及计算机科学、档案学、密码学、管理学等多学科的知识。（正确）

"Q205、对于数据安全防护，访问权限管理是一项良好的安全实践，以下访问权限控制措施中合适的是：（ ）？

A、严格管理数据库权限

B、严格管理运维账号权限

C、最好遵循三权分立原则

D、对服务器主机登录权限做管控

答案:ABCD"

Q206、口令序列认证是基于哈希链的认证，通过双

向哈希算法匹配用户的合法性。(错误)

"Q207、修订后《网络安全法》关于人工智能的规定，包含以下哪些内容？

- A、国家支持人工智能基础理论研究和算法等关键技术研发
- B、推进训练数据资源、算力等基础设施建设
- C、完善人工智能伦理规范，加强风险监测评估和安全监管
- D、禁止人工智能技术应用于商业领域

答案:ABC"

Q208、PKI 是公钥基础设施。(正确)

"Q209、以下不是《电子合同取证流程规范》中规定的电子取证原则的是（ ）？

- A、合法有效
- B、主观真实
- C、完整
- D、防篡改

答案:B"

"Q210、以下哪种是重放攻击的示例？

- A、跨站点脚本（XSS）攻击
- B、截获登录会话 Token 后重新使用以冒充用户
- C、生物特征欺骗攻击
- D、社会工程学攻击

答案:B"

"Q211、需求分析报告中若没有“风险接受条件”，实施阶段最可能出现（ ）。

- A、对残余风险缺乏管理边界和责任归属
- B、备份频率必然增加
- C、自动化测试全部中断
- D、系统无需上线审批

答案:A"

"Q212、根据 GB/T 43697-2024，以下哪个是衍生数据的定义？

- A、原始采集的用户行为数据
- B、经过统计、关联、挖掘、聚合、去标识化等加工活动而产生的数据
- C、从外部渠道购买的商业数据
- D、系统日志自动记录的运行数据

答案:B"

"Q213、某企业高管发现下属团队将未脱敏的客户数据发送至个人邮箱""方便远程工作""。数据安全负责人应如何处理？

- A、立即启动内部调查，删除外部副本，评估泄露风险，开展针对性培训并完善终端管控策略
- B、口头警告即可
- C、仅加强门禁
- D、屏蔽该员工邮箱

答案:A"

"Q214、利用""网络爬虫技术""获取公开信息时，还应当（ ）。

- A、确保对信息权利人著作权、个人信息等的保护，并确保不超范围使用
- B、不得将""网络爬虫技术""及采集到的数据信息用于不正当竞争或其他缺乏合理性、合法性的用途
- C、当抓取的信息侵犯其他方权益时，应及时通知相关方删除、断开或自行删除、断开使用该等侵权数据的链接
- D、在存储""网络爬虫""所收集的数据时，应当注意信息安全

答案:ABCD"

"Q215、根据《密码法》第二十六条，商用密码产品检测认证适用（ ）的有关规定，避免重复检测认证。

- A、《中华人民共和国认证认可条例》

B、《中华人民共和国网络安全法》

C、《中华人民共和国产品质量法》

D、《中华人民共和国标准化法》

答案:A"

"Q216、某跨国企业中国子公司收到欧盟母公司要求，需将中国用户数据传输至欧盟总部进行统一分析。该场景的合规策略应为？

A、需同时评估中国《个人信息保护法》出境要求与 GDPR 数据传输规则，选择满足双重合规的方案

B、总部要求即可直接传输

C、仅遵守中国法律

D、仅遵守 GDPR

答案:A"

"Q217、《个人信息保护合规审计管理办法》自何时起施行？

A、2025-01-01

B、2025-03-01

C、2025-05-01

D、2025-09-01

答案:C"

"Q218、声纹识别虽是常见的生物特征认证方式之一，但其应用中仍面临哪些安全或稳定性挑战？

A、录音回放或语音合成攻击

B、环境噪声会影响识别效果

C、个体声音可能受年龄、健康、情绪等因素影响

D、使用强密码会降低声纹识别安全性

答案:ABC"

Q219、根据《中华人民共和国数据安全法》，国家不会针对其他国家或地区在数据和数据开发利用技术等方面对中华人民共和国采取歧视性的禁止、限制或其他类似措施进行对等反击。（错误）

"Q220、下列哪项是提供重要互联网平台服务、用户

数量巨大、业务类型复杂的个人信息处理者应履行的特别义务？

A、定期发布个人信息保护社会责任报告

B、制定内部管理制度和操作规程

C、采取相应的安全技术措施

D、制定并组织实施个人信息安全事件应急预案

答案:A"

"Q221、建设、运营网络或者通过网络提供服务，应当依照法律、行政法规的规定和国家标准的强制性要求，采取技术措施和其他必要措施，保障网络安全、稳定运行，维护网络数据的（ ）。

A、经济性

B、可用性

C、保密性

D、完整性

答案:BCD"

"Q222、《关于促进数据安全产业发展的指导意见》中，促进数据安全产业发展的措施包括哪些？

A、加强数据安全技术研发

B、培养数据安全人才

C、推进数据安全标准制定

D、推动数据安全产品和服务创新

答案:ABCD"

Q223、信息提供者向征信机构提供个人不良信息，应当事先告知信息主体本人。但是，依照法律、行政法规规定公开的不良信息除外。（正确）

Q224、在 IND-CCA2 安全模型下，攻击者获得挑战密文之后不能继续查询密文的解密结果。（错误）

"Q225、某政务系统遭供应链攻击，因第三方组件含漏洞。应？

A、仅信任开源组件

B、仅内部扫描

C、建立 SBOM（软件物料清单）管理与漏洞情报监控机制

D、禁用所有第三方组件

答案:C"

"Q226、安全需求分析报告中，若没有“控制项优先级排序”，最主要的问题是（ ）。

A、实施阶段难以确定整改先后顺序和资源投入重点

B、日志留存时间会减少

C、数据会自动出境

D、系统可用性必然下降

答案:A"

"Q227、某人力资源平台收集求职者的学历、工作经历等信息，并未经同意向用人单位出售了含有求职者手机号的完整简历。以下说法正确的是？

A、简历信息属公开数据，可自由使用

B、未经个人同意向第三方提供个人信息，违反《个人信息保护法》关于向第三方提供须取得个人单独同意的规定

C、B2B 商业合作不受个保法约束

D、仅违反了合同法

答案:B"

"Q228、对全球重点国家的数据跨境转移要求划分成高中低风险，依据风险的高低即合规措施模式对各国家/地区进行归类分级，并给每一等级的国家适配统一的合规措施，最终形成包含合规措施的数据跨境传输风险矩阵，不包括下列哪一等级？

A、严格管控

B、适度管控

C、宽松管控

D、谨慎管控

答案:D"

Q229、根据数据重要性和敏感程度,将数据分为不同级别，如公开、内部、机密等。（正确）

"Q230、某公司的对外公开网站主页经常被黑客攻击后修改主页内容，该公司应当购买并部署下面哪个设备（ ）？

A、安全路由器

B、网络审计系统

C、网页防篡改系统

D、VPN 专用设备

答案:C"

"Q231、以下 Windows 系统的账号存储管理机制 SAM（Security Accounts Manager）的说法哪个是正确的（ ）？

A、存储在注册表中的账号数据是管理员组用户都可以访问，具有较高的安全性

B、存储在注册表中的账号数据 administrator 账户才有权访问，具有较高的安全性

C、存储在注册表中的账号数据任何用户都可以直接访问，灵活方便

D、存储在注册表中的账号数据只有 System 账号才能访问，具有较高的安全性

答案:D"

"Q232、某企业数据安全团队在年度合规审查中发现，数据安全影响评估（DPIA）仅在新产品上线时开展，已上线产品从未回顾评估。该实践的问题是？

A、违反了数据安全影响评估应在处理活动存续期间持续评估的要求

B、新产品上线时评估已足够

C、已有评估报告即可，无需重新评估

D、由业务部门自行决定评估频率

答案:A"

"Q233、《中华人民共和国民法典》总则编规定，法律对（ ）、网络虚拟财产的保护有规定的，依照其规定。

A、文件

- B、数据
- C、现实资产
- D、专利

答案:B"

"Q234、以下哪种情形不适用《网络安全法》？

- A、在中国境内建设网站
- B、在中国境内运营网站
- C、在中国境内使用网站
- D、在中国境外使用网站

答案:D"

"Q235、某政务系统梳理数据资产时，发现历史系统已下线但数据未归档销毁。治理流程应？

- A、永久保留所有历史数据
- B、直接物理删除
- C、交由法务裁决
- D、建立数据生命周期归档与销毁机制

答案:D"

"Q236、基于智能卡的认证方式包括哪两种因素？

- A、用户名和密码
- B、IC 卡和 PIN
- C、生物特征和算法
- D、共享密钥和口令

答案:B"

"Q237、亚太经济合作组织（APEC）在哪一年通过了《跨境隐私规则体系》（CBPR）？

- A、2010 年
- B、2003 年
- C、2008 年
- D、2011 年

答案:D"

Q238、软件缺陷密度计算：某软件共有 30 万行源代码，总共检出 150 个缺陷，软件缺陷密度值是 0.5。
（正确）

"Q239、通过互联网等信息网络订立的电子合同的标的为交付商品并采用快递物流方式交付的，（ ）为交付时间。

- A、购物订单下单时间
- B、快递订单下单时间
- C、快递发货时间
- D、收货人的签收时间

答案:D"

"Q240、某银行核心系统在数据安全评估中发现：数据库账号密码以明文存储在配置文件中，且该配置文件对所有开发人员开放。该漏洞的主要风险是？

- A、数据库凭证泄露导致未授权访问与数据窃取
- B、系统响应速度下降
- C、硬盘空间不足
- D、前端页面显示错误

答案:A"

"Q241、数据处理者应当采取什么措施保障数据免遭泄露、篡改、破坏、丢失、非法获取或者非法利用？

- A、仅依赖技术手段
- B、仅依赖管理制度
- C、采取技术保护和管理措施
- D、无需采取任何措施

答案:C"

Q242、文本信息隐藏中的语义隐藏主要是通过调整文本格式来达到隐藏信息的目标。（错误）

Q243、DAC 模型允许资源的所有者决定其他用户对其资源的访问权限。（正确）

"Q244、Linux 中关于登陆程序的配置文件默认的为（ ）。

A、/etc/pam.d/system-auth

B、/etc/login.defs

C、/etc/shadow

D、/etc/passwd

答案:B"

Q245、一次性口令是固定的验证数据，由用户自己设置或系统分配，安全性较低。（错误）

"Q246、数据安全需求分析报告中，通常不应缺少的内容包括哪些？

A、业务场景与数据流描述

B、威胁与风险识别结果

C、安全控制需求建议

D、餐饮补贴发放标准

答案:ABC"

"Q247、下列哪些行为可能违反《数据安全法》的规定？

A、非法获取数据

B、篡改数据

C、泄露数据

D、合法利用数据

答案:ABC"

Q248、生日攻击是针对 RC4 算法的分析方法。（错误）

"Q249、以下关于认证和加密的表述中，错误的是（）。

A、加密用以确保数据的保密性

B、认证用以确保报文发送者和接收者的真实性

C、认证和加密都可以阻止对手进行被动攻击

D、身份认证的目的在于识别用户的合法性，阻止非法用户访问系统

答案:C"

Q250、网络运营者应当加强对其用户发布的信息的管理，发现法律、行政法规禁止发布或者传输的信息的，应当立即停止传输该信息，采取删除措施，防止信息扩散，保存有关记录，并向有关主管部门报告。（正确）

"Q251、某金融系统对“用户银行卡余额”分级应考虑的核心因素是？

A、数据存储位置

B、泄露后的危害程度

C、字段名称特征

D、生成时间

答案:B"

"Q252、根据《个人信息保护法》的规定，以下哪种会受到《个人信息保护法》的规制？

A、接受、处理某 APP 违规收集用户位置信息的投诉、举报

B、接受、处理某 APP 出售商品质量不合格的投诉、举报

C、调查、处理某 APP 违法从事金融经营活动

D、调查、处理某 APP 的违法宣传活动

答案:A"

"Q253、在 HDFS 透明加密中，每个文件块都有一个独立的加密密钥，这个密钥由（ ）来管理。

A、HDFS 管理员

B、文件所有者

C、Key Management Service（KMS）

D、操作系统管理员

答案:C"

"Q254、根据《数据安全法》，本法所称""数据安全""的定义是？

A、通过技术手段防止数据被黑客攻击的能力

B、通过采取必要措施，确保数据处于有效保护和合法利用的状态，以及具备保障持续安全状态的能力

C、对数据进行加密存储的技术体系

D、网络安全等级保护制度的组成部分

答案:B"

"Q255、POW 是指（ ）。

A、权益证明

B、工作量证明

C、零知识证明

D、以上都不是

答案:B"

"Q256、大数据存储技术首先要解决的是数据海量化和快速增长需求，其次是处理格式多样化的数据。

谷歌文件系统（GFS）和 Hadoop 的（ ）奠定了大数据存储技术的基础

A、分布式文件系统

B、分布式数据库系统

C、关系型数据库系统

D、非结构化数据分析系统

答案:A"

"Q257、某企业想判断“哪个数据对象最适合作为权限配置基准单元”，以下通常最合理的是（ ）。

A、字段或数据集，根据敏感度和业务使用场景细分控制

B、整家公司一个统一权限级别

C、服务器机柜

D、员工工龄

答案:A"

"Q258、某安全团队在事件处置中，只记录“已解决”，不记录“处置动作、时间线、证据位置、复盘结论”。其最主要风险是（ ）。

A、后续审计和复盘无法验证处置质量

B、磁盘空间立刻不足

C、证书自动过期

D、密码复杂度降低

答案:A"

"Q259、根据《网络安全法》的规定，网络安全事件应急预案应当按照事件发生后的（ ）等因素对网络安全事件进行分级。

A、危害程度

B、影响范围

C、事件大小

D、关注人数

答案:AB"

"Q260、关于表分区的说法正确的有？

A、表分区存储在表空间中

B、表分区可用于任意的数据类型表

C、表分区不能用于含有自定义类型的表

D、表分区的每个分区都必须具有明确的上界值

答案:AC"

"Q261、数据脱敏（Data Masking），指的是通过脱敏规则对敏感信息（比如，身份证号、手机号、客户姓名、客户地址等）进行数据变形，从而降低数据的敏感度，降低个人隐私泄露的风险，实现隐私数据的可靠保护。业界常见的脱敏规则有（ ）。

A、替换

B、加密

C、截断

D、掩码

答案:ABCD"

"Q262、网络安全等级保护 2.0 正式实施日期是（ ）。

A、2017-06-01

B、2019-12-01

C、2019-12-10

D、2019-05-10

答案:B"

Q263、当事人约定使用电子签名、数据电文的文书，不得仅因为其采用电子签名、数据电文的形式而否定其法律效力。（正确）

Q264、硬分叉和软分叉是在区块链网络中进行升级或更改的两种不同方式。软分叉是一种向后兼容的协议更改，旧版本节点仍可与新版本节点通信；硬分叉则是不兼容的协议更改，导致链的分裂。（正确）

"Q265、下列哪些领域属于数字水印的应用（ ）

- A、盗版追踪
- B、版权保护
- C、数字签名
- D、复制保护

答案:ABD"

"Q266、若一次数据泄露事件同时涉及应用日志、数据库审计日志和 WAF 日志，最合理的溯源方式是（ ）。

- A、多源日志时间线关联分析
- B、只看 WAF 日志
- C、只看数据库备份
- D、只问当班运维人员

答案:A"

"Q267、以下违反民法典的有：

- A、为维护公共利益或者该自然人合法权益，合理利用个人信息
- B、信息管理者未经自然人同意向他人提供其个人信息
- C、合理处理该自然人自行公开的或者其他已经合法公开的信息
- D、公开该自然人明确拒绝或者使该自然人的利益受到重大侵害的信息

答案:BD"

"Q268、在哪一年，数据被确定为生产要素之一。

- A、2018 年
- B、2019 年
- C、2020 年
- D、2021 年

答案:B"

"Q269、基于策略的访问控制模型（PBAC）是通过什么来控制对资源的访问权限？

- A、用户行为
- B、系统管理员
- C、定义的访问控制策略
- D、用户角色

答案:C"

"Q270、《中华人民共和国网络安全法》主要涉及下列哪些制度或要求？

- A、网络安全等级保护
- B、关键信息基础设施保护
- C、个人信息保护
- D、网络实名制相关要求

答案:ABCD"

Q271、GB/T 43697-2024《数据安全技术数据分类分级规则》中，个人信息是指以电子或者其他方式记录的与已识别或者可识别的自然人有关的各种信息。（正确）

"Q272、口令安全管理中，下列哪个原则是不正确的？

- A、口令应至少包含 8 个字符以上
- B、口令应包含大小写字母、数字和特殊字符
- C、口令可以与账号相同
- D、口令应有时效机制，定期更换

答案:C"

"Q273、某互联网 APP 收集用户位置信息，但未实施最小频次采集（如每秒 1 次）。应？

- A、维持高频采集
- B、关闭定位功能
- C、仅更新隐私政策
- D、调整采集策略，按业务必要设置合理间隔与精度

答案:D"

"Q274、根据《网络数据安全管理条例》，网络平台服务提供者应当为用户提供哪些功能？

- A、设置易于理解、便于访问和操作的个性化推荐关闭选项
- B、拒绝接收推送信息的功能
- C、删除针对其个人特征的用户标签等功能
- D、自动购买功能

答案:ABC"

"Q275、Wi-Fi 使用_____系列协议。

- A、IEEE 802.11
- B、IEEE 802.12
- C、IEEE 802.11g
- D、IEEE 803.11

答案:A"

"Q276、需求分析阶段若要判断某类数据是否应纳入“强化保护范围”，最重要的依据通常是（ ）。

- A、该数据的泄露、篡改、滥用可能造成的影响程度
- B、系统部署城市
- C、数据库品牌
- D、开发团队人数

答案:A"

"Q277、国家鼓励开发网络数据安全保护和利用技术，促进（ ），推动技术创新和经济社会发展。

- A、国家政务数据开放

B、国家数据资源开放

C、公共数据资源开放

D、敏感数据合理开放

答案:C"

"Q278、关于 MySQL 加密方案的正确描述有哪些？

- A、应用层 AES 加密需自主管理密钥轮转
- B、TDE 加密会增加 I/O 延迟
- C、云 KMS 无法满足等保三级要求
- D、云 KMS 支持硬件级密钥保护
- E、静态配置文件存储密钥最安全

答案:ABD"

"Q279、修订后的《网络安全法》新增条款，对哪项技术的安全与发展作出专门规定？

- A、大数据
- B、云计算
- C、区块链
- D、人工智能

答案:D"

"Q280、某项目拟上线“对外数据开放平台”，方案设计时若忽略数据使用者身份分类，最直接的问题是（ ）。

- A、无法实现差异化访问控制和最小授权
- B、前端页面会变慢
- C、日志会自动清空
- D、备份频率会下降

答案:A"

Q281、修订后的《网络安全法》是自 2017 年该法施行以来的第一次修订。（正确）

"Q282、某电商平台发现第三方支付 SDK 在用户未操作时仍持续读取剪贴板数据。该行为违反了哪些规定？

- A、《个人信息保护法》关于最小必要原则的规定
- B、《App 违法违规收集使用个人信息行为认定方法》
- C、《网络安全法》关于网络运营者义务的规定
- D、《合同法》关于履行义务的规定

答案:ABC"

"Q283、下列哪个情形，个人信息处理者不可处理个人信息：

- A、为应对突发公共卫生事件，或者紧急情况下为保护自然人的生命健康和财产安全所必需
- B、并非履行法定职责或者法定义务所必需，且未获得当事人允许
- C、为公共利益实施新闻报道、舆论监督等行为，在合理的范围内处理个人信息
- D、法律、行政法规规定的其他情形

答案:B"

"Q284、基于身份的攻击通常始于什么类型的活动？

- A、网络钓鱼活动
- B、恶意软件攻击
- C、中间人代理攻击
- D、SIM 卡交换攻击

答案:A"

"Q285、中间人代理攻击是指什么？

- A、攻击者通过感染恶意软件接管用户通道
- B、攻击者通过网络钓鱼诱骗用户输入凭据
- C、攻击者利用漏洞绕过 MFA
- D、攻击者冒充合法服务在用户和真实服务之间充当代理

答案:D"

"Q286、在数据资产盘点中，以下哪项最适合作为“数据资产清单”的核心内容？

- A、数据库品牌和服务器机柜颜色

- B、数据资产名称、所属系统、责任部门、数据类型、敏感级别
- C、员工工位分布图
- D、供应商营销资料

答案:B"

Q287、网络运营者应当对其收集的用户信息严格保密，并建立健全用户信息保护制度。（正确）

"Q288、关于""数据出境安全评估申报指南（第三版）""的主要变化，以下说法正确的是？

- A、将""重要数据""的申报门槛提高
- B、增加了豁免申报的情形说明，与《促进和规范数据跨境流动规定》配套
- C、取消了对境外接收方评估的要求
- D、缩短了申报材料的准备时间

答案:B"

"Q289、在数据质量治理中，“完整性”通常关注（ ）。

- A、必要字段是否缺失、记录是否残缺
- B、是否使用了最新浏览器
- C、机房门禁是否启用
- D、是否完成年度审计

答案:A"

Q290、口令认证是身份认证的常见实现方式之一。（正确）

"Q291、《中华人民共和国民法典》规定，（ ）的个人信息受法律保护。

- A、中国人民
- B、中国公民
- C、自然人
- D、法人

答案:C"

"Q292、《数据安全技术 数据安全风险评估方法》国

家标准于何时发布？

- A、2024-04-25
- B、2025-04-25
- C、2025-06-01
- D、2025-11-01

答案:B"

"Q293、根据《电子签名法》的规定，电子签名需要第三方认证的，由依法设立的（ ）提供认证服务。

- A、网络服务提供者
- B、电子认证服务提供者
- C、征信机构
- D、密码管理机构

答案:B"

"Q294、关键信息基础设施的运营者采购网络产品和服务，可能影响国家安全的，应当通过国家网信部门会同国务院有关部门组织的（ ）。

- A、国家网络审查
- B、国家涉密审查
- C、国家采购审查
- D、国家安全审查

答案:D"

"Q295、运营者采购网络产品和服务，应当（ ）。

- A、按照国家有关规定与网络产品和服务提供者签订安全保密协议
- B、明确提供者的技术支持和安全保密义务与责任
- C、并对义务与责任履行情况进行监督
- D、拒绝支付任何的费用

答案:ABC"

"Q296、在 PKI 系统中，数字证书认证中心（CA）的作用包括哪些？

- A、签发证书

B、分发证书

- C、提供身份认证服务
- D、提供访问控制
- E、提供审计功能

答案:ABC"

"Q297、《中华人民共和国民法典》规定，医疗机构及其医务人员应当对患者的隐私和个人信息保密。

（ ）患者的隐私和个人信息，或者未经患者同意公开其病历资料的，应当承担侵权责任。

- A、泄露
- B、传播
- C、存储
- D、买卖

答案:A"

"Q298、下列哪个不是资源对象？

- A、文件
- B、应用服务
- C、数据
- D、用户

答案:D"

"Q299、下列对爬虫使用说法错误的是（ ）。

- A、网络数据爬取应限于对开放数据的获取。如果网络爬虫获取非开放的数据，便涉嫌违法甚至犯罪
- B、数据爬虫技术不应具有侵入性，可以说，爬虫的侵入性是其违法性的主要体现
- C、数据爬取应当基于正当目的，对开放数据的获取可能因不符合正当目的而具有违法性
- D、爬取公开数据时即使突破网站或 App 的反爬虫技术设置进行爬取，行为人不需承担刑事责任

答案:D"

"Q300、威胁情报在数据安全运营中的直接价值包括哪些？

- A、帮助识别已知攻击方式和高危漏洞利用趋势
- B、支持异常行为关联分析
- C、完全替代风险评估
- D、为防护规则更新提供输入

答案:ABD"

"Q301、在数据安全架构设计中，将“身份认证、访问控制、日志审计、告警联动”作为一体化方案考虑，主要是为了（ ）。

- A、构建可验证、可追溯、可联动的控制闭环
- B、减少所有合规要求
- C、替代数据分类分级
- D、取消人工审批流程

答案:A"

Q302、区块链信息服务提供者不得为不进行真实身份信息认证的用户提供相关服务。（正确）

"Q303、某政务数据目录中，""行政审批结果""数据被标为不予共享。依据政务数据共享规则，该标记是否合理？

- A、合理，所有审批结果均保密
- B、不合理，依法应公开或条件共享的应标注共享属性
- C、视领导批示而定
- D、仅 IT 部门可修改

答案:B"

Q304、收件人指定特定系统接收数据电文的，数据电文进入该特定系统的时间，视为该数据电文的接收时间；未指定特定系统的，数据电文进入收件人的任何系统的首次时间，视为该数据电文的接收时间。（正确）

"Q305、关键信息基础设施发生较大变化，可能影响其认定结果的，运营者应当及时将相关情况报告保护工作部门。保护工作部门自收到报告之日起（ ）内完成重新认定，将认定结果通知运营者，并通报国务院公安部门。

- A、1 个月
- B、2 个月
- C、3 个月
- D、6 个月

答案:C"

"Q306、区块链信息服务提供者应当记录区块链信息服务使用者发布内容和日志等信息，记录备份应当保存不少于（ ）。

- A、3 个月
- B、6 个月
- C、9 个月
- D、12 个月

答案:B"

"Q307、当需求分析发现“同一份数据将被多个外部合作方复用”时，首要控制要求应包括哪些？

- A、按合作方分别界定授权边界
- B、分别约定用途与保存期限
- C、建立共享台账和流转可追溯机制
- D、默认共享条件完全相同

答案:ABC"

Q308、跨站点脚本（XSS）攻击是指攻击者通过在受信任的网站上注入恶意脚本，以窃取用户的凭据或会话信息。（正确）

Q309、数据安全运维是保证数据的安全、可靠、有效、实时,以及可供用户使用的过程。（正确）

Q310、基于生物特征是常见的身份认证方式之一。（正确）

"Q311、下列哪种通信技术不属于低功率短距离的无线通信技术？

- A、广播
- B、超宽带技术
- C、蓝牙

D、Wi-Fi

答案:A"

Q312、为保护商业机密，一般会的核心员工签署竞业限制协议。竞业限制是指员工在终止或解除劳动合同后的一定期限内不得在生产同类产品、经营同类业务或有其他竞争关系的企业任职，也不得自己生产与原企业有竞争关系的同类产品或经营同类业务。（正确）

"Q313、数据目录与数据资产清单的关系，以下表述更准确的是（ ）。

A、两者完全无关

B、数据目录通常是面向管理与使用展示的数据资产清单组织形式

C、数据目录只记录服务器信息

D、数据资产清单只适用于纸质文件

答案:B"

"Q314、企业将研发数据分级为 “核心商业机密”，以下加密策略合理的是？

A、使用简单替换密码算法（如凯撒密码）

B、采用 AES-256 加密存储，并定期更换密钥

C、仅对数据传输加密，存储时明文保存

D、将加密密钥与数据存储在同一服务器

答案:B"

"Q315、某企业数据导出功能未实施审批与水印，导致敏感文件外泄。应？

A、禁用导出功能

B、仅记录日志

C、增加导出审批流，强制添加数字/明文水印溯源

D、仅口头警告

答案:C"

"Q316、根据《人脸识别技术应用安全管理办法》，对不满（ ）周岁的未成年人使用人脸识别技术，应当取得其父母或其他监护人的同意。

A、14 周岁

B、16 周岁

C、18 周岁

D、12 周岁

答案:A"

"Q317、在数据安全测试中，白盒测试更适合发现哪类问题？

A、源代码中的逻辑漏洞与不安全实现

B、机房供电隐患

C、业务部门审批超时

D、采购合同条款错误

答案:A"

Q318、国家保护个人、组织与数据有关的权益，鼓励数据依法合理有效利用，保障数据依法有序自由流动，促进以数据为关键要素的数字经济发展。（正确）

"Q319、区块链中常用的哈希函数是（ ）。

A、MD5

B、SHA-256

C、SM3

D、SHA-3

答案:B"

"Q320、数据安全事件复盘报告最不应缺少的内容是（ ）。

A、事件根因、处置过程、影响范围和后续改进措施

B、办公用品库存

C、停车位占用率

D、会议出席率

答案:A"

"Q321、个人信息处理不包括个人信息的：

A、收集

- B、使用
- C、存储
- D、售卖

答案:D"

Q322、根据《促进和规范数据跨境流动规定》，无论是否属于免于申报数据出境安全评估、订立个人信息出境标准合同、通过个人信息保护认证的情况，数据处理者向境外提供个人信息的，均应当按照法律、行政法规的规定履行告知、取得个人单独同意、进行个人信息保护影响评估等义务（正确）

"Q323、数据处理者应当采取哪些措施来保障数据安全？

题目

- A、建立数据安全管理制度
- B、制定数据安全事件应急预案
- C、加强数据安全风险监测
- D、随意分享数据

答案:ABC"

"Q324、根据《人脸识别技术应用安全管理办法》，处理超过（ ）万人人脸信息的，须向省级以上网信部门备案。

- A、1 万人
- B、5 万人
- C、10 万人
- D、100 万人

答案:C"

Q325、数据备份不属于数据安全措施。（错误）

"Q326、《生成式人工智能服务管理暂行办法》由哪些部门联合发布？

- A、国家网信办单独发布
- B、国家网信办、工信部联合发布
- C、国家网信办、国家发改委、教育部、科技部、工

信部、公安部、广电总局联合发布

D、国务院单独发布

答案:C"

"Q327、在基于规则的安全策略中，如何判断用户是否被允许访问客体？

- A、根据用户的安全级别
- B、根据用户的安全标记
- C、根据用户的安全组
- D、根据用户的角色
- E、根据用户的访问控制列表

答案:ABE"

"Q328、根据《信息安全技术 数据安全能力成熟度模型》，数据安全能力成熟度分为几个等级？

- A、2 个
- B、3 个
- C、5 个
- D、7 个

答案:C"

"Q329、关键系统关键岗位的人员，要求（ ）。

- A、关键岗位人员需要经过背景调查
- B、关键岗位人员离职需遵守脱密流程
- C、技能必须匹配
- D、以上都是

答案:D"

Q330、RBAC 模型通常用于大型组织和企业环境。（正确）

"Q331、下列哪项不是防范社会工程学攻击的主要手段？

- A、提供员工教育和培训
- B、建立安全文化
- C、定期评估和审查安全措施

D、随意公开员工联系方式和内部组织信息

答案:D"

"Q332、防火墙的主要类型包括（）。

A、包过滤防火墙

B、应用层防火墙

C、状态检测防火墙

D、区块链防火墙

答案:ABC"

"Q333、《数据安全技术 数据安全风险评估方法》国家标准于何时正式实施？

A、2025-04-25

B、2025-06-01

C、2025-09-01

D、2025-11-01

答案:D"

"Q334、某企业自当年1月1日起已累计向境外提供8万名用户个人信息（不含敏感信息），还计划再向境外提供3万名用户数据。依据《促进和规范数据跨境流动规定》，以下说法正确的是？

A、8万人不需要合规措施，再增加3万人后共11万人也不需要

B、累计达到10万人须适用标准合同或认证路径，但无需申报安全评估

C、须立即申报数据出境安全评估

D、仅需内部审批，无需其他措施

答案:B"

"Q335、以下哪种行为不适用《个人信息保护法》？

A、在中国境内因商业服务处理自然人个人信息

B、在中国境外以向境内自然人提供产品或者服务为目的处理境内自然人个人信息

C、在中国境外分析、评估境内自然人的行为

D、在中国境内因个人事务处理自然人个人信息

答案:D"

"Q336、根据现行数据跨境法律框架，以下哪种说法准确描述了中国数据出境监管的整体逻辑？

A、所有数据出境均须申报安全评估

B、根据数据类型、数量、敏感程度实施分级管理，匹配相应合规路径

C、个人信息出境无需监管

D、只有外资企业须遵守出境规定

答案:B"

"Q337、国家实施网络（）战略，支持研究开发安全、方便的电子身份认证技术，推动不同电子身份认证之间的互认。

A、认证身份

B、可信身份

C、信誉身份

D、实名制身份

答案:B"

"Q338、建设关键信息基础设施应当确保其具有支持业务稳定、持续运行的性能，并保证安全技术措施（）。

A、同步规划

B、同步收益

C、同步建设

D、同步使用

答案:ACD"

"Q339、常见的半结构化数据有哪些。

A、日志

B、XML

C、JSON

D、文档

答案:ABC"

"Q340、数据安全运维体系的核心不包括（ ）。

- A、日常巡检
- B、告警监测
- C、故障排查与升级管理
- D、只在发生事故后一次性处理

答案:D"

Q341、访问控制技术只应用于物理访问控制和网络访问控制。（错误）

"Q342、身份威胁检测与响应的目的是什么？

- A、发现和清除恶意软件感染
- B、监测并响应可疑身份活动
- C、分析组织的身份信息以发现弱点
- D、清除账户接管攻击的弱点

答案:B"

"Q343、在哪个文件中对数据资产入表进行规定？

- A、《关于构建更加完善的要素市场化配置体制机制的意见》
- B、《关于构建数据基础制度更好发挥数据要素作用的意见》
- C、《企业数据资源相关会计处理暂行规定》
- D、《“数据要素×”三年行动计划（2024-2026年）》

答案:C"

"Q344、关于 LoRa，以下说法不正确的是（ ）。

- A、LoRa 和 NB-IOT、SigFox 均属于 LPWAN 通信技术
- B、LoRa 采用基于扩频技术从而实现远距离传输
- C、LoRa 的部署跟 NB-IOT 一样需要申请频段许可
- D、LoRa 具有传输距离远，抗干扰能力强，功耗低的特点

答案:C"

"Q345、某企业已完成一次全量数据资产盘点，但半

年后新上线了 5 个业务系统。数据治理团队最合理的做法是（ ）。

- A、等待下一年度统一盘点
- B、建立数据资产动态更新机制，将新增系统及时纳入资产目录
- C、只更新服务器清单
- D、只在发生数据泄露后再补录

答案:B"

"Q346、所有权人对自己的不动产或者动产，依法享有占有、（ ）、（ ）和（ ）的权利。

- A、销毁
- B、使用
- C、收益
- D、处分

答案:BCD"

Q347、对于关键业务系统的数据备份，按照网络安全等级保护三级及以上的强制要求，应当采用异地备份。（正确）

Q348、当使用爬虫技术进入到特定程序之中，甚至获取了特定的数据，如果该数据的性质、获取的价值超过法定限制，便会涉嫌“非法获取计算机信息系统数据罪”。如何认定“非法获取计算机信息系统数据罪”中的“情节严重”“情节特别严重”，《最高人民法院、最高人民检察院关于办理危害计算机信息系统安全刑事案件应用法律若干问题的解释》给予了明确的规范。（正确）

"Q349、基于密码的身份验证容易被攻击者滥用的原因是什么？

- A、人们经常重复使用密码并使用字典单词和公开的个人信息创建可猜测的密码
- B、员工需要为他们使用的每个应用程序和设备设置密码，这使他们难以记住
- C、密码策略要求用户定期更改密码并要求密码保持一定的复杂度

D、账户更容易受到网络钓鱼和暴力攻击

答案:A"

Q350、比特币可以一直产生新区块，比特币的总量是无限的。（错误）

"Q351、访问控制的客体是指什么？

A、一个提出请求或要求的实体，是动作的发起者

B、接受其他实体访问的被动实体

C、主动发起访问请求的实体

D、被动接受访问请求的实体

答案:B"

"Q352、某企业在数据共享设计时，要求所有共享数据都先做“用途审批 + 字段裁剪 + 审计留痕”。该设计主要体现了（ ）。

A、最小必要与可追溯原则

B、零日志原则

C、完全匿名化原则

D、去中心化存储原则

答案:A"

"Q353、某政务云虚拟机遭横向移动攻击，因内部网络未微隔离。应？

A、仅加强边界防火墙

B、实施东西向流量微隔离策略，限制非授权通信

C、关闭所有虚拟机

D、忽略，内网无风险

答案:B"

"Q354、某制造企业发现生产配方数据经脱敏处理后，仍可通过组合字段还原。该数据原分级应？

A、维持原级，脱敏即安全

B、上调分级，因去标识化不彻底

C、降级为公开数据

D、交由外部审计定级

答案:B"

"Q355、在单点登录（SSO）认证过程中，为什么需要使用 SSL 通道来传递 Cookie？

A、提高用户体验

B、加快应用系统的响应速度

C、增加 Cookie 的安全性

D、减小 Cookie 被截获的可能性

答案:D"

Q356、数据商在从事数据发布、销售业务时，应当对数据来源以及数据提供方的身份、资质进行审核。（正确）

Q357、数据分类分级是数据安全管理的基礎。（正确）

"Q358、某科技公司产品基于用户浏览记录自动生成用户画像并推送定制广告，未向用户提供关闭选项。依据《个人信息保护法》，该行为违反了哪项要求？

A、数据加密存储要求

B、应当向个人提供不针对其个人特征的选项，或者提供便捷的拒绝方式

C、数据跨境传输要求

D、数据备份要求

答案:B"

"Q359、根据《人脸识别技术应用安全管理办法》，在公共场所安装图像采集、人脸识别设备应当符合哪些要求？

A、为维护公共安全所必需

B、遵守国家有关规定

C、设置显著提示标识

D、可不告知采集目的，仅备案即可

答案:ABC"

"Q360、从数据安全工程技术人员职业能力成长路径看，最高级别最核心的特征之一是（ ）。

A、仅能执行固定流程

B、能够把数据管理、工程实施、运营监测与评估改进整合为体系化能力

C、只会做法律记忆题

D、只会操作单一安全产品

答案:B"

"Q361、社会工程学攻击经常利用人的哪些弱点？

A、轻信他人、缺乏警觉性

B、不了解安全风险、容易冲动操作

C、对“权威”“熟人”“紧急情况”缺少核验

D、以上都是

答案:D"

"Q362、以下哪些属于物联网常见的通信技术？

A、蓝牙（Bluetooth/BLE）

B、Wi-Fi

C、LoRa

D、NB-IoT

答案:ABCD"

"Q363、ZigBee 网络拓扑类型不包括（ ）。

A、星型

B、网状

C、环形

D、树形

答案:C"

"Q364、根据《中华人民共和国个人信息保护法》规定，个人信息的处理包括个人信息的收集、（ ）、提供、公开、删除等。

A、存储

B、使用

C、加工

D、传输

答案:ABCD"

"Q365、以下不属于大数据特性的是（ ）。

A、数据体量大

B、数据价值密度大

C、数据实时性高

D、数据维度多

答案:B"

"Q366、下列关于数据出境安全评估的说法，正确的是？

A、数据出境安全评估结果长期有效

B、数据出境安全评估仅针对重要数据

C、数据出境安全评估由数据处理者自行决定

D、数据出境安全评估结果应当作为数据出境的依据

答案:D"

"Q367、对外共享接口在需求分析阶段，首先要明确的不是（ ）。

A、共享目的与合法依据

B、共享数据范围与字段

C、接口认证与审计要求

D、接口服务器的 CPU 品牌

答案:D"

"Q368、密码猜测/暴力破解攻击的目的是（ ）。

A、窃取用户的生物特征信息

B、获取用户的凭据（账号密码）

C、篡改身份验证信息

D、欺骗用户进行认证

答案:B"

"Q369、某企业数据资产目录未与权限管理系统联动。治理缺陷导致？

- A、权限分配缺乏数据依据，易过度授权
- B、系统性能提升
- C、网络延迟降低
- D、前端优化

答案:A"

"Q370、密码协议相关描述中，错误的是（ ）。

- A、在实际应用中，密码协议应按照灵活性好、可扩展性高的方式制定，不要限制和框住执行步骤，有些复杂的步骤可以不明确处理方式
- B、密码协议定义了两方或多方之间为完成某项任务而指定的一系列步骤，协议中的每个参与方都必须了解协议，且按步骤执行
- C、根据密码协议应用目的的不同，参与该协议的双方可能是朋友和完全信任的人，也可能是敌人和互相完全不信任的人
- D、密码协议（Cryptographic protocol），有时也称安全协议（security protocol），是使用密码学完成某项特定的任务并满足安全需求的协议

答案:A"

"Q371、企业进行数据合规风险评估工作时，在（ ）阶段应明确评估目标和范围，确定评估的基本原则和方法，明确评估的职责和任务，并为评估工作做好充足的准备、资料和技术支持。

- A、评估准备
- B、合规义务识别
- C、合规风险识别
- D、合规风险评价

答案:A"

Q372、IIS FTP 服务器不支持任何形式的访问控制，所有用户都可以匿名访问和上传文件。（错误）

"Q373、物联网中的恶意软件是指什么？

- A、针对物联网设备的恶意软件程序
- B、针对物联网网络的恶意软件程序

- C、针对物联网数据的恶意软件程序
- D、针对物联网用户的恶意软件程序

答案:A"

Q374、为订立、履行个人作为一方当事人的合同所必需，或者按照依法制定的劳动规章制度和依法签订的集体合同实施人力资源管理所必需，处理个人信息不需取得个人同意。（正确）

"Q375、某政府采购项目要求中标供应商提交含有国家秘密级别标注的数据样本用于系统演示。供应商应如何正确处理？

- A、提前向采购方确认是否存在相关保密资质要求，如涉密须按保密规定走审批流程，不得随意提供
- B、直接提供，客户需要为首
- C、提供脱密版本即可
- D、拒绝参与投标

答案:A"

"Q376、根据《生成式人工智能服务管理暂行办法》，提供者发现用户利用生成式人工智能服务从事违法活动的，应当采取哪些措施？

- A、停止提供服务
- B、保存有关记录
- C、向有关主管部门报告
- D、向媒体公开披露用户身份

答案:ABC"

"Q377、网络关键设备和网络安全专用产品应当按照相关国家标准的强制性要求，由具备资格的机构（ ）或者安全检测符合要求后，方可销售或者提供。

- A、鉴定产品功能
- B、安全认证合格
- C、测试产品性能
- D、认证产品质量合格

答案:B"

"Q378、根据《个人信息保护法》的规定，哪些主体会受到侵犯个人信息的惩处？

- A、仅对企业
- B、仅对直接负责的主管人员
- C、仅对直接负责的主管人员和其他直接责任人员
- D、对企业及其直接负责的主管人员和其他直接责任人员

答案:D"

Q379、电子签名，是指数据电文中以电子形式所含、所附用于识别签名人身份并表明签名人认可其中内容的数据。（正确）

"Q380、《网络数据安全条例》规定，重要数据的处理者应当明确（ ）和网络数据安全管理机构。

- A、数据安全负责人
- B、网络数据安全负责人
- C、首席数据官
- D、信息安全官

答案:B"

"Q381、比特币和以太坊等主流公有链最常用的数字签名算法是（ ）。

- A、ECDSA（基于 secp256k1 曲线）
- B、RSA
- C、DSA
- D、AES

答案:A"

"Q382、下列属于韩国关于全球数据跨境管控要求清单的是（ ）。

- A、《电子通信法》
- B、《互联网服务和在线信息管理、提供和使用条例》
- C、《电子金融交易监管条例》
- D、《国家数据分享和准入政策》

答案:C"

"Q383、以太坊属于（ ）。

- A、私有链
- B、公有链
- C、联盟链
- D、以上都不是

答案:B"

"Q384、不属于灾备关键技术的是？

- A、数据复制
- B、数据销毁
- C、灾难检测
- D、系统迁移

答案:B"

"Q385、以下哪些是符合当前网络安全标准（如 NIST SP 800-63B、ISO 27002:2022）的口令安全管理原则？

- A、最小长度建议 8 个字符以上
- B、禁止使用默认口令
- C、共享账号和口令是允许的
- D、在怀疑泄露时应立即更换口令
- E、口令不得以明文形式在网络上传递

答案:ABDE"

"Q386、NAND FLASH 和 NOR FLASH 的区别正确的是（ ）。

- A、NOR 的读速度比 NAND 稍慢一些
- B、NAND 的擦除速度远比 NOR 的慢
- C、NAND 的写入速度比 NOR 慢很多
- D、大多数写入操作需要先进行擦除操作

答案:D"

"Q387、防火墙是网络信息系统建设中常常采用的一类产品，它在内外网隔离方面的作用是（ ）。

- A、既能物理隔离，又能逻辑隔离
- B、能物理隔离，但不能逻辑隔离
- C、不能物理隔离，但是能逻辑隔离
- D、不能物理隔离，也不能逻辑隔离

答案:C"

"Q388、某 SaaS 云服务商为客户存储数据，合同到期后未主动删除客户数据，而是将数据保留用于内部产品优化。该行为的主要违规点是？

- A、超出服务期限继续处理客户数据，违反数据处理目的的限制原则
- B、属于正常商业实践
- C、客户数据归服务商所有，可自由使用
- D、仅违反了合同条款，不违反法律

答案:A"

Q389、数据本地化是数据跨境管理的一种措施，通常理解为某一主权国家/地区，通过制定法律或规则来限制本国/地区数据向境外流动，是对数据出境进行限制的做法之一。（正确）

"Q390、以下可以用于数据完整性验证的技术有()

- A、哈希算法
- B、数字签名
- C、消息认证码(MAC)
- D、数据加密

答案:ABC"

"Q391、供应链安全治理中，SBOM 的直接作用是（ ）。

- A、列明软件物料组成，便于漏洞关联和影响分析
- B、替代所有渗透测试
- C、提升前端美观度
- D、自动删除历史日志

答案:A"

"Q392、在零信任安全模型中，访问控制决策基于哪

些因素？

- A、用户身份验证状态
- B、设备类型
- C、用户地理位置
- D、应用程序版本
- E、网络通信协议

答案:ABCD"

"Q393、某科技公司采集员工人脸信息用于考勤，并将人脸识别数据留存用于后续""安全事件调查""。该做法是否符合《人脸识别技术应用安全管理办

- A、符合，留存有助于安全管理
- B、不符合；人脸信息存储期限应以实现处理目的所必需的最短时间为准，超期留存须有明确法律依据
- C、由企业内部制度决定
- D、须经员工个别同意后可长期留存

答案:B"

"Q394、LoRaWAN 网络中的反重放攻击是指什么？

- A、防止攻击者重复发送相同的数据包以欺骗系统的机制
- B、网络服务器重复发送相同的数据包
- C、终端设备在同一时间窗口内发送多个数据包
- D、网关将数据包重复传输到网络服务器

答案:A"

Q395、数据资源的合法拥有或控制仅需要确保数据来源的合法性，无需考虑数据利用和流通的合法性。（错误）

"Q396、根据《生成式人工智能服务管理暂行办法》，提供者在处理用户投诉和举报方面须承担哪些义务？

- A、建立健全投诉、举报机制，设置便捷的投诉、举报入口

- B、对用户投诉 7 个工作日内必须公开回复
- C、将投诉内容向主管部门实时推送
- D、拒绝处理匿名投诉

答案:A"

"Q397、多因素身份验证的目的是什么？

- A、提高用户方便性
- B、减少数据传输的复杂性
- C、加强身份验证的安全性
- D、加速系统登录速度

答案:C"

Q398、根据《工业和信息化领域数据安全管理办法（试行）》，工业数据发生安全事件且涉及三级数据时，企业应当及时上报数据所在地的省级工业和信息化主管部门。（正确）

"Q399、关于 WI-FI 联盟提出的安全协议 WPA 和 WPA2 的区别。下面描述正确的是（ ）。

- A、WPA 是有线局域安全协议，而 WPA2 是无线局域网协议
- B、WPA 是适用于中国的无线局域安全协议，WPA2 是适用于全世界的无线局域网协议
- C、WPA 没有使用密码算法对接入进行认证，而 WPA2 使用了密码算法对接入进行认证
- D、WPA 是依照 802.11i 标准草案制定的，而 WPA2 是按照 802.11i 正式标准制定的

答案:D"

"Q400、《人工智能生成合成内容标识办法》中，""显式标识""是指（ ）。

- A、采取技术措施在文件数据中添加的、不易被用户明显感知到的标识
- B、在生成合成内容或交互场景界面中添加的、以文字、声音、图形等方式呈现并可以被用户明显感知到的标识
- C、仅通过数字水印技术添加的标识

D、在服务条款中说明的标识方式

答案:B"

"Q401、运输、携带、邮寄计算机信息媒体进出境的，应当如实向（ ）申报。

- A、省级以上人民政府公安机关
- B、国家安全部
- C、国家保密局
- D、海关

答案:D"

"Q402、运营者网络安全管理负责人履行下列职责（ ）。

- A、组织制定网络安全规章制度、操作规程并监督执行
- B、组织对关键岗位人员的技能考核
- C、组织开展网络安全检查和应急演练，应对处置网络安全事件
- D、以上都是

答案:D"

"Q403、在下载软件及操作系统补丁时，我们应该采取哪些措施？

- A、下载正版软件并定期更新
- B、及时跟随软件供应商发布的补丁
- C、只要定期使用防病毒软件并定期更新病毒库，网上的破解版也没有关系
- D、尽可能安装 IT 部门提供的软件清单及补丁，不使用来历不明的软件及补丁

E、操作系统一定要用正版，其他工具软件大可不必

答案:ABD"

"Q404、修订后的《网络安全法》对网络运营者（特别是关键信息基础设施运营者）造成大量数据泄露、关键信息基础设施丧失局部功能等严重危害网络安全后果的，对单位的罚款金额范围是（ ）。

- A、十万元以上一百万元以下
- B、五十万元以上二百万元以下
- C、一百万元以上五百万元以下
- D、二百万元以上一千万元以下

答案:B"

"Q405、运营者的（ ）对关键信息基础设施安全保护负总责。

- A、安全运维团队
- B、信息中心负责人
- C、生产责任人
- D、主要负责人

答案:D"

"Q406、防范社会工程学攻击的最有效措施是什么？

- A、完全消除攻击风险
- B、提供高级技术安全措施
- C、组织内部监控员工行为
- D、综合应用多种防范措施

答案:D"

"Q407、自主访问控制模型（DAC）是基于什么原则来控制资源访问权限？

- A、系统管理员决定
- B、资源所有者决定
- C、角色分配决定
- D、属性规则决定

答案:B"

"Q408、根据《人脸识别技术应用安全管理办法》，以下哪种场景的人脸识别应用属于被明确限制的情形？

- A、公安机关依法侦查刑事犯罪（在法定权限内）
- B、宾馆、银行、车站等经营场所以'刷脸'替代人工服务且不提供其他验证方式

C、滥用人脸识别技术分析个人宗教信仰、政治观点等敏感属性

D、物业管理强制要求业主刷脸进出小区且不提供替代方式

答案:BCD"

Q409、区块链中的共识算法是用来解决分布式系统中存在多个故障节点时的数据一致性问题。（正确）

Q410、门罗币使用环签名机制实现了匿名交易系统。（正确）

"Q411、《中华人民共和国数据安全法》所称数据，是指任何以电子或者其他方式对（ ）的记录。

- A、图片
- B、文字
- C、链接
- D、信息

答案:D"

"Q412、国家建立集中统一、高效权威的数据安全风险（ ）、报告、（ ）、监测预警机制。

- A、预测
- B、评估
- C、信息共享
- D、信息加密

答案:BC"

Q413、线性密码分析是一种已知明文攻击。（正确）

Q414、银行保险机构应当在合同或协议中明确要求服务提供商不得将外包服务转包或变相转包。（正确）

"Q415、某企业在数据安全事件处置后，向监管部门提交的报告中将""10 万人信息泄露""描述为""少量用户数据受影响""。该行为可能面临的法律后果是？

- A、因虚报、瞒报安全事件承担额外法律责任，加重处罚
- B、减轻处罚，因为主动上报了

C、无额外风险

D、仅影响内部考核

答案:A"

"Q416、判断隐私政策是否“易于阅读”，下列哪项更直接相关？

A、在 App 中能够找到隐私政策入口

B、隐私政策以单独文档形式发布

C、进入主功能界面后可通过较少步骤访问隐私政策

D、隐私政策文本的字号、颜色、行距等设置不会造成阅读困难

答案:D"

Q417、生物特征欺骗攻击是指攻击者使用伪造的指纹、面部图像等来欺骗基于生物特征的身份认证系统。（正确）

"Q418、根据《电子签名法》的规定，可靠的电子签名需要同时符合下列哪些条件？

A、电子签名制作数据用于电子签名时，属于电子签名人专有

B、签署时电子签名制作数据仅由电子签名人控制

C、签署后对电子签名的任何改动能够被发现

D、签署后对数据电文内容和形式的任何改动能够被发现

答案:ABCD"

Q419、在访问控制模型中，主体（Subject）是访问的发起者（如用户、进程），客体（Object）是被访问的对象（如文件、数据）。（正确）

"Q420、国家大力推进电子政务建设，提高政务数据的科学性、准确性、（ ），提升运用数据服务经济社会发展的能力。

A、创新性

B、公平性

C、便民性

D、时效性

答案:D"

Q421、验证一个系统是否传输加密，一般采用嗅探工具获取其传输的数据包，查看是否有加密措施或其他手段保障传输保密性。（正确）

"Q422、以下哪些信息不属于个人信息？

A、个人医疗记录

B、个人支付凭证

C、个人位置信息

D、匿名化的犯罪记录

答案:D"

"Q423、某跨境电商将境内用户的姓名、收货地址、订单信息发送至境外物流商。该行为最合适的出境合规路径是？

A、申报数据出境安全评估

B、适用“订立和履行合同所必需”的豁免情形

C、订立个人信息出境标准合同

D、进行个人信息保护认证

答案:B"

Q424、密码猜测/暴力破解攻击是指攻击者尝试使用各种可能的密码组合来猜测用户的密码。（正确）

"Q425、云计算平台的安全计划包括以下哪些内容？

A、系统拓扑

B、系统运营单位

C、与外部系统的互连情况

D、云能力类型和部署模式

答案:ABCD"

"Q426、某企业希望自动发现数据库中的敏感字段，最匹配的能力建设方向是（ ）。

A、自动化资产发现与敏感数据识别

B、完全依赖人工抽样检查

C、只检查数据库容量

D、只检查网络出口带宽

答案:A"

"Q427、某企业已完成数据资产清单，但未将责任部门和数据使用角色纳入清单。该缺陷可能直接导致（ ）。

A、无法开展访问权限治理和责任追溯

B、数据库容量立即下降

C、自动化备份失效

D、加密算法不可用

答案:A"

"Q428、若某企业只能恢复数据，无法恢复原有访问控制和审计策略，恢复结果应认定为（ ）。

A、恢复不完整，安全运行条件尚未恢复

B、已完全恢复

C、只要业务能跑就算合格

D、由业务部门自行判断

答案:A"

"Q429、《网络数据安全条例》规定，大型网络平台服务提供者不得利用网络数据、算法、平台规则等从事相关活动，这体现了哪方面的监管要求？

A、数据本地化存储要求

B、反垄断和数据滥用防范要求

C、个人信息保护要求

D、网络安全等级保护要求

答案:B"

"Q430、国家积极开展数据安全治理、数据开发利用等领域的国际交流与合作，参与数据安全相关国际规则和标准的制定，下列说法错误的是

A、数据随意跨境，无需监管

B、数据跨境需要监管

C、为了商业利益，数据可以自由的交易而不需要审查

D、数据在交易之前应该接受审查

答案:AC"

"Q431、运营者应当对（ ），在其上线应用前进行安全检测。

A、外包开发的系统

B、软件

C、接受捐赠的网络产品

D、开发人员个人使用的电脑

答案:ABC"

"Q432、当前，应用软件安全已经日益引起人们的重视，每年新发现的应用软件漏洞已经占新发现漏洞总数一半以上。下列选项中，哪个与应用软件漏洞成因无关（ ）？

A、传统的软件开发工程未能充分考虑安全因素

B、开发人员对信息安全知识掌握不足

C、相比操作系统而言，应用软件编码所采用的高级语言更容易出现漏洞

D、应用软件的功能越来越多，软件越来越复杂，更容易出现漏洞

答案:C"

Q433、从事数据交易中介服务的机构提供服务，不必要求数据提供方说明数据来源，审核交易双方的身份，并留存审核、交易记录。（错误）

"Q434、某项目上线前未验证日志中是否记录了敏感字段明文。最直接的安全缺口是（ ）。

A、生产运行后可能在日志系统中形成二次泄露面

B、数据库会自动损坏

C、网络带宽会归零

D、系统权限会自动回收

答案:A"

"Q435、在数据处理者发生下列哪些情形时，推动相关权利和义务依法依规同步转移。

- A、合并
- B、分立
- C、解散
- D、被宣告破产

答案:ABCD"

"Q436、某团队在上线前只做了功能测试，没有验证脱敏规则是否在导出链路中生效。该缺陷最可能导致（ ）。

- A、脱敏配置在生产导出中失效，敏感字段明文外发
- B、数据库自动恢复
- C、日志自动脱敏
- D、权限自动收缩

答案:A"

"Q437、研究表明，医疗保健行业遭遇数据泄露的可能性比任何其他行业高出 200%。原因很简单：个人敏感数据在黑市上非常有价值且有利可图。因此医疗行业任何违规行为都会产生严重后果。以下哪些做法是医疗行业数据保护最佳实践。

- A、诊疗叫号的大屏通过遮蔽方式保护敏感个人信息
- B、在用于临床试验数据分析场景的数据，必须经过匿名化方式保护个人隐私
- C、各个科室间开放数据访问，以便于科研与交流
- D、影像资料用于教学时，应当去除/遮蔽可能定位到个人的信息

答案:ABD"

"Q438、《个人信息保护合规审计管理办法》规定，专业机构在合规审计中应当履行哪些义务？

- A、具备开展合规审计的能力
- B、诚信正立，公正客观地作出合规审计职业判断
- C、对获取的信息依法保密
- D、不得转委托其他机构开展个人信息保护合规审计

答案:ABCD"

"Q439、《人脸识别技术应用安全管理办法》规定，人脸识别技术使用者应当建立（ ），保存相关记录不少于（ ）个月。

- A、安全管理制度；3 个月
- B、使用台账；6 个月
- C、使用日志；6 个月
- D、安全评估报告；12 个月

答案:C"

"Q440、某企业数据安全监测平台未覆盖云原生环境（容器/K8s）。该盲区可能导致？

- A、容器镜像漏洞、越权访问等风险无法及时发现
- B、系统性能提升
- C、网络延迟降低
- D、成本节约

答案:A"

"Q441、以下哪些场景可能导致浏览网页时个人信息泄露？

- A、访问钓鱼网站
- B、网页被植入恶意代码或挂马
- C、在不安全页面输入账号口令等敏感信息
- D、开启“请勿跟踪（DNT）”功能

答案:ABC"

Q442、根据中国监管口径（如人民银行 2013 年公告），比特币具有与法定货币等同的法律地位。（错误）

"Q443、在设计“重要数据对外共享”架构时，哪项措施最能体现“默认拒绝、按需放行”思想？

- A、白名单审批 + 精细化授权 + 全量审计
- B、共享平台对所有合作方开放通用账号
- C、只要签合同就允许访问
- D、先开放后补审批

答案:A"

"Q444、任何组织、个人收集数据，应当采取（ ）的方式，不得窃取或者以其他非法方式获取数据。

- A、合法、正当
- B、合规、正当
- C、合法、恰当
- D、合规、恰当

答案:A"

"Q445、假冒身份是指攻击者伪装成以下哪种角色？

- A、政府官员
- B、企业高管
- C、授权人员或合法用户
- D、手机应用程序

答案:C"

Q446、对国家机关和法律、法规授权的具有管理公共事务职能的组织的个人信息保护合规审计，不适用《个人信息保护合规审计管理办法》。（正确）

Q447、维护数据安全，应当坚持总体国家安全观，建立健全数据安全治理体系，提高数据安全保障能力。（正确）

"Q448、选择身份验证类型时，企业需要平衡什么？

- A、用户体验和安全性
- B、成本和效率
- C、隐私和安全
- D、速度和可靠性

答案:A"

"Q449、某企业拟开展数据资产盘点，发现各业务系统数据字典标准不一。治理团队应首先？

- A、制定统一数据标准与元数据管理规范
- B、直接合并所有系统
- C、交由各部门自行维护
- D、仅关注核心数据库

答案:A"

"Q450、《促进和规范数据跨境流动规定》将数据出境合规体系的灵活性体现在哪些方面？

- A、对低风险、小规模的数据出境场景增加豁免情形
- B、赋予自贸区探索便利化出境安排的空间
- C、允许企业自主选择安全评估、标准合同或认证三种路径
- D、取消了对重要数据出境的监管

答案:ABC"

"Q451、某互联网平台计划与境外合作伙伴开展""数据联合建模""，数据不跨境但允许境外技术人员远程访问境内原始数据。该模式的合规风险主要体现在？

- A、境外人员远程访问境内数据实质上构成数据出境，须依法履行出境合规义务
- B、远程访问不构成数据传输，无需合规
- C、只要签署保密协议即可
- D、联合建模属于技术合作，不适用数据出境规定

答案:A"

"Q452、《网络数据安全条例》规定，网络平台服务提供者应当设置易于理解、便于访问和操作的什么选项？

- A、数据删除选项
- B、个性化推荐关闭选项
- C、账号注销选项
- D、数据导出选项

答案:B"

"Q453、传统的数据安全的威胁主要包括

- A、数据复制
- B、计算机病毒
- C、黑客攻击
- D、数据信息存储介质的损坏

答案:BCD"

"Q454、针对 API 访问安全，网络服务提供方应支持哪些功能？

- A、支持涉及云服务租户资源操作的服务
- B、支持服务 API 调用前实施用户鉴别和鉴权的功能
- C、支持用户调用服务 API 的访问控制功能
- D、支持服务 API 的调用日志记录的功能

答案:ABCD"

Q455、Robots 协议是网站所有者通过位于网站根目录下的文本文件 robots.txt，提示"网络爬虫"哪些网页不应被抓取，哪些网页可以抓取。关于 Robots 协议的法律属性，我国目前法律尚无明确规定，其法律地位主要依赖司法裁判和行业惯例确定。（正确）

"Q456、关于 OSPF 配置中使用 MD5 认证，以下说法不正确的是（ ）。

- A、OSPF 认证分为明文认证和密文认证两种方式
- B、OSPF 协议是一种典型的链路状态路由协议，它通过路由器之间通过网络接口的状态来建立链路状态数据库，生成最短路径树
- C、OSPF 的认证可以在链路上进行，也可以在整个区域内进行认证，但是在虚链路上不可以进行认证
- D、该配置可以应用在业务终端与业务服务器之间进行路由控制来建立安全的访问路径

答案:C"

"Q457、依据《电信和互联网用户个人信息保护规定》，下列哪项说法是错误的？

- A、电信业务经营者、互联网信息服务提供者收集、使用用户个人信息的，应当明确告知用户收集、使用信息的目的、方式和范围，查询、更正信息的渠道以及拒绝提供信息的后果等事项
- B、电信业务经营者、互联网信息服务提供者不得收集其提供服务所必需以外的用户个人信息或者将信息用于提供服务之外的目的，不得以欺骗、误导或者强迫等方式或者违反法律、行政法规以及双方的约定收集、使用信息

C、电信业务经营者、互联网信息服务提供者及其工作人员对在提供服务过程中收集、使用的用户个人信息可以未经用户同意向其关联公司提供

D、电信业务经营者、互联网信息服务提供者在用户终止使用电信服务或者互联网信息服务后，应当停止对用户个人信息的收集和使用，并为用户提供注销号码或者账号的服务

答案:C"

"Q458、对基础电信网络实施漏洞探测、渗透性测试等活动（ ）。

- A、在确认存在漏洞后才能进行渗透测试
- B、可直接进行渗透测试
- C、应提前在安全相关论坛上公开有关信息
- D、应当事先向国务院电信主管部门报告

答案:D"

"Q459、防火墙的位置一般为（ ）。

- A、内外网连接的关口位置
- B、内网敏感部门的出口位置
- C、非军事区（DMZ）的两侧
- D、以上都对

答案:D"

"Q460、任何个人、组织都有权对违反本法规定的行为向（ ）投诉、举报。

- A、公安机关
- B、国家安全机关
- C、国家网信部门
- D、其他数据安全有关部门

答案:ABCD"

"Q461、对于需要长期留存且频繁查询的重要数据，最合理的安全存储方案通常应同时考虑哪些要素？

- A、加密存储
- B、访问控制

- C、备份恢复
- D、责任人和审计机制

答案:ABCD"

"Q462、根据《个人信息保护法》，个人信息处理者利用个人信息进行自动化决策，不得对个人在（ ）等交易条件上实行不合理的差别待遇。

- A、交易价格
- B、个人年龄
- C、浏览历史
- D、设备型号

答案:A"

"Q463、SIM 卡交换攻击中，攻击者假装丢失原来的电话号码，然后请求什么？

- A、重置受害者的 MFA 设置
- B、将受害者的电话号码转移到自己的 SIM 卡上
- C、发送恶意软件给受害者的设备
- D、窃取受害者的个人信息

答案:B"

"Q464、某企业接到客户投诉，称其个人信息被用于未授权的精准营销，但企业隐私政策中已有模糊授权条款。合规判断应为？

- A、隐私政策已涵盖，无需处理
- B、模糊的一揽子授权不能替代特定场景的明确同意，须重新获取用户单独同意
- C、仅更新隐私政策版本
- D、向用户道歉即可

答案:B"

"Q465、数据安全防护要求不包括以下哪项？

- A、建立数据安全管理和评价考核制度
- B、严格控制重要数据的使用、加工、传输、提供和公开等关键环节，并采取加密、脱敏、去标识化等技术手段保护敏感数据安全

C、采购网络关键设备和网络安全专用产品目录中的设备产品时，应采购通过国家检测认证的设备和产品

D、因业务需要，确需向境外提供数据的，应当按照国家相关规定和标准进行安全评估

答案:C"

Q466、Fabric 是一种联盟链，只有经过授权的成员才能参与链的维护和交易验证。这使得联盟链适用于需要保护敏感数据和隐私的场景。（正确）

"Q467、根据修订后《网络安全法》（2025 年修正版）及《网络数据安全条例》，关键信息基础设施的运营者在中华人民共和国境内运营中收集和产生的个人信息和重要数据应当在（ ）存储。

- A、境内
- B、境外
- C、境内和境外
- D、由数据处理者自主决定

答案:A"

"Q468、为保障数据可用性，系统设计时应关注（ ）。

- A、网络拓扑结构是否存在单点故障
- B、主要网络设备以及关键业务的服务器是否冗余
- C、通信线路是否有多条链路
- D、是否有数据备份与恢复验证措施

答案:ABCD"

"Q469、某企业因违反《个人信息保护法》被处以 2000 万元罚款，企业认为处罚过重提出异议。以下说法正确的是？

- A、企业有权依法申请行政复议或提起行政诉讼，但不影响罚款的执行
- B、提出异议后罚款自动暂缓执行
- C、只要缴纳 50%罚款即可结案
- D、可以直接起诉监管人员

答案:A"

"Q470、物联网分为感知、网络 and () 三个层次。

- A、应用
- B、推广
- C、传输
- D、运营

答案:A"

Q471、美国联邦层面并未立法禁止或限制数据跨境，但针对重点行业或领域的数据实行专门管控；而中国实行的是"以境内存储为原则、安全评估等合规路径为辅"的数据出境管理策略，而非简单的数据本地化策略。(正确)

"Q472、修订后《网络安全法》建立了结构化分级处罚体系，将违法行为按危害后果划分为几个档次？

- A、两档（一般/严重）
- B、三档（一般/严重/特别严重）
- C、四档
- D、五档

答案:C"

"Q473、口令破解是针对系统进行攻击的常用方法，windows 系统安全策略中应对口令破解的策略主要是账户策略中的账户锁定策略和密码策略，关于这两个策略说明错误的是 ()。

- A、密码策略主要作用是通过策略避免用户生成弱口令及对用户的口令使用进行管控
- B、密码策略对系统中所有的用户都有效
- C、账户锁定策略的主要作用是应对口令暴力破解攻击，能有效地保护所有系统用户应对口令暴力破解攻击
- D、账户锁定策略只适用于普通用户，无法保护管理员账户应对口令暴力破解攻击

答案:C"

"Q474、提供重要互联网平台服务、用户数量巨大、

业务类型复杂的个人信息处理者，应当履行下列义务：

- A、定期发布个人信息保护社会责任报告，接受社会监督
- B、对严重违法法律、行政法规处理个人信息的平台内的产品或者服务提供者，停止提供服务
- C、遵循公开、公平、公正的原则，制定平台规则，明确平台内产品或者服务提供者处理个人信息的规范和保护个人信息的义务
- D、按照国家规定建立健全个人信息保护合规制度体系，成立主要由外部成员组成的独立机构对个人信息保护情况进行监督

答案:ABCD"

Q475、若个人撤回同意，将影响撤回前基于个人同意已进行的个人信息处理活动的效力。(错误)

Q476、存在《个人信息保护法》规定的违法行为的，依照有关法律、行政法规的规定记入信用档案，并予以公示。(正确)

"Q477、使用未经安全审查或安全审查未通过的网络产品或者服务的，由国家有关主管部门依据职责责令停止使用并 ()。

- A、处采购金额一倍以上十倍以下罚款
- B、对直接负责的主管人员和其他直接责任人员处一万元以上十万元以下罚款
- C、判处死刑
- D、对直接负责的主管人员和其他直接责任人员判处三年以上十年以下的有期徒刑

答案:AB"

"Q478、在 DevSecOps 场景下，将密钥扫描 (Secret Scanning) 纳入流水线的主要目的是 ()。

- A、在代码或配置提交阶段尽早发现明文密钥和凭据泄露风险
- B、替代访问控制系统
- C、提升数据库查询性能

D、减少磁盘占用

答案:A"

"Q479、专门安全管理机构具体负责本单位的关键信息基础设施安全保护工作，履行下列职责。

A、组织推动网络安全防护能力建设，开展网络安全监测、检测和风险评估

B、履行个人信息和数据安全保护责任，建立健全个人信息和数据安全保护制度

C、按照规定报告网络安全事件和重要事项

D、建立健全网络安全管理、评价考核制度，拟订关键信息基础设施安全保护计划

答案:ABCD"

Q480、风险危害程度分析,主要考虑数据价值、风险源严重程度等因素。风险危害程度分析遵循就高从严、整体分析原则,如果该风险涉及多项数据,应进行累加判断,将涉及数据的风险按照最高危害等级判断。(正确)

"Q481、履行个人信息保护职责的部门依法履行职责，当事人不应该（ ）。

A、应当予以协助、配合

B、拒绝

C、阻挠

D、逃逸

答案:BCD"

Q482、《个人信息保护合规审计管理办法》以附件形式提供了《个人信息保护合规审计指引》，个人信息处理者开展合规审计应当参照执行。(正确)

"Q483、《数据安全法》的立法目的是什么？

A、打击数据犯罪

B、促进数据交易

C、保护数据安全，促进数据开发利用

D、限制数据处理活动

答案:C"

"Q484、某物业公司在小区出入口安装人脸识别门禁，要求所有业主必须录入人脸信息方可进出。该做法是否符合《人脸识别技术应用安全管理办

A、符合，物业有权设置安全管理措施

B、不符合，应提供非人脸识别的替代验证方式

C、符合，已提前张贴公示

D、不符合，须公安机关审批

答案:B"

"Q485、对不同的数据类型提出不同的保护要求，对特定类型的数据提出本地化要求。最常见的受限的数据类型包括？

A、生物健康

B、金融

C、征信

D、敏感个人信息

答案:ABC"

"Q486、书面形式的涉密载体，应在封面或者首页做出国家秘密标志，汇编涉密文件、资料或摘录、引用属于国家秘密内容的应按照其中（ ）标注。

A、最高密级和最长保密期限

B、最高密级和最短保密期限

C、最低密级和最长保密期限

D、最低密级和最短保密期限

答案:A"

"Q487、根据 GB/T 39204-2022《信息安全技术 关键信息基础设施安全保护要求》，对安全管理机构负责人和关键岗位人员应进行（ ）。

A、只进行学历审查，无需技能考核

B、安全背景审查和安全技能考核

C、仅由所在部门负责人推荐即可上岗

D、仅在发生安全事件后再行审查

答案:B"

Q488、网信部门和有关部门在履行网络安全保护职责中获取的信息，只能用于维护网络安全的需要，不得用于其他用途。（正确）

"Q489、根据《关键信息基础设施安全保护条例》，依据各自职责对关键信息基础设施实施安全保护和监督管理的是（ ）人民政府有关部门。

- A、县级
- B、地市级
- C、省级
- D、国务院

答案:C"

"Q490、发现疑似内部泄露事件后，最有助于快速缩小调查范围的信息组合是（ ）。

- A、访问日志 + 导出日志 + 身份信息 + 时间窗口
- B、只看员工通讯录
- C、只看办公地点
- D、只看工资信息

答案:A"

Q491、一个基本的信息安全系统至少应包括身份认证、访问控制和审计功能。（正确）

"Q492、多因素身份验证包括以下哪些因素？

- A、用户名和密码
- B、令牌和生物识别
- C、网络流量分析和数据包过滤
- D、加密和解密算法

答案:B"

"Q493、某企业打算建设 SOAR 能力，其核心目标通常是（ ）。

- A、实现安全事件处置流程的标准化、编排和自动化
- B、替代全部监管沟通
- C、完全取消人工分析

D、减少数据资产数量

答案:A"

Q494、根据《网络安全等级保护条例》及《网络安全法》，第三级和第四级信息系统应当依法开展等级测评并接受公安机关监督检查。（正确）

"Q495、未满（ ）的未成年人为无民事行为能力人，其网络打赏行为是无效的。

- A、8 周岁
- B、10 周岁
- C、12 周岁
- D、14 周岁

答案:A"

Q496、PKI 公钥基础设施是创建、管理、存储、分发和撤销数字证书所需的硬件、软件、人员、策略和流程的集合。（正确）

Q497、关于信息系统安全等级保护第三级的系统运维管理，应建立系统安全管理制度，对日常操作流程作出具体规定。（正确）

Q498、APEC 跨境隐私规则体系（CBPR）于 2011 年获 APEC 领导人批准通过。（正确）

"Q499、数据血缘（Data Lineage）的核心价值是（ ）。

- A、只记录数据大小变化
- B、追踪数据从产生、加工、流转至销毁的链路，支撑溯源和影响分析
- C、替代数据备份系统
- D、仅用于数据库性能优化

答案:B"

"Q500、依据《个人信息保护法》，在下列哪些情形下，处理敏感个人信息可以依法不取得个人同意？

- A、人民法院为审理案件，在法定权限内为履行法定职责所必需
- B、公安机关为侦查犯罪，在法定权限内为履行法定

职责所必需

C、检察机关为履行法律监督职责，在法定权限内为履行法定职责所必需

D、行政机关为本机关宣传报道需要

答案:ABC"

"Q501、撞库攻击利用了用户倾向于（ ）。

A、使用弱密码

B、在多个网站使用相同的用户名和密码组合

C、在公共计算机进行认证

D、在社交媒体上公开个人信息

答案:B"

"Q502、数据出境安全评估中，境外接收方维度应重点考察哪些内容？

A、处理数据的目的、方式和范围是否合法、正当、必要

B、履行数据安全保护义务的管理与技术能力

C、所在国家或地区的数据保护环境

D、办公楼外观设计风格

答案:ABC"

"Q503、哈希算法的典型应用场景包括（ ）。

A、数据完整性校验

B、密码存储

C、数字签名

D、数据加密

答案:ABC"

"Q504、大数据应用安全策略包括

A、防止 APT 攻击

B、用户访问控制

C、整合工具和流程

D、数据实时分析引擎

答案:ABCD"

"Q505、定期进行安全评估和审查的目的是什么？

A、提高员工安全意识

B、发现和修复安全漏洞

C、增加网络防火墙配置

D、优化数据存储和管理

答案:B"

"Q506、《人脸识别技术应用安全管理办法》由哪些部门联合发布？

A、国家互联网信息办公室、公安部

B、国家互联网信息办公室、工业和信息化部

C、公安部、工业和信息化部

D、国家互联网信息办公室、市场监督管理总局

答案:A"

"Q507、在处理敏感信息时，以下哪种做法是安全的？

A、明文存储密码

B、使用不可逆加密算法存储密码

C、通过不安全的渠道传输密码

D、在日志中记录敏感信息

答案:B"

"Q508、发现系统 0Day 漏洞时，应当（ ）。

A、悄悄修复即可

B、应当及时修复

C、应当通告上级主管部门及相关监管机构

D、查看日志，如果利用该漏洞攻击可以暂时先不修复

答案:BC"

"Q509、以下哪些属于双因素身份验证的组合方式？

A、用户名 + 密码

- B、密码 + 指纹
- C、密码 + 面部识别
- D、密码 + 短信验证码
- E、智能卡 + PIN 码

答案:BCDE"

"Q510、某跨境电商向境外传输数据，下列哪些字段禁止出境？

- A、中国用户的收货地址
- B、欧盟用户信用卡末四位
- C、处方药购买记录
- D、普通商品名称
- E、物流运单号

答案:AC"

"Q511、某企业数据管理员在使用 GB/T 43697-2024 进行分级时，发现某数据表同时包含 2 级和 3 级数据字段。应如何定级？

- A、按平均值定为 2.5 级
- B、按就高原则，整体定为 3 级
- C、两个字段分别独立定级
- D、由业务部门自主选择级别

答案:B"

"Q512、以下（ ）是访问控制中最小权限原则的一个例子。

- A、用户只能访问他们所需的文件夹
- B、为用户分配 root 权限以便他们更容易管理系统
- C、禁止用户访问任何文件夹
- D、分配所有用户都可以访问的文件夹

答案:A"

"Q513、以下不是信息的基本安全性质的是？

- A、机密性
- B、不可抵赖性

- C、完整性
- D、可用性

答案:B"

"Q514、根据《电子签名法》的规定，下列哪种情形不得视为发件人发送？

- A、未经发件人授权发送
- B、发件人的信息系统自动发送
- C、收件人按照发件人认可的方法对数据电文进行验证后结果相符
- D、经约定，发件人通过加密形式发送

答案:A"

"Q515、Kerberos 认证协议中的""AS""代表什么？

- A、认证服务器
- B、授权服务器
- C、应用服务器
- D、票据授予服务器

答案:A"

"Q516、下列哪项不属于《数据安全法》规定的国家安全机关在数据安全工作中的职责？

- A、承担数据安全监管职责
- B、指导、督促数据处理者加强数据安全保护
- C、组织开展数据安全宣传教育
- D、决定数据处理者的经营策略

答案:D"

Q517、使用商业密码的信息不属于国家秘密。（正确）

"Q518、身份认证中，如何防止身份信息在传输过程中被恶意篡改？

- A、完全杜绝恶意篡改是不可能的，只能在身份信息被恶意篡改后，接收端可以检测出来
- B、可以加密身份信息，在传输过程中解密验证身份信息

C、可以加密身份信息，传输后由发送端解密验证身份信息

D、只要身份信息正确，就可以防止恶意篡改

答案:A"

Q519、根据《网络安全法》的规定，国务院电信主管部门、公安部门和其他有关机关依照本法和有关法律、行政法规的规定，在各自职责范围内负责网络安全保护和监督管理工作。（正确）

Q520、Windows 访问控制中的访问令牌不包含用户及所属组的安全标识符（SID）。（错误）

"Q521、某金融机构将客户信用评分数据集出售给商业数据经纪商，数据集中已删除姓名和身份证号，但保留了年龄、职业、地区、消费记录等字段。合规团队发现通过关联分析可还原 70%的个人身份。该数据集的处理方式是否合规？

A、合规，已删除直接标识符

B、不合规，脱敏不彻底，仍属于可识别个人信息，不得出售

C、合规，出售数据属正常商业行为

D、是否合规由购买方决定

答案:B"

Q522、Kerberos 协议对参与方的系统时钟同步有要求，否则票据验证可能失败。（正确）

Q523、根据处理个人信息应当遵循公开、透明原则，个人信息处理与利用的目的、方式、范围等应予以明示，个人信息处理与利用的一般政策、事项等应予以公开。（正确）

"Q524、GB/T 43697-2024《数据安全技术 数据分类分级规则》于何时发布？

A、2023-12

B、2024-03

C、2024-09

D、2025-01

答案:B"

"Q525、根据《中华人民共和国数据安全法》规定，维护数据安全，应当坚持总体国家安全观，建立健全数据安全（ ），提高数据安全保障能力。

A、保障体系

B、治理体系

C、标准体系

D、评估体系

答案:B"

Q526、VLAN 是一种基于物理隔离的网络访问控制技术，用于将网络划分为不同的子网。（错误）

"Q527、某企业不同系统中“客户编号”的编码规则不一致，导致跨系统关联困难。最合适的治理动作是（ ）。

A、删除所有历史客户数据

B、建立统一主数据标准与映射规则

C、仅让业务人员手工比对

D、将所有编号改为随机值且不保留映射

答案:B"

"Q528、保护工作部门应当建立健全本行业、本领域的关键信息基础设施网络安全监测预警制度，及时掌握本行业、本领域关键信息基础设施运行状况、（ ），预警通报网络安全威胁和隐患，指导做好安全防范工作。

A、安全态势

B、风险状态

C、人员情况

D、保障措施

答案:A"

"Q529、《人工智能生成合成内容标识办法》规定，服务提供者须在用户服务协议中明确说明哪些内容？

A、生成合成内容标识的方法

B、标识的样式等规范内容

C、提示用户仔细阅读并理解相关标识管理要求

D、用户的个人信息处理方式

答案:ABC"

Q530、CA 可以创建、管理、存储、分发和撤销证书所需要的一组硬件、软件、人力资源、相关政策和操作规范以及为 PKI 体系中的各成员提供全部的安全服务。（正确）

"Q531、某实施项目交付时，如果没有回滚方案，最大的上线风险是（ ）。

A、安全变更失败后难以及时恢复业务和控制状态

B、员工无法登录办公邮箱

C、数据库一定损坏

D、法规自动失效

答案:A"

"Q532、某企业数据安全合规审计发现，其向第三方提供个人信息的记录保存仅 6 个月，而《个人信息保护法》规定的相关记录应保存多久？

A、6 个月

B、个人信息保护影响评估报告和处理情况记录至少保存三年

C、1 年

D、2 年

答案:B"

"Q533、依 ISO 27001 标准制定信息安全管理体系方针，应考虑的输出是？

A、业务战略

B、法律法规要求

C、合同要求

D、以上全部

答案:D"

"Q534、哪种身份认证方式容易被破解和盗用？

A、生物特征识别

B、智能卡认证

C、双因素认证

D、用户名和密码

答案:D"

"Q535、在监测运营中，若只关注外部攻击而忽略内部异常访问，说明体系缺少（ ）。

A、内外部一体化的数据安全监测视角

B、机房装修标准

C、采购审批制度

D、公开数据目录

答案:A"

"Q536、下列不属于能够保证数据安全的技术是？（ ）

A、磁盘加密技术

B、数据库加密技术

C、文件加密技术

D、数据分类技术

答案:D"

"Q537、某企业备份策略仅有“定期备份”，没有“恢复验证”。其主要缺陷是（ ）。

A、无法证明备份在真实故障下可恢复可用

B、备份数量过多

C、一定会导致勒索软件攻击

D、与数据分类分级无关

答案:A"

"Q538、SM3 用于生成（ ）位的消息摘要。

A、64

B、128

C、256

D、512

答案:C"

"Q539、一份文件为秘密级，保密期限是 10 年，标志形式应当是（ ）？

- A、秘密 10 年
- B、秘密★
- C、秘密★10 年
- D、秘密●10 年

答案:C"

"Q540、CWPP 的定义，下列正确的是

- A、全称 CloudWorkloadProtectionPlatform，意为云工作负载保护平台
- B、主要是指对云上应用和工作负载（包括虚拟主机和容器主机上的工作负载）进行保护的技术
- C、实现了比过去更加细粒度的防护，是云上安全的最后一道防线
- D、是零信任模型的四大核心技术之一

答案:AB"

"Q541、某 DeFi 项目的智能合约在处理用户提款时，先向用户地址转账，再更新账户余额记录。这种做法最可能导致以下哪种安全问题？

- A、交易顺序依赖（Front-Running）
- B、重入攻击（Reentrancy Attack）
- C、时间戳依赖（Timestamp Dependence）
- D、短地址攻击（Short Address Attack）

答案:B"

"Q542、若一批历史数据无法确定来源部门，也无法确认责任人，最合理的治理方式是（ ）。

- A、继续默认可用
- B、建立问题数据台账，补做来源核验与责任归属认定
- C、全部向外开放
- D、全部自动匿名化

答案:B"

"Q543、根据《个人信息保护法》，发生个人信息安全事件时，个人信息处理者应当立即采取补救措施，并通知（ ）。

- A、仅通知网信部门，由其代为通知用户
- B、仅通知用户本人，无需通知监管部门
- C、履行个人信息保护职责的部门和受影响的个人
- D、仅在媒体上公告即可

答案:C"

"Q544、数据资产盘点完成后，如果未与 CMDB 或应用拓扑打通，最直接的问题是（ ）。

- A、难以建立数据与基础设施、应用系统之间的关联映射
- B、员工培训无法开展
- C、所有权限将自动丢失
- D、数据自动匿名化

答案:A"

"Q545、违反《中华人民共和国数据安全法》规定，给他人造成损害的，构成犯罪的，（ ）。

- A、依法承担民事责任，并追究刑事责任
- B、不用承担民事责任，但追究刑事责任
- C、既不用承担民事责任，也不追究刑事责任
- D、只用承担民事责任，不用追究刑事责任

答案:A"

"Q546、嵌入式安全的目标是什么？

- A、保护硬件免受物理攻击
- B、保护软件免受网络攻击
- C、保护系统数据的完整性和机密性
- D、保护设备免受电磁干扰

答案:C"

"Q547、无线传感器网络节点应具有的主要特征是

()。

- A、能量受限
- B、与环境无关
- C、实时性
- D、不可扩展

答案:A"

"Q548、数据在进行传输前，需要由协议自上而下对数据进行封装。TCP/IP 协议中数据封装顺序是 ()。

- A、传输层、网络接口层、互联网络层
- B、传输层、互联网络层、网络接口层
- C、互联网络层、传输层、网络接口层
- D、互联网络层、网络接口层、传输层

答案:B"

"Q549、某金融机构 API 遭未授权调用，因未实施 OAuth2.0/细粒度鉴权。应？

- A、部署统一 API 网关，实施令牌校验、角色权限与接口级鉴权
- B、仅 IP 限制
- C、关闭 API
- D、仅记录日志

答案:A"

"Q550、某企业数据出境评估中，无法明确境外接收方对数据的保存期限和到期处理方式。最合理的结论是 ()。

- A、出境评估材料不完整，需补充后再决定是否继续推进
- B、该问题不影响合规性
- C、由境外接收方口头承诺即可
- D、先传输后补文档

答案:A"

Q551、大数据技术是从各种各样类型的数据中快速

获得有价值信息的能力。(正确)

"Q552、下列 () 访问控制技术可以控制网络上的数据流，限制特定主机或用户的访问。

- A、MAC
- B、DAC
- C、RBAC
- D、ACL

答案:D"

"Q553、下面哪个模型和软件安全开发无关 () ？

- A、微软提出的""安全开发生命周期 (SDL) ""
- B、GrayMcGraw 等提出的""使安全成为软件开发必须的部分 (BSI) ""
- C、OWASP 维护的""软件保证成熟度模型 (SAMM) ""
- D、""信息安全保障技术框架 (IATF) ""

答案:D"

"Q554、在零信任安全模型中，以下哪些措施可以用于实施细粒度的访问控制？

- A、角色基础访问控制
- B、双因素身份验证
- C、完全信任所有内部用户
- D、强制访问控制列表
- E、加密网络流量

答案:ABDE"

"Q555、软件运行时频繁被黑客利用漏洞远程攻击获取数据，某软件公司准备加强软件安全管理，在下面做法中，对于解决问题没有直接帮助的是 ()

- A、要求开发人员采用敏捷开发模型进行开发
- B、要求所有的开发人员参加软件安全意识培训
- C、要求规范软件编码，并制定公司的安全编码准则
- D、要求增加软件安全测试环节，尽早发现软件安全

问题

答案:A"

"Q556、下列哪项最适合作为“数据资产地图”的最小展示单元之一？

- A、数据对象与业务流程关系
- B、员工午餐时间安排
- C、办公楼楼层分布
- D、宣传海报版本号

答案:A"

"Q557、运营者应当保障专门安全管理机构的运行经费，并（ ）。

- A、配备相应的人员
- B、开展与网络安全和信息化有关的决策应当有专门安全管理机构人员参与
- C、购买指定安全厂商的安全服务
- D、鼓励员工直接进行漏洞攻击测试

答案:AB"

Q558、如果法律、行政法规对收集、使用数据的目的、范围有规定，则应当在规定的目的和范围内收集、使用数据。（正确）

"Q559、安全等级保护实施过程中应遵循以下哪些基本原则？

- A、自主保护原则
- B、重点保护原则
- C、同步建设原则
- D、动态调整原则

答案:ABCD"

"Q560、生物识别身份验证包括哪些类型？

- A、指纹识别
- B、面部识别
- C、声纹识别

D、虹膜识别

E、手写识别

答案:ABCDE"

Q561、PBAC 模型基于资源的分类和用户的授权级别来确定访问权限。（错误）

"Q562、某企业拟建设“数据共享交换平台”，在需求分析阶段最应先明确的是（ ）。

- A、共享对象、共享目的、共享数据范围及审批边界
- B、会议室投影品牌
- C、员工福利预算
- D、外包保洁合同期限

答案:A"

"Q563、某企业数据安全年度评估发现，过去一年内共识别出 47 个数据安全风险，但仅完成了 8 个风险的整改。风险管理负责人应如何优化？

- A、建立风险优先级矩阵（按影响×可能性排序），高风险限期整改，中低风险纳入计划跟踪，引入持续监控机制
- B、将未整改风险标记为""已知悉""关闭
- C、减少风险识别数量
- D、要求监管部门延长整改期限

答案:A"

"Q564、某企业数据安全监测平台发现某 API 接口返回状态码异常频繁（500 错误）。该现象可能预示？

- A、接口遭恶意探测或存在逻辑漏洞
- B、网络带宽充足
- C、用户活跃度下降
- D、磁盘空间过大

答案:A"

"Q565、某企业使用生成式 AI 工具批量生成新闻报道并在自媒体发布，未标注 AI 生成标识。依据《生成式人工智能服务管理暂行办法》及《互联网信息

服务深度合成管理规定》，该行为违反了什么要求？

- A、数据备份义务
- B、深度合成内容显著标识义务
- C、个人信息保护义务
- D、商标使用规范

答案:B"

"Q566、访问控制中的审计是指（ ）。

- A、对用户行为进行实时监控
- B、检查和记录用户的访问活动
- C、对系统进行漏洞扫描
- D、对网络流量进行流量分析

答案:B"

"Q567、根据修订后《网络安全法》关于人工智能的规定，国家在人工智能领域支持的内容不包括以下哪项？

- A、支持人工智能基础理论研究和算法等关键技术研发
- B、推进训练数据资源、算力等基础设施建设
- C、完善人工智能伦理规范
- D、禁止人工智能技术用于商业领域

答案:D"

"Q568、数据安全评估工作中，评估报告的整改建议应满足哪些要求？

- A、与发现的问题逐项对应
- B、具有可执行性
- C、可明确责任主体与优先级
- D、尽量笼统概括，避免过细

答案:ABC"

"Q569、某企业应急演练未包含""勒索软件+数据篡改""复合场景。演练设计是否完整？

- A、完整，单场景足够

B、不完整，应覆盖多威胁叠加的实战场景

- C、仅影响考核分数
- D、无需演练

答案:B"

"Q570、某单位门户网站开发完成后，测试人员使用模糊测试进行安全性测试，以下关于模糊测试过程的说法正确的是（ ）。

- A、模拟正常用户输入行为，生成大量数据包作为测试用例
- B、数据处理点、数据通道的入口点和可信边界点往往不是测试对象
- C、监测和记录输入数据后程序正常运行的情况
- D、深入分析测试过程中产生崩溃或异常的原因，必要时需要测试人员手工重现并分析

答案:D"

"Q571、在设计“重要数据对外提供”方案时，哪项控制措施最能体现“默认审慎”原则？

- A、默认禁止，按审批结果和最小必要范围有条件开放
- B、默认全开放，事后追责
- C、只要求口头承诺
- D、仅依赖文件命名规范

答案:A"

Q572、数据脱敏技术可以保护个人隐私。（正确）

"Q573、（ ）即非法用户利用合法用户的身份，访问系统资源。

- A、身份假冒
- B、信息窃取
- C、数据篡改
- D、越权访问

答案:A"

"Q574、某企业完成了多次数据出境评估，但没有将

整改结果沉淀为统一制度。其最主要的问题是（ ）。

A、个案整改无法转化为组织级能力，重复问题会再次出现

B、说明企业整改速度太快

C、只影响文档管理

D、不会影响后续评估

答案:A"

Q575、风险危害程度分析,主要考虑数据价值、风险源严重程度等因素。风险危害程度分析遵循就高从严、整体分析原则,如果该风险涉及多项数据,应遵循就高从严原则,将涉及数据的风险按照最高危害等级判断。(正确)

"Q576、以下关于数据库常用的安全策略理解不正确的是（ ）。

A、最小特权原则，是让用户在可以合法存取或修改数据库的前提下，分配最小的特权，使得这些信息恰好能够完成用户的工作

B、最大共享策略，在保证数据库的完整性、保密性和可用性的前提下，最大程度地共享数据库中的信息

C、粒度最小的策略，将数据库中数据项进行划分，粒度越小，安全级别越高，在实际中需要选择最小粒度

D、按内容存取控制策略，不同权限的用户访问数据库的不同部分

答案:C"

"Q577、《中华人民共和国民法典》规定，网络用户利用网络服务实施侵权行为的，权利人有权通知网络服务提供者采取删除、屏蔽、断开链接等必要措施。通知应当包括构成侵权的初步证据及权利人的（ ）。

A、近期行为特征

B、历史浏览记录

C、真实身份信息

D、IP 地址

答案:C"

Q578、国家建立健全数据交易管理制度，规范数据交易行为，培育数据交易市场。(正确)

"Q579、《关键信息基础设施安全保护条例》规定安全保护措施应当与关键信息基础设施（ ）。

A、同步规划

B、同步建设

C、同步使用

D、以上都正确

答案:D"

"Q580、某企业监测到内部员工通过 U 盘拷贝大量代码至私人设备。DLP 系统已触发告警，安全团队应？

A、立即阻断并启动内部调查

B、忽略，员工有权带走

C、仅记录不处理

D、直接开除员工

答案:A"

Q581、政务数据中包含的个人信息可以直接参与数据交易，作为政府的新经济营收增长创新模式。(错误)

"Q582、访问控制是一种针对什么的防范措施？

A、病毒攻击

B、越权使用资源

C、网络拒绝服务攻击

D、网络钓鱼攻击

答案:B"

"Q583、遵循国家数据分类分级保护要求，按照数据所属行业领域进行分类分级管理，依据以下哪些原则对数据进行分类分级？（ ）

A、就高从严原则

- B、点面结合原则
- C、科学实用原则
- D、边界清晰原则

答案:ABCD"

"Q584、在评估个人信息和重要数据接口采集行为时，最关键的验证点包括哪些？

- A、采集的数据项
- B、采集频率和触发条件
- C、采集目的与业务必要性
- D、接口开发语言名称

答案:ABC"

"Q585、运维团队为方便排障，长期保留生产环境明文调试日志，其中包含用户敏感字段。整改重点应是（ ）。

- A、调整日志策略，对敏感字段脱敏或禁止明文落盘
- B、继续保留，便于分析
- C、只限制日志查看人员
- D、仅压缩日志文件

答案:A"

"Q586、有下列情形之一的，个人信息处理者应当事前进行个人信息保护影响评估，并对处理情况进行记录：

- A、向境外提供个人信息
- B、利用个人信息进行自动化决策
- C、委托处理个人信息、向其他个人信息处理者提供个人信息、公开个人信息
- D、处理敏感个人信息

答案:ABCD"

"Q587、根据《银行保险机构数据安全管理办法》，各银行保险机构发生数据安全重大事件时，应立即采取应急处置措施，及时消除安全隐患，防止危害扩大，并于（ ）小时内向国家金融监督管理总局或

者其派出机构报告？

- A、12 小时
- B、2 小时
- C、1 小时
- D、48 小时

答案:B"

"Q588、某企业将数据安全合规工作完全外包给第三方咨询公司，内部不设数据安全负责人，所有决策均由外包方代为执行。该模式存在的主要问题是？

- A、违反""数据安全主体责任不可外包""原则，企业须保留内部数据安全负责人和核心决策权
- B、外包是合理降本增效手段，完全合规
- C、只要外包合同约定合理即可
- D、须经监管部门批准后才能外包

答案:A"

"Q589、下面哪个不是生成树的优点（ ）？

- A、生成树可以管理冗余链路，在链路发生故障时可以恢复网络连接
- B、生成树可以防止环路的产生
- C、生成树可以防止广播风暴
- D、生成树能够节省网络带宽

答案:D"

"Q590、二维码目前不能表示的数据类型（ ）。

- A、文字
- B、数字
- C、二进制
- D、视频

答案:D"

Q591、在区块链中，哈希函数的抗碰撞性保证了用户的私钥安全。（错误）

"Q592、某互联网平台依据《网络数据安全管理办法

例》对“重要数据”进行识别，发现某业务数据未纳入目录。下一步应？

- A、忽略，企业可自主决定
- B、对照识别指南复核，确属重要数据的应补充备案与防护
- C、立即删除该数据
- D、仅内部记录

答案:B"

"Q593、在单点登录（SSO）中，为什么采用 SSL 进行用户、应用系统和认证服务器之间的通信？

- A、提高用户体验
- B、加快应用系统的响应速度
- C、减小敌手截获和窃取信息的可能性
- D、增加数据的传输效率

答案:C"

"Q594、依据《中华人民共和国数据安全法》，开展数据处理活动应当依照法律、法规的规定，建立健全（ ）管理制度。

- A、数据风险评估
- B、数据泄露应急处置
- C、数据交易
- D、全流程数据安全

答案:D"

"Q595、《人工智能生成合成内容标识办法》中，“隐式标识”是指（ ）。

- A、在生成合成内容中以文字方式添加的标识
- B、在生成合成内容或交互场景界面中以图形方式呈现的标识
- C、采取技术措施在生成合成内容文件数据中添加的、不易被用户明显感知到的标识
- D、仅对视频内容要求的标识

答案:C"

"Q596、在数据出境评估中，若无法说明境外接收方的技术和管理能力，最合理的处理结论是（ ）。

- A、评估结论应保持审慎，不宜直接放行
- B、只要双方关系好即可
- C、可先传再补材料
- D、忽略该项要求

答案:A"

"Q597、根据《个人信息保护法》第六十六条第一款，违反规定处理个人信息或者处理个人信息未履行个人信息保护义务，被责令改正但拒不改正的，并处（ ）以下罚款。

- A、十万元
- B、三十万元
- C、五十万元
- D、一百万元

答案:D"

"Q598、《数据安全法》中，（ ）是核心数据的范畴。

- A、涉密数据
- B、重要数据
- C、商密数据
- D、关系国家安全、国民经济命脉、重要民生、重大公共利益等数据

答案:D"

"Q599、根据《促进和规范数据跨境流动规定》，以下哪种情形可以免于申报数据出境安全评估、订立标准合同或进行个人信息保护认证？

- A、非关基运营者向境外累计提供 100 万人以上个人信息（不含敏感个人信息）
- B、按照依法制定的劳动规章制度和依法签订的集体合同实施跨境人力资源管理所必需的员工个人信息出境
- C、向境外提供已被有关部门公开发布为重要数据的

数据

D、关键信息基础设施运营者向境外提供个人信息

答案:B"

"Q600、下列关于收集数据说法正确的是:

A、应当采取合法、正当的方式

B、公安部门可以采取非法的方式

C、不得窃取或者以其他非法方式获取数据

D、公安部门可以窃取或者以其他非法方式获取数据

答案:AC"

"Q601、隐私政策应对 App 运营者基本情况进描述, 以下哪一项不是必要的?

A、公司名称

B、注册地址

C、个人信息保护相关负责人联系方式

D、经营范围

答案:D"

Q602、网络运营者在开展转换、汇聚、分析等数据加工活动的过程中, 知道或者应知道可能危害国家安全、公共安全、经济安全和社会稳定的, 应立即开展调研分析。(错误)

"Q603、以下哪些属于常见的 DDoS 攻击方式?

A、利用僵尸网络发起超大流量攻击

B、利用 DNS、NTP 等反射/放大攻击

C、发送大量畸形包、半连接请求或高频请求耗尽系统资源

D、篡改网站首页内容

答案:ABC"

"Q604、以下哪个不是信息安全系统中的基本功能?

A、身份认证

B、访问控制

C、审计功能

D、数据备份

E、加密解密

答案:DE"

"Q605、某企业数据安全团队进行年度风险评估, 发现云存储桶 (Bucket) 的访问控制策略配置错误, 导致部分内部文档公开可访问。应立即采取?

A、立即修正访问控制策略为私有, 排查已暴露文件是否含敏感信息, 评估泄露影响范围

B、删除所有云存储桶

C、更换云服务商

D、仅修改存储桶名称

答案:A"

"Q606、下列哪些是访问控制的技术指标?

A、访问控制策略规则类型

B、访问控制规则最大数量

C、访问控制规则检查速度

D、产品自身安全和质量保证级别

E、用户权限分配方式

答案:ABCD"

"Q607、某企业数据资产目录与 CMDB 未打通, 导致安全策略无法自动联动。应?

A、维持孤立系统

B、建立数据资产与基础设施配置项的关联映射

C、仅手工同步

D、交由运维处理

答案:B"

"Q608、某医院在未取得患者同意的情况下, 将脱敏后的电子病历数据提供给 AI 医疗公司进行算法训练。以下分析正确的是?

A、脱敏不等于匿名化, 若仍可关联识别患者则须取得同意

B、医疗健康数据属于敏感个人信息, 处理须取得单

独同意

C、向第三方提供须符合《个人信息保护法》关于向其他处理者提供的规定

D、算法训练属于科研目的，可以不受个保法约束

答案:ABC"

"Q609、个人信息的处理包括个人信息的：

A、收集

B、使用

C、存储

D、售卖

答案:ABC"

"Q610、国家采取措施，（ ）来源于中华人民共和国境内外的网络安全风险和威胁，保护关键信息基础设施免受攻击、侵入、干扰和破坏，依法惩治网络违法犯罪活动。

A、监测

B、防御

C、加密

D、处置

答案:ABD"

Q611、个人信息是一种特殊的数据类型。（正确）

"Q612、下列（ ）访问控制模型通常用于军事、政府等高安全级别场合。

A、自主访问控制

B、强制访问控制

C、角色访问控制

D、基于属性的访问控制

答案:B"

"Q613、产生哪些情形之一的，SDK 提供方应当主动删除个人信息？

A、处理目的已实现、无法实现或为实现处理目的不再必要

B、SDK 提供者停止提供产品或服务，或者保存期限已届满

C、个人撤回同意

D、SDK 提供者违反法律、行政法规或违反约定处理个人信息

答案:ABCD"

"Q614、某团队开发数据共享平台时，将访问控制逻辑硬编码在前端页面中。该做法的主要问题是（ ）。

A、前端逻辑容易被绕过，访问控制应在服务端可信边界实现

B、前端代码更高效

C、便于用户修改权限

D、可替代审计系统

答案:A"

"Q615、全球主要数据跨境限制模式中提倡""数据跨境自由流动，推动跨境数据自由流动规则构建""的国家包括？

A、美国

B、日本

C、新加坡

D、荷兰

答案:ABC"

"Q616、公有链与私有链的主要区别是（ ）。

A、公有链使用智能合约，而私有链不使用智能合约

B、公有链更安全，而私有链更高效

C、公有链使用密码学加密算法，而私有链不使用加密算法

D、公有链可以被任何人参与，而私有链仅限于特定的参与者

答案:D"

"Q617、嵌入式系统中的安全芯片是指什么？

- A、专用芯片，用于提供硬件级安全功能
- B、芯片上的加密引擎，用于执行密码算法
- C、芯片上的安全存储器，用于保存加密密钥
- D、芯片上的防火墙，用于阻止外部攻击

答案:A"

"Q618、ZigBee 的（ ）负责设备间无线数据链路的建立、维护与结束。

- A、物理层
- B、MAC 层
- C、网络/安全层
- D、支持/应用层

答案:B"

"Q619、某企业拟对数据流通和交易活动开展专项安全评估，下列最不应忽略的维度是（ ）。

- A、数据来源合法性与授权边界
- B、合作方海报设计
- C、办公楼停车位数量
- D、会议室装修风格

答案:A"

"Q620、某互联网平台监测到某 SDK 暗中上传用户剪贴板内容。应急响应应？

- A、立即停用该 SDK，更新版本，通知用户
- B、忽略，SDK 由第三方负责
- C、仅更新隐私政策
- D、删除用户剪贴板数据

答案:A"

Q621、ABAC 模型基于对用户的身分进行访问控制决策。（错误）

"Q622、国家积极开展数据安全治理、数据开发利用等领域的国际交流与合作，参与数据安全相关国际规则和标准的制定，目的是：

- A、促进数据跨境安全、自由流动
- B、促进数据跨境安全，安全流动
- C、促进数据自由跨境，自由流动
- D、促进数据自由跨境，安全流动

答案:A"

"Q623、根据《中华人民共和国个人信息保护法》有关规定，下列哪些规定情形仍需取得个人同意方可处理个人信息？

- A、为订立、履行个人作为一方当事人的合同所必需
- B、为履行法定职责或者法定义务所必需
- C、为应对突发公共卫生事件，紧急情况下保护生命健康和财产安全所必需
- D、为商业营销目的分析用户消费偏好

答案:D"

"Q624、数字水印主要用于什么？

- A、数据加密
- B、版权保护
- C、身份验证
- D、数据传输

答案:B"

"Q625、如果存在个人信息对外共享、转让、公开披露等情况，隐私政策中应明确以下哪些内容？

- A、对外共享、转让、公开披露个人信息的目的
- B、涉及的个人信息类型
- C、具体的个人信息内容
- D、接收方类型或身份

答案:ABD"

"Q626、在访问控制中，下面哪个措施可以增强系统的身份认证安全性？

- A、多因素认证
- B、开放注册

C、共享账号和口令

D、强制口令重用

答案:A"

"Q627、某 App 运营商在隐私政策中写明""我们可能与业务合作伙伴共享您的信息以提供更好的服务""，但未列明具体接收方类型和共享的信息种类。该表述是否符合《个人信息保护法》的要求？

A、符合，已有概括性告知

B、不符合，须以清晰易懂的语言具体说明处理目的、接收方信息和个人信息种类

C、符合，由用户自行阅读理解

D、是否符合由工信部认定

答案:B"

"Q628、大数据强调（ ），而非小数据的随机抽样。

A、关键数据

B、重要数据

C、海量数据

D、高质量数据

答案:C"

"Q629、网络安全等级保护建设的流程是什么？

A、定级、备案、监督检查、建设整改、等级测评

B、定级、备案、建设整改、等级测评、监督检查

C、建设整改、等级测评、监督检查、定级、备案

D、等级测评、定级、备案、建设整改、监督检查

答案:B"

Q630、国家对关键信息基础设施实行重点保护，采取措施，监测、防御、处置来源于中华人民共和国境内外的网络安全风险和威胁，保护关键信息基础设施免受攻击、侵入、干扰和破坏，依法惩治危害关键信息基础设施安全的违法犯罪活动。（正确）

"Q631、大数据采集中，（ ）最能保障数据的可用性。

A、数据备份

B、数据加密

C、数据脱敏

D、数据压缩

答案:A"

"Q632、发改委首次将区块链纳入""新基建""范围的时间是（ ）。

A、2016 年

B、2015 年

C、2022 年

D、2020 年

答案:D"

Q633、PBFT 比 POW 能源消耗更高。（错误）

"Q634、某组织准备开展数据出境安全评估，以下内容应纳入评估材料准备？

A、出境数据的种类、数量和级别

B、境外接收方的处理目的、方式和范围

C、出境后可能面临的安全风险及应对措施

D、全体员工社保缴费明细

答案:ABC"

"Q635、有 A 和 B 二人互相比收入，在双方互不泄露自己收入的场景下，那种隐私计算技术不能比较出二人收入高低（ ）？

A、零知识证明

B、联邦学习

C、安全多方计算

D、数据脱敏

答案:ABD"

Q636、个人信息处理者可以采取数量拆分等手段向境外提供个人信息且无需订立标准合同。（错误）

"Q637、准备登陆电脑系统时，发现有人在您的旁边

看着，正确做法是（ ）。

- A、不理会对方
- B、提示对方避让
- C、报警
- D、关机后离开

答案:B"

"Q638、某银行的第三方技术服务提供商遭勒索攻击所致，直接影响了这些银行的支付及客户服务系统。

问题：在遭受勒索软件攻击后，发现攻击者窃取了大量客户数据。以下哪些措施可以最大程度地减少数据泄露的风险？

- A、立即通知所有受影响的客户，并要求他们更改密码
- B、对受影响的数据进行加密，以防止未经授权的访问
- C、将数据备份到外部存储设备，并定期进行数据恢复测试
- D、加强内部网络安全监控，及时发现并阻止潜在的网络攻击
- E、与网络安全专家合作，进行彻底的安全审计和漏洞扫描

答案:ABCDE"

"Q639、某评估团队在合规评估中发现“制度存在，但执行记录缺失”。这一发现通常意味着（ ）。

- A、制度有效性无法被证明，需进一步核查落地情况
- B、说明制度设计非常先进
- C、说明技术控制不需要了
- D、可以直接判定完全合规

答案:A"

Q640、从事个人信息处理活动，应具有明确合理的目的，运营商可以根据服务体验、产品研发、算法推荐、风险控制等因素，要求用户同意超范围或者

与服务场景无关的个人信息处理行为。（错误）

"Q641、为了保护民事主体的合法权益，调整民事关系，维护社会和经济秩序，适应中国特色社会主义发展要求，弘扬社会主义核心价值观，根据宪法，制定（ ）。

- A、《中华人民共和国刑法》
- B、《中华人民共和国民法典》
- C、《中华人民共和国治安管理处罚法》
- D、《中华人民共和国劳动法》

答案:B"

"Q642、某项目要求对外提供数据查询接口，开发团队打算直接复用内部管理接口。数据安全工程师应优先指出的风险是（ ）。

- A、内部接口往往权限粒度过粗，直接外部复用可能导致越权暴露
- B、可减少开发成本，属于推荐做法
- C、只要加验证码即可
- D、与数据安全无关

答案:A"

"Q643、国家网信部门公布的""数据出境负面清单""机制的主要作用是什么？

- A、列明无需出境合规的数据类型
- B、标识在特定条件下禁止或限制出境的数据范围
- C、对所有出境数据征收税费
- D、替代数据出境安全评估

答案:B"

"Q644、发生或者可能发生个人信息泄露、篡改、丢失的，个人信息处理者应当立即采取补救措施，并通知履行个人信息保护职责的部门和个人。通知应当包括下列事项：

- A、发生或者可能发生个人信息泄露、篡改、丢失的信息种类
- B、发生或者可能发生个人信息泄露、篡改、丢失的

原因和可能造成的危害

C、个人信息处理者采取的补救措施和个人可以采取的减轻危害的措施

D、个人信息泄露者的联系方式

答案:ABC"

"Q645、根据《数据安全工程技术人员国家职业标准（2023 年版）》，数据资产识别工作的首要目标是（ ）。

A、直接删除历史数据

B、明确数据资产与业务之间的关系

C、只统计数据库数量

D、优先建设容灾中心

答案:B"

Q646、访问控制的目标只有一个，即防止非法用户进入系统。（错误）

"Q647、生物识别身份验证方法包括以下哪些？

A、指纹识别、面部识别、虹膜扫描、声纹识别、手掌识别等

B、智能卡、USB 密钥等

C、用户名和密码或 PIN

D、双因素/多因素身份验证

答案:A"

"Q648、某企业自当年 1 月 1 日起累计向境外提供 8000 名员工健康档案数据（属于敏感个人信息），且该场景**不属于**跨境人力资源管理所必需。根据现行规定，应采取哪种合规路径？

A、无需任何措施，8000 人未达门槛

B、须申报数据出境安全评估

C、须订立个人信息出境标准合同或通过个人信息保护认证

D、仅需内部审批

答案:C"

"Q649、某企业合规团队希望把风险评估结果与预算分配联动，最合理的做法是（ ）。

A、按风险等级与潜在损失影响进行资源优先配置

B、预算平均分配给所有问题

C、只给最容易整改的问题预算

D、先做品牌宣传再做整改

答案:A"

"Q650、利用 SSL 协议可以建立加密的传输通道。SSL 协议是在（ ）之间实现加密传输。

A、物理层和链路层

B、网络层和传输层

C、传输层和应用层

D、应用层和系统层

答案:C"

Q651、区块链上的数据一旦写入就无法更改。（错误）

"Q652、下述哪项不是区块链中应用的技术（ ）。

A、密码学

B、大数据

C、共识算法

D、P2P 网络

答案:B"

"Q653、以下不是关键信息基础设施重要行业和领域的是？

A、公共通信

B、能源、交通、水利

C、公共服务

D、各类电商网购平台

答案:D"

"Q654、某电信运营商遭受大规模数据泄露，涉及 200 万用户通话记录。依据《电信和互联网用户个人

信息保护规定》，企业应如何处理？

- A、立即向工业和信息化部门报告
- B、通知受影响的用户
- C、采取补救措施防止危害扩大
- D、仅向用户发送统一声明即视为履行义务

答案:ABC"

"Q655、根据《个人信息保护法》，违反本法规定，构成违反治安管理行为的，依法给予（ ）；构成犯罪的，依法追究刑事责任。

- A、罚款
- B、警告
- C、治安管理处罚
- D、行政拘留

答案:C"

Q656、为了建立向客户提供安全的云计算服务的能力，云服务商应制定安全计划。当云计算平台提供多个应用或服务时，云服务商应可以制定一个统一的安全计划。（错误）

"Q657、某企业灾备演练发现，虽然数据库恢复成功，但 DNS 切换和应用配置回写需要人工逐项执行，导致整体恢复时间远超目标。该现象主要说明（ ）。

- A、恢复链路缺乏自动化编排和端到端验证
- B、数据库备份完全无效
- C、只需增加带宽即可
- D、日志留存时间过长

答案:A"

"Q658、下列哪个是中国移动的官方网站域名？

- A、www.10086.cn
- B、www.10086.com
- C、www.10086.gov.cn
- D、www.10086.cn

答案:A"

"Q659、在零信任安全模型中，以下哪些因素可以用于控制用户和设备的访问权限？

- A、用户的角色和职务
- B、设备的操作系统
- C、用户的地理位置
- D、设备的网络带宽
- E、网络带宽使用量

答案:ABC"

Q660、依据《电信和互联网用户个人信息保护规定》，电信业务经营者、互联网信息服务提供者应当对用户个人信息保护情况每年至少进行一次自查，记录自查情况，及时消除自查中发现的安全隐患。（正确）

"Q661、某企业向境外关联公司提供员工工资单数据（含姓名、银行账号、工资金额），以便境外 HR 系统处理薪酬。境外关联公司所在国已被国家网信部门认定为与中国具有同等保护水平的国家。该出境方案可以？

- A、无需任何合规措施，关联公司内部共享不受限制
- B、若所在国获得充分性认定，可简化出境手续，但仍须在劳动合同中告知员工跨境处理情况
- C、充分性认定意味着完全豁免所有出境义务
- D、须申报安全评估，充分性认定不产生实际效果

答案:B"

"Q662、在合规评估中，若评估对象无法提供“个人信息共享记录”，最合理的初步结论是（ ）。

- A、共享活动的可追溯性控制存在明显缺陷
- B、说明企业没有共享行为
- C、由合作方记录即可
- D、对合规没有影响

答案:A"

"Q663、根据《电子签名法》的规定，电子认证服务

提供者应当妥善保存与认证相关的信息，信息保存期限至少为电子签名认证证书失效后（ ）年。

- A、5
- B、4
- C、3
- D、2

答案:A"

"Q664、在异常行为监测中，若发现某账号在非工作时间批量导出大量敏感数据，最优先的动作是（ ）。

- A、立即告警并根据策略进行临时管控
- B、等第二天上班再确认
- C、直接删除全部日志
- D、先优化 UI 界面

答案:A"

Q665、情感分析是分析一句话是正面情绪还是负面情绪（积极还是消极），而不仅仅是判断其是主观描述还是客观描述。（正确）

"Q666、某企业在威胁情报中发现某恶意家族专门通过云存储同步客户端窃取文件。最合理的防护优化不包括（ ）。

- A、加强终端外发监控和云同步审计
- B、审查云同步白名单策略
- C、只增加食堂安保
- D、增加敏感文件水印与访问告警

答案:C"

"Q667、重放攻击是指攻击者截获合法用户的身份验证流量，并在稍后的时间重新发送该流量，以冒充合法用户进行身份验证。以下哪种是重放攻击的示例？

- A、跨站点脚本（XSS）攻击
- B、令牌劫持攻击

C、生物特征欺骗攻击

D、社会工程学攻击

答案:B"

"Q668、收到银行升级通知修改密码并给有相关连接地址时（ ）。

- A、点开链接看看怎么回事
- B、核对电话号码后发现没有诈骗电话的标记，所以可以点开连接
- C、诈骗短信直接删除
- D、转发亲友，一起修改银行口令为数字结合字母（包含大小写）和特殊字符的复杂口令

答案:C"

"Q669、MFA 可以使用哪些因素进行身份验证？

- A、用户名和密码（知识因素）
- B、指纹（生物因素）
- C、面部识别（生物因素）
- D、短信验证码（持有因素）
- E、智能卡（持有因素）

答案:ABCDE"

"Q670、依据《数据安全法》，开展数据处理活动应当依照法律、法规的规定，建立健全（ ）管理制度。

- A、全流程数据安全
- B、“谁处理谁负责”
- C、风险评估
- D、应急处置

答案:A"

"Q671、下列针对数据安全的运维要求中，正确的操作是（ ）？

- A、确认需要备份的是哪些数据/数据库，设定备份与归档的策略
- B、从数据备份的完整性与成本方面的均衡角度考

虑，增量备份结合全量备份是一个推荐的措施

C、需要对备份后的数据进行恢复校验，以确保恢复后的数据可用

D、定期对数据相关风险进行评估

答案:ABCD"

"Q672、《中华人民共和国民法典》规定，信息处理者不得泄露或者篡改其收集、（ ）的个人信息；未经自然人同意，不得向他人非法提供其个人信息，但是经过加工无法识别特定个人且不能复原的除外。

A、整合

B、存储

C、获取

D、管理

答案:B"

"Q673、某互联网平台基于用户消费记录向其展示个性化广告，但未在隐私政策中披露画像分析逻辑，也未提供关闭选项。该行为违反？

A、《个人信息保护法》第 24 条（自动化决策透明度）及《网络数据安全条例》个性化推荐关闭要求

B、仅违反《广告法》

C、属于正常商业行为无需披露

D、《商标法》

答案:A"

"Q674、比特币总共发行量有（ ）万个。

A、1050

B、1100

C、2100

D、4200

答案:C"

"Q675、物联网中的数据备份和恢复为什么重要？

A、防止数据丢失和损坏

B、加快数据传输速度

C、降低数据存储成本

D、保护数据的隐私性

答案:A"

"Q676、《中共中央、国务院关于构建数据基础制度更好发挥数据要素作用的意见》以解决市场主体遇到的实际问题为导向，创新数据产权观念，淡化所有权、强调使用权，聚焦数据使用权流通，创造性提出建立下列哪一项“三权分置”的数据产权制度框架？

A、数据资源持有权、数据加工使用权和数据产品经营权

B、数据资源所有权、数字加工使用权和数字产品经营权

C、数据资源使用权、数据加工分配权和数据产品转让权

D、数字资源分配权、数字加工持有权和数字产品使用权

答案:A"

"Q677、在单点登录（SSO）中，为什么采用 SSL 进行通信？

A、提高用户体验

B、加快应用系统的响应速度

C、减小敌手截获和窃取信息的可能性

D、增加数据的传输效率

E、提供数据加密和安全性保障

答案:CE"

"Q678、区块链是一种（ ）。

A、分布式数据库技术

B、中心化数据库技术

C、人工智能算法

D、云计算技术

答案:A"

"Q679、某政务平台数据共享审查中，发现某委办局申请将公民婚姻状况数据共享给商业房产中介。该申请是否应批准？

- A、不应批准；政务数据共享须符合政务目的，且须保护个人隐私，不得向商业机构提供超出法定范围的公民个人信息
- B、应批准，数据共享有利于市场发展
- C、由委办局自行决定
- D、批准但要求中介签署保密协议

答案:A"

"Q680、以下哪些是访问控制的应用场景类型？

- A、物理访问控制
- B、网络访问控制
- C、操作系统访问控制
- D、数据库/数据访问控制
- E、应用系统访问控制

答案:ABCDE"

Q681、App 收集个人信息前应提供由用户主动选择同意或不同意的选项，不同意应仅影响与所拒绝提供个人信息相关的业务功能。（正确）

"Q682、数据生命周期管理的特征有？

- A、改善用户体验
- B、降低运营效率
- C、高效存储访问
- D、遵守数据法规

答案:ACD"

"Q683、某企业合规审计中发现，App 在用户未打开任何使用地图功能的情况下，每 5 分钟自动获取一次精确位置信息。该问题应被定性为？

- A、违反最小必要原则，超频率、超范围采集位置信

息

- B、合理行为，位置信息有助于改善体验
- C、仅属于技术配置问题，无合规风险
- D、须经公安机关才能认定违法

答案:A"

"Q684、常见的反爬措施包括（ ）。

- A、通过 UA 识别爬虫
- B、设置 IP 访问频率，如果超过一定频率，弹出验证码
- C、通过网络并发识别爬虫
- D、请求时间窗口过滤统计

答案:ABCD"

"Q685、根据《公安机关办理刑事案件电子数据取证规则》的相关规定，冻结电子证据的方法有哪些？

- A、计算电子数据的完整性校验值
- B、锁定网络应用账号
- C、采取写保护措施
- D、网上发布禁用通知

答案:ABC"

"Q686、2024 年 2 月 3 日，工业和信息化部发布了《工业领域数据安全能力提升实施方案（2024-2026 年）》，该方案的重点任务不包括（ ）。

- A、提升工业企业数据共享能力
- B、提升工业企业数据保护能力
- C、提升数据安全监管能力
- D、提升数据安全产业支撑能力

答案:A"

Q687、数据作为一种新型生产要素，与土地、劳动力、资本、技术等传统要素并列，成为经济活动中不可或缺的部分。（正确）

"Q688、零信任安全模型强调什么类型的访问控制？

- A、宽松的访问控制
- B、基于持续验证的动态访问控制
- C、随意的访问控制
- D、强制的访问控制
- E、开放的访问控制

答案:BD"

"Q689、某项目安全实施时，只完成了“产品安装”，未完成策略调优和联调验证。该交付状态意味着（ ）。

- A、安全能力尚未真正形成生产可用状态
- B、产品已可视为完全生效
- C、联调验证可永久省略
- D、审计记录不再重要

答案:A"

Q690、为了优化个人作为一方当事人的合同下的服务，处理个人信息不需取得个人同意。（错误）

"Q691、某系统要把交易数据实时发送给外部合作伙伴，为降低篡改风险，最应该补充的控制是（ ）。

- A、消息完整性校验机制
- B、删除全部交易日志
- C、取消合作关系
- D、关闭数据库备份

答案:A"

Q692、根据欧洲 GDPR、中国个保法等制度规范中对个人信息的定义，"直接或间接的可识别性"是判断个人信息的根本依据。（正确）

"Q693、某企业监测到某外部 IP 频繁尝试弱口令爆破。防火墙已拦截，安全团队应？

- A、将 IP 加入黑名单并核查暴露面
- B、忽略，已拦截
- C、开放端口诱捕
- D、修改所有密码为 123456

答案:A"

Q694、PBAC 模型基于一组策略来管理访问控制。（正确）

"Q695、个人敏感信息包括（ ）。

- A、身份证件号码
- B、行踪信息
- C、交易信息
- D、征信信息

答案:ABCD"

"Q696、区块链带来的价值包含。

- A、降低信任成本
- B、提高业务效率
- C、创造合作机制
- D、增强监管能力

答案:ABCD"

"Q697、根据《数据安全法》，国家对（ ）数据实行更加严格的管理制度。

- A、重要数据和敏感个人信息
- B、核心数据
- C、涉密数据
- D、生产控制数据

答案:B"

"Q698、根据《密码法》的规定，各级人民政府及其有关部门应当遵循（ ），依法平等对待包括外商投资企业在内的商用密码科研、生产、销售、服务、进出口等单位。

- A、透明原则
- B、非歧视原则
- C、自由竞争原则
- D、平等原则

答案:B"

"Q699、履行个人信息保护职责的部门履行下列个人信息保护职责：

- A、开展个人信息保护宣传教育，指导、监督个人信息处理者开展个人信息保护工作
- B、调查、处理违法个人信息处理活动
- C、组织对应用程序等个人信息保护情况进行测评，并公布测评结果
- D、接受、处理与个人信息保护有关的投诉、举报

答案:ABCD"

"Q700、软件成分分析（SCA）最直接用于识别哪类风险？

- A、第三方组件和开源依赖中的已知漏洞与许可证风险
- B、员工考勤异常
- C、机房门禁漏洞
- D、纸质文档丢失

答案:A"

"Q701、如果 APP 要将用户数据转移至其他公司，该公司应当（ ）。

- A、事先告知用户数据转移的目的和方式，并获得用户明示同意
- B、不需要获得用户同意，因为这些数据属于公司资产
- C、将用户数据转移后再通知用户
- D、不需要通知用户，因为这些数据已经匿名化

答案:A"

"Q702、处理个人信息的，应当遵循合法、正当、必要原则，不得过度处理，并符合下列条件：

- A、征得该自然人或者其监护人同意，但是法律、行政法规另有规定的除外
- B、公开处理信息的规则
- C、明示处理信息的目的、方式和范围

D、不违反法律、行政法规的规定和双方的约定

答案:ABCD"

"Q703、某企业应急演练中，发现备份数据加密密钥丢失导致无法恢复。说明？

- A、密钥管理流程存在重大缺陷，需建立密钥托管与恢复机制
- B、备份无意义
- C、仅影响测试环境
- D、交由开发处理

答案:A"

Q704、采用多个独立的哈希算法同时进行映射，可以有效的降低布隆过滤器误报率。（正确）

"Q705、下列哪些是网络访问控制的应用参考？

- A、网络接入控制
- B、网络通信连接控制
- C、网络隔离基于 VLAN
- D、基于身份的网络认证
- E、防火墙规则配置

答案:ABCD"

"Q706、有关部门在开展关键信息基础设施网络安全检查时（ ）。

- A、应当加强协同配合、信息沟通
- B、避免不必要的检查和交叉重复检查
- C、检查工作收取的费用可以进行抵税
- D、应要求被检部门购买指定的安全服务和安全产品

答案:AB"

"Q707、以下哪一国家在支付数据保护方面采取的是境内存储副本，对转移或出境无限制的模式？

- A、中国
- B、印度
- C、荷兰

D、美国

答案:B"

"Q708、国家（ ）负责统筹协调网络安全工作和相关监督管理工作。

A、电信主管部门

B、网信部门

C、工业和信息化部门

D、公安部门

答案:B"

"Q709、运营者发生合并、分立、解散等情况，应（ ）。

A、不需要做特别处理

B、及时报告保护工作部门

C、及时在安全论坛上公开信息以及相关情况

D、按照保护工作部门的要求对关键信息基础设施进行处置

答案:BD"

"Q710、《工业和信息化部等十六部门关于促进数据安全产业发展的指导意见》中提升产业创新能力包括哪几个部分？

A、加强核心技术攻关

B、构建数据安全产品体系

C、促进数据安全发展

D、布局新兴领域融合创新

答案:ABD"

Q711、如果存在个人信息出境情况，隐私政策中应将出境个人信息类型逐项列出并显著标识（如字体加粗、标星号、下划线、斜体、颜色等）。（正确）

"Q712、物联网中的社交工程是指什么？

A、攻击者利用社交媒体进行攻击

B、攻击者通过社交网络窃取数据

C、攻击者利用人们的社交行为进行欺骗和攻击

D、攻击者利用物联网设备进行社交活动

答案:C"

"Q713、根据《数据安全法》的规定，公安机关、国家安全机关在各自职责范围内承担数据安全监管职责，以下说法错误的是（ ）。

A、公安机关、国家安全机关调取有关组织和个人的数据应当出于维护国家安全或者侦查犯罪的需要

B、公安机关、国家安全机关调取有关组织和个人的数据应当经过严格的批准手续，依法进行

C、公安机关、国家安全机关依法调取有关组织和个人的数据，有关组织和个人可以予以拒绝

D、有关组织和个人拒不配合数据调取的，可以由有关主管部门责令改正，给予警告，并处五万元以上五十万元以下罚款

答案:C"

"Q714、根据《数据安全法》，国家对数据实行什么管理制度？

A、行业自律

B、分类分级

C、企业申报

D、等级保护

答案:B"

"Q715、网络监控和锁定控制的目的是。

A、检测和记录网络上的异常行为

B、监视网络流量

C、限制网络用户的访问

D、加密网络通信

E、防止未经授权的网络连接

答案:ABE"

"Q716、相关行业组织按照章程，依法制定（ ），加强行业自律，指导会员加强数据安全保护，提高数据安全保护水平，促进行业健康发展。

- A、数据安全行为规范和团体标准
- B、数据处理行为规范和团体标准
- C、数据安全行为规范和个人标准
- D、数据处理行为规范和个人标准

答案:A"

Q717、如果发生业务功能变更、个人信息出境情况变更、使用目的变更、个人信息保护相关负责人联络方式变更等情形时，隐私政策应进行相应修订，并通过电子邮件、信函、电话、推送通知等方式及时告知用户。（正确）

"Q718、某社交网站的用户点击了该网站上的一个广告。该广告含有一个跨站脚本，会将他的浏览器定向到旅游网站，旅游网站则获得了他的社交网络信息。虽然该用户没有主动访问该旅游网站，但旅游网站已经截获了他的社交网络信息（还有他的好友们的信息），于是犯罪分子便可以躲藏在社交网站的广告后面，截获用户的个人信息了。这种向 Web 页面插入恶意 html 代码的攻击方式称为（ ）。

- A、SQL 注入攻击
- B、缓冲区溢出攻击
- C、分布式拒绝服务攻击
- D、跨站脚本攻击

答案:D"

"Q719、如果某业务系统定位网络安全等级保护三级，在其遭受灾难性网络攻击严重影响业务系统使用，对社会造成恐慌时，公安机关需调查取证，在取证时，应关注（ ）。

- A、查看攻击的源 IP
- B、攻击的类型
- C、攻击的时间
- D、查看相关系统的 syslog 日志

答案:ABCD"

"Q720、根据《数据安全法》，重要数据的处理者向有关主管部门报送的风险评估报告应当包括哪些内

容？

- A、处理的重要数据的种类、数量
- B、开展数据处理活动的情况
- C、面临的数据安全风险及其应对措施
- D、所有员工的信息安全考核成绩

答案:ABC"

"Q721、具有一定社会知名度，被他人使用足以造成公众混淆的笔名、艺名、网名、译名、字号、姓名和名称的简称等，参照适用（ ）和（ ）保护的有关规定。

- A、姓名权
- B、隐私权
- C、肖像权
- D、名称权

答案:AD"

"Q722、以下哪种机制能有效防止 API 接口被恶意批量调用？

- A、启用 IP 白名单
- B、实施速率限制（Rate Limiting）
- C、使用 JSON 格式传输数据
- D、关闭接口文档访问权限

答案:B"

Q723、网络安全法规定国家实行网络安全等级保护制度。（正确）

Q724、MAC 模型是一种在系统级别实施的安全策略。（正确）

Q725、在网络设备测评中网络设备应具有登录失败处理功能，可采取结束会话、限制非法登录次数和当网络登录连接超时自动退出等措施。（正确）

"Q726、《网络数据安全条例》明确，国家推进（ ）公共服务建设，按照政府引导、用户自愿原则进行推广应用。

- A、数字身份认证
- B、网络身份认证
- C、实名制登记
- D、生物特征认证

答案:B"

"Q727、某组织对外提供开放数据集，计划只做“使用协议签署”，不做脱敏和字段裁剪。其最主要缺陷是（）。

- A、忽略了技术控制措施，单靠协议不足以约束风险
- B、协议已经足够替代所有控制
- C、开放数据不需要任何保护
- D、只要免费就不存在风险

答案:A"

Q728、国家安全部、国家保密局和国务院其他有关部门，在国务院规定的职责范围内做好计算机信息系统安全保护的有关工作。（正确）

"Q729、当同一数据对象在多个系统中重复存在且版本不一致时，应优先实施（）。

- A、主数据治理和数据同步机制
- B、只保留最旧版本数据
- C、由每个系统各自维护
- D、取消所有外部接口

答案:A"

"Q730、访问控制技术通过对访问的申请、批准和撤销的全过程进行有效控制，从而确保什么样的访问才能给予批准？

- A、合法用户的非法访问
- B、非法用户的合法访问
- C、合法用户的合法访问
- D、非法用户的非法访问

答案:C"

"Q731、某系统进行代码审计时发现多个敏感接口未

校验调用来源，最可能的风险是（）。

- A、接口可被内部或外部伪造调用请求滥用
- B、机房供电中断
- C、数据库备份自动停止
- D、用户体验显著提升

答案:A"

"Q732、保护工作部门结合（）制定关键信息基础设施认定规则，并报国务院公安部门备案。

- A、本行业
- B、本领域实际
- C、信息安全论坛上的公开信息
- D、个人安全见解

答案:AB"

"Q733、安全开发中，把“凭据配置”“访问控制规则”“脱敏规则”全部写死在代码中，长期来看最不利于（）。

- A、后续维护、审计和动态调整
- B、系统版本管理
- C、数据库连接稳定性
- D、服务器散热效率

答案:A"

Q734、自上年1月1日起累计向境外提供100万人个人信息的数据处理者向境外提供个人信息，需申报出境安全评估。（正确）

"Q735、HTTPS的主要作用是（）。

- A、加快网页加载
- B、加密传输数据
- C、防止DDoS攻击
- D、限制访问权限

答案:B"

Q736、拜占庭容错类共识机制通过牺牲去中心化来

提高性能，因此广泛用于所有联盟链和私有链系统。（错误）

"Q737、根据《数据安全法》的规定，从事数据交易中介服务的机构提供服务时，哪些要求是必需的？

- A、要求数据提供方说明数据来源
- B、要求数据提供方说明数据内容
- C、审核交易双方的身份
- D、留存审核、交易记录

答案:ACD"

"Q738、根据《生成式人工智能服务管理暂行办法》，提供具有舆论属性或社会动员能力的生成式人工智能服务，须履行什么程序？

- A、向工商部门注册备案
- B、经国家网信部门专项许可
- C、按照国家有关规定开展安全评估，并履行算法备案手续
- D、仅限国有企业提供

答案:C"

"Q739、根据《数据安全法》，国家建立数据安全应急处置机制。发生数据安全事件时，有关主管部门应当依法启动应急预案，采取相应的应急处置措施，防止危害扩大，并及时向社会发布与公众有关的（ ）。

- A、内部调查报告
- B、警示信息
- C、完整事件档案
- D、责任人名单

答案:B"

"Q740、根据《中华人民共和国个人信息保护法》其他有关规定，下列哪些规定情形不需取得个人同意？

- A、为订立、履行个人作为一方当事人的合同所必需，或者按照依法制定的劳动规章制度和依法签订

的集体合同实施人力资源管理所必需

B、为履行法定职责或者法定义务所必需

C、为应对突发公共卫生事件，或者紧急情况下为保护自然人的生命健康和财产安全所必需

D、为公共利益实施新闻报道、舆论监督等行为，在合理的范围内处理个人信息

答案:ABCD"

"Q741、智能卡身份验证需要哪些设备来读取智能卡？

- A、读卡器
- B、手机（NFC）
- C、电脑（含读卡器）
- D、平板电脑（含读卡器）
- E、智能手表

答案:ABCD"

"Q742、零信任身份验证的实现需要哪些技术？

- A、基于用户行为分析的访问控制（UABA）
- B、访问控制列表（ACL）
- C、身份提供者（IdP）
- D、安全信息和事件管理（SIEM）
- E、安全套接字层（SSL/TLS）

答案:ACDE"

"Q743、根据《个人信息保护法》，个人信息处理者不能证明自己没有过错的，应当承担（ ）责任。

- A、损害赔偿
- B、刑事
- C、行政
- D、连带

答案:A"

Q744、私有链是非公开链，它比公有链的隐私性更好、访问控制更强。（正确）

"Q745、某企业准备建立“跨境共享专区”，将境外合作方访问统一收敛到专用区。该设计最主要的安全收益是（ ）。

- A、便于集中实施鉴权、审计、脱敏和边界控制
- B、自动消除所有法律义务
- C、替代数据出境评估
- D、保证所有数据都可公开

答案:A"

"Q746、处理个人信息应当具有明确、合理的目的，并应当与处理目的直接相关，采取对（ ）影响最小的方式。

- A、个人权益
- B、舆论影响
- C、经济损失
- D、集体利益

答案:A"

"Q747、风险评估过程一般应包括？

- A、风险分析
- B、风险识别
- C、风险评价
- D、以上都是

答案:D"

Q748、国家机关应遵循公开透明原则，及时准确的公开政务数据。（错误）

"Q749、以下关于数据出境个人信息保护认证的说法，正确的是？

- A、认证由企业自行完成，无需第三方参与
- B、认证由国家认证认可监督管理委员会认可的专业机构开展
- C、认证完成后永久有效
- D、认证仅适用于大型企业

答案:B"

"Q750、以下做法，不正确的是（ ）。

- A、离职后将个人负责的项目的敏感文档一并带走
- B、将敏感信息在云盘备份
- C、会议室使用完毕后及时擦除白板
- D、在公共场所谈论敏感信息

答案:ABD"

"Q751、若企业希望通过年度审计推动持续改进，而不是“年审一次就结束”，最合理的机制是（ ）。

- A、建立整改跟踪台账，将审计发现与风险评估、制度修订、培训计划联动
- B、审计报告归档后不再跟进
- C、审计只统计问题数量
- D、只对高层汇报，不对执行层反馈

答案:A"

"Q752、网络安全访问控制技术主要用于保护什么？

- A、计算机网络系统和资源
- B、用户隐私
- C、数据中心
- D、网络流量

答案:A"

"Q753、数据标签化治理的主要作用包括哪些？

- A、支持按标签进行检索、管控和审计
- B、帮助识别数据敏感性和业务属性
- C、完全替代数据分类分级制度
- D、为自动化安全策略联动提供依据

答案:ABD"

"Q754、Windows 文件系统权限管理使用访问控制列表机制，以下哪个说法是错误的（ ）？

- A、安装 Windows 系统时要确保文件格式适用的是 NTFS，因为 Windows 的 ACL 机制需要 NTFS 文件格式的支持

B、由于 Windows 操作系统自身有大量文件和目录，因此很难对每个文件和目录设置严格的访问权限，Windows 上的 ACL 存在默认设置安全性不高的问题

C、Windows 的 ACL 机制中，文件和文件夹的权限是与主体进行关联的，即文件夹和文件的访问权限信息是写在文件系统的元数据中而非用户数据库中

D、由于 ACL 具有很好的灵活性，在实际使用中可以为每一个文件设定独立用户的权限

答案:C"

"Q755、若一项共享需求只需要用户手机号后 4 位用于客服核验，则最合理的方案是（ ）。

A、按最小必要原则仅提供掩码后的后 4 位

B、提供完整手机号和身份证号

C、提供所有注册信息

D、默认导出整表

答案:A"

Q756、从数据主体角度进行分类，可将数据分为公共数据、组织数据、个人信息等三个类别。（正确）

Q757、根据 GB/T 43697-2024，数据一旦遭到泄露、篡改、损毁或者非法获取、非法使用，对国家安全造成一般危害的数据，至少应被识别为重要数据。（正确）

"Q758、某企业数据出境前未实施内容审查，导致违规数据流出。应？

A、仅人工审批

B、禁止所有出境

C、仅加密传输

D、建立出境数据内容审核与自动化过滤机制

答案:D"

Q759、个人信息是以电子或者其他方式记录的与已识别或者可识别的自然人有关的各种信息，不包括匿名化处理后的信息。其中"匿名化"是指个人信息经过处理无法识别特定自然人且不能复原的过程。（正

确）

Q760、加密是一种用于验证消息真实性和发送者身份的机制。（错误）

"Q761、Linux 中查看文件权限常用的命令是（ ）。

A、ls -l 文件名

B、chmod 744 文件名

C、passwd 文件名

D、cat 744 文件名

答案:A"

"Q762、下列哪个是常见的单点登录（SSO）技术？

A、OAuth

B、SAML

C、LDAP

D、RADIUS

答案:B"

"Q763、网络运营者兼并、重组、破产的，数据承接方应承接数据安全和义务。没有数据承接方的，应当对数据（ ）处理。

A、封存

B、删除或匿名化

C、仅匿名化

D、存储

答案:B"

"Q764、某企业的数据目录中存在多个名称不同但实际含义相同的字段（如 customer_no 与 cust_id）。最优先的问题不是（ ）。

A、语义重复和标准不统一

B、后续共享与分析时易误用

C、主数据管理难度上升

D、必须立即删除全部历史数据

答案:D"

"Q765、某金融类 APP 用户反馈账户出现异常交易，安全团队调查发现攻击者利用了网络流量劫持手段。以下哪种情况最可能导致用户的登录会话被劫持？

- A、APP 在 HTTP 请求头中携带了明文的用户 ID
- B、APP 使用 HTTPS 协议但未启用证书绑定
- C、APP 的登录密码要求必须包含大小写字母和特殊字符
- D、APP 在用户首次登录时强制要求绑定手机号

答案:B"

"Q766、在大数据关键技术中，Hadoop 的分布式文件系统 HDFS 属于大数据（ ）。

- A、存储技术
- B、分析技术
- C、并行分析技术
- D、挖掘技术

答案:A"

"Q767、以下哪些是网络访问控制的应用场景？

- A、控制网络通信连接
- B、实现网络设备之间的逻辑隔离
- C、管理数据库访问
- D、控制操作系统的访问权限
- E、限制应用系统的访问

答案:ABD"

"Q768、企业应针对数据网络安全设置应急预案与实地演练，下列说法错误的是？

- A、应每年至少组织开展 1 次本组织的应急演练。关键信息基础设施跨组织、跨地域运行的，应定期组织或参加跨组织、跨地域的应急演练
- B、应在应急预案中明确，一旦信息系统中断、受到损害或者发生故障时，需要维护的关键业务功能，并明确遭受破坏时恢复关键业务和恢复全部业务的时间

C、应在应急预案中包括非常规时期、遭受大规模攻击时等处置流程

D、应急预案不仅应包括本组织应急事件的处理，也应包括多个运营者间的应急事件的处理

答案:A"

"Q769、分组密码算法是一类十分重要的密码算法，下面描述中，错误的是（ ）。

- A、分组密码算法要求输入明文按组分成固定长度的块
- B、分组密码的算法每次计算得到固定长度的密文输出块
- C、分组密码算法也称作序列密码算法
- D、常见的 DES、IDEA 算法都属于分组密码算法

答案:C"

"Q770、（ ）有权对违反本法规定的行为向有关主管部门投诉、举报？

- A、只有从事数据安全工作的人员有权
- B、只有从事数据安全工作的组织有权
- C、只有从事数据安全工作的人员和组织有权
- D、任何个人、组织都有权

答案:D"

"Q771、采取技术措施，监测、记录网络运行状态、网络安全事件，并按照规定留存相关的网络日志不少于（ ）。

- A、九个月
- B、三个月
- C、六个月
- D、开始网络服务后的一年

答案:C"

"Q772、数字中国，最重要的生产要素是（ ）？

- A、资本
- B、互联网

C、高智商劳动力

D、数据

答案:D"

"Q773、某政务云平台发生勒索软件攻击，部分虚拟机被加密。应急指挥组应优先？

A、支付赎金

B、隔离受感染节点，启用备份恢复，保留取证日志

C、格式化所有服务器

D、断开互联网即可

答案:B"

"Q774、拒绝服务攻击（DDOS）是黑客常用手段，会严重影响系统与数据可用性，以下属于 DDOS 防御手段的是（ ）？

A、流量清洗

B、过滤畸形包头

C、防火墙上开启 Synflood 与 UDPflood 过滤功能

D、增加数据库缓存层，缓解对数据库穿透访问带来的压力

答案:ABCD"

"Q775、《数据安全法》维护数据安全，应当坚持（ ），建立健全（ ），提高（ ）。

A、数据安全治理体系，国家安全观，数据安全治理体系

B、总体国家安全观，数据安全治理体系，数据安全保障能力

C、数据安全保障能力，数据安全治理体系，国家安全观

D、国家安全观，数据安全保障能力，数据安全治理体系

答案:B"

"Q776、以下哪个是国产自主可控联盟链（ ）。

A、HyperledgerFabric

B、以太坊

C、FiscoBcos

D、长安链

答案:CD"

Q777、数据的使用权和所有权可以分离，使得数据在不泄露原始信息的前提下，能够被多次开发利用。（正确）

"Q778、某企业数据资产目录与合规要求脱节，未映射法规条款。应？

A、仅满足 IT 管理

B、交由法务处理

C、建立数据资产-合规要求映射矩阵，支撑审计与整改

D、无需映射

答案:C"

"Q779、根据《生成式人工智能服务管理暂行办法》，违反本办法规定的，依照哪些法律法规给予处罚？

A、《网络安全法》

B、《数据安全法》

C、《个人信息保护法》

D、《互联网信息服务管理办法》

答案:ABCD"

"Q780、下列哪些是与数据安全合规相关的法律文件？

A、《数据安全法》

B、《网络安全法》

C、《个人信息保护法》

D、《网络安全等级保护条例》

答案:ABCD"

"Q781、根据《人脸识别技术应用安全管理暂行办法》，以下哪项是人脸识别技术使用者必须履行的告知义

务？

A、仅需在隐私政策中笼统说明

B、以显著方式告知人脸信息的处理目的、方式、范围及存储期限

C、张贴英文说明即可

D、仅在首次采集时口头告知

答案:B"

"Q782、特定领域、特定群体、特定区域或达到一定精度和规模的，一旦被泄露或篡改、损毁，可能直接危害国家安全、经济运行、社会稳定、公共健康和安全的数据被称为（）。

A、一般数据

B、重要数据

C、核心数据

D、敏感数据

答案:B"

"Q783、以下哪些行为属于《个人信息保护法》规定的侵犯个人信息的行为？

A、App 中没有隐私政策，或者隐私政策中没有明确处理个人信息规则，App 首次运行时未通过弹窗等明显方式提示用户阅读隐私政策等收集使用规则

B、申请打开可收集个人信息的权限或个人敏感信息时，未同步告知用户其目的，或者目的不明确

C、以欺诈、诱骗等不正当方式误导用户同意收集个人信息或打开可收集个人信息的权限，欺骗误导用户提供身份证号码以及个人生物特征信息的行为

D、收集与其提供的服务无关的个人信息，过度收集的个人信息类型或打开的可收集个人信息权限与现有业务功能无关

答案:ABCD"

"Q784、《数据安全法》对数据处理者提出了哪些要求？

A、遵守法律法规和商业道德

B、采取必要措施保障数据安全

C、配合有关部门的监督检查

D、自由处理数据，无需任何限制

答案:ABC"

"Q785、根据《个人信息保护合规审计指引》，对个人信息处理者与其他个人信息处理者共同处理个人信息进行合规审计的，应当重点审查下列事项？

A、是否约定各自的权利义务

B、是否开展个人信息保护影响评估

C、个人信息权益保护机制

D、个人信息安全事件报告机制

答案:ACD"

Q786、隐私政策中应当将收集个人信息的业务功能逐项列举，不应使用"等、例如"字样。（正确）

"Q787、共识由多个节点按照一定机制验证数据，保证数据的（）。

A、完整性

B、安全性

C、一致性

D、多样性

答案:C"

"Q788、开展数据处理活动，下列说法错误的是：

A、通过设置钓鱼链接的手段获取数据

B、通过向用户发送调查问卷的形式获取数据

C、在暗网出售攻击商业公司获取的数据

D、通过向有资质从事数据交易中介服务的机构购买数据

答案:AC"

"Q789、以下哪种认证方式属于双因素认证？

A、基于智能卡（卡+PIN 码）

B、基于生物特征（单独使用）

C、Kerberos 认证协议

D、静态口令认证（单独使用）

E、一次性口令（OTP）结合密码认证

答案:AE"

"Q790、以下哪些选项属于《个人信息保护法》的目的？

A、保护个人信息权益

B、规范个人信息处理活动

C、促进个人信息合理利用

D、推动个人信息数据无限制跨境流动

答案:ABC"

"Q791、什么是单点登录（SSO）的主要优势？

A、提高网络用户的效率

B、减少网络操作的成本

C、增强网络安全性

D、集中存储用户身份信息

E、提供多个系统的资源

答案:ABC"

"Q792、为切实服务受重大突发事件影响的客户，支持受影响的个人、机构和行业，银行业金融机构可以采取的措施不包括以下哪一项？

A、减免受影响客户账户查询、挂失和补办、转账、继承等业务的相关收费

B、与受重大影响客户协商调整债务期限、利率和偿还方式等

C、为受重大影响客户提供续贷服务

D、适当延长受重大影响客户的报案时限，减免保单补发等相关费用

答案:D"

Q793、一个数据集中存在 Bob 的数据，即使数据集的其他部分（除了 Bob）是已知的，差分隐私也能阻止攻击者识别 Bob（正确）

"Q794、个人信息处理者在处理个人信息前，应当以显著方式、清晰易懂的语言真实、准确、完整地向个人告知下列事项（ ）。"

A、个人信息处理者的名称或者姓名和联系方式

B、个人信息的处理目的、处理方式，处理的个人信息种类、保存期限

C、个人行使本法规定权利的方式和程序

D、法律、行政法规规定应当告知的其他事项

答案:ABCD"

"Q795、动态令牌是一种常见的身份认证方法，它基于（ ）原理。"

A、事先共享的密钥

B、时钟同步算法

C、数字签名

D、会话密钥

答案:B"

Q796、令牌劫持攻击是指攻击者获取合法用户的身份验证令牌或会话标识符，并使用它们来冒充该用户进行身份验证。（正确）

"Q797、某企业建立“客户主数据”“财务数据”“研发配方数据”等标签体系，其最直接的收益是（ ）。

A、便于按业务属性组织数据和实施差异化保护

B、让所有数据自动匿名化

C、使所有数据都无需分类分级

D、降低所有系统的网络带宽

答案:A"

"Q798、对数据进行哈希处理的主要作用是（ ）。

A、加密数据

B、验证数据完整性

C、隐藏数据

D、传输数据

答案:B"

"Q799、关于数据分类分级，下述正确的是？

- A、分类分级仅适用于公共数据
- B、所有数据都必须分级为四级
- C、分类分级只考虑数据规模
- D、分类分级有助于差异化保护

答案:D"

Q800、网络产品和服务提供者因违反《未成年人网络保护条例》的规定，受到关闭网站、吊销相关业务许可证或者吊销营业执照处罚的，5年内不得重新申请相关许可，其直接负责的主管人员和其他直接责任人员5年内不得从事同类网络产品和服务业务。（正确）

Q801、访问控制是网络安全中不常用的一种安全技术。（错误）

"Q802、符合下列哪些情况下，个人信息处理者就应当按照相关规定设置专职的个人信息保护负责人和个人信息保护工作机构？

- A、主要业务涉及个人信息处理，且从业人员规模大于200人
- B、处理超过100万人的个人信息，或预计在12个月内处理超过100万人的个人信息
- C、处理超过10万人的个人敏感信息的
- D、以上全部情况均无需设置专职的个人信息保护负责人和个人信息保护工作机构

答案:ABC"

"Q803、发现数据库存有未加密身份证号，第一响应措施是？

- A、立即删除数据
- B、禁用相关API访问权限
- C、通知用户修改
- D、启动加密迁移

答案:B"

"Q804、国家大力推进电子政务建设，提高政务数据的（），提升运用数据服务经济社会发展的能力。

- A、公益性、准确性
- B、科学性、准确性、时效性
- C、准确性、便利性、公益性
- D、科学性、准确性、高效性

答案:B"

Q805、修订后《网络安全法》将个人信息和重要数据违法行为的处罚，明确转致适用《数据安全法》《个人信息保护法》等法律的相关规定。（正确）

"Q806、关于数据交易标的的说法中，正确的是：

- A、涉及未经授权的企业数据、商业秘密等特定权益的数据可以进行交易
- B、数据交易标的仅包括数据产品
- C、数据交易标的包括数据产品、数据服务、第三方专业服务等
- D、危害国家安全、公共利益和社会稳定的数据在符合安全监管条件下可以进行交易

答案:C"

"Q807、某企业数据资产目录未包含数据血缘关系。治理缺陷导致？

- A、系统性能提升
- B、网络带宽节约
- C、问题数据溯源困难，影响质量整改与影响评估
- D、前端优化

答案:C"

Q808、《个人信息金融信息保护技术规范》规定，因业务需要，确需向境外机构提供个人金融信息的，应依据国家、行业有关部门制定的办法与标准开展个人金融信息出境安全评估，确保境外机构数据安全保护能力达到国家、行业有关部门与金融业机构的安全要求。（正确）

"Q809、以下哪些是数字证书认证中心（CA）的主

要职责？

- A、签发数字证书
- B、撤销数字证书并发布证书撤销列表（CRL）
- C、为用户私钥提供托管和恢复服务
- D、维护证书全生命周期管理

答案:ABD"

"Q810、某医疗机构委托第三方 IT 公司对其医疗信息系统进行运维。运维过程中 IT 公司员工可以访问患者就诊记录。该场景下合规要点包括？

- A、医疗机构须与 IT 公司签署包含数据安全条款的数据处理委托协议
- B、限制运维人员访问的最小必要权限范围
- C、对运维人员操作进行审计日志记录
- D、IT 公司可自行留存患者数据用于内部研究

答案:ABC"

"Q811、某企业数据治理团队在梳理数据资产时发现，公司内部有 20 个部门各自建立了不同格式的""客户信息表""，字段名称和数据标准均不统一。治理团队的首要行动应是？

- A、制定企业级数据标准和主数据管理（MDM）规范，统一关键数据字段定义和格式
- B、删除 19 个冗余表，仅保留一个
- C、交由各部门自行协商统一
- D、购买数据集成工具解决

答案:A"

"Q812、根据《个人信息保护法》，以下哪种情形，个人信息处理者无需事前进行个人信息保护影响评估？

- A、处理敏感个人信息
- B、向境外提供个人信息
- C、利用个人信息进行自动化决策
- D、对已匿名化数据进行内部统计分析

答案:D"

"Q813、APP 收集敏感用户数据时应该（ ）。

- A、在 APP 中嵌入广告，以此换取用户数据
- B、强制用户授权所有权限
- C、明确告知用户数据收集的目的和方式，并获得用户明示同意
- D、不需要获得用户同意，因为这些数据对 APP 运营至关重要

答案:C"

"Q814、令牌劫持攻击的示例是（ ）。

- A、密码猜测/暴力破解攻击
- B、攻击者通过 XSS 漏洞窃取用户的 Session Cookie
- C、中间人攻击
- D、侧信道攻击

答案:B"

"Q815、根据《数据出境安全评估办法》，开展出境评估前，数据处理者应准备哪些材料？

- A、出境合同副本或委托协议
- B、数据处理者与接收方权责分配表
- C、数据出境影响评估报告
- D、提供方和接收方的基本信息表

答案:ACD"

"Q816、应急预案中若未明确“谁有权触发停机、隔离、外部通报”，最可能导致（ ）。

- A、处置迟缓与职责争议
- B、带宽自动增加
- C、日志自动压缩
- D、数据库备份自动完成

答案:A"

"Q817、根据《密码法》的规定，密码管理部门因工

作需要，按照国家有关规定，可以提请公安、交通运输、海关等部门（ ）提供免检等便利，有关部门应当予以协助。

- A、核心密码有关物品
- B、核心密码有关人员
- C、普通密码有关物品
- D、普通密码有关人员

答案:ABCD"

Q818、在对数据合规风险进行发生可能性分析时，对发生可能性较小的风险事件，应及时采取应对措施，积极相应，避免严重结果的发生。（错误）

"Q819、强制访问控制模型（MAC）基于什么来确定资源的访问权限？

- A、资源所有者授权
- B、用户角色分配
- C、固定的安全策略和标签
- D、用户行为和环境信息

答案:C"

"Q820、《数据安全法》规定，国家建立数据安全风险评估、报告、信息共享、监测预警机制，这些机制的主要作用包括哪些？

- A、及时发现数据安全风险
- B、提高数据安全防护和应对能力
- C、为风险处置和监管协同提供支撑
- D、增加数据处理活动的复杂性

答案:ABC"

"Q821、某开发团队将密钥硬编码在程序中，以便快速上线。数据安全工程师应指出的最主要问题是（ ）。

- A、密钥管理失控，代码泄露将导致加密保护失效
- B、可以提高可维护性
- C、只影响系统性能

D、与数据安全无关

答案:A"

Q822、数据交易只能通过数据交易场所进行交易。（错误）

"Q823、某金融机构数据治理发现""客户风险评级""数据更新滞后。该问题影响？

- A、页面加载速度
- B、数据库容量
- C、网络延迟
- D、风控模型准确性与合规审计结论

答案:D"

"Q824、国家机关应当遵循公正、（ ）、便民的原则，按照规定及时、准确地公开政务数据。依法不予公开的除外。

- A、公平
- B、创新
- C、准确
- D、开放

答案:A"

Q825、区块链是利用密码技术将共识确认的区块按顺序追加形成的分布式账本。（正确）

"Q826、某组织将数据分为“原始数据、加工数据、衍生数据、共享数据”等层次，这首先体现的是（ ）。

- A、数据的业务分类设计
- B、密码算法设计
- C、机房温控策略
- D、备份介质分层

答案:A"

"Q827、某 APP 在用户协议中约定""用户点击同意即表示授权本公司及关联公司处理用户全部个人信息用于任何目的""。该条款的效力是？

- A、该条款无效；授权范围须具体明确，""任何目的""的概括性授权违反目的限制原则
- B、条款有效，用户已同意即可
- C、合法，用户自愿同意受合同法保护
- D、由法院最终认定，监管部门无权认定无效

答案:A"

"Q828、发生关键信息基础设施整体中断运行或者主要功能故障等特别重大网络安全事件或者发现特别重大网络安全威胁时，保护工作部门应当在收到报告后（ ）。"

- A、将相关信息尽快发布到境内的安全论坛网站上
- B、及时向国家网信部门、国务院公安部门报告
- C、在处理完安全威胁并经过至少 30 个工作日的分析后再将相关信息发布到境内的安全论坛网站上
- D、如果发生的损失公司难以承担可以选择不报

答案:B"

"Q829、修订后的《网络安全法》对直接负责的主管人员的个人罚款上限提升至（ ）。"

- A、十万元
- B、五十万元
- C、一百万元
- D、二百万元

答案:C"

"Q830、关于信息系统安全等级保护第三级的系统运维管理，应建立系统安全管理制度，对（ ）作出具体规定。"

- A、系统安全策略
- B、安全配置
- C、日常操作流程
- D、都是

答案:D"

Q831、垃圾邮件攻击是一种随机发送欺骗性电子邮件

件的社会工程学攻击。（错误）

Q832、区块链的数据是不可篡改的，所以不存在安全问题。（错误）

"Q833、安全开发上线“门禁”策略中，最符合数据安全工程实践的是（ ）。

- A、未通过关键安全检查的构建禁止进入生产发布阶段
- B、所有检查放到上线后再做
- C、只记录问题，不影响发布
- D、以业务紧急为由永久豁免

答案:A"

"Q834、如果同一安全事件同时涉及数据泄露、业务中断和完整性破坏，处置方案应强调（ ）。

- A、分类定级、分工协同和并行处置
- B、只处理业务中断即可
- C、只处理数据泄露即可
- D、先对外公关，不必技术处置

答案:A"

"Q835、App 运营者不应在用户协议、服务协议、隐私政策等文件中出现（ ）条款。"

- A、免除自身责任
- B、加重用户责任
- C、排除用户主要权利
- D、免除用户责任

答案:ABC"

"Q836、数据分类可根据数据管理和使用需求，结合已有数据分类基础，灵活选择业务属性将数据细化分类。开展行业领域数据分类步骤是（ ）。

- ①明确数据范围 ② 细化业务分类 ③业务属性分类 ④ 确定分类规则

A、①②③④

B、①④②③

C、④③①②

D、④①②③

答案:A"

"Q837、单点登录（SSO）认证过程中，当请求中携带的 Cookie 无效时，拦截器通常会怎么处理？

A、放行访问请求

B、重定向用户到统一认证服务器的登录界面

C、删除目标应用系统

D、忽略该请求

答案:B"

"Q838、根据 GB/T 43697-2024，以下哪些字段单独来看可能是低级别数据，但组合后应升级处理？

A、用户姓名（单独 2 级）

B、手机号（单独 2 级）

C、家庭住址（单独 2 级）

D、三者组合后关联性增强，应综合评估为 3 级

答案:ABCD"

"Q839、根据《促进和规范数据跨境流动规定》，""自由贸易试验区""内的数据出境有何特殊规定？

A、完全不受数据出境法规约束

B、可依据试验区数据出境负面清单，对清单外数据享有更便利的出境安排

C、仅需内部审批无需其他合规程序

D、与境内其他地区完全相同无特殊规定

答案:B"

"Q840、区块链信息服务提供者开发上线（ ）的，应当按照有关规定报国家和省、自治区、直辖市互联网信息办公室进行安全评估。

A、新产品

B、新应用

C、新功能

D、以上都需要

答案:D"

Q841、口令序列认证依赖于单向的哈希函数。（正确）

"Q842、根据《信息安全技术 网络安全等级保护定级指南》，等级保护对象的定级要素包括？

A、侵害行为主体

B、受侵害的客体

C、对客体的侵害程度

D、侵害的方式

答案:BC"

"Q843、在进行数据安全风险评估时，以下哪项是关键的第一步？

A、制定详细的风险应对措施

B、选择合适的风险评估方法和工具

C、识别并确定评估的范围和对象

D、汇总并报告评估结果

答案:C"

Q844、审计库是访问控制参考模型的组成要素之一。（正确）

"Q845、以下哪些是信息安全系统中访问控制的实现方式？

A、基于角色的访问控制（RBAC）

B、基于属性的访问控制（ABAC）

C、强制访问控制（MAC）

D、自主访问控制（DAC）

E、基于策略的访问控制（PBAC）

答案:ABCDE"

"Q846、关于 APP 收集儿童数据，以下哪种做法是正确的？

A、不需要获得家长或监护人同意，因为这些数据对 APP 运营至关重要

B、需要在 APP 中添加父母授权功能，以便父母同意数据收集

C、允许未成年人自主决定是否授权数据收集

D、可以随意收集儿童数据，只需在隐私政策中声明即可

答案:B"

"Q847、某 API 返回用户数据：{name, phone, location}，不同客户需差异化脱敏，应部署在？

A、数据库视图层

B、业务逻辑层

C、API 网关+动态策略引擎

D、前端渲染层

答案:C"

Q848、CA 与 PKI 是两个独立的概念，不会混用。（错误）

"Q849、某企业数据安全事件发生后，未按规定向用户告知。该行为违反？

A、《个人信息保护法》关于安全事件通知义务

B、《广告法》

C、《商标法》

D、《劳动法》

答案:A"

"Q850、SDK 软件开发工具包，SDK 公示中应在清单中标明下列哪些内容？

A、名称

B、开发者

C、版本号

D、主要功能

答案:ABCD"

Q851、《个人信息保护合规审计管理办法》规定，对同一个人信息安全事件或风险，监管部门不得重复要求个人信息处理者委托专业机构开展合规审计。

（正确）

"Q852、Linux 命令中关于以下说法不正确的是（ ）。

A、PASS_MAX_DAYS 90 是指登陆密码有效期为 90 天

B、PASS_WARN_AGE 7 是指登陆密码过期 7 天前提示修改

C、FAIL_DELAY 10 是指错误登陆限制为 10 次

D、SYSLOG_SG_ENAB yes 当限定超级用户组管理日志时使用

答案:C"

"Q853、根据《跨境流动规定》的规定，企业在哪些情况下可以选择通过个人信息保护认证的方式向境外提供个人信息？

A、适用于所有数据处理者，无论规模大小

B、累计向境外提供超过 100 万人的个人信息时

C、作为 CII 的数据处理者向境外提供个人信息时

D、作为 CII 以外的数据处理者，自当年 1 月 1 日起，累计向境外提供 10 万人以上、不满 100 万人个人信息（不含敏感个人信息）时

答案:D"

"Q854、根据 GB/T 43697-2024，""公共数据""的定义是？

A、所有可公开访问的互联网数据

B、各级政务部门及具有公共管理职能的组织在依法履行职责过程中收集、产生的数据

C、免费下载的开源数据集

D、社交媒体上的公开内容

答案:B"

"Q855、在隐私计算方案评审中，如果业务要求“多方联合建模但原始数据不出域”，优先考虑的技术路径是（ ）。

A、联邦学习或安全多方计算

- B、全文明文共享
- C、只做数据库备份
- D、停用建模功能

答案:A"

Q856、网络安全（cybersecurity）是指通过采取必要措施，防范对网络的攻击、侵入、干扰、破坏和非法使用以及意外事故，使网络处于稳定可靠运行的状态，以及保障网络数据的完整性、保密性、可用性的能力。（正确）

"Q857、根据《数据安全法》第三十六条，未经主管机关批准，境内的组织、个人不得向外国司法或者执法机构（ ）境内的数据。

- A、使用
- B、提供
- C、存储
- D、加工

答案:B"

Q858、中国数据跨境法律法规处于创新制定和持续完善的过程。随着《网络安全法》《数据安全法》《个人信息保护法》发布，数据保护相关上位法的"三驾马车"已然形成；相关规范性文件、国家标准等陆续出台构成规则体系。（正确）

"Q859、《数据安全法》从哪个角度为执行者设定了合规的要求？

- A、信息保护角度
- B、数据保护角度
- C、信息安全角度
- D、数据与安全的角度

答案:D"

"Q860、关于 Wi-Fi 联盟提出的安全协议 WPA 和 WPA2 的区别，下列哪些描述是错误的？

- A、WPA 是有线局域安全协议，而 WPA2 是无线局域网协议

B、WPA 是适用于中国的无线局域安全协议，WPA2 是适用于全世界的无线局域网协议

C、WPA 没有使用密码算法对接入进行认证，而 WPA2 使用了密码算法对接入进行认证

D、WPA 与 WPA2 在加密机制上完全相同，没有本质区别

答案:ABCD"

"Q861、根据《电子签名法》的规定，（ ）与手写签名或者盖章具有同等的法律效力。

- A、哈希签名
- B、数字签名
- C、可靠的电子签名
- D、加密签名

答案:C"

Q862、要实现访问控制的目标，需要进行有效的身份认证和授权，并进行系统的安全审计和监控。（正确）

Q863、中间人攻击是指攻击者通过欺骗、诱骗或操纵用户来获取其身份验证凭据。（错误）

"Q864、以下哪些属于敏感个人信息？

- A、基因数据
- B、银行账户信息
- C、学历信息
- D、医疗健康信息

答案:ABD"

"Q865、下列哪个不是访问控制参考模型的组成要素？

- A、主体
- B、参考监视器
- C、客体
- D、数据库管理系统

答案:D"

"Q866、某互联网平台将""用户 IP 地址""定为一般数据，但结合时间戳与浏览轨迹可精准定位个人。该定级问题在于？

- A、未考虑数据关联与聚合后的敏感性提升
- B、IP 地址本身无价值
- C、定级标准过高
- D、技术实现困难

答案:A"

"Q867、根据《促进和规范数据跨境流动规定》，通过数据出境安全评估的结果有效期为（ ）年。

- A、1 年
- B、2 年
- C、3 年
- D、5 年

答案:C"

"Q868、某企业拟实施零信任架构，但现有系统仍依赖 IP 白名单。改造第一步应？

- A、建立统一身份中心，实施基于身份的持续验证与动态授权
- B、扩大 IP 白名单
- C、关闭外网访问
- D、仅加强口令策略

答案:A"

Q869、口令安全管理中，建议使用与账号相同的口令，以增加系统的安全性。（错误）

Q870、物理访问控制主要涉及对物理场所和设备的访问进行控制，而网络接入控制和网络通信连接控制属于网络访问控制。（正确）

"Q871、PKI 公钥基础设施主要基于以下哪类密码技术实现信息安全服务？

- A、对称加密算法
- B、非对称加密算法（公钥密码）

C、单向哈希算法

D、流密码算法

答案:B"

"Q872、大型网络平台服务提供者应当（ ）发布个人信息保护社会责任报告，报告内容包括但不限于个人信息保护措施和成效、个人行使权利的受理情况、主要由外部成员组成的个人信息保护监督机构履行职责情况等

- A、每年度
- B、每季度
- C、每月
- D、每半年

答案:A"

"Q873、《中华人民共和国民法典》总则编规定，法律对（ ）、（ ）的保护有规定的，依照其规定。

- A、文件
- B、数据
- C、网络虚拟财产
- D、专利

答案:BC"

Q874、当发生有可能危害关键业务的安全事件时，应及时向安全管理机构报告，并组织研判，形成事件报告，应及时将可能危害关键业务的安全事件通报到可能受影响的内部部门和人员，并按照规定向供应链涉及的、与事件相关的其他组织通报安全事件。（正确）

"Q875、打开一份邮件时，处理邮件附件的正确做法是（ ）？

- A、确认发件人信息真实后，查杀病毒后打开
- B、置之不理
- C、删除附件
- D、直接打开运行

答案:A"

Q876、4A 系统提供的服务包括认证、授权、账号和审计。（正确）

"Q877、下面哪项是加强安全意识推广的有效方式？

- A、提供员工奖励计划
- B、发送周期性的安全通知
- C、禁止员工使用公司电子邮件
- D、随机抽查员工隐私信息

答案:B"

"Q878、某在华外资企业拟将中国境内员工个人信息传输至境外总部，用于跨境人力资源管理。根据《促进和规范数据跨境流动规定》，以下说法正确的是？

- A、只要是外资企业即可当然豁免数据出境合规义务
- B、如确属按照依法制定的劳动规章制度和依法签订的集体合同实施跨境人力资源管理所必需，可免于申报数据出境安全评估、订立个人信息出境标准合同和通过个人信息保护认证
- C、所有员工个人信息出境都必须申报数据出境安全评估
- D、只要不含敏感个人信息即可无需任何合规措施

答案:B"

Q879、区块依靠区块头信息将各自连接起来形成区块链。（正确）

"Q880、下列属于传感设备的是。

- A、RFID
- B、红外感应器
- C、全球定位系统
- D、激光扫描器

答案:ABCD"

"Q881、K-匿名方法主要用于什么？

- A、数据加密
- B、数据脱敏（匿名化处理）

C、数据备份

D、数据恢复

答案:B"

"Q882、某企业引入隐私计算平台后，仍允许开发人员随意下载中间结果文件。该问题说明（ ）。

- A、技术能力已被管理缺陷抵消
- B、隐私计算天然无风险
- C、中间结果不属于数据
- D、只要平台合规即可忽略操作权限

答案:A"

"Q883、在嵌入式系统中，远程认证是如何实现的？

- A、使用数字证书进行身份验证
- B、使用单向哈希函数进行消息认证
- C、使用多因素身份验证进行认证
- D、使用物理令牌进行认证

答案:A"

Q884、根据《中华人民共和国个人信息保护法》规定，个人信息处理者应对其个人信息处理活动负责，并采取必要措施保障所处理个人信息的安全。（正确）

"Q885、零信任（ZT）身份验证是什么？

- A、不信任任何用户或设备，需要对每个请求进行身份验证和授权
- B、只信任内部用户，不信任外部用户
- C、只信任特定设备，不信任其他设备
- D、只信任特定网络，不信任其他网络

答案:A"

"Q886、《中华人民共和国民法典》规定，处理个人信息时，应当遵循（ ）、正当、必要原则。

- A、合法
- B、合理

C、适度

D、适当

答案:A"

"Q887、如果在方案设计阶段忽略了“异常中断时的数据恢复需求”，最可能造成什么问题？

A、安全控制无法与业务连续性要求匹配

B、前端颜色主题不统一

C、员工考勤失真

D、接口文档过长

答案:A"

"Q888、《网络数据安全条例》涉及的主要内容包括哪些方面？

A、一般性数据安全合规要求

B、个人信息保护的细化要求

C、重要数据安全治理

D、数据跨境流动管理

答案:ABCD"

"Q889、某企业发现某数据表因业务调整已停用3年，但分类分级目录仍标记为重要数据。应如何处理？

A、维持标记以防万一

B、复核后动态调整或归档降级

C、立即删除所有数据

D、交由法务部门裁决

答案:B"

"Q890、某组织在数据资产梳理时，仅以“数据库表”为粒度管理，而未识别表内敏感字段。该做法的主要局限是（ ）。

A、难以支撑字段级权限控制和精细化脱敏

B、会自动导致出境风险

C、会使备份全部失效

D、等保测评无法开展

答案:A"

"Q891、物联网中的固件更新主要用于什么目的？

A、修复安全漏洞

B、提升设备性能

C、扩展设备功能

D、降低设备成本

答案:A"

"Q892、在《数据出境安全评估办法》中，以下哪些情形属于应申报安全评估的法定触发条件？

A、向境外提供重要数据

B、自上年1月1日起累计出境敏感个人信息超过1万人份

C、自上年1月1日起累计出境个人信息超10万人份

D、关键信息基础设施运营者向境外提供个人信息

答案:ABCD"

"Q893、公司审计中的个人信息处理活动应符合哪些要求？

A、公司的销售战略

B、法律法规

C、董事会决议

D、领导的个人喜好

答案:B"

"Q894、数据脱敏中无效化的方法是什么？

A、数据加密

B、数据替换

C、数据截断或隐藏

D、数据备份

答案:C"

"Q895、云计算平台的特点。

- A、虚拟化
- B、基于互联网
- C、大型的集中计算
- D、按需使用

答案:ABCD"

"Q896、单点登录（SSO）的主要目标是什么？

- A、提高用户体验
- B、减少系统管理和维护成本
- C、增加数据安全性
- D、加快应用系统的响应速度

答案:A"

"Q897、以下哪种行为不适用《数据安全法》？

- A、中国境内开展数据处理活动的行为
- B、中国境外开展数据处理活动且未损害中华人民共和国国家安全、公共利益或公民、组织合法权益的行为
- C、中国境外开展数据处理活动损害中国国家安全、公共利益的行为
- D、中国境外开展数据处理活动损害公民合法权益的行为

答案:B"

Q898、等保 2.0 对人工智能有额外的安全扩展要求。（错误）

"Q899、某企业的安全监测平台每天产生上万条告警，但真正高价值告警极少。应首先优化（ ）。

- A、规则质量与告警关联能力
- B、办公区照明强度
- C、数据库厂商
- D、打印纸张规格

答案:A"

"Q900、我国应对大数据安全的主要举措包括

- A、健全政策法规，防范大数据安全风险
- B、加强顶层设计，引领大数据安全发展
- C、构建标准体系，引领大数据规范发展
- D、构筑信息屏障，禁止跨部门数据流通

答案:ABC"

"Q901、区块链的区块头主要包含时间戳、随机数、目标哈希值、默克尔值等信息。以下哪项不在区块头中？

- A、时间戳
- B、默克尔根值
- C、交易明细
- D、目标哈希值

答案:C"

"Q902、对于计算机口令，以下说法正确的是（ ）？

- A、尽量复杂
- B、简单好记即可
- C、定期更换
- D、多个系统用一套账号口令，能够提升工作效率

答案:AC"

"Q903、某企业在数据安全合规审计后出具的整改报告中，仅列出问题清单而未提供整改计划和完成时限。该报告的缺陷是？

- A、不符合合规审计闭环要求，须包含具体整改措施、责任人和完成期限
- B、发现问题即视为审计完成
- C、整改计划由被审计方自行制定，无需在报告中体现
- D、报告格式由企业自主决定

答案:A"

"Q904、某互联网平台用户注销后，关联数据仍保留 90 天。应？

- A、依法及时删除或匿名化，明确保留期限与例外情形
- B、永久保留
- C、仅隐藏前端显示
- D、仅加密存储

答案:A"

"Q905、隐私政策中应对 App 运营者在个人信息保护方面采取的措施和具备的能力进行说明，如（ ）等。

- A、身份鉴别
- B、访问控制
- C、恶意代码防范
- D、安全审计

答案:ABCD"

"Q906、电信业务经营者、互联网信息服务提供者应尽力优化用户体验，下列哪些行为是错误的？

- A、在非服务所必需或无合理场景下，不得自启动和关联启动其它 APP，或进行唤醒、调用、更新等行为
- B、为方便用户使用，可以签署""一揽子""授权，获取用户终生所有授权
- C、采取自动续订、自动续费方式提供服务的，应当征得用户同意，不得默认勾选、强制捆绑开通
- D、在自动续订、自动续费前以默示方法告知用户，服务期间提供便捷的随时退订方式和自动续订、自动续费取消途径

答案:BD"

Q907、SELinux 是一种用于增强操作系统安全性的产品。（正确）

"Q908、修订后的《网络安全法》中，以下哪项属于新增柔性执法条款规定的不予行政处罚情形？

- A、违法金额较小
- B、违法行为轻微并及时改正且没有造成危害后果

- C、当事人提出申诉
- D、违法所得已退还

答案:B"

"Q909、保护工作部门应（ ）。

- A、定期组织开展本行业、本领域关键信息基础设施网络安全检查检测
- B、指导监督运营者及时整改安全隐患
- C、要求部门购买指定的安全服务
- D、完善安全措施

答案:ABD"

"Q910、履行个人信息保护职责的部门依法履行职责，当事人（ ）。

- A、应当予以协助
- B、拒绝
- C、阻挠
- D、应当予以配合

答案:AD"

"Q911、某企业安全审计发现，运维团队使用共享账号（admin/admin123）登录所有服务器，无法追溯操作记录。合规整改应优先？

- A、为每位运维人员分配独立账号，启用特权访问管理（PAM）与操作审计
- B、修改共享密码为复杂密码
- C、减少运维人员数量
- D、关闭远程运维功能

答案:A"

Q912、媒体欺骗是指攻击者通过伪造图像、视频或音频材料来引导目标执行某些操作。（正确）

Q913、垃圾邮件攻击通常是随机发送大量欺骗性电子邮件，而针对特定个人或组织的精准攻击则称为鱼叉式钓鱼攻击。（正确）

"Q914、下面哪项是网络端口和节点的安全控制的目的

标？

- A、保护网络设备的物理安全
- B、防止网络攻击
- C、限制用户对网络资源的访问
- D、控制网络带宽的使用
- E、检测和阻止恶意流量

答案:ABE"

"Q915、有关部门以及网络安全服务机构在关键信息基础设施安全检测评估中获取的信息（ ）。

- A、可以在网络上公开售卖
- B、不能用于其他用途
- C、可以提供给安全从业人员进行参考学习
- D、可以提供给境外安全论坛进行谈论、研究和学习以促进互动和安全行业发展

答案:B"

"Q916、UNIX/Linux 系统中实现自主访问控制的基本方法是什么？

- A、使用""9 比特位模式""标识文件的访问权限信息
- B、基于用户组的访问控制
- C、依赖数字证书进行身份验证
- D、使用访问控制列表（ACL）来控制文件访问权限
- E、运行访问控制管理软件来控制访问

答案:ABD"

"Q917、某企业在开展数据出境安全评估申报时，发现境外接收方拒绝配合提供其所在国的数据保护法规证明和隐私政策文档。企业应如何处理？

- A、该拒绝表明境外接收方无法满足评估要求，企业应暂停出境并重新评估合作方合规能力
- B、可以在不提供文件的情况下继续申报
- C、由企业单方面声明境外接收方合规
- D、向监管部门反映境外方拒绝配合，申请豁免

答案:A"

"Q918、某企业 API 网关未实施限流与防爬策略，遭恶意调用导致服务降级。应？

- A、仅扩容服务器
- B、忽略攻击
- C、配置 IP 黑白名单、请求频率限制、签名验签机制
- D、关闭所有 API

答案:C"

Q919、工业和信息化领域重要数据和核心数据处理者，还应当明确数据处理关键岗位和岗位职责，并要求关键岗位人员签署数据安全责任书。（正确）

"Q920、根据 GB/T 43697-2024，对于已完成分类分级的数据，应（ ）进行复核，确保分级的持续准确性。

- A、一次性完成后无需复核
- B、仅在发生数据泄露时复核
- C、定期进行复核，并在业务变更、法规更新时及时调整
- D、每 5 年复核一次

答案:C"

"Q921、以下哪类可以作为网络安全等级保护的定级对象？

- A、一台裸金属服务器，里面还没有装操作系统
- B、某部委部长用的 PC 终端
- C、某电商网站数据中心边界路由器
- D、某能源系统的能源调度云平台

答案:D"

"Q922、从事数据交易中介服务的机构提供服务时，下列说法正确的是：

- A、为保密需求，使用虚假身份进行交易
- B、为保密需求，不留存交易记录

C、保留交易记录

D、交易前核实双方身份

答案:CD"

"Q923、根据《个人信息保护合规审计管理办法》，专业机构在合规审计中获取的个人信息、商业秘密等，在合规审计工作结束后应当（ ）。

A、报送监管部门存档

B、及时删除相关信息

C、继续保存以备查用

D、向行业协会备案

答案:B"

"Q924、运营者应当设置专门安全管理机构，并对（ ）进行安全背景审查。

A、专门安全管理机构负责人

B、公司内的所有人员

C、关键岗位人员

D、所有入职不满 30 个自然日的人员

答案:AC"

"Q925、修订后的《网络安全法》柔性执法条款规定，可以依法从轻、减轻或不予行政处罚的情形包括（ ）。

A、主动消除或减轻违法行为危害后果

B、违法行为轻微并及时改正且没有造成危害后果

C、初次违法且危害后果轻微并及时改正

D、主动向有关部门投案

答案:ABC"

"Q926、身份信息在传输过程中需要保证哪些安全性？

A、机密性、完整性、可用性

B、机密性、可复制性、可用性

C、完整性、可变性、可用性

D、完整性、可靠性、可复制性

答案:A"

Q927、数据加密标准 DES 的分组长度为 128 比特。（错误）

"Q928、运营者对保护工作部门开展的关键信息基础设施网络安全检查检测工作，以及下列哪些部门依法开展的关键信息基础设施网络安全检查工作，应当予以配合？

A、公安机关

B、国家安全机关

C、保密行政管理部门

D、密码管理部门

答案:ABCD"

"Q929、某企业发现多个系统对同一事件的告警级别定义不一致。该问题最可能影响（ ）。

A、事件分级响应和资源调度的一致性

B、数据库品牌选择

C、员工工位安排

D、网络出口地址规划

答案:A"

"Q930、关于数据汇聚，下列说法正确的是：（ ）？

A、单条数据是脱敏的，那么汇聚数据也是非敏感的

B、单条数据是脱敏的，汇聚数据可能会导致背景推理泄密

C、如果单条数据脱敏，那么汇聚数据没有实际分析的意义

D、数据汇聚是双刃剑，可能带来高价值数据，也可能导致泄密

答案:BD"

"Q931、某政务系统监测到异常大批量数据导出行为，安全团队应首先？

A、立即阻断并核查操作人身份与授权

B、忽略，可能是正常备份

C、仅记录日志不处理

D、直接关闭数据库

答案:A"

"Q932、《个人信息保护合规审计管理办法》规定，监管部门可以要求个人信息处理者委托专业机构开展合规审计，以下哪种情形不属于触发条件？

A、发现个人信息处理活动存在较大风险

B、个人信息处理活动可能侵害众多个人的权益

C、企业主动申请合规认证

D、发生导致 100 万人以上个人信息泄露的安全事件

答案:C"

"Q933、在数据交易安全评估中，若无法确认数据提供方是否有权处分数据，最合理的结论是（ ）。

A、交易合法性存在重大疑点，应暂停推进

B、可先交易后补材料

C、由购买方自行承担风险即可

D、只要价格合理即可交易

答案:A"

"Q934、在通信过程中，只采用数字签名可以解决（ ）等问题。

题目

A、数据完整性

B、数据的抗抵赖性

C、数据的篡改

D、数据的保密性

答案:ABC"

"Q935、APP 运营商应做到（ ）。

A、向用户推荐下载 APP 应遵循公开、透明原则

B、应用提供者应真实、准确、完整地明示开发运营者、产品功能、隐私政策、权限列表等必要信息，

并同步提供明显的取消选项

C、APP 应当经用户确认同意后方可下载安装，切实保障用户知情权、选择权

D、除基本功能软件外，APP 应当可便捷卸载，不得以空白名称、透明图标、后台隐藏等方式恶意阻挠用户卸载

答案:ABCD"

"Q936、直接可识别性的例子如姓名、身份 ID 等基本身份信息，下列哪一项不属于直接可识别性的例子？

A、指纹

B、声纹

C、虹膜

D、牙模

答案:D"

Q937、访问控制是指对资源对象的访问者授权，不涉及控制访问的方法和运行机制。（错误）

Q938、个人信息保护合规审计、重要数据风险评估、重要数据出境安全评估等应当加强衔接，避免重复评估、审计。重要数据风险评估和网络安全等级测评的内容重合的，相关结果可以互相采信。（正确）

"Q939、银行保险机构在实施信息科技外包时应当坚持的原则不包括？

A、不得将信息科技管理责任、网络安全主体责任外包

B、以不妨碍核心能力建设、积极掌握关键技术为导向

C、保持外包风险、成本和收益的平衡

D、保障网络和信息安全，加强重要数据和个人信息保护

答案:C"

"Q940、某企业安全审计发现，员工使用同一套用户名密码访问内网 OA、邮件、ERP 等多个系统，且密

码为""company2020""。该安全隐患应如何处置？

- A、强制要求所有系统使用独立强密码并定期更换
- B、推行统一身份认证（SSO）并加入多因素认证（MFA）
- C、开展密码安全意识培训
- D、仅为高管账号增强密码保护即可

答案:ABC"

Q941、RBAC 是一种基于角色的访问控制模型。（正确）

"Q942、下列关于收集数据说法错误的是：

- A、通过非正当技术手段获取数据
- B、应当采取合法、正当的方式
- C、不得窃取或者以其他非法方式获取数据
- D、公安部门可以窃取或者以其他非法方式获取数据

答案:AD"

"Q943、从事数据交易中介服务的机构提供服务，下列说法错误的是：

- A、数据保密，既不审核交易双方的身份，也无需数据提供方说明数据来源，不留存审核、交易记录
- B、审核交易双方的身份，无需数据提供方说明数据来源，并留存审核、交易记录
- C、数据提供方说明数据来源，无需审核交易双方的身份，并留存交易记录
- D、数据提供方说明数据来源，审核交易双方的身份，并留存审核、交易记录

答案:ABC"

"Q944、某工厂智能生产线 PLC 控制系统暴露在内网中，安全扫描发现存在未修复的高危漏洞。但生产部门表示""修复需要停线，损失太大""。安全团队应如何处理？

- A、记录风险，上报管理层决策，同时制定隔离+补偿控制方案，在不停线前提下降低风险
- B、接受业务部门意见，暂缓修复

C、强制停线修复

D、仅打补丁即可

答案:A"

"Q945、某零售连锁企业在全国门店安装人脸识别系统，用于识别黑名单顾客。该行为应满足哪些合规要求？

- A、确保该应用场景合法必要
- B、取得被采集人的单独同意
- C、处理超过 10 万人须备案
- D、提供投诉举报渠道

答案:ABCD"

"Q946、《人工智能生成合成内容标识办法》自何时起施行？

- A、2025-03-14
- B、2025-05-01
- C、2025-09-01
- D、2026-01-01

答案:C"

"Q947、某金融机构数据治理发现""交易 IP""数据未实施留存策略，违反监管要求。应？

- A、忽略监管要求
- B、仅存储 3 天
- C、交由网络部门处理
- D、补全日志留存机制，满足法定保存期限

答案:D"

Q948、在交易的性能方面，区块链比中心化系统强。（错误）

"Q949、定密责任人在职权范围内承担有关国家秘密的（ ）工作。

- A、确定
- B、变更

- C、解除
- D、以上都正确

答案:D"

"Q950、访问控制中的强制访问控制（MAC）模型基于（ ）策略。

- A、最小权限策略
- B、最大权限策略
- C、需要达到特定级别的授权策略
- D、基于属性的策略

答案:C"

"Q951、某政务系统监测到异常大量数据查询（超出正常业务阈值）。安全团队应？

- A、核查查询账号权限与业务合理性，防数据爬取或内鬼
- B、忽略，查询属正常操作
- C、仅限制查询次数
- D、关闭查询功能

答案:A"

"Q952、个人对其个人信息的处理享有（ ）。

- A、知情权
- B、决定权
- C、有权限制他人对其个人信息进行处理
- D、有权拒绝他人对其个人信息进行处理

答案:ABCD"

"Q953、根据《评估申报指南（第二版）》和《标准合同备案指南（第二版）》，以下哪些行为属于数据跨境传输行为？

- A、数据处理者将在国内运营过程中收集和产生的数据传送到国外服务器
- B、数据处理者将其在境内收集的数据存储在本地，仅允许国内机构查询和下载
- C、境外的机构可以查询、调取在境内收集和存储的

数据

D、在境外分析、评估境内自然人的行为数据，以提供更好的服务给境内自然人

答案:ACD"

"Q954、假设您接到一通电话，对方自称是您的银行客服，告诉您有人在试图从您的账户中转出大笔资金，要求您立即通过电话或短信提供个人信息或验证码。以下哪些选项是正确的？

- A、这通电话可能是一起电信诈骗
- B、如果您提供个人信息或验证码，您的账户可能会被黑客攻击者控制
- C、银行客服部门通常会在电话中要求客户提供个人信息或验证码
- D、如果您不提供信息或验证码，您的账户将会被冻结或关闭
- E、如果您怀疑这是一起电信诈骗，最好的做法是不要提供任何个人信息或验证码，并立即联系银行客服部门以确认该电话是否真实

答案:ABE"

"Q955、某企业希望在代码提交时自动阻止开发者提交包含身份证号样例和真实手机号的测试数据。最合适的控制点是（ ）。

- A、代码仓库预提交钩子或流水线敏感信息扫描
- B、上线后一周回看日志
- C、人工口头提醒即可
- D、只依靠员工自觉

答案:A"

"Q956、国家支持开展数据安全知识宣传普及，下列说法正确的是：

- A、只有企业参与数据安全保护工作
- B、只有企业、科研机构参与数据安全保护工作
- C、只有企业、科研机构、有关部门参与数据安全保护工作

D、有关部门、行业组织、科研机构、企业、个人等共同参与数据安全保护工作

答案:D"

"Q957、根据 GB/T 39204-2022《信息安全技术 关键信息基础设施安全保护要求》，关键信息基础设施从业人员每人每年网络安全教育培训时长不得少于（ ）。

A、10 学时

B、20 学时

C、30 学时

D、40 学时

答案:C"

"Q958、某企业数据库审计系统仅记录成功登录，未记录高危 SQL 操作。应？

A、扩展审计策略，覆盖 DDL/DCL、批量删除、越权查询等高危操作

B、仅记录登录即可

C、关闭审计

D、仅开发可见

答案:A"

"Q959、国家保护个人、组织与数据有关的权益，鼓励数据依法合理有效利用，保障数据依法有序自由流动，促进以（ ）为关键要素的数字经济发展。

A、数据

B、信息

C、创新能力

D、硬核科技

答案:A"

"Q960、关于修订后《网络安全法》的处罚责任主体，以下说法正确的是？

A、仅处罚机构，不处罚个人

B、仅处罚个人，不处罚机构

C、同时对违法机构和直接负责的主管人员、直接责任人员予以处罚

D、仅在造成实际损失时才处罚

答案:C"

Q961、窃取或者以其他非法方式获取数据，开展数据处理活动排除、限制竞争，或者损害个人、组织合法权益的，依照有关法律、行政法规的规定处罚。（正确）

"Q962、最小特权管理的原则是（ ）。

A、每个用户都拥有系统中的最大权限

B、每个用户只拥有完成任务所必要的权限集

C、特权分配应按需使用

D、特权拥有者可以随意使用权限

答案:B"

"Q963、车载系统中的黑客攻击是指什么？

A、对车辆进行物理破坏

B、对车辆进行远程控制

C、对车辆进行常规维护

D、对车辆进行装饰和改装

答案:B"

"Q964、根据《中华人民共和国网络安全法》的规定，关键信息基础设施的运营者应当（ ）。

A、定期对从业人员进行网络安全教育、技术培训和技能考核

B、对重要系统和数据库进行容灾备份

C、制定网络安全事件应急预案，并定期进行演练

D、设置专门安全管理机构和安全管理负责人，并对该负责人和关键岗位的人员进行安全背景审查

答案:ABCD"

"Q965、对于数据安全防护，访问控制措施是一个基础的防护手段，以下哪些可以被认为是访问控制措施？（ ）？

- A、基于五元组的访问控制
- B、基于时间的访问控制
- C、基于角色的访问控制
- D、基于物理安全的访问控制

答案:ABCD"

"Q966、根据《征信业管理条例》的规定，个人信息主体有权每年（ ）免费获取本人的信用报告。

- A、一次
- B、两次
- C、三次
- D、四次

答案:B"

"Q967、以下属于《中华人民共和国民法典》规定的个人信息的是：

- A、住址
- B、电话号码
- C、电子邮箱
- D、健康信息

答案:ABCD"

"Q968、根据《征信业管理条例》的规定，征信机构对个人不良信息的保存期限，自不良行为或者事件终止之日起为（ ）年；超过（ ）年的，应当予以删除。

- A、2
- B、3
- C、4
- D、5

答案:D"

"Q969、大数据应用所采用的技术有：（ ）？

- A、大规模存储与大规模计算
- B、数据的清洗与分析处理

C、结合数学建模与人工智能

D、都正确

答案:D"

Q970、对于用户明确拒绝使用、关闭或退出的特定业务功能，App 可以再次询问用户是否打开该业务功能或相关系统权限。（错误）

"Q971、在中国境外处理中国境内自然人个人信息的活动的场景，哪个不适用《中华人民共和国个人信息保护法》？

- A、以向境内自然人提供产品或者服务为目的
- B、以向境外自然人提供产品或者服务为目的
- C、大规模分析、评估境内自然人的行为
- D、法律与行政法规规定的其他情形

答案:B"

"Q972、侧信道攻击是以下哪种攻击的典型示例？

- A、密码猜测/暴力破解攻击
- B、社会工程学攻击
- C、XSS 攻击
- D、时序分析攻击

答案:D"

"Q973、根据《数据安全法》，各地区、各部门应当按照国家数据分类分级保护制度，确定本地区、本部门以及相关行业、领域的（ ），并对其实施重点保护。

- A、个人信息主体
- B、重要数据的具体目录
- C、数据安全负责人
- D、数据处理技术方案

答案:B"

Q974、一般来说，对称加密比非对称加密更快。（正确）

"Q975、云服务商的""责任共担模型""中，客户必须

自行管理？

- A、物理服务器安全
- B、数据分级定义与应用
- C、网络基础设施更新
- D、数据中心访问日志

答案:B"

"Q976、区块链信息服务提供者应（ ）。

- A、对存储在链上和链下的信息进行溯源
- B、使用数字签名来标识交易发送主体的身份，识别交易发送账号
- C、对交易信息进行记录，包括交易发送账号、接收账号、交易生成的时间戳等
- D、提供查询交易信息和交易回执的接口

答案:ABCD"

"Q977、（ ）等部门在各自职责范围内负责相关网络安全保护和监督管理工作。

- A、国务院公安
- B、国家保密行政管理
- C、国家商业管理中心
- D、国家密码管理

答案:ABD"

Q978、隐私政策中可以出现多个业务功能对应一类个人信息的情况。（正确）

"Q979、基于 OTP 的攻击是指攻击者如何绕过 MFA 的？

- A、攻击者发送大量垃圾邮件给用户
- B、攻击者窃取包含 OTP 的介质或实时中间人代理截获 OTP
- C、攻击者冒充受害者请求重置 MFA
- D、攻击者利用恶意软件感染用户设备

答案:B"

"Q980、下列选项中，不属于敏感个人信息的是（ ）

- A、特定职业（外卖员、快递员等）用于实现服务履约场景下在一定期间内因为所处具体地理位置、活动地点和活动轨迹的移动变化而形成的连续轨迹信息
- B、对自然人的物理、生物或行为特征进行技术处理得到的、能够单独或者与其他信息结合识别该自然人身份的个人信息
- C、与个人的银行、证券等账户和账户资金交易相关的个人信息
- D、与个人信仰的宗教、宗教组织、宗教活动相关的个人信息

答案:A"

"Q981、以下哪个方面不是数据合规审查中需要关注的要点？

- A、数据来源的合规性
- B、数据使用的合规性
- C、数据跨境的合规性
- D、数据价值的评估

答案:D"

"Q982、在访问控制中，以下哪个概念描述了对特定资源进行访问操作时所需的身份验证信息？

- A、认证
- B、授权
- C、验证
- D、鉴别

答案:A"

"Q983、2015 年，以色列防务公司与美国斯坦福大学成功利用手机电量消耗获取位置信息，这种攻击方式属于（ ）？

- A、钓鱼攻击
- B、中间人攻击
- C、操纵攻击

D、边信道攻击

答案:D"

"Q984、某企业数据资产盘点发现测试环境含生产数据副本。治理要求应？

A、允许复用

B、交由开发决定

C、严格生产与测试数据隔离，实施脱敏或生成合成数据

D、仅加密即可

答案:C"

"Q985、某企业数据安全团队在检查中发现，数据库服务器操作系统已有 2 年未升级，且安全补丁缺失 19 个（含 4 个高危漏洞）。处置优先级应如何确定？

A、低优先级，系统运行正常即可

B、高危漏洞须立即制定修复计划，评估业务影响后最短时间内完成修复

C、等待下次年度维护窗口处理

D、由业务部门决定是否修复

答案:B"

"Q986、假设您在 QQ 上收到了一条私信，内容是老朋友邀请您参加调查可以赢取 100 元礼品卡，并附有链接。以下哪些选项是正确的？

A、不用怀疑，这个好友加了很多年了，他肯定不会骗我，立即回答问题以获取礼品卡

B、QQ 和他聊天确认身份后再回答问题也不迟

C、这条私信可能是一条社交软件钓鱼消息

D、如果您点击该链接并回答问题，您的账户可能会被黑客攻击者控制

E、电话或用其他聊天软件提醒 QQ 好友他的 QQ 可能被盗了

答案:CDE"

Q987、大数据发展应当全面实施国家大数据战略，坚持依法管理、保障安全原则。（正确）

Q988、SDK 收集使用个人信息和申请敏感权限应遵循合理、最小、必要原则。作为个人信息共同控制者或独立控制者收集使用用户个人信息的 SDK 时，只需与用户签署所使用的 APP 协议，无需向用户取得 SDK 单独授权。（错误）

"Q989、身份信息在传输过程中是否可以被恶意篡改？

A、可以

B、不可以

C、取决于网络环境

D、取决于身份客体权限

答案:A"

"Q990、某企业计划向合作伙伴公开部分业务数据，数据安全工程师首先应判断（ ）。

A、该数据是否属于可公开范围以及是否需要脱敏处理

B、合作伙伴办公地点是否靠近地铁

C、合作伙伴员工人数

D、合作伙伴网站配色

答案:A"

"Q991、某企业数据资产识别发现某数据湖含大量未分类原始数据。治理优先级应为？

A、先实施基础分类分级与访问控制，再逐步精细化治理

B、直接删除未分类数据

C、仅关注结构化数据

D、交由 AI 全自动处理

答案:A"

Q992、区块链信息服务提供者应当对不同类型的节点和节点管理人员设置不同权限，明确不同权限所对应的节点操作内容。记录每次对节点读写和访问、节点管理人员身份变更和管理权限变更等操作。（正确）

"Q993、下列哪项最适合作为数据资产地图的高级视图内容？

- A、跨系统数据依赖关系与下游影响分析
- B、企业周年庆活动计划
- C、办公楼消防演练照片
- D、员工停车位编号

答案:A"

"Q994、维护数据安全，应当坚持总体国家安全观，建立健全（ ），提高数据安全保障能力。

- A、信息安全治理体系
- B、数据安全治理体系
- C、信息安全保障体系
- D、数据安全保障体系

答案:B"

"Q995、保护工作部门应当建（ ）。

- A、建立健全本行业、本领域的关键信息基础设施网络安全监测预警制度
- B、及时掌握本行业、本领域关键信息基础设施运行状况、安全态势
- C、确认部门购买了指定安全厂商的服务和产品
- D、预警通报网络安全威胁和隐患，指导做好安全防范工作

答案:ABD"

"Q996、存储介质的清除或销毁指通过采用合理的方式对计算机介质进行信息清除或销毁处理，主要包括以下哪些内容？

- A、识别要清除或销毁的介质
- B、确定存储介质处理方法和流程
- C、处理方案审批
- D、存储介质处理和记录

答案:ABCD"

"Q997、本次《网络安全法》修订（2025年）的重

要意义体现在以下哪些方面？

- A、首次将人工智能纳入网络安全法律体系
- B、明确了党对网络安全工作的领导地位
- C、全面提升了法律责任的惩处力度
- D、与《数据安全法》《个人信息保护法》形成系统衔接

答案:ABCD"

"Q998、访问控制的主体是指什么？

- A、一个提出请求或要求的实体，是动作的发起者
- B、接受其他实体访问的被动实体
- C、主动发起访问请求的实体
- D、被动接受访问请求的实体

答案:A"

"Q999、修订后的《网络安全法》新增规定，网络运营者处理个人信息应当遵守本法和哪两部法律的规定？

- A、《民法典》和《数据安全法》
- B、《民法典》和《个人信息保护法》
- C、《数据安全法》和《个人信息保护法》
- D、《刑法》和《个人信息保护法》

答案:B"

"Q1000、访问控制产品的技术指标中，以下哪个指标对性能影响最大？

- A、支持的访问控制策略规则类型
- B、访问控制规则最大数量
- C、访问控制规则检查速度
- D、产品自身安全和质量保证级别

答案:C"

"Q1001、工业和信息化领域数据处理者应当对数据处理活动负安全主体责任，对各类数据实行分级防护，不同级别数据同时被处理且难以分别采取保护措施，应当按照其中级别最高的要求实施保护，

确保数据持续处于有效保护和合法利用的状态。下列关于数据处理者的做法正确的是（）。

A、建立数据全生命周期安全管理制度，针对不同级别数据，制定数据收集、存储、使用、加工、传输、提供、公开等环节的具体分级防护要求和操作规程

B、根据需要配备数据安全管理人员，统筹负责数据处理活动的安全监督管理，协助行业监管部门开展工作

C、根据应对数据安全事件的需要，制定应急预案，并开展应急演练

D、定期对从业人员开展数据安全教育和培训

答案:ABCD"

"Q1002、《关键信息基础设施安全保护条例》于（）正式施行。

A、2020-09-01

B、2021-09-01

C、2021-06-01

D、2021-10-01

答案:B"

"Q1003、单点登录（SSO）的优点是什么？

A、用户只需记住一个用户名和密码，即可访问多个应用程序

B、提高了数据安全性

C、减少了 IT 管理工作量

D、提高了用户体验

E、减少了成本

答案:ACDE"

"Q1004、网络运营者应当加强对其用户发布的信息的管理，发现法律、行政法规禁止发布或者传输的信息的，应当立即停止传输该信息，采取（）等处置措施，防止信息扩散，保存有关记录，并向有关主管部门报告。

A、更改

B、撤回

C、删除

D、消除

答案:C"

Q1005、根据《促进和规范数据跨境流动规定》，自上年 1 月 1 日起累计向境外提供 100 万人以上个人信息（不含敏感个人信息）的数据处理者，应当申报数据出境安全评估。（正确）

"Q1006、什么是身份攻击面映射？

A、分析组织的身份信息以发现弱点

B、监测并响应可疑身份活动

C、清除账户接管攻击的弱点

D、定位恶意软件感染的账户

答案:A"

"Q1007、以下哪个是访问控制中常见的强化措施？

A、双因素认证

B、防火墙配置

C、密码加密

D、网络监控

答案:A"

"Q1008、LoRaWAN 网络中的 Join 请求是指什么？

A、终端设备请求加入 LoRaWAN 网络

B、网关请求与网络服务器建立连接

C、应用服务器请求接收终端设备的数据

D、网络服务器请求接收网关的数据

答案:A"

Q1009、单位只需做一次数据分类分级就可以了，以后就不需要再做了。（错误）

"Q1010、某企业拟实施数据分类分级自动化打标，但规则库未与业务语义对齐。应？

A、仅依赖正则表达式

B、放弃自动化

C、交由 IT 手动打标

D、引入业务专家标注样本，训练/优化机器学习分类模型

答案:D"

"Q1011、以下哪项属于个人信息影响的评估场景？

A、处理敏感个人信息

B、利用个人信息进行自动化决策

C、委托处理个人信息、向第三方提供个人信息、公开个人信息

D、向境外提供个人信息

答案:ABCD"

Q1012、国家鼓励开发网络数据安全保护和利用技术，促进公共数据资源开放，推动技术创新和经济社会发展。（正确）

"Q1013、关于数字证书有效期，以下说法正确的是？

A、所有数字证书的有效期均为 1 年

B、根 CA 证书通常有效期最长，可达 20 年以上

C、SSL 证书的有效期固定为 2 年

D、代码签名证书有效期不超过 1 年

答案:B"

Q1014、原始数据，是指初次产生或源头收集的、未经加工处理的数据。（正确）

Q1015、修订后的《网络安全法》新增条款，首次在网络安全基本法律层面系统性回应了人工智能治理需求。（正确）

"Q1016、在 ZigBee MAC 安全中，MAC 安全帧不包括（ ）。

A、报头

B、报尾

C、负载

D、帧序列号

答案:C"

"Q1017、下列说法中正确的是。

A、定级/备案是信息安全等级保护的首要环节

B、等级测评是发现安全保护差距的重要手段

C、建设整改是等级保护工作落实的关键

D、监督检查是使信息系统保护能力不断提高的保障

答案:ABCD"

"Q1018、关于 “安全水印” 和 “强稳健水印”，下列说法正确的是（ ）

A、强稳健水印算法需要抵抗实际应用场景中存在的、非恶意的信号处理操作。

B、安全的水印算法需要抵抗蓄意的、恶意的攻击，例如指纹算法需抵抗共谋攻击。

C、安全的水印算法一定是稳健的水印算法。

D、稳健的水印算法一定是安全的水印算法。

答案:ABC"

"Q1019、根据《密码法》的规定，国家密码管理部门对采用（ ）技术从事电子政务电子认证服务的机构进行认定，会同有关部门负责政务活动中使用电子签名、数据电文的管理。

A、核心密码

B、普通密码

C、商用密码

D、混合密码

答案:C"

"Q1020、身份认证的目的是确认通信过程中另一端的个体是谁，这个目的主要是为了保证什么？

A、保证通信的安全性

B、保证通信的可靠性

C、保证通信的速度

D、保证通信的速率

答案:A"

Q1021、UNIX/Linux 系统中，使用 9 比特位模式来标识文件的访问控制权限信息。（正确）

"Q1022、某政务服务大厅计划用人脸识别替代身份证核验，以提高办事效率。该应用场景须重点核查哪些合规要点？

- A、是否有法律授权或行政许可依据
- B、是否提供人工核验作为替代方案
- C、收集的人脸数据是否超过必要范围
- D、是否向公众显著告知

答案:ABCD"

"Q1023、某数据安全产品上线后，未建立配置基线，运维人员可随意修改审计策略。其直接后果可能是（ ）。

- A、审计覆盖范围漂移，导致关键访问行为失管失审
- B、数据库自动加密
- C、用户身份认证自动增强
- D、日志留存时间自动增加

答案:A"

"Q1024、动态数据脱敏一般用在何处？

- A、开发环境
- B、生产环境
- C、备份环境
- D、验证环境

答案:B"

"Q1025、语句 SELECT 'ACCP' FROM DUAL 的执行结果是（ ）。

- A、ACCP
- B、X
- C、编译错

D、提示未选中行

答案:A"

Q1026、匿名化，是指个人信息经过处理无法识别特定自然人且不能复原的过程。将个人信息匿名化处理后的信息，不是《个人信息保护法》规定的个人信息。（正确）

"Q1027、某企业数据治理委员会在审查时发现，数据安全风险矩阵中存在大量""责任不清""的数据集。整改优先项应是？

- A、为每个数据集明确数据 Owner（业务负责人）和 Data Steward（数据管家），建立责任到人的闭环机制
- B、将所有数据归 IT 部门管理
- C、外包给第三方管理
- D、删除无责任人的数据集

答案:A"

"Q1028、下列有关网络数据安全和相关监督管理工作的说法中，正确的是（ ）

- A、国家安全部门负责统筹协调网络数据安全和相关监督管理工作。
- B、有关主管部门发现网络数据处理者的网络数据处理活动存在较大安全风险的，可以按照规定的权限和程序要求网络数据处理者修改平台规则、完善技术措施，但不得要求其暂停相关服务。
- C、有关主管部门及其工作人员对在履行职责中知悉的个人隐私、个人信息、商业秘密、保密商务信息等网络数据应当依法予以保密，不得泄露或者非法向他人提供。
- D、网络平台服务提供者应当通过平台规则或者合同等明确接入其平台的第三方产品和服务提供者的网络数据安全保护义务，督促第三方产品和服务提供者加强网络数据安全保护。预装应用程序的智能终端等设备生产者，不适用该规定。

答案:C"

"Q1029、某政务数据共享平台要求各部门提交数据分级清单，但某部门仅提交表名无字段说明。审核

应？

- A、直接通过
- B、退回补充字段级分类分级说明
- C、按部门名称定级
- D、默认全部为公开数据

答案:B"

"Q1030、某数据脱敏工具上线前测试发现：手机号脱敏后仍可通过日志中保留的原始值还原。该问题说明（ ）。"

- A、脱敏效果验证不充分，日志与脱敏输出需一并纳入测试范围
- B、脱敏已经足够
- C、日志不属于测试范围
- D、只需增加前端掩码即可

答案:A"

"Q1031、因使用自动化采集技术等无法避免采集到非必要个人信息或者未依法取得个人同意的个人信息，以及个人注销账号的，网络数据处理者应当采取的措施是（ ）"

- A、向主管部门报告后再进行收集
- B、删除个人信息或者进行匿名化处理
- C、采集的同时继续完善相关技术措施
- D、根据自身业务的实际情况决定是否继续收集信息

答案:B"

"Q1032、某企业安全评估发现，其数据备份全部在同一城市的同一机房（不同楼栋），未实现异地灾备。风险评估结论应为？"

- A、存在城市级灾难下数据永久丢失的单点风险，须补充异地灾备方案
- B、同一机房不同楼栋已满足灾备要求
- C、灾备要求由企业自主决定
- D、现状合理，成本过高

答案:A"

"Q1033、以下哪些属于敏感个人信息？"

- A、个人基因信息
- B、个人声纹信息
- C、不满十四周岁未成年人的个人信息
- D、公开招聘岗位说明书

答案:ABC"

"Q1034、某企业恢复演练显示，数据库虽能恢复，但上层应用无法接入恢复后的数据。该现象说明（ ）。"

- A、恢复验证应覆盖业务可用性而非仅数据文件可恢复
- B、只要数据在就算恢复成功
- C、应用可后续手工适配
- D、无需再演练

答案:A"

"Q1035、对于用户删除账号和数据，以下哪种做法是不正确的？"

- A、提供用户删除账号和数据的功能
- B、删除用户数据的备份和镜像
- C、限制用户删除账号和数据的时间和方式
- D、在用户提交删除请求后及时处理并回复用户

答案:C"

Q1036、考虑到操作方便性和人员复用性，用户角色和权限不一定到最小权限。（错误）

Q1037、在 Linux 中，`ls -l 文件名` 可用于查看文件权限信息。（正确）

Q1038、关键信息基础设施保护和网络安全等级保护各自独立，互不相关。（错误）

"Q1039、某政务系统遭数据篡改，因未启用区块链存证或哈希校验。应？"

- A、仅依赖数据库日志

B、忽略篡改风险

C、对关键业务数据实施哈希上链或定期完整性校验

D、仅前端提示

答案:C"

"Q1040、模 13 的最小本原元为 ()。

A、1

B、2

C、3

D、5

答案:B"

"Q1041、违反本法规定处理个人信息，或者处理个人信息未履行本法规定的个人信息保护义务的，由履行个人信息保护职责的部门责令改正，给予警告，没收违法所得，对违法处理个人信息的应用程序，责令暂停或者终止提供服务；拒不改正的，并处 () 罚款。

A、一百万元以下

B、一百万元以上

C、两百万元以上

D、任意金额

答案:A"

"Q1042、对客体的侵害外在表现为对定级对象的破坏，业务信息安全和系统服务安全受到破坏后，可能产生以下哪些侵害后果？

A、影响行使工作职能

B、导致业务能力下降

C、引起法律纠纷

D、导致财产损失

E、造成社会不良影响

答案:ABCDE"

"Q1043、零信任身份验证的核心是什么？

A、基于用户行为的持续访问控制

B、基于角色的静态访问控制

C、基于设备状态的访问控制

D、基于位置的访问控制

E、基于时间的访问控制

答案:ACDE"

"Q1044、某金融机构数据资产盘点发现""交易流水""数据无保留策略，无限期增长。应？

A、无限期存储

B、直接删除历史数据

C、交由云服务商决定

D、制定数据保留与清理策略，符合合规与成本要求

答案:D"

Q1045、不同国家和地区主要通过双边或多边区域性合作实现对数据跨境的协调管理，其中最为知名影响范围最广的便是欧盟主导推进的数据跨境治理体系，致力于在数据跨境传输过程中为个人数据主体提供充足保护。(正确)

"Q1046、某数据表同时被市场、客服、风控三个部门使用，但没有明确责任主体。治理整改的优先措施应是 ()。

A、默认由 IT 部门统一负责

B、删除该数据表

C、明确数据 Owner 和 Data Steward 职责

D、仅限制客服部门访问

答案:C"

Q1047、信息提供者向征信机构提供未公开的个人不良信息，可以不用事先告知信息主体本人。(错误)

"Q1048、《中华人民共和国数据安全法》已由中华人民共和国第十三届全国人民代表大会常务委员会第二十九次会议于 () 通过。

A、2020-06-10

B、2020-06-11

C、2021-06-10

D、2021-06-11

答案:C"

Q1049、任何情形下，重要数据的处理者提供、委托处理、共同处理重要数据前，都应当进行风险评估。（错误）

"Q1050、下面哪种情况可以被视为社会工程学攻击的目标？

- A、数据中心的物理安全
- B、强密码设置
- C、缺乏安全意识的员工
- D、服务器硬件升级

答案:C"

"Q1051、BLP 模型主要关注保证数据的哪个方面？

- A、完整性
- B、可用性
- C、机密性
- D、可审计性

答案:C"

"Q1052、根据《人脸识别技术应用安全管理办法》，以下哪类主体在使用人脸识别技术时享有特别豁免？

- A、商业零售企业
- B、国家机关依法履行法定职责
- C、互联网平台企业
- D、物业管理公司

答案:B"

"Q1053、根据《生成式人工智能服务管理暂行办法》，生成式人工智能服务提供者不得生成哪类内容？

- A、煽动颠覆国家政权的内容
- B、含有虚假有害信息的内容

C、侵犯他人合法权益的内容

D、合法的文学创作内容

答案:ABC"

"Q1054、使用智能卡身份验证时，智能卡中可能存储的信息有哪些？

- A、用户名和密码
- B、数字证书和私钥
- C、指纹和面部识别信息
- D、身份证号码和地址信息
- E、银行卡信息和密码

答案:BC"

"Q1055、某金融机构核心数据库未启用透明加密（TDE），且备份为明文。应？

- A、仅依赖网络防火墙
- B、仅加密备份
- C、忽略，内网安全
- D、启用 TDE 加密存储，对备份介质实施加密与访问控制

答案:D"

Q1056、互联网信息服务终端软件捆绑其他软件的，应当以显著的方式提示用户，由用户主动选择是否安装或者使用，并提供独立的卸载或者关闭方式，不得附加不合理条件。（正确）

"Q1057、《数据安全法》中的""数据""，不仅包括电子形式，也包括以其他方式记录的信息。即无论是（ ）、或是（ ）的数据都需要受到《数据安全法》的管辖，范围相当宽泛。

- A、涉密，非涉密
- B、电子形式，纸质形式
- C、国有，非国有
- D、商业，非商业

答案:B"

"Q1058、在中华人民共和国境外开展数据处理活动，损害中华人民共和国国家安全、() 或者公民、组织合法权益的，()。

- A、公共利益，依法追究法律责任
- B、国家利益，依法追究法律责任
- C、公共利益，不能追究法律责任
- D、国家利益，不能追究法律责任

答案:A"

"Q1059、业务连续性测试中，如果只测试主站恢复，不测试上下游依赖系统联动，主要缺陷是()。

- A、无法证明完整业务链的可恢复性
- B、主站恢复即可代表全部恢复
- C、依赖系统不属于数据安全范围
- D、只会影响界面样式

答案:A"

Q1060、政务数据是指政府部门及法律法规授权具有行政职能的组织在履行职责过程中生成或获取的数据。(正确)

Q1061、PKI 公钥基础设施是利用公钥密码理论和技术来实现信息安全服务的具有通用性的安全基础设施。(正确)

Q1062、大数据利用会带来新的垄断。(正确)

"Q1063、以下关于信息系统安全建设整改工作方法说法中正确的是。

- A、突出重要系统，涉及所有等级，试点示范，行业推广，国家强制执行
- B、利用信息安全等级保护综合工作平台使等级保护工作常态化
- C、管理制度建设和技术措施建设同步或分步实施
- D、加固改造缺什么补什么，也可以进行总体安全建设整改规划

答案:BCD"

"Q1064、某系统需跨网络边界传输敏感个人信息，下列哪项是最合理的方案组合？

- A、明文传输 + 事后补日志
- B、加密传输 + 身份认证 + 完整性校验 + 审计记录
- C、只做访问白名单
- D、只做数据库备份

答案:B"

"Q1065、根据《关键信息基础设施安全保护条例》，未经国家网信部门、国务院公安部门批准或者保护工作部门、运营者授权，任何个人和组织不得对关键信息基础设施实施()。

- A、日常的网络访问行为
- B、安全规则的合规咨询
- C、漏洞探测、渗透性测试等可能影响或者危害关键信息基础设施安全的活动
- D、已公开的网络性能测试

答案:C"

"Q1066、某互联网 APP 遭 DDoS 攻击，业务中断 2 小时。应急响应团队应？

- A、仅联系运营商扩容
- B、启用流量清洗，启动业务降级预案，事后复盘防护策略
- C、关闭所有服务器
- D、起诉攻击者

答案:B"

"Q1067、从职业标准视角看，数据安全工程技术人员在高级阶段最核心的特征是()。

- A、只会执行既定操作
- B、能围绕数据资产、工程建设、运营监测和评估整改形成体系化能力
- C、只负责法律条文记忆

D、只负责购买安全产品

答案:B"

"Q1068、电信业务经营者、互联网信息服务提供者应当采取以下哪些措施防止用户个人信息泄露、毁损、篡改或者丢失？

A、确定各部门、岗位和分支机构的用户个人信息安全管理责任

B、建立用户个人信息收集、使用及其相关活动的 workflows 和安全管理制

C、妥善保管记录用户个人信息的纸介质、光介质、电磁介质等载体，并采取相应的安全储存措施

D、记录对用户个人信息进行操作的人员、时间、地点、事项等信息

答案:ABCD"

"Q1069、关于侧信道攻击（Side-channel Attack），以下说法正确的是：（）

A、可通过电磁泄漏推测私钥

B、只适用于对称加密算法

C、常与时间、功耗等物理行为相关

D、可通过缓存访问模式推测密钥

答案:ACD"

Q1070、SELinux 是一种专门用于 Windows 操作系统的安全增强系统。（错误）

Q1071、钓鱼攻击是一种常见的社会工程学攻击形式。（正确）

"Q1072、某企业安全架构未覆盖云原生环境，容器镜像含高危漏洞。应？

A、仅扫描宿主机

B、实施镜像安全扫描、运行时防护与微服务零信任策略

C、禁用容器技术

D、仅依赖云平台

答案:B"

Q1073、传输层安全协议（TLS）仅依赖对称加密保证数据传输安全。（错误）

"Q1074、根据《个人信息保护法》，无需取得个人同意即可处理个人信息的法定情形中，以下哪项不属于？

A、为履行法定职责或者法定义务所必需

B、为应对突发公共卫生事件所必需

C、为提升企业商业竞争力所必需

D、依照本法规定在合理的范围内处理个人自行公开的个人信息

答案:C"

Q1075、DDOS 是指分布式拒绝服务攻击。（正确）

"Q1076、多因素认证（MFA）可以包括（）。

A、密码

B、指纹

C、短信验证码

D、人脸信息

答案:ABCD"

"Q1077、下列属于能够保障数据安全的措施有哪些？（）

A、加密数据传输和存储

B、强化访问控制

C、定期备份和恢复

D、实施网络安全措施

答案:ABCD"

Q1078、修订后《网络安全法》对网络运营者的罚款上限从五十万元提升至五百万元。（错误）

"Q1079、《人工智能生成合成内容标识办法》由哪些部门联合发布？

A、国家网信办、工业和信息化部

B、国家网信办、工业和信息化部、公安部、国家广播电视总局

C、工业和信息化部、公安部、市场监督管理总局

D、国家网信办、公安部、最高人民法院

答案:B"

"Q1080、根据《网络安全法》的规定，（ ）应当为公安机关、国家安全机关依法维护国家安全和侦查犯罪的活动提供技术支持和协助。

A、电信运营商

B、科研机构

C、外包服务商

D、网络运营者

答案:D"

Q1081、传统方法的数据计算模式是以数据为中心的。（错误）

"Q1082、ZigBee 采用了 CSMA-CA（ ），同时为需要固定带宽的通信业务预留了专用时隙，避免了发送数据时的竞争和冲突。

A、自愈功能

B、自组织功能

C、碰撞避免机制

D、数据传输机制

答案:C"

"Q1083、访问者可以是下列哪些？

A、用户

B、进程

C、应用程序

D、文件

答案:ABC"

"Q1084、某企业数据安全培训流于形式，员工仍常犯口令/钓鱼错误。应？

A、仅发通知

B、开展实战化演练、情景模拟与考核挂钩，提升意识转化率

C、仅年度一次培训

D、交由 HR 处理

答案:B"

"Q1085、某企业在设计跨部门数据共享方案时，希望既满足业务流转效率，又降低泄露风险。下列哪种思路最优？

A、按用户角色和场景设计差异化访问控制与审计策略

B、默认允许所有内部人员读取全部数据

C、完全禁止共享

D、只依赖口头审批

答案:A"

"Q1086、在访问控制中，RBAC 模型中的权限继承是指（ ）。

A、用户继承角色的权限

B、角色继承用户的权限

C、角色继承其他角色的权限

D、用户继承其他用户的权限

答案:C"

"Q1087、根据《个人信息保护法》，国家网信部门统筹协调有关部门推进以下哪些工作？

A、制定个人信息保护具体规则、标准

B、推进个人信息保护社会化服务体系建设

C、支持研究开发和推广应用安全、方便的个人信息保护技术

D、制定个人信息犯罪的刑事量刑标准

答案:ABC"

"Q1088、某企业数据资产识别发现某 API 接口返回字段过多，含冗余敏感信息。应？

A、实施 API 数据最小化返回策略，按需裁剪

B、维持现状

C、关闭接口

D、仅前端隐藏

答案:A"

"Q1089、涉密人员离岗、离职前，应当将所保管和使用的国家秘密载体全部清退，并（ ）。

A、登记销毁

B、订卷归档

C、办理移交手续

D、不一定办理移交手续

答案:C"

"Q1090、从安全角度看，下面哪项是网络购物中不好的习惯（ ）？

A、计算机上的系统不进行升级

B、为计算机安装病毒查杀和安全加固方面的软件

C、设置只能下载和安装经过签名的安全的 ActiveX 控件

D、浏览器时设置不在计算机中保留网络历史记录和表单数据

答案:A"

"Q1091、国家对公共通信和信息服务、能源、交通、水利、金融、公共服务、电子政务等重要行业和领域，以及其他一旦遭到破坏、丧失功能或者数据泄露，可能严重危害（ ）的关键信息基础设施，在网络安全等级保护制度的基础上，实行重点保护。

A、公共利益

B、国计民生

C、国家安全

D、个人数据完整性

答案:ABC"

Q1092、在开展数据资产评估时，需要考虑数据资产的信息属性、法律属性，以及价值属性。（正确）

Q1093、依据《网络数据安全条例》，数据处理者在采用自动化工具访问、收集数据时，应当评估

对网络服务的性能、功能带来的影响，不得干扰网络服务的正常功能。（正确）

"Q1094、在关键信息基础设施安全保护工作中，（ ）应当根据保护工作部门的需要，及时提供技术支持和协助。

A、网络上公开的安全论坛

B、安全工具开发公司

C、学习安全知识的学员

D、国家网信部门

答案:D"

"Q1095、互联网领域为何需要数据脱敏？

A、提升用户体验

B、增加数据流量

C、保护用户隐私

D、降低运营成本

答案:C"

"Q1096、数据资产标签治理中，“法律义务标签”的主要作用是（ ）。

A、标识该数据是否存在特定留存、审批、出境或保密要求

B、标识办公区是否有访客

C、区分数据库品牌

D、物理机房网络带宽配置

答案:A"

"Q1097、访问控制的核心功能是什么？

A、仅授权用户身份

B、对主体访问客体的请求进行授权与控制

C、仅监测网络流量

D、仅进行身份认证

答案:B"

Q1098、国务院根据实际需要，可以制定公共数据采

集、归集、存储、共享、开放、应用等活动的具体管理办法。（正确）

"Q1099、如果只对主机地址为 172.16.30.55 进行访问列表的设置，下面各项正确的有？

- A、172.16.30.55 0.0.0.255
- B、172.16.30.55 0.0.0.0
- C、any 172.16.30.55
- D、host 172.16.30.55

答案:BD"

Q1100、我国引导多种类型的数据交易场所，包括国家级数据交易场所、区域性数据交易场所，以及行业性数据交易场所。（正确）

"Q1101、移动互联网应用在申请系统权限时，应当遵循什么原则？

- A、一次性申请全部权限，减少打扰
- B、按业务功能最小必要原则申请权限
- C、优先申请敏感权限，后续再解释
- D、只要写入隐私政策即可随时调用权限

答案:B"

"Q1102、某企业长期不对低风险事件做复盘，理由是“影响不大”。这种做法的主要隐患是（ ）。

- A、小问题可能持续累积并演化为系统性风险
- B、可以显著减少工作量且无副作用
- C、只影响培训计划
- D、不会影响制度改进

答案:A"

"Q1103、在车载系统中，CAN 总线是什么？

- A、一种汽车品牌的总线标准
- B、一种车载音响系统
- C、一种用于车辆通信的总线标准
- D、一种驾驶员的控制界面

答案:C"

"Q1104、以下哪种情形，数据处理者无需向省级网信部门备案标准合同？

- A、处理不满 100 人个人信息的小微企业内部数据共享
- B、符合豁免情形的跨境合同履行场景
- C、向境外提供 10 名员工信息用于出差安排
- D、以上均无需备案

答案:D"

"Q1105、在网络环境下，身份是用来区别于其他个体的一种标识，必须具有什么特点？

- A、唯一性
- B、可复制性
- C、可变性
- D、随机性

答案:A"

Q1106、增量备份只备份自上次完全备份以来发生变化的数据。（正确）

"Q1107、某政务系统应急演练中，备份数据恢复耗时超过 RTO（恢复时间目标）。说明？

- A、演练成功
- B、备份策略或恢复流程需优化，未达业务连续性要求
- C、无需改进
- D、仅影响非核心业务

答案:B"

Q1108、限制性规范，即一国家/地区的数据出境规则，根据当地法律体系、历史传统、风险偏好的区别而呈现出不同严苛程度。目前，尚无国家完全禁止数据出境，或者对数据出境完全不加限制，大部分国家/地区集中分布于中段。（正确）

"Q1109、《数据安全法》规定：在中华人民共和国（ ）开展数据处理活动及其安全监管，适用本法。

在中华人民共和国（ ）开展数据处理活动，损害中华人民共和国国家安全、公共利益或者公民、组织合法权益的，依法追究法律责任。

- A、大陆，全境
- B、境内，境外
- C、国内，国外
- D、国内，全境

答案:B"

"Q1110、数据安全技术实施文档通常应包括哪些内容？

- A、实施步骤与回滚方案
- B、参数配置要求
- C、验收标准
- D、供应商宣传海报

答案:ABC"

"Q1111、 $503 \bmod 31$ 的值为（ ）。

- A、3
- B、7
- C、17
- D、23

答案:B"

Q1112、经过匿名化处理后的个人数据，仍属于个人信息。（错误）

"Q1113、MFA 是什么的缩写？

- A、多因素身份验证（Multi-Factor Authentication）
- B、生物识别身份验证
- C、智能卡身份验证
- D、单点登录

答案:A"

"Q1114、在数据库加密场景中，透明加密（TDE）的优势是？

- A、无需修改应用程序即可实现加密
- B、仅加密数据库查询语句
- C、加密密钥完全由用户手动管理
- D、对数据库性能无任何影响

答案:A"

"Q1115、若企业在出境评估中只关注“数据是否加密”，却忽略了“数据主体权利行使路径”，最可能违反的是（ ）。

- A、对数据主体权益影响的综合评估要求
- B、纯技术性加密要求
- C、办公自动化要求
- D、门禁管理要求

答案:A"

Q1116、最小特权管理的原则是在系统中每个主体都应该具备完成任务所需的最大权限。（错误）

"Q1117、数据跨境合规管控中跨境后的管理阶段包括下列哪些要点？

- A、目的完成后及时删除/销毁数据
- B、如超出目的范围跨境，重新进行合规评估
- C、保障数据主体权利响应通道
- D、开展数据跨境合规审计

答案:ABD"

"Q1118、根据 NIST SP 800-145《NIST Definition of Cloud Computing》，云计算的基本特征包括以下哪些？

- A、按需自服务（On-demand Self-service）
- B、广泛的网络接入（Broad Network Access）
- C、资源池化（Resource Pooling）
- D、快速弹性（Rapid Elasticity）
- E、可计量服务（Measured Service）

答案:ABCDE"

"Q1119、开展数据处理活动，应当遵守法律、法规，尊重社会公德和伦理，遵守商业道德和职业道德，诚实守信，履行数据安全保护义务，承担社会责任，不得危害国家安全、（ ），不得损害个人、组织的合法权益。

- A、公共利益
- B、国家利益
- C、私有企业利益
- D、国有企事业单位利益

答案:A"

"Q1120、《人脸识别技术应用安全管理办法》自何时起施行？

- A、2025-03-01
- B、2025-06-01
- C、2025-09-01
- D、2026-01-01

答案:B"

"Q1121、某企业想在需求分析阶段引入威胁建模，最不适合作为分析对象的是（ ）。

- A、数据采集环节的过度收集风险
- B、数据传输链路的篡改风险
- C、数据共享环节的越权访问风险
- D、终端硬件资产管理配置

答案:D"

"Q1122、大数据存储技术首先要解决的是数据海量化和快速增长需求，谷歌文件系统（GFS）和Hadoop 的（ ）奠定了大数据存储技术的基础。

- A、分布式文件系统
- B、分布式数据库系统
- C、关系型数据库系统
- D、非结构化数据分析系统

答案:A"

"Q1123、修订后《网络安全法》明确，网络安全工作坚持（ ）的领导。

- A、国务院
- B、国家网信部门
- C、中国共产党
- D、全国人民代表大会

答案:C"

"Q1124、GB/T 43697-2024 规定的分类分级工作流程中，第一步应是？

- A、直接进行数据打标
- B、梳理数据资产，建立数据目录
- C、编制数据安全策略
- D、部署数据分类工具

答案:B"

"Q1125、中国现行跨境法律监管体系由""1+3+N""组成，其中""3""代表下列哪些法律？

- A、《个人信息保护法》
- B、《网络安全法》
- C、《数据安全法》
- D、《数据出境安全评估办法》

答案:ABC"

"Q1126、数据资产地图如果缺少“访问主体”维度，最直接影响的是（ ）。

- A、难以完成基于角色的权限分析
- B、备份介质无法采购
- C、用户界面无法上线
- D、网络线路会中断

答案:A"

"Q1127、以下哪一行为，符合国家关于信息处理的要求？

- A、甲利用作为银行职员的便利为境外刺探、非法提

供银行金融数据

B、甲银行 APP 软件未经客户明确同意，擅自收集客户的人脸信息

C、甲银行柜员乙为客户办理业务需要，经过客户同意，按照银行流程扫描客户身份证原件

D、甲公司要求银行提供该公司员工乙的支付劳务工资记录，银行未经审查直接向甲公司提供

答案:C"

"Q1128、隐私保护和合规性的目的是什么？

A、防止物理安全威胁

B、保护个人信息和敏感数据的安全和隐私

C、提高网络防火墙的性能

D、加速数据传输速度

答案:B"

"Q1129、2013 年，斯诺登爆料美国从 2007 年开始实施棱镜计划（PRISM），对全球进行电子监听。棱镜计划是（ ）主导（ ）？

A、美国联邦法院

B、美国驻华大使馆

C、美国国家安全局

D、美国中央情报局

答案:C"

"Q1130、单点登录（SSO）的局限性包括。

A、单点故障可能影响多个应用系统

B、安全性依赖于认证服务器的可靠性

C、需要对现有应用系统进行适配和改造

D、不适用于跨域访问的场景

E、需要额外的硬件和软件支持

答案:ABC"

"Q1131、处理千万级数据分类分级，技术选型优先级？（ ）

A、Excel 人工标注

B、Spark 分布式计算+规则引擎

C、关系型数据库触发器

D、内存哈希表

答案:B"

Q1132、差分密码分析是一种选择明文攻击。（正确）

Q1133、个人信息处理者不得以个人不同意处理其个人信息或者撤回同意为由，拒绝提供产品或者服务；处理个人信息属于提供产品或者服务所必需的除外。（正确）

"Q1134、在数据安全方案设计中，“最小必要”原则的直接体现包括哪些？

A、仅开放完成业务所需的数据字段

B、仅授予完成任务所需的最小权限

C、默认收集所有数据以备后续分析

D、按场景决定是否必须长期留存

答案:ABD"

"Q1135、联邦学习包括哪种类型？（ ）

A、横向联邦学习

B、跨设备联邦学习

C、纵向联邦学习

D、联邦迁移学习

答案:ACD"

"Q1136、根据《个人信息保护合规审计管理办法》，监管部门可以要求个人信息处理者委托专业机构开展合规审计的情形包括（ ）。

A、发现个人信息处理活动存在严重影响个人权益等较大风险

B、个人信息处理活动可能侵害众多个人的权益

C、发生导致 100 万人以上个人信息泄露的安全事件

D、发生导致 10 万人以上敏感个人信息泄露的安全

事件

答案:ABCD"

"Q1137、网络安全等级保护总共有几个保护级别？

- A、3 个
- B、4 个
- C、5 个
- D、6 个

答案:C"

"Q1138、关于数据安全，以下哪项说法不合理（ ）？

- A、数据安全应当全员参与
- B、人是薄弱的环节
- C、部署数据安全的产品就可以解决数据安全问题
- D、有必要增强数据安全意识培训

答案:C"

Q1139、身份认证方式包括基于口令、挑战应答认证、基于时间同步认证、基于事件同步认证、基于智能卡和基于生物特征等。（正确）

"Q1140、某企业拟使用差分隐私保护统计查询，但噪音添加过大导致结果失真。应？

- A、取消差分隐私
- B、增加噪音
- C、仅内部使用
- D、优化隐私预算分配，平衡隐私保护强度与数据可用性

答案:D"

"Q1141、涉及的重要行业和领域的（ ）是负责关键信息基础设施安全保护工作的部门。

- A、主管部门
- B、监督管理部门
- C、税务部门

D、行政处罚部门

答案:AB"

"Q1142、以下哪种访问控制模型是基于一组属性规则来确定用户对资源的访问权限？

- A、自主访问控制模型（DAC）
- B、强制访问控制模型（MAC）
- C、角色基础访问控制模型（RBAC）
- D、属性基础访问控制模型（ABAC）

答案:D"

"Q1143、下列行为不符合个人信息处理法律法规？

- A、最小化采集
- B、内部制定管理制度，确保个人信息处理合规
- C、采取加密、去标识等措施
- D、APP 设计开发时采用默认采集默认授权的模式

答案:D"

"Q1144、在数据安全取证中，保全“原始日志副本并计算校验值”的主要目的在于（ ）。

- A、证明证据在保全过程中未被篡改
- B、提高数据库性能
- C、缩短备份时间
- D、减少员工培训成本

答案:A"

Q1145、布隆过滤器目的是检查某个元素是否存在于集合中。（正确）

"Q1146、某政务系统监测到 SQL 注入攻击尝试，WAF 已拦截。安全团队下一步应？

- A、忽略，WAF 已生效
- B、分析攻击特征，修复代码漏洞，更新防护规则
- C、关闭 WAF
- D、仅记录不处理

答案:B"

"Q1147、在以下认证机制中，安全性相对最高且常用于关键系统的是（ ）。

- A、双因素认证
- B、三因素认证
- C、多因素认证
- D、单因素认证

答案:C"

"Q1148、在单点登录（SSO）过程中，拦截器的主要作用是什么？

- A、检查被请求的 URL 是否需要认证保护
- B、在未认证时将用户重定向到统一认证服务器登录界面
- C、直接生成访问票据
- D、直接修改数据库中的用户口令

答案:AB"

"Q1149、关键信息基础设施发生重大网络安全事件或者发现重大网络安全威胁时，运营者应当（ ）。

- A、按照有关规定向保护工作部门、公安机关报告
- B、将相关信息尽快发布到境内的安全论坛网站上
- C、将相关信息尽快发布到境外的安全论坛网站上
- D、在处理完安全威胁并经过至少 30 个工作日的分析后再将相关信息发布到境内的安全论坛网站上

答案:A"

"Q1150、使用多因素身份验证（MFA）可以做什么？

- A、提高安全性
- B、提高用户体验
- C、降低成本
- D、提高速度

答案:A"

Q1151、在使用可信执行环境（TEE）时，只要确保 Enclave 内的代码逻辑正确，就完全不需要担心侧信

道攻击的风险。（错误）

"Q1152、根据《信息安全技术 数据安全能力成熟度模型》，以下哪些是提高数据安全能力成熟度的重要措施？

- A、建立完善的数据安全管理制度
- B、加强数据安全培训和教育
- C、开展数据安全风险评估
- D、提升数据安全技术和防护能力

答案:ABCD"

"Q1153、运营者还应当按照国家法律法规的规定和相关国家标准的强制性要求，履行下列安全保护义务。

- A、设置专门网络安全管理机构 and 网络安全管理负责人，并对该负责人和关键岗位人员进行安全背景审查
- B、制定网络安全事件应急预案并定期进行演练
- C、对重要系统和数据库进行容灾备份，及时对系统漏洞等安全风险采取补救措施
- D、采取监测、记录网络运行状态、网络安全事件的技术措施，并按照规定留存相关的网络日志不少于六个月

答案:ABCD"

"Q1154、假设您收到一封邮件，主题是""您的账户已被锁定""，内容要求您点击链接解锁账户。以下哪些选项是正确的？

- A、这封邮件可能是一封钓鱼邮件
- B、如果您点击该链接并提供您的账户信息，您的账户可能会被黑客攻击者控制
- C、如果您认为这是误报并忽略该邮件，您的账户将会被解锁
- D、如果您收到这封邮件，您应该立即点击链接以解锁您的账户
- E、如果您收到这封邮件，您应该立即回复邮件并要求客服解锁您的账户

答案:AB"

"Q1155、敏感个人信息是一旦泄露或者非法使用，容易导致自然人的人格尊严受到侵害或者人身、财产安全受到危害的个人信息，哪些属于《中华人民共和国个人信息保护法》定义的个人敏感信息？

- A、宗教信仰
- B、不满十四岁未成年人的个人信息
- C、金融账户、行踪轨迹
- D、医疗健康、生物特征

答案:ABCD"

Q1156、掌握有关主管部门规定的特定种类、规模的重要数据的网络数据处理者，可以根据自身风险等级决定是否对网络数据安全负责人和关键岗位的人员进行安全背景审查。审查时，可以申请公安机关、国家安全机关协助。（错误）

"Q1157、个人信息保护影响评估报告和处理情况记录应当至少保存（ ）。

- A、一年
- B、三年
- C、五年
- D、十年

答案:B"

"Q1158、我国目前确定了五大生产要素包括：（ ）？

- A、土地、能源、人才、资本、知识
- B、土地、劳动力、资本、技术、数据
- C、土地、能源、商业、人才、信息技术
- D、土地、能源、劳动力、资本、信息

答案:B"

"Q1159、某项目在部署数据库审计系统时，只在主库安装审计，忽略了只读副本和数据导出节点。该风险在于（ ）。

- A、数据访问审计链条不完整，可能遗漏异常读取和

外发路径

- B、主库足以覆盖所有访问行为
- C、只读副本无需安全控制
- D、导出节点不属于数据处理环节

答案:A"

"Q1160、某政务系统在进行数据共享时，将包含公民身份证号的原始数据直接共享给多个委办局。数据治理团队应建议？

- A、实施字段级脱敏或令牌化，仅共享必要字段，建立数据共享审批台账
- B、关闭数据共享功能
- C、加密传输即可
- D、仅限 IT 部门访问

答案:A"

"Q1161、对计算机信息系统中发生的案件，有关使用单位应当在（ ）内向当地县级以上人民政府公安机关报告。

- A、12 小时
- B、24 小时
- C、48 小时
- D、72 小时

答案:B"

"Q1162、《个人信息保护合规审计管理办法》由哪个部门公布？

- A、公安部
- B、工业和信息化部
- C、国家互联网信息办公室
- D、市场监督管理总局

答案:C"

"Q1163、对于重要数据的销毁方案设计，下列哪项是正确认识？

- A、只要删除文件名即可

B、应结合数据载体类型、恢复风险和审计要求设计销毁策略

C、销毁仅是法务事项

D、备份副本可永久保留

答案:B"

Q1164、数据脱敏只能用于静态数据。(错误)

"Q1165、根据《征信业管理条例》的规定，金融信用信息基础数据库接收从事信贷业务的机构按照规定提供的（）。

A、信贷信息

B、信用信息

C、不良信息

D、纳税信息

答案:A"

"Q1166、风险评估中“资产价值”分析的意义在于（）。

A、帮助判断风险影响程度和控制优先级

B、决定办公楼租金

C、决定员工福利

D、决定营销预算

答案:A"

"Q1167、某云计算平台需要为跨国企业客户提供细粒度的数据访问控制，要求：

访问权限需动态结合用户部门、数据敏感级别、访问时间和地理位置；

合规要求：欧盟员工不得访问存储在美国服务器上的 GDPR 受限数据；

安全策略：高敏感数据只能在工作时间从公司 IP 段访问。

以下哪种访问控制机制最能满足这一复杂需求？

A、基于角色的访问控制（RBAC）

B、基于属性的访问控制（ABAC）

C、自主访问控制（DAC）

D、强制访问控制（MAC）

答案:B"

"Q1168、根据《人脸识别技术应用安全管理办法》，违反规定使用人脸识别技术的，由哪个部门进行处罚？

A、仅公安机关

B、仅工信部门

C、国家或地方网信部门依据职责进行处罚

D、市场监管部门独立处罚

答案:C"

"Q1169、某企业发现分类分级工具对非结构化文档（如 PDF、Word）识别率低。实施团队应？

A、放弃文档分类

B、结合 OCR、NLP 技术与人工抽检提升准确率

C、仅处理结构化数据

D、要求员工全部转为 Excel

答案:B"

"Q1170、任何个人和组织发现危害关键信息基础设施安全的行为，有权向（）部门进行举报。

A、网信

B、公安

C、行业主管

D、监管部门

答案:ABCD"

"Q1171、根据《征信业管理条例》的规定，征信机构可以通过（）提供信息？

A、信息主体

B、企业交易对方

C、行业协会

D、互联网媒体

答案:ABC"

Q1172、根据 GB/T 43697-2024,《数据安全技术 数据分类分级规则》,数据的分类分级标准是固定不变的,不受具体环境和行业的影响。(错误)

"Q1173、根据《人工智能生成合成内容标识办法》,违反标识义务的服务提供者,由哪些主管部门依据各自职责进行处理?

- A、仅国家网信部门
- B、仅公安部门
- C、网信、工信、公安、广电等主管部门
- D、仅工信部门

答案:C"

"Q1174、某金融机构数据治理委员会发现""客户手机号""在 CRM、客服、营销系统中格式不一致。应?

- A、维持现状,各系统独立运行
- B、建立主数据管理(MDM)机制,统一清洗与映射
- C、删除冗余系统
- D、仅 IT 部门处理

答案:B"

"Q1175、某网站为了更好向用户提供服务,在新版本设计时提供了用户快捷登录功能,用户如果使用上次的 IP 地址进行访问,就可以无需验证直接登录,该功能推出后,导致大量用户账号被盗用,关于以上问题的说法正确的是:

- A、网站问题是由于开发人员不熟悉安全编码,编写了不安全的代码,导致攻击面增大,产生此安全问题
- B、网站问题是由于用户缺乏安全意识导致,使用了不安全的功能,导致网站攻击面增大,产生此问题
- C、网站问题是由于使用便利性提高,带来网站用户数增加,导致网站攻击面增大,产生此安全问题
- D、网站问题是设计人员不了解安全设计关键要素,

设计了不安全的功能,导致网站攻击面增大,产生此问题

答案:D"

"Q1176、企业网络安全管理制度包括?

- A、风险管理制度
- B、网络安全考核及监督问责制度
- C、自动化机制策略
- D、人员管理制度
- E、安全审计策略

答案:ABD"

"Q1177、下列哪项最适合保护云计算环境中静态数据的机密性()。

- A、数字签名
- B、全同态加密
- C、防火墙
- D、访问日志

答案:B"

"Q1178、以下哪种不属于社会工程学攻击的示例?

- A、钓鱼网站
- B、重放攻击
- C、电话欺诈
- D、欺骗性电子邮件

答案:B"

Q1179、如果数据安全可能影响到国家安全,那么数据级别最低应定为核心数据。(错误)

"Q1180、安全需求分析若已识别“外部共享 + 高频调用 + 敏感字段”,最合理的优先控制组合是()。

- A、鉴权、限流、字段最小化、审计
- B、只做页面验证码
- C、只增加服务器 CPU

D、只做合同存档

答案:A"

"Q1181、在数据标签与血缘治理成熟后，最容易直接提升的能力是（ ）。

A、问题定位、影响分析与精准整改

B、打印机耗材管理

C、办公区巡逻效率

D、市场推广转化率自动翻倍

答案:A"

"Q1182、数据安全能力成熟度等级（ ）对参与国际、国家或行业相关标准制定提出了要求。

A、二级

B、三级

C、四级

D、五级

答案:D"

Q1183、数据产权三权分置中的“三权”指数据资源持有权、数据加工使用权、数据产品经营权。（正确）

Q1184、区块链具备可追溯性，因此攻击者无法隐藏其在链上的攻击行为和身份。（错误）

Q1185、区块链就是比特币。（错误）

"Q1186、以下哪些属于 Windows 本地身份与访问控制相关的机制或场景？

A、文件共享访问控制

B、进程权限管理

C、用户登录认证

D、访问令牌

E、网络通信连接控制

答案:ABCD"

"Q1187、在数据安全运营指标中，MTTD 的含义是（ ）。

A、平均发现时间

B、平均恢复时间

C、平均备份时间

D、平均培训时长

答案:A"

"Q1188、以下哪项不是身份的必要特点？

A、唯一性

B、可复制性

C、可变性

D、持久性

答案:B"

"Q1189、某企业数据治理项目缺乏高层支持，推进缓慢。应？

A、降低项目目标

B、暂停项目

C、建立数据治理委员会，明确战略定位与考核机制

D、仅 IT 部门推动

答案:C"

"Q1190、以下哪种机制最常用于实现针对单个文件或目录的细粒度访问控制？

A、防火墙

B、VPN（Virtual Private Network）

C、IDS（Intrusion Detection System）

D、ACL（Access Control List）

答案:D"

"Q1191、《促进和规范数据跨境流动规定》对既有数据出境规则作出的主要调整包括哪些？

A、对非关键信息基础设施运营者累计向境外提供不满 10 万人个人信息（不含敏感个人信息）的情形，新增豁免规则

B、将“累计向境外提供 1 万人以上敏感个人信息须

申报安全评估”调整为完全豁免

C、新增合同履行、跨境人力资源管理、紧急救助等豁免情形

D、取消了重要数据出境须申报安全评估的要求

答案:AC"

Q1192、政务数据类型包括文字、数字、图表、图像、音视频等。（正确）

"Q1193、某开发团队将脱敏逻辑写在前端展示层，而导出接口直接返回原始字段。该实现的最大问题是（ ）。

A、脱敏控制未覆盖所有数据输出链路

B、前端框架版本过低

C、日志数量不足

D、网络延迟升高

答案:A"

"Q1194、根据《个人信息保护法》，违法行为情节严重的，由省级以上履行个人信息保护职责的部门责令改正，没收违法所得，并处（ ）以下罚款，或者并处上一年度营业额百分之五以下罚款。

A、一千万元

B、五千万元

C、一亿元

D、两亿元

答案:B"

"Q1195、因业务需要，确需进行境外远程维护的，应事先（ ）。

A、进行远程调试确保境外网络能进行访问

B、报国家行业主管或监管部门和国务院公安部门

C、进行远程调试确保境外网络无法直接进行访问

D、咨询企业股东

答案:B"

Q1196、4A 系统主要提供网络安全服务，不包括身

份认证和授权管理。（错误）

"Q1197、身份认证是为了确认通信过程中的另一端个体是谁，这个个体可以是哪些类型？

A、人

B、物体

C、虚拟过程

D、以上都可以

答案:D"

"Q1198、双因素认证是指结合几种认证方式进行身份认证？

A、一种

B、两种

C、三种

D、四种

答案:B"

"Q1199、某项目交付时，只交了安装包，没有交运行管理手册和故障处置说明。该交付最主要的缺陷是（ ）。

A、缺乏可持续运维所需的知识转移与操作规范

B、影响前端显示风格

C、会直接触发数据出境

D、只影响采购流程

答案:A"

"Q1200、在开展数据资产盘点时，元数据的主要价值是（ ）。

A、只用于美化数据展示界面

B、描述数据的名称、来源、结构、用途和责任归属，支撑检索、治理与审计

C、替代数据库备份

D、只用于统计服务器数量

答案:B"

"Q1201、关于冯·诺依曼结构与哈佛结构，下列哪项说法是错误的？

- A、冯·诺依曼结构共用数据存储空间和程序存储空间，共用同一组存储器总线
- B、哈佛结构有分离的数据和程序存储空间及分离的访问总线
- C、哈佛结构在指令执行时，取址和取数可以并行操作
- D、冯·诺依曼结构的数据和指令必须通过不同的总线访问

答案:D"

Q1202、社会工程学攻击是指攻击者在用户和身份验证服务器之间插入自己的设备或软件，以截获和篡改身份验证信息。（错误）

"Q1203、省级以上人民政府应当将（ ）发展纳入本级国民经济和社会发展规划。

- A、信息经济
- B、智慧经济
- C、数字经济
- D、数据经济

答案:C"

"Q1204、以下哪些情况下，数据处理者向境外提供数据可以免于申报数据出境安全评估、订立个人信息出境标准合同、通过个人信息保护认证？

- A、在国际贸易活动中收集产生的数据，不包含个人信息或者重要数据
- B、数据处理者在境外收集和产生的个人信息，处理过程中没有引入境内个人信息或者重要数据
- C、为履行跨境支付合同，确需向境外提供个人信息
- D、为进行人员统一管理，确需向境外提供企业应聘者信息

答案:ABC"

"Q1205、对于 APP 收集用户数据，下列哪种做法不符合隐私法规？

- A、事先告知用户数据收集的目的和方式
- B、强制用户授权全部权限才能使用 APP
- C、允许用户自主选择授权的权限
- D、用户注销账号后仍然继续收集其数据

答案:BD"

"Q1206、以下不属于数据生命周期的是？

- A、采集
- B、分级
- C、存储
- D、销毁

答案:B"

"Q1207、采用智能交通管理系统（ITMS）可以实现以下哪些目标？

- A、缓解交通拥堵
- B、减少交通事故
- C、优化交通运行效率
- D、直接处理居民楼电梯故障

答案:ABC"

"Q1208、某政务系统分类分级完成后，未将结果同步至数据资产管理平台。该缺失导致？

- A、分级成果无法落地应用
- B、系统性能下降
- C、网络带宽浪费
- D、前端显示异常

答案:A"

Q1209、大数据发展应当全面实施国家大数据战略，坚持统筹规划、创新引领原则。（正确）

"Q1210、在网络传递身份时，需要先建立什么关系？

- A、信任关系
- B、合作关系

C、竞争关系

D、加密关系

答案:A"

"Q1211、以下哪一项不属于定量描述的数据分级要素？（）

A、重要性

B、规模

C、精度

D、覆盖度

答案:A"

Q1212、重要数据的处理者应当按照规定对其数据处理活动定期开展风险评估，并向有关主管部门报送数据清单。（错误）

"Q1213、某互联网公司数据泄露事件调查发现，攻击者通过 SQL 注入获取了 300 万用户的明文密码。事后修复除了修复 SQL 注入漏洞外，还应？

A、强制所有用户重置密码，将密码存储方式改为加盐哈希

B、仅通知部分高价值用户

C、删除泄露数据库

D、关闭注册功能

答案:A"

"Q1214、网络运营者应当按照网络安全等级保护制度的要求，履行（）安全保护义务，保障网络免受干扰、破坏或者未经授权的访问，防止网络数据泄露或者被窃取、篡改。

A、采取防范计算机病毒和网络攻击、网络侵入等危害网络安全行为的技术措施

B、制定内部安全管理制度和操作规程，确定网络安全负责人，落实网络安全保护责任

C、采取数据分类、重要数据备份和加密等措施

D、采取监测、记录网络运行状态、网络安全事件的技术措施，并按照规定留存相关的网络日志不少于

六个月

答案:ABCD"

"Q1215、下列哪些属于数据跨境合规的主要难点？

A、数据体量大

B、政策限制多

C、属性识别难

D、载体拆分难

答案:ACD"

"Q1216、《中华人民共和国民法典》规定，网络用户利用网络服务实施侵权行为的，权利人有权通知网络服务提供者采取（）、删除、断开链接等必要措施。通知应当包括构成侵权的初步证据及权利人的真实身份信息。

A、屏蔽

B、过滤

C、加密

D、拉黑

答案:A"

"Q1217、以下属于关键信息基础设施重要行业和领域的是？

A、公共通信

B、能源、交通、水利

C、公共服务

D、各类电商网购平台

答案:ABC"

"Q1218、《网络安全法》要求采取监测、记录网络运行状态、网络安全事件的技术措施，并按照规定留存相关的网络日志不少于（）。

A、一年

B、三个月

C、六个月

D、九个月

答案:C"

"Q1219、数据交易应当遵循（ ）原则。

- A、自愿原则
- B、公平原则
- C、诚信原则
- D、以上都正确

答案:D"

Q1220、MAC 模型是一种灵活的权限管理模型，允许资源的所有者自主决定访问权限。（错误）

"Q1221、某隐私保护区块链项目需要实现以下功能：

交易匿名性：发送方身份无法被追踪；

交易合法性：确保每笔交易来自合法用户；

不可关联性：同一用户的多笔交易无法被关联。

以下哪种签名方案最符合上述需求？

- A、ECDSA 签名：每个用户使用唯一私钥对交易签名
- B、环签名（Ring Signature）：交易签名混合多个可能的发送方公钥
- C、群签名（Group Signature）：用户通过群管理员颁发的凭证签名
- D、BLS 聚合签名：多个交易签名可被聚合成单个签名

答案:B"

"Q1222、身份和访问管理（IAM）的目标是什么？

- A、确保正确的人能够以正确方式访问正确的资源
- B、保护网络免受攻击
- C、保护数据安全
- D、保护应用安全

答案:A"

"Q1223、违反《中华人民共和国个人信息保护法》规定处理个人信息，或处理个人信息未履行本法规

定的个人信息保护义务的，履行个人信息保护职责的部门可做出下列处罚措施？

- A、警告
- B、督促整改
- C、对违法处理个人信息的应用程序，责令暂停或者终止服务
- D、没收违法所得

答案:ACD"

"Q1224、在单点登录（SSO）认证过程中，Cookie 的作用是什么？

- A、存储用户的登录凭据
- B、保存用户的个人信息
- C、传递访问票据和用户信息
- D、加密用户的通信数据

答案:C"

"Q1225、在单点登录（SSO）过程中，Cookie 被用于存放什么信息？

- A、访问票据（Token）
- B、用户的部分标识信息
- C、用户的个人敏感信息
- D、SSL 通道的加密密钥
- E、应用系统的配置信息

答案:AB"

"Q1226、以下哪些是 Fabric 的层级。

- A、合约层
- B、共识层
- C、数据层
- D、应用层

答案:ABCD"

"Q1227、已被发现，但相关软件厂商还未第一时间给出补丁进行修复的漏洞称之为？（ ）

- A、已有漏洞
- B、CVE 漏洞
- C、Nday 漏洞
- D、0DAY 漏洞

答案:D"

"Q1228、某企业监测到内部研发人员将含客户数据的测试代码提交至公开 GitHub 仓库。应？

- A、立即撤销提交，强制密码轮换，开展安全意识培训
- B、忽略，测试数据无价值
- C、仅内部警告
- D、删除 GitHub 账号

答案:A"

"Q1229、关键信息基础设施的运营者采购网络产品和服务，应当按照规定与提供者签订（ ），明确安全和保密义务与责任。

- A、保密合同
- B、安全保密协议
- C、安全责任条款
- D、安全服务合同

答案:B"

"Q1230、数据脱敏的主要目的是（ ）。

- A、提高数据存储效率
- B、保护敏感信息
- C、加快数据处理速度
- D、减少数据备份成本

答案:B"

"Q1231、某系统发生数据泄露后，团队先修复漏洞但未保留证据镜像。该问题可能导致（ ）。

- A、后续责任认定和溯源分析困难
- B、漏洞会自动复现

- C、备份会立即损坏
- D、用户权限自动恢复

答案:A"

"Q1232、区块链的核心特点是（ ）。

- A、可逆性
- B、匿名性
- C、不可篡改性
- D、高速性

答案:C"

"Q1233、《数据安全法》规定，国家开展数据安全监测预警，建立数据安全风险评估、报告、信息共享、监测预警机制。这些机制的目的是什么？

- A、增加数据处理的复杂性
- B、限制数据处理活动
- C、提高数据安全风险应对能力
- D、阻碍数据流通

答案:C"

"Q1234、某互联网企业将用户消费记录与第三方平台的地理位置数据进行跨平台关联分析，生成精细用户画像。该行为的核心合规风险是？

- A、跨平台关联分析须有合法依据，且须告知用户
- B、数据融合后敏感性可能升级，须重新评估处理合规性
- C、使用第三方数据须确保其来源合法
- D、跨平台数据分析属于纯技术行为，不受监管

答案:ABC"

"Q1235、某政务系统需实现敏感字段动态脱敏，但现有加密方案为静态存储加密。应？

- A、维持静态加密
- B、引入字段级动态脱敏网关或数据库代理，按需展示
- C、仅前端隐藏

D、删除敏感字段

答案:B"

"Q1236、在 LoRaWAN 网络中，终端设备如何验证网络服务器的身份？

A、使用设备的唯一标识和共享密钥进行认证

B、通过 Wi-Fi 连接进行验证

C、不需要验证

D、通过手机应用进行验证

答案:A"

"Q1237、某企业内部系统遭到勒索软件攻击，部分核心数据被加密。应急负责人发现没有最近的可用备份。该事件暴露的根本问题是？

A、备份策略未落地或备份可用性未经验证，业务连续性保障缺失

B、防火墙性能不足

C、员工数量过多

D、服务器内存不够

答案:A"

"Q1238、某医院将患者电子病历定为核心数据，但依据行业指南该数据属重要数据。定级团队应？

A、坚持医院自主定级

B、依据国家标准与行业指南调整至正确级别

C、合并两个级别

D、忽略指南要求

答案:B"

"Q1239、某企业在做个人信息合规审计时，只核查是否有隐私政策，却未验证实际处理活动是否与隐私政策一致。其最主要缺陷是（ ）。"

A、只做文件合规，未验证行为合规

B、隐私政策已足够说明合规

C、实际活动无需审查

D、由用户投诉后再核查即可

答案:A"

"Q1240、对于任用的终止或变化时规定职责和义务在任用终止后仍然有效的内容应包括在（ ）合同中。"

A、管理人员

B、承包方人员

C、第三方人员

D、技术人员

答案:ABCD"

"Q1241、字典攻击是指（ ）。"

A、使用各种可能组合穷举破解密码的暴力攻击

B、使用预先建立的常见用户名/密码列表进行尝试

C、在通信双方之间插入攻击者截获信息

D、获取已泄露凭据在其他平台尝试使用

答案:B"

Q1242、加密算法 AES 是对称加密算法。（正确）

"Q1243、某金融机构数据安全团队发现，核心交易系统的日志中存在大量""select *""全表查询记录，来源 IP 为内网某开发工作站。应如何处置？

A、核查该账号的业务合理性，若无正当理由应立即限制权限并启动内部调查

B、全表查询属正常开发行为

C、仅限制该 IP 的外网访问

D、重启数据库服务

答案:A"

"Q1244、基于密码的身份验证依赖于什么？

A、用户名和密码或 PIN

B、指纹和密码

C、面部识别和密码

D、虹膜扫描和密码

答案:A"

"Q1245、区块链信息服务安全风险主要包括？

A、记录在区块链上的信息难以被修改和删除，导致违法信息、不良信息在上链后难以被有效处置

B、区块链分布式存储和去中心化的特征，数据存储在节点服务器，导致违法信息、不良信息难以被清除

C、区块链上运行的智能合约存在代码漏洞、恶意调用、执行异常等问题，导致无法提供正常的信息服务

D、使用 P2P 网络、共识机制等技术构建区块链网络，面临网络攻击、节点故障、隐私数据泄露等安全问题

答案:ABCD"

"Q1246、国家网信部门应当统筹协调有关部门对关键信息基础设施的安全保护采取下列（ ）措施。

A、对关键信息基础设施的安全风险进行抽查检测，提出改进措施，必要时可以委托网络安全服务机构对网络存在的安全风险进行检测评估

B、促进有关部门、关键信息基础设施的运营者以及有关研究机构、网络安全服务机构等之间的网络安全信息共享

C、定期组织关键信息基础设施的运营者进行网络安全应急演练，提高应对网络安全事件的水平和协同配合能力

D、对网络安全事件的应急处置与网络功能的恢复等，提供技术支持和协助

答案:ABCD"

"Q1247、上市公司对于数据的公开有严格要求，以下选项哪些是上市公司对外披露数据的合理手段（ ）？

A、在财报未披露前先面向社会公开，彰显公开透明的原则

B、遵循信息披露制度，上市公司必须披露定期报告

C、不得对外公示财报，以保守商业秘密

D、按照法定要求向证监会以及投资者披露财务经营

等会计信息

答案:BD"

Q1248、智能合约是存储在区块链分布式账本中的计算机程序，由区块链用户部署并在满足条件时自动执行。（正确）

"Q1249、HASH 加密使用复杂的数字算法来实现有效的加密，其常见算法包括？

A、MD2

B、MD4

C、MD5

D、Cost256

答案:ABC"

"Q1250、近年来快递行业经常出现大规模个人信息泄露，因此针对快递行业的个人隐私保护，有哪些做法可以有效保护个人信息。

A、快递公司内部查询个人信息时添加点击授权按钮，并且留存查询日志以供日后审计

B、个人信息展示给快递员时，进行遮蔽处理，例如只现实姓，手机号前三位与后四位

C、面单隐私保护，提供虚拟面单信息

D、当发现快递员有高频次查询、录入个人信息时进行阻断拦截

答案:ABC"

"Q1251、《数据安全法》规定，数据处理活动应当遵守法律、法规，尊重社会公德和伦理，遵守商业道德和职业道德，诚实守信，履行数据安全保护义务，承担什么责任？

A、社会责任

B、法律责任

C、道德责任

D、政治责任

答案:A"

Q1252、个人一旦撤回同意，即之前所有基于个人同

意已进行的个人信息处理活动全部无效。（错误）

"Q1253、安全人员发现了针对服务器的口令爆破攻击，于是设置了以下账户锁定策略：3 次无效登陆锁定账户；锁定时间 30 分钟；复位账户锁定计数器 5 分钟。以下关于以上策略设置后的说法哪个是正确的？

A、设置账户锁定策略后，攻击者无法再进行口令暴力破解，所有输错密码的用户就会被锁住

B、如果正常用户不小心输错了 3 次密码，那么该账户就会被锁定 30 分钟，30 分钟内即使输入正确的密码，也无法登录系统

C、如果正常用户不小心连续输入错误密码 3 次，那么该用户账号被锁定 5 分钟，5 分钟内即使输入了正确的密码，也无法登录系统

D、攻击者在进行口令破解时，只要连续输错 3 次密码，该账户就被锁定 10 分钟，而正常用户登陆不受影响

答案:B"

"Q1254、风险评估报告若只有“风险列表”，没有“风险处置建议”，其最主要缺陷是（ ）。

A、无法直接指导整改和资源配置

B、日志留存时间不足

C、加密算法一定过时

D、系统一定存在出境风险

答案:A"

"Q1255、以下行为存在信息泄露隐患的是（ ）？

A、打印文件后删除打印机缓存内容

B、使用碎纸机粉碎看过的重要资料

C、为方便办公拍摄屏幕

D、数据在 U 盘加密处理

答案:C"

Q1256、数据混排就是一个对数据集添加随机噪声，进行扰动的过程。（错误）

"Q1257、在单点登录（SSO）认证过程中，哪个组件负责生成访问票据并将其存放在 Cookie 中？

A、认证服务器

B、目标应用系统

C、Web 拦截器

D、客户端浏览器

E、统一认证中心

答案:AE"

"Q1258、为什么说在网络环境下，信任不是对一个人的可靠性认可？

A、因为网络环境下，人们很容易伪造身份信息

B、因为网络环境下，人们很难判断对方的可靠性

C、因为网络环境下，信任主要是基于秘密信息

D、因为在网络环境下，信息主要是基于权限控制

答案:C"

Q1259、银行保险监管统计，是指国家金融监督管理总局及其派出机构组织实施的以银行保险机构为对象的统计调查、统计分析、统计信息服务、统计管理和统计监督检查等活动，以及银行保险机构为落实相关监管要求开展的各类统计活动。（正确）

Q1260、如果法律、行政法规规定提供数据处理相关服务应当取得行政许可，则服务提供者应当依法取得许可。（正确）

"Q1261、国家对计算机信息系统安全专用产品的销售实行（ ）制度。具体办法由公安部会同有关部门制定。

A、登记备案

B、注册

C、许可证

D、核准

答案:C"

"Q1262、根据《个人信息保护法》，""去标识化""的定义是？

- A、个人信息经过处理，使其在不借助额外信息的情况下无法识别特定自然人的过程
- B、个人信息经过处理无法识别特定自然人且不能复原的过程
- C、将个人信息删除或彻底销毁的过程
- D、对个人信息进行加密存储的过程

答案:A"

"Q1263、在访问控制中，RBAC 模型中的角色可以与以下哪个概念对应？

- A、用户组
- B、文件权限
- C、认证凭证
- D、审计日志

答案:A"

Q1264、访问控制参考模型由参考监视器、客体、访问控制数据库和审计库构成。（错误）

"Q1265、数据标签体系中，以下哪类标签最直接服务于安全管控？

- A、业务主题标签
- B、敏感级别标签
- C、可视化颜色标签
- D、界面布局标签

答案:B"

"Q1266、为降低本国数据传输至境外造成的安全风险，我国针对性推出了哪项政策法规？

- A、《关键信息基础设施安全保护条例》
- B、《网络安全产品漏洞管理规定》
- C、《数据出境安全评估办法》
- D、《信息安全等级保护管理办法》

答案:C"

"Q1267、履行个人信息保护职责的部门履行个人信息保护职责，可以采取下列措施：

- A、询问有关当事人，调查与个人信息处理活动有关的情况
- B、查阅、复制当事人与个人信息处理活动有关的合同、记录、账簿以及其他有关资料
- C、实施现场检查，对涉嫌违法的个人信息处理活动进行调查
- D、检查与个人信息处理活动有关的设备、物品；对有证据证明是用于违法个人信息处理活动的设备、物品，向本部门主要负责人书面报告并经批准，可以查封或者扣押

答案:ABCD"

"Q1268、在合规审计中，如果审计机构只审制度、不抽样验证系统配置和运行记录，最大的风险是（ ）。

- A、可能形成“制度合规、行为不合规”的误判
- B、能显著提升审计准确率
- C、可以完全替代技术测试
- D、不会影响审计结论

答案:A"

"Q1269、某金融机构在制定 AI 风控模型时，使用了历史数据中存在系统性偏差的贷款审批记录（如对某特定地区申请者审批率明显偏低）。合规团队应指出的风险是？

- A、模型可能延续并放大历史歧视性偏差，违反公平原则和自动化决策透明度要求
- B、历史数据属于客观事实，使用无需审查
- C、只要模型准确率达标即合规
- D、风险由数据提供方承担

答案:A"

"Q1270、下列哪些情形发生时，个人信息处理者应当主动删除个人信息；个人信息处理者未删除的，个人有权请求删除？

- A、处理目的已实现
- B、个人撤回同意

- C、个人信息保存期限已届满
- D、个人信息处理者停止提供产品或者服务

答案:ABCD"

"Q1271、某金融机构接到监管通知，要求其对特定业务系统开展个人信息保护合规审计并限期提交报告。该机构以""内部审计已在3个月前完成""为由拒绝。该拒绝理由是否成立？

- A、成立，近期已完成内部审计
- B、不成立；监管部门要求的合规审计属于法定义务，须单独响应，不能以内部审计替代
- C、视监管要求具体文件而定
- D、内部审计与外部审计等效

答案:B"

"Q1272、根据《数据安全法》，数据安全检测评估、认证机构应当（），不得向他人提供、泄露在开展服务活动中获取的数据。

- A、遵守国家有关规定，具备相应条件
- B、仅服务于政府机构
- C、获得国家网信部门特别批准
- D、由国有机构独家承担

答案:A"

"Q1273、根据《网络安全法》的规定，网络产品、服务的提供者实施哪种行为会受到处罚？

- A、提供符合相关国家标准的强制性要求的网络产品、服务
- B、不在网络产品、服务中设置恶意程序
- C、在规定或者当事人约定的期限内，终止提供安全维护
- D、发现网络产品、服务存在安全缺陷、漏洞等风险时，立即采取补救措施，按照规定及时告知用户并向有关主管部门报告

答案:C"

"Q1274、运营者应当建立健全网络安全保护制度和

责任制，保障人力、财力、物力投入。（）对关键信息基础设施安全保护负总责，领导关键信息基础设施安全保护和重大网络安全事件处置工作，组织研究解决重大网络安全问题。

- A、国家网信部门
- B、国务院公安部门
- C、省级人民政府有关部门
- D、运营者的主要负责人

答案:D"

"Q1275、IIS FTP 服务器支持以下哪些访问限制技术手段？

- A、账号登录认证
- B、IP 地址限制
- C、数据加密传输
- D、用户行为分析

答案:AB"

"Q1276、区块链的类型有。

- A、私有链
- B、公有链
- C、联盟链
- D、专有链

答案:ABC"

"Q1277、访问控制的目标是什么？

- A、保护系统资源免受未经授权的访问
- B、限制合法用户越权使用系统资源
- C、管理用户的账号和口令
- D、监测和审计用户的访问活动
- E、提供网络连接和通信功能

答案:ABD"

"Q1278、根据《生成式人工智能服务管理暂行办法》，提供者应当建立生成内容审核机制。用户反映

所生成内容侵犯其合法权益时，提供者应当（ ）。

- A、依法及时采取更正、删除、屏蔽等措施，防止侵权内容扩散
- B、拒绝处理用户投诉
- C、仅在收到法院判决后才处理
- D、转交第三方机构处理

答案:A"

"Q1279、如果个人信息处理者将个人信息用于用户画像、个性化展示或者自动化决策，通常应当向个人说明哪些内容？

- A、相关处理的目的是或应用场景
- B、可能对个人权益产生的影响
- C、个人拒绝或关闭个性化展示的方式
- D、相关处理结果应保持公平、公正并具有透明度

答案:ABCD"

"Q1280、依据工业数据分类分级指南，下列哪些属于三级数据？

- A、受影响的用户和企业数量较少、生产生活区域范围较小、持续时间较短
- B、对国民经济、行业发展、公众利益、社会秩序乃至国家安全造成严重影响
- C、恢复工业数据或消除负面影响所需付出的代价较大
- D、易引发特别重大生产安全事故或突发环境事件，或造成直接经济损失特别巨大

答案:BD"

"Q1281、在单点登录（SSO）认证过程中，认证状态信息或访问票据通常可能存储在哪里？

- A、Cookie 中
- B、服务端 Session 中
- C、统一认证服务器或认证中心
- D、数据库中（如用户账户与票据关联信息）

E、纸质登记表中

答案:ABCD"

"Q1282、某互联网公司的用户画像系统将用户划分为""高风险负债人群""，并向合作方金融机构推送该标签用于贷款审批。以下分析正确的是？

- A、使用自动化决策对用户进行分类须告知用户并保证透明度
- B、向合作方提供敏感推断信息须取得用户单独同意
- C、基于自动化决策的标签可能影响用户信贷权益，应提供人工复核途径
- D、标签数据属于衍生数据，无需遵守个保法

答案:ABC"

"Q1283、根据《电子签名法》的规定，审查数据电文作为证据的真实性，应当考虑哪些因素？

- A、生成、储存或者传递数据电文方法的可靠性
- B、保持内容完整性方法的可靠性
- C、用以鉴别发件人方法的可靠性
- D、其他相关因素

答案:ABCD"

"Q1284、《网络数据安全条例》规定，网络数据处理者向境外提供个人信息，以下哪种方式不是合规路径？

- A、通过国家网信部门组织的数据出境安全评估
- B、经专业机构进行个人信息保护认证
- C、符合个人信息出境标准合同的规定
- D、自行与境外接收方签订保密协议

答案:D"

"Q1285、区块链中的“女巫攻击”（Sybil Attack）是指？

- A、双花攻击
- B、单个攻击者伪装成多个节点来控制区块链网络
- C、篡改历史区块

D、DDoS 攻击

答案:B"

"Q1286、某政务系统数据梳理发现""身份证号""在多个表中重复存储但未脱敏。应？

A、维持现状

B、建立统一身份标识库，减少冗余并实施加密/脱敏

C、直接删除

D、仅加密一个表

答案:B"

Q1287、双花攻击指的是攻击者选取之前已经上链的交易，重新提交至交易池中。（错误）

Q1288、数字证书认证中心（CA）是 PKI 系统的核心部件。（正确）

Q1289、社会工程学是一种利用心理学和社交工程学的攻击技术。（正确）

"Q1290、个人信息处理者因业务等需要，确需向中华人民共和国境外提供个人信息的，应当具备下列哪些条件？

A、依照《中华人民共和国个人信息保护法》相关规定通过国家网信部门组织的安全评估

B、按照国家网信部门的规定经专业机构进行个人信息保护认证

C、按照国家网信部门制定的标准合同与境外接收方订立合同，约定双方的权利和义务

D、法律、行政法规或者国家网信部门规定的其他条件

答案:ABCD"

"Q1291、某金融业关键系统为了满足业务的需要准备进行升级改造，以下哪一项不是此次改造中信息系统安全需求分析过程需要考虑的主要因素（ ）？

A、必须遵循的相关法律法规，国家以及金融行业安全标准

B、系统所承载该业务正常运行的安全需求

C、消除或降低该银行信息系统面临的所有安全风险

D、该金融业的业务整体安全策略

答案:C"

Q1292、APP 运营商应通过简洁、清晰、易懂的方式告知用户个人信息处理规则，如发生变动，应及时告知用户最新情况。突出显示敏感个人信息的目的、方式和范围，建立已收集个人信息清单，不得采用默认勾选、缩小文字、冗长文本等方式诱导用户同意个人信息处理规则。（正确）

"Q1293、防御 API 未授权访问（BOLA）的关键措施是？

A、启用 HTTPS

B、资源归属校验（req.user_id == token.sub）

C、JSON Schema 验证

D、响应数据脱敏

答案:B"

"Q1294、在合规评估项目立项阶段，若未识别评估对象涉及的行业专项规则，最可能带来的问题是（ ）。

A、评估标准不完整，遗漏行业特定义务

B、办公室网络自动断开

C、用户界面颜色失真

D、日志留存自然增加

答案:A"

"Q1295、威胁建模在数据安全方案设计中的主要作用是（ ）。

A、识别不同处理环节面临的安全威胁，并据此设计控制措施

B、估算办公面积需求

C、替代法规合规审查

D、自动生成全部制度文件

答案:A"

"Q1296、某企业建立统一数据标签体系后，最适合优先与其联动的安全能力是（ ）。

- A、访问控制与审计策略
- B、办公区工位管理
- C、会议签到系统
- D、打印机采购流程

答案:A"

"Q1297、访问控制的目的是为了限制什么？

- A、访问主体对访问客体的访问权限
- B、访问客体对访问主体的访问权限
- C、访问主体和客体之间的通信权限
- D、访问主体和客体之间的数据传输速度

答案:A"

"Q1298、自然人死亡的，其近亲属为了自身的合法正当利益，可以对死者的相关个人信息行使（ ）权利；死者生前另有安排的除外。

- A、查阅
- B、复制
- C、更正
- D、删除

答案:ABCD"

Q1299、《信息安全技术 关键信息基础设施安全保护要求》规定了关键信息基础设施分析识别、安全防护、检测评估、监测预警、主动防御、事件处置等方面的安全要求。（正确）

Q1300、在零信任架构中，所有设备都被默认信任。（错误）

Q1301、X.509 认证协议规定的强认证机制（Strong Authentication Procedures）采用挑战-应答方式，使用随机数（nonce）防止重放攻击。（正确）

"Q1302、某企业数据安全合规审计中，发现研发部门在测试环境使用了生产数据库的真实备份，包含大量用户个人信息。应如何整改？

- A、立即清理测试环境中的生产数据，建立数据脱敏机制，强制测试环境使用合成数据或脱敏数据
- B、为测试环境增加访问权限控制即可
- C、让研发人员签署保密协议即可
- D、将测试环境纳入生产环境管理范围

答案:A"

"Q1303、一旦遭到破坏、丧失功能或者数据泄露，可能严重危害（ ）的，应当纳入关键信息基础设施保护范围。

- A、国家安全
- B、国计民生
- C、公共利益
- D、个人收入

答案:ABC"

"Q1304、访问控制中“最小权限原则”指的是（ ）。

- A、只允许管理员访问数据
- B、用户在登录时自动获得全部权限
- C、用户仅被授予完成任务所需的最少权限
- D、用户权限随时间逐渐提高

答案:C"

"Q1305、在中华人民共和国（ ）开展数据处理活动及其安全监管适用《中华人民共和国数据安全法》。

- A、境内部分地区
- B、境内以及境外
- C、境外
- D、境内

答案:D"

"Q1306、侵犯未成年人在网络空间合法权益的情形包括未经监护人同意，收集使用（ ）周岁以下（含）未成年人个人信息。

- A、8

B、12

C、14

D、16

答案:C"

"Q1307、虚拟专用网络（VPN）通过什么来建立安全的连接？

A、加密和隧道技术

B、用户角色

C、系统管理员

D、用户属性

答案:A"

"Q1308、数据安全风险评估结果在有效期内出现以下情形之一的，重要数据和核心数据处理者对发生变化及其影响的部分，重新开展数据安全风险评估，并更新评估报告。（）

A、拟新增跨主体提供、委托处理、转移重要数据或者核心数据的

B、发生涉及重要数据、核心数据的安全事件的

C、重要数据、核心数据预计将发生重大变更的

D、重要数据、核心数据安全状态发生变化对数据安全造成不利影响的，包括但不限于数据处理目的、方式、适用范围和安全制度策略等发生重大调整的

答案:ABD"

"Q1309、高斯噪声用于差分隐私时，衡量噪声强度的关键参数是？（）

A、均值

B、标准差

C、中位数

D、众数

答案:B"

"Q1310、某企业希望在不改动业务逻辑的前提下快速降低开放接口的敏感数据暴露。最常见且有效的

手段是（）。

A、在网关或中间层实施字段裁剪、脱敏和访问控制

B、关闭数据库索引

C、改用纸质流转

D、增加网页广告位

答案:A"

Q1311、根据《中华人民共和国数据安全法》，国家对维护国家安全、利益以及履行国际义务相关的数据可以实施出口管制。（正确）

"Q1312、某公司的员工，正当他在忙于一个紧急工作时，接到一个电话，被告知系统发现严重漏洞，紧急修复，需提供他的系统管理账户信息，接下来他的正确做法是（）。

A、核实之后，如是真实情况，才可提供账号信息

B、诈骗电话，直接挂机

C、直接拒绝

D、报警

答案:C"

"Q1313、敏感个人信息是一旦泄露或者非法使用，容易导致自然人的人格尊严受到侵害或者人身、财产安全受到危害的个人信息，包括（）等信息。

A、特定身份

B、生物识别

C、宗教信仰

D、医疗健康

答案:ABCD"

"Q1314、如果应急预案没有区分“数据泄露”“数据篡改”“数据不可用”三类事件，最直接的问题是（）。

A、不同事件类型无法匹配针对性的处置路径

B、系统自动加密会失败

C、员工无法登录邮箱

D、数据库主键冲突增加

答案:A"

"Q1315、防火墙（Firewall）通过什么来保护内部网络免受未经授权的访问和攻击？

A、身份验证

B、双因素认证

C、过滤网络流量

D、定义的访问控制策略

答案:C"

"Q1316、根据《生成式人工智能服务管理暂行办法》，提供者在用户使用生成式人工智能服务时，应当（ ）。"

A、无需核验用户身份

B、按照《网络安全法》的规定要求用户提供真实身份信息

C、允许匿名使用全部功能

D、仅在付费时核验身份

答案:B"

Q1317、在数据交易过程中，数据的隐私保护和安全性是首要考虑的问题，通常通过匿名化、加密等技术手段来实现。（正确）

"Q1318、某电商平台合规团队在审查供应商协议时，发现某数据分析服务商合同中约定""服务商可将分析结果用于改进其他客户的服务""。该条款存在哪些合规风险？

A、数据处理目的超出委托范围，违反《个人信息保护法》关于受托方不得超出委托目的处理个人信息的规定

B、仅属于商业条款，无合规风险

C、该条款合法，属于正常商业授权

D、风险由服务商单独承担，平台无责

答案:A"

"Q1319、以下哪些主体须遵守《人脸识别技术应用

安全管理办法》？

A、在境内使用人脸识别技术处理人脸信息的组织

B、在境内使用人脸识别技术处理人脸信息的个人

C、境外组织向境内提供人脸识别技术服务的

D、仅限于商业互联网企业

答案:ABC"

Q1320、安全保护等级初步确定为第二级及以上的，定级对象的网络运营者需组织网络安全专家和业务专家对定级结果的合理性进行评审，并出具专家评审意见。（正确）

"Q1321、某平台希望把多条零散告警串成一条完整攻击链，最需要强化的能力是（ ）。

A、告警关联分析与上下文整合

B、单纯增加防火墙数量

C、减少日志采集种类

D、关闭异常监测

答案:A"

"Q1322、Kerberos 认证协议是哪种身份认证协议？

A、基于生物特征认证协议

B、基于智能卡认证协议

C、基于时间同步认证协议

D、基于用户名和密码认证协议

答案:C"

"Q1323、根据《数据安全法》，以下哪些做法符合数据安全保护的原则和要求？

A、采取必要措施，保障数据安全和个人信息权益

B、未经个人同意，擅自向第三方提供个人信息

C、建立健全数据安全治理体系，提高数据安全保护能力

D、在处理重要数据时，确保数据安全性和可控性

答案:ACD"

"Q1324、能够把零散的、规则的、不规则的数据通过有效的采集方法采集，并进行储存、加工、处理、分析使其进一步产生新的价值的是（ ）。"

- A、物联网
- B、大数据
- C、移动互联网
- D、云计算

答案:B"

"Q1325、某科技公司发现其 AI 图像识别模型的训练集中包含大量未经授权使用的网络爬取图片，且图片中含有可识别的人脸信息。安全合规团队应优先采取？"

- A、立即停止使用该训练集，评估数据来源合规性，开展个人信息保护影响评估
- B、将图片模糊化后继续使用
- C、仅补充签署用户协议
- D、删除模型即可

答案:A"

Q1326、在 App 界面中应当能够找到隐私政策，包括通过弹窗、文本链接、常见问题（FAQs）等形式。（正确）

"Q1327、对于跨行业融合产生的衍生数据，治理团队在分级时最需要额外关注（ ）。

- A、聚合后新的敏感性和影响范围
- B、原始 Excel 模板颜色
- C、机房地址是否改变
- D、API 文档页边距

答案:A"

"Q1328、学习社会工程学防范措施有哪些好处？"

- A、提高信息安全意识
- B、学习如何鉴别和防御网络攻击者
- C、增强个人信息保护能力

D、了解最新的安全漏洞和威胁

E、防止财产损失

答案:ABCDE"

Q1329、企业应采取网络审计措施，监测、记录系统运行状态、日常操作、故障维护、远程运维等，留存相关日志数据不少于 6 个月。（正确）

"Q1330、某企业将""员工行为监控系统""产生的数据（含浏览记录、文件操作日志）用于人事考核，但未在劳动合同或员工手册中披露。该做法存在的合规风险是？"

- A、未向员工告知个人信息处理规则，违反透明度原则；将监控数据用于考核须有明确法律依据或单独告知同意
- B、企业有权对员工进行全面监控，无需告知
- C、劳动关系中个保法不适用
- D、只要不涉及身份证号即合规

答案:A"

"Q1331、WiFi 安全技术中，物理层安全需求不包含（ ）。

- A、抗干扰
- B、抗衰落
- C、高效的密钥管理需求
- D、抗窃听性

答案:C"

"Q1332、《中共中央、国务院关于构建数据基础制度更好发挥数据要素作用的意见》以解决市场主体遇到的实际问题为导向，创新数据产权观念，淡化所有权、强调使用权，聚焦数据使用权流通，创造性提出建立下列哪一项""三权分置""的数据产权制度框架？"

- A、数据资源持有权、数据加工使用权和数据产品经营权
- B、数据资源所有权、数据加工使用权和数据产品经营权

C、数据资源使用权、数据加工分配权和数据产品转让权

D、数字资源分配权、数字加工持有权和数字产品使用权

答案:A"

"Q1333、某企业数据安全监测平台告警疲劳严重（每日千条误报）。优化方向应为？

A、关闭所有告警

B、优化规则、引入基线学习与关联分析，降低误报率

C、增加运维人员

D、更换供应商

答案:B"

"Q1334、根据《工业和信息化领域数据安全管理办法（试行）》，企业在处理重要数据时，应如何确保数据安全？

A、采取必要的加密措施

B、定期进行数据备份和恢复

C、随意处置数据

D、建立数据安全监测和预警机制

答案:ABD"

"Q1335、《中华人民共和国数据安全法》所称数据，是指任何以电子或者其他方式对信息的记录。其中数据处理，包括数据的（ ）、（ ）、使用、加工、传输、提供、（ ）等。

A、收集

B、存储

C、过滤

D、公开

答案:ABD"

"Q1336、根据《个人信息保护法》，在哪些情形下，个人有权请求删除个人信息？

A、处理目的已实现、无法实现或者为实现处理目的不再必要

B、个人信息处理者停止提供产品或者服务，或者保存期限已届满

C、个人撤回同意

D、个人信息处理者违反法律、行政法规或者约定处理个人信息

答案:ABCD"

"Q1337、某系统需处理大量文件上传，若要测试其是否存在敏感数据绕过上传校验的问题，最合适的测试方法是（ ）。

A、构造边界条件、异常格式和混淆内容进行上传测试

B、只看 UI 颜色

C、只查服务器 CPU

D、只检查合同条款

答案:A"

"Q1338、某平台发现分类分级规则库未随法规更新。维护团队应？

A、规则库固定不变

B、定期依据最新国标/行标修订分类分级规则

C、交由用户自定义

D、删除规则库

答案:B"

"Q1339、《中华人民共和国数据安全法》所称数据安全，是指任何以电子或者其他方式对信息的记录。其中数据安全，是指通过采取必要措施，确保数据处于有效保护和合法利用的状态，以及具备保障（ ）状态的能力。

A、持续安全

B、持续稳定

C、部分安全

D、部分稳定

答案:A"

"Q1340、根据《个人信息保护法》，个人信息处理者应当采取以下哪些措施确保个人信息处理活动符合法律、行政法规的规定？

- A、制定内部管理制度和操作规程
- B、对个人信息实行分类管理
- C、采取相应的加密、去标识化等安全技术措施
- D、定期对从业人员进行安全教育和培训

答案:ABCD"

"Q1341、2018 年 9 月 UNECEWP.29TFCS 工作组发布了《UN_ ECE -WP.29_recommendations on Cyber Security》等三份指导性文件，成为后续（）、（）和（）标准研制的重要参考依据

- A、网络安全
- B、数据保护
- C、软件升级
- D、威胁分析

答案:ABC"

"Q1342、《中华人民共和国网络安全法》规定，国家实行网络安全（ ）保护制度。

- A、架构
- B、分级
- C、涉密
- D、等级

答案:D"

"Q1343、关于 APP 数据安全，以下哪种做法是不正确的？

- A、对用户数据进行加密存储
- B、定期备份用户数据
- C、未经用户同意，将用户数据上传至第三方服务器
- D、防止黑客攻击和数据泄露

答案:C"

"Q1344、某企业发现供应链中一个小型软件供应商发生数据泄露，该供应商持有企业部分客户数据的访问权限。企业应首先采取哪些措施？

- A、立即撤销或冻结该供应商的系统访问权限
- B、评估可能受影响的数据范围和客户数量
- C、依据事件影响程度决定是否触发安全事件报告义务
- D、等待供应商自行处置后再跟进

答案:ABC"

"Q1345、重要数据的处理者应当按照规定对其数据处理活动定期开展风险评估，并向有关主管部门报送（ ）。

- A、数据清单
- B、数据流图
- C、差距整改报告
- D、风险评估报告

答案:D"

"Q1346、最小特权管理原则的目标是什么？

- A、防止特权滥用
- B、确保特权拥有者具备完成任务所需的权限
- C、限制特权拥有者超出完成任务所需的额外权限
- D、提供特权拥有者完全自由的权限管理
- E、保护系统免受外部攻击

答案:ABC"

"Q1347、国家建立（ ），根据数据在经济社会发展中的重要程度，以及一旦遭到篡改、破坏、泄露或者非法获取、非法利用，对国家安全、公共利益或者个人、组织合法权益造成的危害程度，对数据实行分类分级保护。

- A、数据分类分级保护制度
- B、数据保护制度
- C、数据管理制度

D、数据安全治理制度

答案:A"

"Q1348、针对数据迁移保护，对网络服务提供方提出以下哪些要求？

A、在客户服务合同到期时，安全地返还云计算平台上的客户数据

B、为客户数据迁移提供技术手段，并协助完成数据迁移

C、在客户定义的时间内，删除云计算平台上存储的客户数据，并确保不能以商业市场的技术手段恢复

D、无需用户同意，自主将数据迁移至关联应用程序服务商

答案:ABC"

"Q1349、某企业在合规审计中发现，制度要求“所有对外共享须审批”，但系统层面没有任何审批流或留痕。此问题说明（ ）。

A、制度要求未落地到可验证的技术或流程控制

B、制度已存在即可视为合规

C、只要员工知道制度就够了

D、无需整改

答案:A"

"Q1350、等保 2.0 有安全扩展要求包括哪些方面？

A、云计算安全扩展要求

B、移动互联安全扩展要求

C、物联网安全扩展要求

D、工业控制系统安全扩展要求

答案:ABCD"

Q1351、数据备份不会影响系统的正常运行和性能。（错误）

"Q1352、根据《数据安全法》，在中华人民共和国境外开展数据处理活动，损害中华人民共和国国家安全、公共利益或者公民、组织合法权益的，如何处理？

A、依法追究法律责任

B、由境外法院管辖

C、不予追究

D、由当事人协商解决

答案:A"

"Q1353、根据《生成式人工智能服务管理暂行办法》，提供和使用生成式人工智能服务，应当遵守法律、行政法规，尊重社会公德和伦理道德，坚持哪些原则？

A、坚持社会主义核心价值观

B、采取有效措施防止生成虚假信息

C、尊重知识产权、商业道德

D、保护个人隐私

答案:ABCD"

"Q1354、行为人发表的文学、艺术作品以真人真事或者特定人为描述对象，含有侮辱、诽谤内容，侵害他人（ ）的，受害人有权依法请求该行为人承担民事责任。

A、姓名权

B、隐私权

C、名誉权

D、名称权

答案:C"

"Q1355、修订后《网络安全法》与《数据安全法》《个人信息保护法》的关系是？

A、三部法律相互独立，分别适用

B、网安法为上位法，数安法和个保法须服从网安法

C、形成数据安全保护领域的协同互补体系，网安法将个人信息和数据处理违法行为转致适用数安法、个保法的处罚规定

D、数安法和个保法将被网安法完全取代

答案:C"

"Q1356、某企业分类分级报告未包含数据流转图与权限映射表。报告完整性如何？

- A、完整，有清单即可
- B、不完整，缺乏流转与权限视图无法支撑落地管控
- C、仅影响美观
- D、需外部机构签字

答案:B"

"Q1357、以下行为不正确的是（ ）？

- A、账号口令写在便利贴，贴在显示器上方便使用
- B、开电脑时未锁屏，电脑未设置带口令的屏保
- C、数据库账号管理三权分立
- D、看完涉密文件用碎纸机粉碎

答案:AB"

"Q1358、配套《人工智能生成合成内容标识办法》发布的强制性国家标准是（ ）。

- A、《网络安全技术 人工智能生成合成内容标识方法》（强制性国家标准）
- B、《数据安全技术 数据分类分级规则》
- C、《数据安全技术 数据安全风险评估方法》
- D、《数据安全技术 个人信息保护合规审计要求》

答案:A"

"Q1359、某系统上线前希望发现“接口是否存在越权读取敏感字段”的问题，最适合增加的测试是（ ）。

- A、基于不同角色令牌的接口权限测试
- B、仅做 UI 兼容测试
- C、只检测硬盘坏道
- D、只测试页面加载速度

答案:A"

"Q1360、某企业对同一客户在 CRM、ERP、客服系统中形成了 3 套不同口径的“客户等级”。优先级最高的治理动作是（ ）。

- A、建立统一口径的数据标准与主数据治理流程
- B、只保留客服系统口径
- C、由各部门继续独立维护
- D、停止所有客户分析

答案:A"

"Q1361、数据安全方案中，若公共接口允许无限次调用且无频率控制，可能导致的首要风险是（ ）。

- A、接口被批量滥用、爬取或拖垮服务
- B、数据库自动加密
- C、密钥自动轮换
- D、日志自动归档

答案:A"

"Q1362、在应用安全中，“SQL 注入”主要是由于下列哪种原因？

- A、数据库版本过低
- B、缺少输入校验
- C、数据库权限过高
- D、网络连接不稳定

答案:B"

"Q1363、依据 ISO 27001，信息系统审计是（ ）。

- A、应在系统运行期间进行，以便于准确地发现弱点
- B、审计工具在组织内应公开可获取，以便于提升员工的能力
- C、发现信息系统脆弱性的手段之一
- D、只要定期进行，就可以替代内部 ISMS 审核

答案:C"

"Q1364、防范 API 密钥泄露的最佳做法是？

- A、硬编码到客户端
- B、JWT 短期令牌+动态刷新
- C、使用 Basic Auth

D、定期人工更换

答案:B"

"Q1365、某金融机构计划引入第三方大数据风控服务，风控服务商需要访问客户交易流水数据。合规审查应重点关注？

- A、数据处理委托协议中的安全保护义务条款
- B、风控服务商的数据安全资质与能力
- C、是否需要获得客户单独同意
- D、数据在服务商处的留存期限与销毁机制

答案:ABCD"

"Q1366、零信任安全模型的核心概念是什么？

- A、信任所有用户和设备
- B、控制网络边界安全
- C、仅限制外部网络访问
- D、不信任任何用户和设备，始终验证

答案:D"

"Q1367、某业务方要求“对所有数据永久留存，以便未来可能的数据价值挖掘”。安全架构设计时最合理的回应是（ ）。

- A、数据价值未知时可无限期留存
- B、应按明确目的和必要性设置分层留存策略，不得无限制长期保留
- C、只要内网存储就可以永久保留
- D、由业务部门决定即可

答案:B"

"Q1368、下面哪个是社会工程学的常见形式？

- A、加密技术
- B、数据分析
- C、钓鱼攻击
- D、防火墙配置

答案:C"

Q1369、侧信道攻击是指攻击者通过分析身份验证系统的侧信道信息，如时间延迟、功耗消耗等，来推断出有效的身份验证凭据。（正确）

"Q1370、信息通过网络进行传输的过程中，存在被篡改的风险，为了解决这一安全隐患通常采用的安全防护技术是（ ）。

- A、信息隐藏技术
- B、数据加密技术
- C、数据备份技术
- D、消息认证技术

答案:D"

"Q1371、如果组织希望实现“按数据重要性自动触发差异化保护策略”，最需要的基础前提是（ ）。

- A、稳定的数据分类分级结果与标签映射机制
- B、所有员工统一使用同一账号
- C、只依赖人工经验判断
- D、关闭日志系统

答案:A"

"Q1372、违反国家核心数据管理制度，危害国家主权、安全和发展利益的，由有关主管部门处（ ）万元以上（ ）万元以下罚款，并根据情况责令暂停相关业务、停业整顿、吊销相关业务许可证或者吊销营业执照；构成犯罪的，依法追究刑事责任。

- A、100200
- B、200500
- C、2001000
- D、5001000

答案:C"

"Q1373、大数据强调（ ），而非小数据的随机抽样。

- A、关键数据
- B、重要数据
- C、海量数据

D、高质量数据

答案:C"

Q1374、县级以上人民政府应当将密码工作纳入本级国民经济和社会发展规划，所需经费列入本级财政预算。（正确）

"Q1375、ZigBee 根据服务与需求使多个器件之间进行通信（ ）。

A、物理层

B、MAC 层

C、网络/安全层

D、支持/应用层

答案:D"

Q1376、口令序列认证是基于哈希链的认证。（正确）

"Q1377、入网访问控制是网络访问的第一层访问控制，主要用于。

A、防止非法操作

B、控制用户的访问时间和地点

C、识别和验证用户名和口令

D、检查用户账号的默认限制

E、记录用户对网络资源的访问

答案:ABCD"

"Q1378、在元数据治理中，“业务元数据”最能回答的问题是（ ）。

A、这份数据在业务上代表什么、由谁负责、用于什么场景

B、服务器网卡型号是什么

C、硬盘品牌是什么

D、机房照明强度是多少

答案:A"

Q1379、在网络安全等级保护测评过程中，应对信息系统的登录采取两种或两种以上的组合技术对用户

身份进行鉴别。（正确）

"Q1380、某企业发现其高危数据告警均通过邮箱发送，但值守人员周末不看邮箱，导致事件响应滞后。首要优化方向是（ ）。

A、建立多通道值守告警和轮值响应机制

B、减少周末值守要求

C、取消邮件告警

D、只在工作日收集日志

答案:A"

"Q1381、AES 中的非线性组件是（ ）。

A、S 盒

B、行移位

C、列混合

D、轮密码加

答案:A"

"Q1382、修订后《网络安全法》要求行政处罚裁量基准的制定目的是？

A、降低企业违法成本

B、规范行政机关依法行使行政处罚裁量权，避免处罚畸轻畸重

C、简化行政处罚程序

D、统一各地区的处罚金额

答案:B"

"Q1383、违反必要性原则，收集与其提供的服务无关的个人信息的情形有哪些？

A、捆绑多项业务功能一揽子征求用户同意，不同意则不提供任何单一服务

B、当用户拒绝某一业务功能收集个人信息的请求时，App 停止提供其他业务功能

C、新增业务功能时，需收集的个人信息超出原有同意范围，如用户不同意收集，则拒绝提供原有业务功能，新增业务功能将取代原有业务功能的除外

D、在用户使用业务功能时，收集个人信息的频率等超出所使用的业务功能需要

答案:ABCD"

"Q1384、下列哪些是 Wi-Fi 的特点？

- A、可基于 AP 组建基础设施网络
- B、可建立临时对等连接
- C、只能传送信息给 FFD 或从 FFD 接收信息
- D、必须使用 ZigBee 协议

答案:AB"

"Q1385、分布式账本的特征包括。

- A、中心化
- B、防篡改
- C、透明性
- D、抗毁坏

答案:BCD"

"Q1386、在零信任安全模型中，多因素身份验证通常包括以下哪些因素？

- A、用户名和密码
- B、指纹扫描
- C、手机验证码
- D、IP 地址
- E、数字证书

答案:ABC"

"Q1387、某企业实施分类分级时，业务部门拒绝配合提供数据字典。项目经理应？

- A、强制要求并上报管理层协调
- B、自行猜测字段含义
- C、跳过该部门数据
- D、仅依赖技术元数据

答案:A"

Q1388、访问控制参考模型由主体、参考监视器、客体、访问控制数据库和审计库构成。（正确）

"Q1389、个人信息处理者向中华人民共和国境外提供个人信息的，应当向个人告知：

- A、境外接收方的联系方式
- B、境外接收方的名称或者姓名
- C、境外接收方的处理目的和处理方式
- D、个人信息的种类以及个人向境外接收方行使本法规定权利的方式和程序

答案:ABCD"

"Q1390、下列哪项主要工作在数据链路层，而不是网络层？

- A、有线等价保密协议（WEPP）
- B、虚拟专用网（VPN）
- C、IPSec
- D、路由选择

答案:A"

"Q1391、以下属于安全多方计算攻击模型的是（）

- A、诚实模型
- B、半诚实模型
- C、隐蔽模型
- D、恶意模型

答案:BCD"

"Q1392、数据安全风险评估是指：

- A、对数据安全进行全面评估和分析的过程
- B、对数据网络设备进行性能测试的过程
- C、对数据网络连接进行速度测试的过程
- D、对数据网络用户进行身份验证的过程

答案:A"

Q1393、访问控制的目的是保护系统的机密性，但不包括保护系统的完整性和可用性。（错误）

"Q1394、为确保信息资产的容量可以通过增加容量或减少需求来实现，应考虑以下哪些因素来增加容量？

- A、雇用新员工
- B、获得新的设施或空间
- C、获得更强大的处理系统、内存和存储
- D、利用云计算，它具有直接解决容量问题的固有特征

答案:ABCD"

Q1395、不涉及个人信息的数据可以任意进行跨境传输。（错误）

"Q1396、访问控制包括哪些方面？

- A、授权
- B、控制访问方法和运行机制
- C、安全审计和监控
- D、入侵检测

答案:ABC"

"Q1397、实践中常使用软件缺陷密度

（Defects/KLOC）来衡量软件的安全性，假设某个软件共有 30 万行源代码，总共检出 150 个缺陷，则可以计算出其软件缺陷密度值是（ ）。

- A、0.0005
- B、0.05
- C、0.5
- D、5

答案:C"

"Q1398、某政务系统数据梳理发现""地理信息数据""涉密但未标密。应？

- A、公开共享
- B、立即依据保密规定定密，实施隔离管控
- C、仅内部使用
- D、删除所有数据

答案:B"

"Q1399、某企业数据安全合规审计发现，数据出境业务中有 3 项应当申报安全评估但未申报。企业认为""数据已加密，不存在风险""。审计人员应如何回应？

- A、加密是技术控制手段，但不能豁免安全评估的法定程序要求；须立即补办申报手续
- B、加密后出境无需评估，企业说法正确
- C、由企业自行判断风险等级
- D、数据量小可豁免

答案:A"

"Q1400、某政务平台梳理出 200 个数据表，但元数据描述缺失。分类分级实施第一步应？

- A、直接打标分级
- B、补全元数据与业务含义说明
- C、随机抽样分级
- D、交由 AI 自动处理

答案:B"

"Q1401、在合规评估项目中，评估范围定义错误最容易导致（ ）。

- A、关键系统或关键处理活动被遗漏，结论失真
- B、日志自动增加
- C、带宽占用下降
- D、数据库自动升级

答案:A"

"Q1402、下列哪些数据对象适合作为数据分类分级的最小分析单元？

- A、数据项（字段）
- B、数据集（如表、文件）
- C、衍生数据
- D、跨行业融合数据

答案:ABCD"

"Q1403、根据《个人信息保护法》第三十八条，个人信息处理者因业务需要向境外提供个人信息的，须具备的条件不包括以下哪一项？

- A、通过国家网信部门组织的安全评估
- B、经专业机构进行个人信息保护认证
- C、与境外接收方订立标准合同
- D、向国家市场监督管理总局备案注册

答案:D"

"Q1404、GB/T 43697-2024 将数据分为哪几种主要类型？

- A、个人数据
- B、公共数据
- C、行业数据（业务数据）
- D、衍生数据

答案:ABCD"

"Q1405、区块链技术最初是为了解决什么问题而提出的（ ）。"

- A、数据存储效率
- B、数字版权管理
- C、货币的去中心化
- D、社交网络隐私

答案:C"

"Q1406、在数据安全架构设计中，若上游系统传输的数据未经分类分级直接进入共享平台，最直接的问题是（ ）。

- A、平台无法按风险实施差异化控制
- B、平台一定会宕机
- C、用户密码复杂度降低
- D、日志无法留存

答案:A"

Q1407、数据交易市场需要遵循明确的数据交易规则和法律法规，以确保交易的合法性和公平性。（正

确）

"Q1408、某企业在数据安全事件发生后，向监管部门报告称""已采取措施，影响可控""，但实际上对泄露数据的类型、数量、影响范围尚未完成排查。该报告是否合规？

- A、合规，只要第一时间报告即满足要求
- B、不合规；报告须包含事件基本情况，在未完成排查前应明确说明信息待核实，不得以""可控""误导监管
- C、监管不关注事件规模，只要报告即可
- D、可以在复盘后再补充报告，初始报告无需准确

答案:B"

"Q1409、物联网中的网络隔离是指什么？

- A、将物联网设备与互联网隔离
- B、将不同的物联网设备划分到独立的网络
- C、阻止物联网设备之间的通信
- D、限制物联网设备的访问速度

答案:B"

Q1410、个人信息保护影响评估报告和处理情况记录应当至少保存两年。（错误）

"Q1411、某政务系统接口遭参数篡改攻击，因未实施签名校验。应？

- A、仅前端校验
- B、忽略参数篡改
- C、对关键请求参数实施防篡改签名（如 HMAC）与重放攻击防护
- D、仅记录日志

答案:C"

"Q1412、访问控制的控制策略是指什么？

- A、一个提出请求或要求的实体，是动作的发起者
- B、接受其他实体访问的被动实体
- C、主动发起访问请求的实体

D、主体对客体的访问规则集，即属性集合

答案:D"

Q1413、撞库攻击是指攻击者通过获取已经泄露的用户名和密码组合，尝试在其他网站或服务中使用这些凭据进行身份验证。（正确）

"Q1414、根据《数据安全法》规定，维护数据安全，应当坚持总体国家安全观，建立健全数据安全（），提高数据安全保障能力。

A、保障体系

B、治理体系

C、标准体系

D、评估体系

答案:B"

"Q1415、无民事行为能力人、限制民事行为能力人造成他人损害的，由（ ）承担侵权责任。

A、监护人

B、亲人

C、父母

D、配偶

答案:A"

"Q1416、在科举考试中，考官必须采用锁厅制进行封闭出卷，封闭在考场中出题，并且周围有兵丁把守，禁止内外交流，这种措施体现了数据安全的什么手段（ ）？

A、脱敏

B、物理隔离

C、身份识别与多因素认证

D、加密

答案:B"

"Q1417、《中华人民共和国民法典》规定，信息处理者不得泄露或者篡改其（ ）、存储的个人信息；未经自然人同意，不得向他人非法提供其个人信息，但是经过加工无法识别特定个人且不能复原的除

外。

A、收集

B、获取

C、整合

D、管理

答案:A"

"Q1418、有关部门组织开展关键信息基础设施安全检测评估（ ）。

A、需要被检部门购买指定安全公司的服务以及安全设备

B、不得向被检测评估单位收取费用

C、如果发现被检部门未自费购买指定安全公司的服务及安全设备，则该部门安全负责人将按刑法处罚

D、按实际的评估成本进行收费

答案:B"

"Q1419、根据 GB/T 43697-2024，数据分级的主要依据是？

A、数据在经济社会发展中的重要程度

B、数据一旦泄露、篡改或破坏后可能造成的危害程度

C、数据文件的物理存储位置

D、数据受损对国家安全、公共利益或个人权益的影响

答案:ABD"

Q1420、电子签名，是指数据电文中以电子形式所含、所附用于识别签名人权利能力并表明签名人认可其中内容的数据。（错误）

"Q1421、某企业已完成数据出境安全评估并获批，但后续业务调整导致出境数据类型超出评估时的申报范围。应如何处理？

A、在原批准范围内可直接扩展

B、须重新申报安全评估，不得超出评估时明确的范围

C、向数据接收方告知即可

D、内部重新审批后出境

答案:B"

Q1422、使用未公开披露的监管数据，可以在连接互联网的台式机或笔记本等工作机中进行。（错误）

"Q1423、根据《人脸识别技术应用安全管理办法》，人脸信息的存储期限应以（ ）为准，不得超过处理目的所需最短时间。

A、行业平均水平

B、合同约定期限

C、实现处理目的所必要的最短时间

D、企业自主设定的保存期限

答案:C"

"Q1424、数据备份和恢复是大数据安全中的重要措施，其目的是（ ）。

A、保护数据免受未经授权的访问

B、提高数据处理和分析的效率

C、防止数据丢失和损失

D、监控和追踪数据传输的速度和带宽

答案:C"

"Q1425、零信任安全模型要求哪些策略来监控和检测潜在的威胁？

A、实时流量分析

B、防火墙配置

C、持续身份验证策略

D、加密通信

E、硬件防护设备

答案:AC"

"Q1426、《数据安全法 数据分类分级规则》（GB/T 43697-2024）中对于衍生数据的定义是（ ）。

A、组织在自身生产经营活动中收集、产生的不涉及

个人信息和公共利益的数据

B、经过统计、关联、挖掘、聚合、去标识化等加工活动而产生的数据

C、各级政务部门、具有公共管理和服务职能的组织及其技术支撑单位，在依法履行公共事务管理职责或提供公共服务过程中收集、产生的数据

D、在某个行业领域内依法履行工作职责或开展业务活动中收集和产生的数据

答案:B"

"Q1427、区块链技术中的挖矿是指（ ）。

A、通过解决复杂的数学问题来创建新的区块

B、通过购买和出售加密货币来获取利润

C、通过在区块链网络中传输数据来验证交易

D、通过分配计算资源来维护区块链网络的安全性

答案:A"

"Q1428、网络安全等级保护第三级对于应用访问的身份鉴别的要求：需采用（ ）身份鉴别技术的组合来进行身份鉴别，并保证至少有一种是不可伪造的。

A、一个及以上

B、两个及以上

C、至少三个

D、生物特征识别

答案:B"

"Q1429、下列哪些是访问控制的主要产品？

A、4A 系统

B、安全网关

C、系统安全增强

D、防火墙

E、数据库管理系统

答案:ABCD"

"Q1430、我国定义的五大生产要素，不包括：

() ?

- A、数据
- B、能源
- C、劳动力
- D、资本

答案:B"

"Q1431、某企业已形成数据资产地图,但未将“数据处理责任人”纳入其中。该缺陷最可能导致 ()。

- A、无法有效开展责任追溯和整改闭环
- B、系统 CPU 使用率升高
- C、数据加密自动失效
- D、网络带宽立即下降

答案:A"

"Q1432、下列哪些属于《数据安全法》规定的数据处理者应当履行的义务?

- A、采取技术措施保障数据安全
- B、配合国家安全机关的数据安全监管工作
- C、对外提供数据前进行安全评估
- D、拒绝任何数据安全检查和评估

答案:ABC"

"Q1433、某企业数据安全负责人发现,公司《数据安全管理制度》已三年未修订,其中引用的法规条款多处已被新法取代。应采取什么措施?

- A、组织专项修订,对照现行有效法规条款逐一核对更新,并重新培训相关人员
- B、制度已有即可,不必频繁修订
- C、仅更新条款号,内容无需改动
- D、等下次监管检查时再修订

答案:A"

"Q1434、根据《数据安全法》,开展数据处理活动应当依照法律、法规的规定,建立健全 () 管理制

度,组织开展数据安全教育培训。

- A、全流程数据安全
- B、数据风险评估
- C、数据泄露应急处置
- D、数据归档管理

答案:A"

"Q1435、某 App 运营者在 App 上线 6 个月后将隐私政策从""仅限产品功能使用""单方面修改为""可用于第三方商业合作"",未通知现有用户重新授权。该行为违反?

- A、《个人信息保护法》关于同意须在信息处理前获取,及变更处理目的须重新获取同意的规定
- B、《合同法》格式条款规定
- C、《消费者权益保护法》退款规定
- D、《广告法》

答案:A"

"Q1436、以下数据中属于国家核心数据的是 () ?

- A、关系国家安全的数据
- B、关系国民经济命脉的数据
- C、关系重要民生的数据
- D、关系重大公共利益的数据

答案:ABCD"

"Q1437、根据《数据安全法》,国家建立数据安全风险评估、报告、信息共享、监测预警机制。负责统筹协调建立该机制的部门是?

- A、国务院工业和信息化主管部门
- B、国务院公安部门
- C、国家数据安全工作协调机制
- D、国务院保密行政管理部门

答案:C"

"Q1438、场景:某国际集团官方微博发布声明称,客房预订数据库被黑客入侵,约 5 亿名客人的信息

或被泄露。包括 1.3 亿客人信息（姓名+护照号+信用卡），内部运维账号（可访问核心数据库）。

问题：可降低第三方风险的防御措施是？

- A、强制第三方接入 MFA 双因素认证
- B、签订数据保护协议并定期审计
- C、向第三方开放数据库只读权限
- D、实施网络隔离（如跳板机访问）
- E、共享管理员账号提升效率

答案:ABD"

Q1439、在联盟链场景下，由于节点准入机制的存在，区块链账本数据即使未加密存储也不会导致隐私泄露风险。（错误）

Q1440、访问控制产品的技术指标包括支持的访问控制策略规则类型和最大规则数量。（正确）

"Q1441、数据的单位，从小到大依次排序正确的是？（ ）

- A、TB<GB<MB<KB
- B、MB<GB<TB<PB
- C、PB<TB<MB<GB
- D、MB<TB<EB<GB

答案:B"

"Q1442、安全管理机构要求包括？

- A、应成立网络安全工作委员会或领导小组，明确一名领导班子成员作为首席网络安全官，专职管理或分管关键信息基础设施安全保护工作
- B、应设置专门的网络安全管理机构，明确机构负责人及岗位，建立并实施网络安全考核及监督问责机制
- C、应为每个关键信息基础设施明确一名安全管理责任人
- D、应将安全管理机构人员纳入本组织信息化决策体系

答案:ABCD"

"Q1443、用户名和密码是一种常见的身份认证方法，它属于（ ）类型的认证。

- A、双因素认证
- B、多因素认证
- C、单因素认证
- D、强制认证

答案:C"

"Q1444、数据安全工程技术人员在数据出境安全评估中的高级能力，最能体现在哪项工作上？

- A、仅统计出境数据量
- B、综合评估数据类型、出境链路、境外接收方能力、所在国环境、合同约束及数据主体权益影响
- C、只关注是否签了合同
- D、只要加密传输即可视为合规

答案:B"

Q1445、IIS FTP 服务器仅支持用户账户认证，不支持匿名访问控制和 IP 地址限制。（错误）

"Q1446、在实施数据安全项目时，若多个技术控制项之间存在联动关系，最合理的交付策略是（ ）。

- A、建立依赖关系和分阶段实施计划，避免控制项孤立部署
- B、随机选择先后顺序
- C、只要买齐产品即可
- D、先上线业务，后补全部安全控制

答案:A"

"Q1447、属性基础访问控制模型（ABAC）是基于什么来决定用户对资源的访问权限？

- A、用户属性
- B、资源属性
- C、环境属性
- D、用户角色

答案:ABC"

"Q1448、《重要数据识别指南》中的""重要数据""是指哪些（ ）。"

- A、关系国家安全、国民经济命脉、重要民生、重大公共利益等数据
- B、一旦泄露可能直接影响国家安全、经济安全、社会稳定、公共健康和安全
- C、未公开的政府信息，大面积人口、基因健康、地理、矿产资源等
- D、以上都是

答案:D"

"Q1449、以""境外实体接触""为标准，数据跨境主要包括？"

- A、数据跨越国界的传输、转移行为
- B、尽管数据尚未跨越国界，但能够被境外的主体进行访问
- C、数据跨越国界的提供行为
- D、数据跨越国界的服务行为

答案:AB"

"Q1450、等保 2.0 有安全扩展要求不包括下面哪一项？"

- A、云计算
- B、AI（人工智能）
- C、移动互联
- D、物联网

答案:B"

"Q1451、国家建立网络安全监测预警和（ ）。国家网信部门应当统筹协调有关部门加强网络安全信息收集、分析和通报工作，按照规定统一发布网络安全监测预警信息。"

- A、信息共享制度
- B、信息传输制度
- C、信息通报制度

D、信息保护制度

答案:C"

Q1452、适用本条例的计算机信息系统包括未联网的微型计算机。（错误）

Q1453、TCP/IP 协议中数据封装顺序是：传输层、互联网络层、网络接口层。（正确）

"Q1454、以下哪些属于企业在评估数据资产经济利益流入可能性时需要考虑的因素？"

- A、数据来源的合法性
- B、市场分析的结果
- C、合同协议的约束
- D、历史数据的表现
- E、数据分析技术的成熟度

答案:BCD"

"Q1455、根据《个人信息保护法》，个人对个人信息处理享有哪些权利？"

- A、知情权、决定权
- B、查阅、复制权
- C、更正、补充权
- D、删除权

答案:ABCD"

"Q1456、无线传感网相关标准。"

- A、传感器到通信模块接口技术标准
- B、节点设备技术标准等
- C、电路标准
- D、感知标准

答案:AB"

"Q1457、利用网络爬虫技术侵入除国家事务、国防建设、尖端科学技术领域以外的计算机信息系统，获取该系统中存储、处理或传输的数据的，可能构成的罪名是？"

- A、非法侵入计算机信息系统罪

B、非法获取计算机信息系统数据罪

C、侵犯公民个人信息罪

D、破坏计算机信息系统罪

答案:B"

Q1458、数据分类分级是开展数据安全体系建设的基础。（正确）

"Q1459、某企业数据质量评估发现""客户地址""字段缺失率超 30%。该问题影响？

A、数据可用性分析与业务决策准确性

B、系统响应速度

C、网络带宽

D、前端显示

答案:A"

"Q1460、依据《个人信息保护法》，个人信息处理者委托他人处理个人信息时，委托方应当履行哪些义务？

A、与受托人约定处理目的、期限、方式、个人信息种类、保护措施以及双方权利义务

B、对受托人的个人信息处理活动进行监督

C、在法定情形下事前进行个人信息保护影响评估

D、委托后即可免除个人信息保护责任

答案:ABC"

"Q1461、关键信息基础设施安全保护条例适用于：在中华人民共和国境内（ ）关键信息基础设施，以及开展关键信息基础设施的安全保护。

A、规划

B、建设

C、维护

D、售卖

答案:ABC"

"Q1462、在数据安全能力成熟度模型中，哪些因素会影响企业的数据安全能力？

A、组织结构

B、技术水平

C、员工素质

D、制度流程

答案:ABCD"

"Q1463、某政务系统数据梳理发现""行政审批材料""含个人签名与印章，未脱敏即归档。应？

A、直接公开

B、对敏感元素实施图像脱敏或访问控制

C、仅加密存储

D、删除材料

答案:B"

"Q1464、部署 IPsec VPN 时，以下说法正确的是（ ）。

A、配置 MD5 安全算法可以提供可靠的数据加密

B、配置 AES 算法可以提供可靠的数据完整性验证

C、部署 IPsec VPN 网络时，需要考虑 IP 地址的规划，尽量在分支节点使用可以聚合的 IP 地址段，来减少 IPsec 安全关联（SA）资源的消耗

D、报文验证头协议（AH）可以提供数据机密性

答案:C"

"Q1465、某企业发现分类分级工具将""测试数据""误标为生产重要数据。应如何处理？

A、维持标记

B、明确测试/生产环境边界，调整工具规则并人工复核

C、删除测试环境

D、交由外部认证

答案:B"

"Q1466、以下行为违法的有：

A、通过普通邮政、快递等无保密措施的渠道传递国家秘密载体的

B、邮寄、托运国家秘密载体出境，或者未经有关主管部门批准，携带、传递国家秘密载体出境的

C、将涉密计算机、涉密存储设备接入互联网及其他公共信息网络的

D、使用非涉密计算机、非涉密存储设备存储、处理国家秘密信息的

答案:ABCD"

Q1467、删除不满十四周岁未成年人的个人信息，不需要取得未成年人的父母或其他监护人的同意。（错误）

"Q1468、以下 4 种对 BLP 模型的描述中，正确的是（）：

A、BLP 模型用于保证系统信息的机密性，规则是“向上读，向下写”

B、BLP 模型用于保证系统信息的机密性，规则是“向下读，向上写”

C、BLP 模型用于保证系统信息的完整性，规则是“向上读，向下写”

D、BLP 模型用于保证系统信息的完整性，规则是“向下读，向上写”

答案:B"

"Q1469、国家建立集中统一、高效权威的数据安全风险（ ）机制。

A、评估

B、报告

C、信息共享

D、监测预警

答案:ABCD"

"Q1470、认证是证实某事是否名副其实或者是否有效的一个过程。以下关于认证的叙述中，不正确的是（）。

A、认证能够有效阻止主动攻击

B、认证常用的参数有口令、标识符、生物特征等

C、认证不允许第三方参与验证过程

D、身份认证的目的是识别用户的合法性，阻止非法用户访问系统

答案:C"

Q1471、密码学中的“一次一密”是理论上唯一已知的绝对安全的加密方法。（正确）

"Q1472、关于特权访问，下列哪些说法正确的是？

A、特权访问用户必须包含最高管理者

B、特权访问用户通常不包含顾客

C、特权访问应遵循最小必要授权原则

D、特殊访问权应与其职能角色一致

答案:BCD"

"Q1473、关于区块链的隐私保护，正确的是？

A、智能合约的代码逻辑本身可确保合约交互数据的保密性

B、零知识证明可用于隐藏交易细节

C、环签名技术用于混淆交易发送者

D、所有区块链均默认隐藏用户地址

答案:BC"

"Q1474、对于安全交付验收，若只验证“功能可用”，不验证“审计、留痕、权限、生效”，最主要问题是（）。

A、安全能力可能未真正落地

B、数据库容量一定不足

C、备份将全部失效

D、机房门禁会异常

答案:A"

Q1475、凡是涉及收集个人信息的企业都应该制定隐私政策。（正确）

"Q1476、身份认证的目的是什么？

A、对事物的资质审查

- B、对事物真实性的确认
- C、对事物的合法性的确认
- D、对事物的权限进行确认

答案:B"

"Q1477、以下关于模糊测试过程的说法正确的是。

- A、模糊测试的效果与覆盖能力，与输入样本选择密切相关
- B、为保障安全测试的效果和自动化过程，关键是将发现的异常进行现场保护记录，系统可能无法恢复异常状态进行后续的测试
- C、通过异常样本重现异常，人工分析异常原因，判断是否为潜在的安全漏洞，如果是安全漏洞，就需要进一步分析其危害性、影响范围和修复建议
- D、对于可能产生的大量异常报告，应借助自动化工具辅助分析，而非全部人工分析

答案:ABCD"

"Q1478、生物特征认证一般需要经过哪三个过程？

- A、图像采集、特征提取和特征匹配
- B、用户名和密码、共享密钥和口令、算法
- C、IC 卡和 PIN、共享密钥和口令、算法
- D、随机数值、共享密钥和口令、算法

答案:A"

"Q1479、数据合规风险评估流程包括评估准备、合规义务识别、风险识别、()、风险评价等。

- A、风险管理
- B、风险分析
- C、风险检测
- D、风险源识别

答案:B"

"Q1480、以下关于""重要数据""出境的说法，正确的是？

- A、重要数据出境无需任何合规程序

B、重要数据出境须经数据出境安全评估，无法通过标准合同或认证替代

C、重要数据出境只需内部审批

D、重要数据出境可与个人信息出境合并申报

答案:B"

"Q1481、《电子合同取证流程规范》中规定的电子取证的基本流程包含

- A、申请
- B、受理
- C、批准
- D、验证
- E、出证

答案:ABDE"

"Q1482、根据《个人信息保护法》，以下哪些是国家网信部门在个人信息保护领域的职责？

- A、制定个人信息保护具体规则、标准
- B、指导、监督重要互联网平台服务的个人信息保护工作
- C、构建个人信息保护社会共治格局
- D、代替公安机关侦查个人信息犯罪案件

答案:ABC"

"Q1483、在身份认证中，挑战-响应协议是一种常见的认证方法，它的基本原理是()。

- A、服务器发送一个随机挑战给客户端，客户端使用密码进行响应
- B、客户端发送一个随机挑战给服务器，服务器使用密码进行响应
- C、客户端发送一个随机挑战给服务器，服务器使用公钥进行响应
- D、服务器发送一个随机挑战给客户端，客户端使用公钥进行响应

答案:A"

"Q1484、在信息安全 CIA 三要素中，下列哪种措施最直接用于保障数据的机密性（Confidentiality）？

- A、数据备份与冗余存储
- B、数据加密
- C、日志审计
- D、数据完整性校验

答案:B"

"Q1485、GDPR 第 15 条主要规定了数据主体的哪项权利？

- A、删除权
- B、访问权
- C、更正权
- D、反对权

答案:B"

"Q1486、数据安全责任，按照（）的原则确定。

- A、谁所有谁负责、谁持有谁负责、谁管理谁负责、谁使用谁负责、谁采集谁负责
- B、谁所有谁负责、谁持有谁负责、谁管理谁负责、谁使用谁负责
- C、谁所有谁负责、谁持有谁负责、谁管理谁负责
- D、谁所有谁负责、谁持有谁负责

答案:A"

"Q1487、防止计算机中信息被窃采取的手段不包括？

- A、用户识别
- B、权限控制
- C、病毒控制
- D、数据加密

答案:C"

"Q1488、某政务系统数据梳理发现""财政预算数据""未区分公开版与内部版。应？

- A、统一公开
- B、建立数据多版本管理，明确公开边界与审批流程
- C、统一保密
- D、仅 IT 控制

答案:B"

Q1489、非敏感个人信息处理者无需定期进行合规审计。（错误）

"Q1490、某业务提出“先收集全量用户行为，后续再决定用途”，从数据安全需求分析角度看，主要问题是（）。

- A、违反最小必要和目的明确原则
- B、便于后续算法训练，属于最佳实践
- C、只要加密存储就没有问题
- D、与数据安全无关

答案:A"

"Q1491、某金融机构数据脱敏后仍可通过关联分析还原。应？

- A、评估脱敏算法强度，采用不可逆哈希/泛化/扰动组合策略
- B、维持当前脱敏
- C、取消脱敏
- D、仅加密即可

答案:A"

Q1492、爬虫技术本身是中立的，因此可以利用爬虫爬取任何数据。（错误）

"Q1493、防范恶意软件应基于恶意软件检测和修复软件、信息安全意识、适当的系统访问和变更管理控制，下列哪些防范措施是正确的？

- A、实施防止或检测使用未经授权软件的规则和控制
- B、实施防止或检测使用已知或可疑恶意网站的控制
- C、减少可被恶意软件利用的漏洞
- D、安装并定期更新恶意软件检测和修复软件，以扫

描计算机和电子存储介质

答案:ABCD"

Q1494、社会工程学攻击者通常试图操纵人们的行为和心理状态，以获得未经授权的访问或敏感信息。

（正确）

"Q1495、在 CP-ABE （密文策略属性基加密）中，使用 LSSS（线性秘密共享）矩阵的主要目的是（ ）。

- A、为每个用户生成独立的公钥
- B、将访问策略转换为一组线性关系，控制密钥聚合
- C、确保加密密文的对称性
- D、实现密钥撤销机制

答案:B"

"Q1496、网络社会工程学攻击的防范措施应该包括哪些方面？

- A、提高警觉性、保护个人信息、使用安全软件、定期更新密码等
- B、提高人际交往能力、增强自信心、增强抵抗力、加强运动等
- C、提高学历水平、增强沟通能力、增加社交圈子、扩大人脉等
- D、以上都不是

答案:A"

"Q1497、根据《网络安全法》的规定，关键信息基础设施的运营者应当履行下列哪些安全保护义务？

- A、设置专门安全管理机构和安全管理负责人，并对该负责人和关键岗位的人员进行安全背景审查
- B、定期对从业人员进行网络安全教育、技术培训和技能考核
- C、对重要系统和数据库进行容灾备份
- D、制定网络安全事件应急预案，并定期进行演练

答案:ABCD"

Q1498、书面形式的涉密载体，应在封面或者首页做

出国家秘密标志，汇编涉密文件、资料或摘录、引用属于国家秘密内容的应按照其中最高密级和最长保密期限标注。（正确）

"Q1499、Windows 系统中，用户登录时会创建一个包含哪些信息的访问令牌？

- A、用户的安全标识符（SID）
- B、用户的权限
- C、用户所属组的信息
- D、用户的访问历史记录
- E、网页 Cookie

答案:ABC"

"Q1500、通信协议要求通信者传输什么信息？

- A、个人资料
- B、身份信息
- C、财务信息
- D、账号密码信息

答案:B"

"Q1501、某企业将所有高危告警都交由人工逐条处理，结果平均处理时长持续超标。最合理的优化方向是（ ）。

- A、对重复性高、规则明确的告警引入自动化编排和分级处置
- B、关闭所有高危告警
- C、缩短日志留存时间
- D、只允许周末处理

答案:A"

"Q1502、《数据安全法》中的 “数据”，不仅包括电子形式，也包括以其他方式记录的信息。即无论是()、或是()的数据都需要受到《数据安全法》的管辖，范围相当宽泛。（）

- A、涉密，非涉密
- B、电子形式，纸质形式

C、国有，非国有

D、商业，非商业

答案:B"

"Q1503、某政务数据共享目录中，""统一社会信用代码""数据应标注为？

A、公开共享

B、不予共享

C、有条件共享

D、涉密数据

答案:A"

"Q1504、以下哪些描述符合基于单向哈希链的口令序列认证机制？

A、服务器保存较高轮次的哈希结果，客户端提交较低一轮次的哈希结果，服务器通过再计算一次哈希进行校验

B、每次登录成功后，服务器保存的验证值会更新

C、随着认证次数增加，后续可用的哈希链长度会逐步减少

D、该机制的安全性依赖于单向哈希函数的抗逆性

E、该机制必须依赖非对称加密算法才能实现

答案:ABCD"

"Q1505、网络安全等级保护第三级信息系统测评过程中，关于数据安全及备份恢复的测评，应检查

（ ）中是否为专用通信协议或安全通信协议服务，避免来自基于通信协议的攻击破坏数据完整性。

A、操作系统

B、网络设备

C、数据库管理系统

D、应用系统

答案:ABCD"

"Q1506、生物特征认证一般需要经过以下哪些过程？

A、图像采集

B、特征提取

C、图像处理

D、特征匹配

E、哈希计算

答案:ABD"

"Q1507、某金融机构数据治理委员会发现数据标准未随业务变更更新。应？

A、标准固定不变

B、仅年度评审

C、交由业务部门随意修改

D、建立数据标准动态维护与版本管理机制

答案:D"

"Q1508、数据本地化要求数据服务器位于本法域境内，在境内存储或处理数据。目前，全球多个国家/地区提出了本地化要求，宽严程度有所不同，以下哪一国家不是采用境内存储、处理模式的？

A、美国

B、土耳其

C、澳大利亚

D、俄罗斯

答案:A"

"Q1509、若要系统中每次缺省添加用户时，都自动设置用户的宿主目录为/users，需修改哪一个配置文件？（ ）

A、/etc/default/useradd

B、/etc/login.defs

C、/etc/shadow

D、/etc/passwd

答案:A"

"Q1510、感知层一般分为（ ）等部分。

- A、数据分析
- B、数据采集
- C、数据短距离传输
- D、数据保存

答案:BC"

"Q1511、个人信息处理者利用个人信息进行自动化决策，应当保证决策的（ ）和结果公平、公正，不得对个人在交易价格等交易条件上实行不合理的差别待遇。

- A、可行性
- B、自动化
- C、透明度
- D、精准度

答案:C"

"Q1512、某政务系统在完成数据共享申请审核时，发现申请方填写的数据用途为""内部分析""，但实际接入后进行了商业化数据加工。该行为违反了？

- A、超出审批用途使用数据，违反数据共享审批的使用限制
- B、网络带宽使用规定
- C、服务器采购规定
- D、仅违反内部操作规程

答案:A"

"Q1513、根据《促进企业数据资源开发利用的意见》内容，下列哪些行为可以促进企业数据资源开发利用？

- A、健全企业数据权益实现机制
- B、培育企业数字化竞争力
- C、服务经济社会高质量发展
- D、营造开放透明可预期的发展环境

答案:ABCD"

"Q1514、根据《个人信息保护法》，在处理个人信息

前，个人信息处理者应当采用什么方式告知？

- A、在官网底部以小字标注即可
- B、仅在注册时弹窗显示一次
- C、显著方式、清晰易懂的语言，真实、准确、完整地告知
- D、以书面合同形式寄送纸质版

答案:C"

"Q1515、利用爬虫技术爬取网站数据，以下说法正确的是（ ）？

- A、爬虫技术本身是中立的，因此可以利用爬虫爬取数据
- B、数据属于数据所有者，不可以利用爬虫爬取
- C、如果是公开/公示性质的数据，可以爬取
- D、如果可以爬取，则爬取数据时应当降低爬取的频次，防止影响被爬取页面的可用性

答案:CD"

"Q1516、某政务系统监测到某接口返回 HTTP 200 但内容为空（可能遭篡改）。安全团队应？

- A、核查源站数据完整性与 WAF/缓存策略
- B、忽略，200 表示成功
- C、直接下线接口
- D、仅记录不处理

答案:A"

"Q1517、以下哪类智慧城市应用中可能存在海量个人信息，需要重点保护？

- A、电子政务系统
- B、轨道交通系统
- C、智慧校园一卡通
- D、智慧气象分析系统

答案:ABC"

"Q1518、《生成式人工智能服务管理暂行办法》自何时起施行？

- A、2023-06-01
- B、2023-08-15
- C、2024-01-01
- D、2023-10-01

答案:B"

"Q1519、《网络安全法》要求网络运营者履行哪些数据保护义务？

- A、建立用户信息保护制度
- B、发现数据泄露应及时告知用户
- C、对收集信息保密
- D、定期向工信部提交备案

答案:ABC"

"Q1520、根据 GB/T 43697-2024，对于包含个人信息的数据，定级时应如何处理？

- A、个人信息统一为 2 级
- B、参照个人信息保护相关法规，结合数据内容的敏感程度综合判定
- C、所有个人信息均定为 4 级
- D、由数据所有人自主决定级别

答案:B"

"Q1521、关于信息系统安全等级保护第三级的系统运维管理，应对系统相关的人员进行应急预案培训，应急预案的培训至少（ ）举办一次。

- A、每季度
- B、每半年
- C、每年
- D、每 2 年

答案:C"

"Q1522、根据《促进和规范数据跨境流动规定》，以下哪类数据即使进行了脱敏处理，向境外提供时仍须履行出境合规义务？

- A、去标识化后无法还原个人身份的匿名化数据

- B、脱敏不彻底、结合其他信息仍可识别个人的数据
- C、公开发布的统计汇总数据
- D、企业内部运营的财务汇总数据

答案:B"

"Q1523、根据《跨境流动规定》和《标准合同备案指南（第二版）》的规定，关于个人信息出境标准合同的条件，以下哪项描述是正确的？

- A、适用于所有类型的数据处理者，无论规模大小
- B、当年累计向境外提供超过 100 万人的个人信息时适用
- C、当年累计向境外提供 1 万人以上的敏感个人信息时可通过签署标准合同出境
- D、向境外提供被公开发布为重要数据的个人信息时，应通过数据出境安全评估，不得选择订立个人信息出境标准合同

答案:D"

"Q1524、某企业数据备份恢复演练发现，部分数据库因外键约束无法单独恢复。应？

- A、放弃恢复
- B、制定依赖关系拓扑图，实施关联数据一致性恢复方案
- C、仅恢复部分表
- D、交由 DBA 手工处理

答案:B"

Q1525、服务器基于同样的数字序列中的计数值、密钥和算法计算出所期望的输出值，如果该值与客户端计算出的值相同，则认证成功。（正确）

"Q1526、某企业数据资产目录中，敏感数据未标注使用限制。治理要求应？

- A、补充数据使用策略与访问边界说明
- B、无需标注
- C、仅内部可见
- D、交由用户决定

答案:A"

"Q1527、风险评估中，若将“发生概率很低但影响极大”的事件一律判为低风险，最可能的问题是（ ）。

- A、低估尾部高影响风险，导致关键控制不足
- B、可显著降低整改成本
- C、能提高培训通过率
- D、可替代所有应急预案

答案:A"

"Q1528、关于《中华人民共和国数据安全法》下列说法正确的是：

- A、开展涉及国家秘密的数据处理活动，适用《中华人民共和国保守国家秘密法》等法律、行政法规的规定
- B、《中华人民共和国数据安全法》自 2021 年 9 月 1 日起施行
- C、《中华人民共和国数据安全法》于 2021 年 9 月 1 日通过
- D、《中华人民共和国数据安全法》所称数据，是指任何以电子或者其他方式对文字的记录

答案:AB"

Q1529、APT 攻击往往利用社会工程学、结合蠕虫、病毒、木马、0day 漏洞、注入攻击、勒索加密等多种复杂的组合手段。（正确）

"Q1530、某金融机构拟使用联邦学习联合建模，但原始数据未本地化隔离。应？

- A、集中原始数据训练
- B、确保各方数据不出域，仅交换模型梯度/参数
- C、直接共享数据集
- D、仅加密传输

答案:B"

"Q1531、在访问控制中，以下哪个概念描述了用户或主体的访问权限在特定时间段内有效？

- A、审计
- B、审查
- C、时效
- D、撤销

答案:C"

"Q1532、根据《数据安全法》，国家建立数据分类分级保护制度，对数据实行分类分级保护的依据是？

- A、数据在经济社会发展中的重要程度
- B、数据遭到篡改、破坏、泄露对国家安全造成的危害程度
- C、对公共利益或个人、组织合法权益造成的危害程度
- D、数据的存储格式（结构化或非结构化）

答案:ABC"

"Q1533、若企业希望在 CI/CD 中实现“敏感代码变更自动触发更严格安全审查”，最合理的依据是（ ）。

- A、按涉及数据级别和关键模块范围定义不同审查门槛
- B、所有代码一律同样处理
- C、仅按提交时间判断
- D、由开发者自行声明是否高风险

答案:A"

"Q1534、零信任身份验证的优点是什么？

- A、提高了数据安全性
- B、减少了 IT 管理工作量
- C、提高了用户体验
- D、减少了成本
- E、可以防止内部威胁

答案:ABE"

"Q1535、某平台拟上线“对外数据共享接口”，最先应设计的安全方案不包括（ ）。

- A、接口调用身份认证
- B、最小必要字段返回
- C、调用日志审计
- D、前端 UI 页面配色

答案:D"

"Q1536、电子合同的标的物为采用在线传输方式交付的，() 为交付时间。电子合同当事人对交付商品或者提供服务的方式、时间另有约定的，按照其约定。

- A、合同签署时间
- B、合同标的物进入对方当事人指定的特定系统时间
- C、合同标的物进入对方当事人指定的特定系统且能够检索识别的时间
- D、当事人确认签收时间

答案:C"

Q1537、网络属于虚拟空间，网络主权原则不是参与网络国际治理与合作的重要原则。(错误)

"Q1538、开发测试阶段引入自动化安全测试工具的主要收益包括哪些？

- A、提升常见漏洞发现效率
- B、支持回归测试和持续集成
- C、完全替代人工研判
- D、减少上线前的已知缺陷残留

答案:ABD"

Q1539、数据出境安全评估仅针对大规模数据传输，小量数据传输不需要评估（错误）

Q1540、公司的信息安全是信息安全部门负责，与其他员工无关。(错误)

"Q1541、以下关于区块链共识机制的描述中，哪一项最准确地反映了拜占庭容错类共识机制的特点()。

- A、基于工作量证明，需大量计算资源，适用于开放环境

- B、节点间通过轮流出块达成一致，避免能源浪费

- C、可容忍部分节点作恶，通过多轮通信达成一致，适用于联盟链

- D、节点通过抵押代币投票选出出块者，适用于通用图灵完备智能合约平台

答案:C"

"Q1542、根据《促进和规范数据跨境流动规定》，以下哪种情形可以免于申报数据出境安全评估、订立个人信息出境标准合同、通过个人信息保护认证？

- A、关键信息基础设施运营者向境外提供个人信息
- B、向境外提供重要数据
- C、数据处理者在境外收集和产生的个人信息传输至境内处理后再向境外提供，且处理过程中未引入境内个人信息或者重要数据
- D、自当年 1 月 1 日起累计向境外提供 100 万人以上个人信息（不含敏感个人信息）

答案:C"

"Q1543、以下关于定级工作说法正确的是。

- A、确定定级对象过程中，定级对象是指起支撑、传输作用的信息网络以及用于生产、调度、管理、指挥、作业、控制、办公等目的的各类业务系统
- B、确定信息系统安全保护等级仅仅是指确定信息系统属于五个等级中的哪一个
- C、在定级工作中同类信息系统的安全保护等级不能随着部、省、市行政级别的降低而降低
- D、新建系统在规划设计阶段应确定等级，按照信息系统等级，同步规划、同步设计、同步实施安全保护技术措施和管理措施

答案:ACD"

Q1544、数据安全，是指通过采取必要措施，确保数据处于有效保护和合法利用的状态，以及具备保障持续安全状态的能力。(正确)

"Q1545、计算机信息系统实行安全等级保护。安全等级的划分标准和安全等级保护的具体办法，由() 会同有关部门制定。

- A、国家安全部
- B、国家保密局
- C、公安部
- D、国家网信部门

答案:C"

"Q1546、下列关于区块链中""智能合约""的基本概念描述，哪一项是错误的？

- A、智能合约是存储在区块链上的一段可自动执行的程序代码
- B、智能合约一旦部署就无法修改或终止
- C、智能合约的执行结果需要经过区块链网络中的节点验证
- D、智能合约可以读取链下真实世界的数据

答案:D"

"Q1547、网络产品、服务具有（ ）的，其提供者应当向用户明示并取得同意。

- A、收集型号功能
- B、卫星导航功能
- C、4G 或 5G 上网功能
- D、收集用户信息功能

答案:D"

Q1548、假冒身份是指攻击者伪装成他人，以获取目标系统或机构的访问权限。（正确）

"Q1549、安全审计和监控（Security Auditing and Monitoring）可以帮助发现什么？

- A、异常行为和安全漏洞
- B、用户行为
- C、系统管理员
- D、资源属性

答案:A"

Q1550、重放攻击是指攻击者截获合法用户的身份验证流量，并在稍后的时间重新发送该流量，以冒充

合法用户进行身份验证。（正确）

"Q1551、在溯源取证过程中，若日志时间不同步，最容易造成的问题是（ ）。

- A、事件链条还原困难、证据关联失真
- B、备份文件自动丢失
- C、数据库自动断连
- D、加密算法失效

答案:A"

Q1552、网络爬虫按照系统结构和实现技术，大致可以分为以下几种类型：通用网络爬虫、聚焦网络爬虫、增量式网络爬虫、深层网络爬虫。（正确）

"Q1553、近年来，我国多措并举、多管齐下，陆续健全了与数据安全相关的法律体系。从防护对象来看，以下哪些法律法规针对个人信息或企业数据安全建设提出明确防护目标，是数据保护和数据利用的整体性法律框架？

- A、《个人信息保护法》
- B、《数据安全法》
- C、《密码法》
- D、《刑法》

答案:AB"

"Q1554、运营者采购网络产品和服务，可能影响国家安全的，应当按照网络产品和服务安全审查办法的要求（ ）。

- A、通过网络安全审查，并与提供者签订安全保密协议
- B、放弃采购需求
- C、直接进行采购
- D、提前 7 个工作日向安全部门提交安全申请，在通过后方可进行采购

答案:A"

"Q1555、数据安全事件溯源时，最关键的基础材料通常包括哪些？

- A、数据访问日志
- B、系统运行日志
- C、操作审计记录
- D、员工通讯录封面照片

答案:ABC"

"Q1556、在数据库安全性控制中，授权的数据对象（ ），授权子系统就越灵活。

- A、粒度越小
- B、约束越细致
- C、范围越大
- D、约束范围大

答案:A"

"Q1557、根据《个人信息保护法》，符合哪些条件的个人信息处理者，应当指定个人信息保护负责人？

- A、处理超过 1 万人个人信息的
- B、处理个人信息达到国家网信部门规定数量的
- C、所有个人信息处理者均须指定
- D、仅大型互联网平台须指定

答案:B"

Q1558、履行个人信息保护职责的部门在履行职责中，发现违法处理个人信息涉嫌犯罪的，应当及时移送公安机关依法处理。（正确）

"Q1559、防范网络社会工程学攻击，通常应采取哪些措施？

- A、使用复杂密码并避免在多个系统复用
- B、安装并及时更新安全软件
- C、开展员工安全意识培训
- D、建立可疑事件上报与核验机制

答案:ABCD"

"Q1560、根据《生成式人工智能服务管理暂行办法》，生成式人工智能服务提供者在训练数据方面，应当采取哪些措施？

A、使用具有合法来源的数据和基础模型

B、不得使用含有知识产权保护等法律法规禁止的内容的数据

C、采取措施提高训练数据质量，增强训练数据的真实性、准确性、客观性

D、无需对训练数据进行任何标注

答案:ABC"

"Q1561、网络访问控制列表（ACL）主要通过过滤什么来实现对网络资源的访问限制？

- A、网络流量
- B、用户行为
- C、系统管理员
- D、定义的访问控制策略

答案:A"

"Q1562、根据《数据安全法》，依法开展数据安全检测评估的机构，在开展服务活动中获取的数据，应当如何处理？

- A、可以用于商业分析
- B、可以提供给数据交易平台
- C、不得向他人提供或泄露
- D、须上报国家网信部门统一管理

答案:C"

"Q1563、科举考生答卷采用黑墨水，称为""墨卷""，""墨卷""收拢之后，会统一由抄书吏再用红墨水抄写一遍，称之为""朱卷""，考官批改""朱卷""，这种措施是为了（ ）？

- A、身份验证
- B、去标识化
- C、备份
- D、加密

答案:B"

Q1564、我国相关法律对电子数据的审查判断作了明

确要求，提出"以收集原始存储介质为原则，以直接提取电子数据为例外"的原则。（正确）

"Q1565、数据安全合规性评估与数据安全风险评估的主要区别在于（ ）。

A、前者更关注是否符合法规和制度要求，后者更关注安全风险的识别、分析和处置

B、两者完全相同

C、合规评估只看技术，风险评估只看法律

D、风险评估无需报告

答案:A"

Q1566、《网络数据安全条例》是横跨网络安全、数据安全与个人信息保护三大领域的行政法规，是三部上位法的下位配套规范。（正确）

"Q1567、根据《网络安全法》的规定，网络运营者不得（ ）其收集的个人信息，经过处理无法识别特定个人且不能复原的除外。

A、泄露

B、篡改

C、毁损

D、使用

答案:ABC"

"Q1568、在访问控制中，ABAC（Attribute-Based Access Control）是指（ ）。

A、基于用户的访问控制

B、基于角色的访问控制

C、基于资源的访问控制

D、基于属性的访问控制

答案:D"

"Q1569、在数据安全合规评估中，常见的信息收集方法包括哪些？

A、问卷调查

B、访谈

C、资料查阅

D、只凭经验判断

答案:ABC"

"Q1570、（ ）被称为""社会生活的百科全书""，在法律体系中居于基础性地位，也是市场经济的基本法。

A、《中华人民共和国治安管理处罚法》

B、《中华人民共和国民法典》

C、《中华人民共和国刑法》

D、《中华人民共和国宪法》

答案:B"

"Q1571、若要验证“访问控制策略与数据分类分级结果是否联动生效”，最佳验收方式是（ ）。

A、按不同角色对不同级别数据进行实际访问测试和审计回看

B、只检查制度是否写明

C、只询问管理员

D、只看采购发票

答案:A"

"Q1572、某平台在高峰期大量触发敏感数据导出告警，但事后发现多为正常批处理任务。最合理的优化方向是（ ）。

A、引入业务上下文和基线建模，降低误报

B、关闭全部导出告警

C、停止批处理业务

D、只保留人工邮件通知

答案:A"

"Q1573、明朝时期，规定科举考生必须采用统一字体""台阁体""答卷，这在个人信息处理上是什么措施？（ ）

A、身份验证

B、去标识化

C、同态加密

D、多方安全计算

答案:B"

"Q1574、某金融机构发现某员工离职前批量下载客户资料。事后审计发现权限未及时回收。该事件暴露？

A、账号生命周期管理与离职审计流程失效

B、网络带宽过大

C、数据库容量不足

D、前端框架缺陷

答案:A"

"Q1575、标识符在数据脱敏中的作用是？

A、数据加密

B、数据定位

C、数据替换

D、数据删除

答案:B"

"Q1576、《网络数据安全条例》规定，国家数据出境安全管理体系的责任主体包括哪些？

A、国家网信部门统筹协调建立国家数据出境安全管理专项工作机制

B、研究制定国家网络数据出境安全管理相关政策

C、协调处理网络数据出境安全重大事项

D、由各数据处理者自主管理

答案:ABC"

"Q1577、人离开后电脑不锁屏可能导致窥屏方式的数据泄密，以下锁定屏幕的方法正确的是（ ）。"

A、Windows 键+L

B、Ctrl 键+L

C、Alt 键+L

D、Shift 键+L

答案:A"

"Q1578、大数据采集中，（ ）是一种重要的安全技术，可以帮助识别和防止潜在的网络攻击和漏洞。"

A、防火墙

B、入侵检测系统

C、加密技术

D、认证技术

答案:B"

"Q1579、PKI 公钥基础设施利用什么来实现信息安全服务的安全基础设施？

A、共享密钥

B、生物特征

C、公钥密码理论和技术

D、随机数值

答案:C"

"Q1580、以下哪些因素会影响比特币性能。"

A、节点数量

B、钱包数量

C、共识算法

D、网络带宽

答案:ACD"

"Q1581、安全网关产品主要通过什么方式对网络通信连接进行访问控制？

A、利用网络数据包信息和威胁特征库

B、使用加密算法对数据进行加密

C、监控用户行为并进行分析

D、建立虚拟专用网络

答案:A"

"Q1582、《生成式人工智能服务管理暂行办法》对国家机关利用生成式 AI 服务的规定是？

A、国家机关可无限制使用，不受本办法约束

B、国家机关可根据工作需要使用，但不得利用该服务从事本办法禁止的活动

C、国家机关须获得专项许可后方可使用

D、国家机关仅限内部测试，不得上线应用

答案:B"

Q1583、根据 GB/T 43697-2024《数据安全技术 数据分类分级规则》，数据的分类分级宜在数据使用之前确定，且应当遵循动态调整原则（如数据汇聚、加工、共享、出境等场景下应重新评估）。（正确）

"Q1584、我国的数据基础制度包括（）。

A、数据产权制度

B、流通交易制度

C、收益分配制度

D、安全治理制度

答案:ABCD"

"Q1585、在安全实施交付中，部署手册的必要内容通常包括哪些？

A、安装顺序

B、依赖关系

C、参数说明

D、回滚方案

答案:ABCD"

"Q1586、大数据安全与隐私保护关键技术有

A、数据发布匿名保护技术

B、数据水印技术、社交网络匿名保护技术

C、角色挖掘技术、数据溯源技术

D、风险自适应的访问控制

答案:ABCD"

"Q1587、修订后的《网络安全法》对网络运营者（特别是关键信息基础设施运营者）造成特别严重危害网络安全后果的，最高罚款上限提升至（）。

A、一百万元

B、五百万元

C、一千万元

D、五千万元

答案:C"

"Q1588、根据修订后《网络安全法》（2025年修正版）和《数据出境安全评估办法》，关键信息基础设施的运营者向境外提供个人信息和重要数据的，应当通过国家（）会同国务院有关部门组织的安全评估。

A、公安部门

B、网信部门

C、保密部门

D、工信部门

答案:B"

"Q1589、根据 NIST SP 800-145，以下哪一项不属于云计算的四种部署模式？

A、公有云（Public Cloud）

B、私有云（Private Cloud）

C、混合云（Hybrid Cloud）

D、国有云

答案:D"

"Q1590、Spectre（幽灵）和 Meltdown（熔断）漏洞于2018年1月被公开披露，常见CPU无一幸免，该漏洞导致数据泄露的原理是（）？

A、主板内存泄露

B、CPU预测执行（推测执行）机制可能导致数据泄露

C、Windows系统下的缺陷导致的缓冲区溢出

D、Linux下未能内存隔离导致数据可能泄露

答案:B"

"Q1591、民法调整平等主体的自然人、法人和（）之间的人身关系和财产关系。

- A、法人组织
- B、非法人组织
- C、自然人组织
- D、个体工商户

答案:B"

Q1592、数据出境安全评估结果在任何场景有效期为2年。（错误）

Q1593、当使用爬虫技术进入到特定程序之中，甚至获取了特定的数据，如果该数据的性质、获取的价值超过法定限制，便会涉嫌"非法获取计算机信息系统数据罪"。如何认定该罪中的"情节严重""情节特别严重"，《最高人民法院、最高人民检察院关于办理危害计算机信息系统安全刑事案件应用法律若干问题的解释》给予了明确的规范。（正确）

"Q1594、根据《生成式人工智能服务管理暂行办法》，生成式人工智能服务提供者对于使用其服务生成的内容，应当采取什么措施以防范虚假信息传播？

- A、采取有效措施防止生成虚假信息，并在显著位置提示用户所生成的内容为人工智能生成
- B、由用户自行判断内容真实性，提供者不承担责任
- C、生成内容无需标识，用户有权自主发布
- D、仅在涉及政治内容时才需标识

答案:A"

Q1595、目前，针对数据跨境的治理在全球范围内并未形成统一的规制体系。（正确）

"Q1596、某律师事务所使用境外商业大模型服务处理含客户身份信息的合同材料，数据被上传至境外服务器。该行为的主要合规风险是？

- A、涉及个人信息跨境传输，须履行相应出境合规义务
- B、委托境外处理个人信息须与境外接收方签订协议
- C、须评估境外服务商数据处理安全保障能力
- D、大模型服务属于技术工具，使用无需任何合规措

施

答案:ABC"

Q1597、各业务功能实际收集的个人信息类型应与隐私政策所描述内容一致，在合理范围内可以超出隐私政策所述范围。（错误）

Q1598、《中华人民共和国数据安全法》中的“数据”，不仅包括电子形式，也包括以其他方式记录的信息。（正确）

"Q1599、常见的非结构化数据有哪些。

- A、视频
- B、图片
- C、日志
- D、文档

答案:ABD"

"Q1600、为了规范数据处理活动，保障数据安全，促进数据开发利用，以下做法正确的是：

- A、保护个人、组织的合法权益
- B、不用考虑个人利益，只要考虑组织的合法利益
- C、维护国家主权、安全和发展利益
- D、维护国家主权、安全和长远利益

答案:AC"

"Q1601、以下关于""人脸识别技术""的定义，符合《人脸识别技术应用安全管理办法》表述的是？

- A、仅指静态图像中的人脸识别
- B、通过分析面部特征信息对自然人身份进行识别认证的信息技术
- C、仅用于门禁系统的生物特征验证技术
- D、基于步态的身份识别技术

答案:B"

Q1602、保护工作部门根据认定规则负责组织认定本行业、本领域的关键信息基础设施，及时将认定结果通知运营者，并通报国务院公安部门。（正确）

"Q1603、某企业数据安全负责人离职，企业未在合理期限内重新指定。主管部门检查时发现该空缺。该问题的合规规定性是？

- A、违反《个人信息保护法》关于个人信息保护负责人的规定，须限期整改
- B、属于内部人事问题，不属于合规事项
- C、只要 IT 系统正常运行即可
- D、仅影响企业内部管理评分

答案:A"

"Q1604、国家建立数据分类分级保护制度，根据数据在经济社会发展中的重要程度，以及一旦遭到篡改、破坏、泄露或者非法获取、非法利用，对（ ）造成的危害程度，对数据实行分类分级保护。国家数据安全工作协调机制统筹协调有关部门制定重要数据目录，加强对重要数据的保护。

- A、国家安全
- B、公共利益
- C、个人
- D、组织合法权益

答案:ABCD"

"Q1605、某企业应急响应团队在处置数据泄露事件时，未保留原始日志与取证镜像。该操作违反？

- A、电子证据保全与溯源分析要求
- B、数据备份规范
- C、网络带宽管理
- D、前端设计规范

答案:A"

"Q1606、数据脱敏的主要目的是什么？

- A、数据加密
- B、隐私保护
- C、数据备份
- D、数据恢复

答案:B"

"Q1607、恢复攻击是指攻击者如何获取访问权限？

- A、通过请求重置受害者的账户来绕过 MFA
- B、通过网络钓鱼诈骗获得受害者的登录凭据
- C、通过感染恶意软件窃取受害者的个人信息
- D、通过冒充合法软件与受害者进行通信

答案:A"

"Q1608、工业企业工业数据分类维度包括？

- A、管理数据域
- B、生产数据域
- C、研发数据域
- D、运维数据域

答案:ABCD"

"Q1609、以下哪项政务数据可以开放？（ ）

- A、涉及国家秘密
- B、商业秘密
- C、个人隐私
- D、领导任命前的公示

答案:D"

"Q1610、在数据质量治理中，“唯一性”主要关注（ ）。

- A、同一业务对象是否被重复记录
- B、数据是否完成加密
- C、日志是否超过 6 个月
- D、是否配置了防火墙

答案:A"

"Q1611、某团队在威胁情报中发现针对某数据库中间件的活跃利用情报后，最优先的动作通常是（ ）。

- A、核查资产暴露面并验证本组织是否受影响

- B、先做品牌公关
- C、删除全部历史日志
- D、停用所有数据库

答案:A"

"Q1612、某企业两个系统中的同一客户生日字段格式不一致，一个为 YYYY-MM-DD，另一个为时间戳。最优先的治理动作是（ ）。

- A、建立统一数据标准并执行格式转换规则
- B、删除其中一个系统
- C、保留现状，由人工理解
- D、只修改前端显示样式

答案:A"

Q1613、通过磁盘阵列、数据备份、异地容灾等手段保证数据的安全。（正确）

"Q1614、某企业将""员工考勤记录""定为内部公开数据，但包含病假、就医等敏感信息。定级应调整为？

- A、维持内部公开
- B、调整为敏感个人信息，限制访问范围
- C、删除考勤系统
- D、仅 HR 可见即可

答案:B"

"Q1615、某组织准备按数据类型和场景设计多套加密策略，以下最关键的输入条件是（ ）。

- A、数据级别、业务敏感性和使用方式
- B、企业 Logo 颜色
- C、员工办公时长
- D、打印纸张品牌

答案:A"

"Q1616、某医疗 AI 公司使用真实患者影像数据训练诊断模型，未对数据进行脱敏或获取患者授权。该行为的法律风险包括？

- A、违反《个人信息保护法》关于敏感个人信息处理的规定
- B、违反《数据安全法》关于医疗数据合规使用的规定

- C、违反医疗健康数据相关行业规范
- D、可能构成侵犯患者隐私权

答案:ABCD"

"Q1617、根据《数据安全法》，非经中华人民共和国主管机关批准，境内的组织、个人不得向外国司法或者执法机构提供存储于（ ）的数据。

- A、境外服务器上的数据
- B、中华人民共和国境内的数据
- C、任何加密数据
- D、企业内部数据

答案:B"

Q1618、存储、处理涉及国家秘密信息的网络的运行安全保护，除应当遵守《网络安全法》外，还应当遵守保密法律、行政法规的规定。（正确）

Q1619、数字证书认证中心是 PKI 系统的最核心部件。（正确）

Q1620、PKI 公钥基础设施以公钥加密为基础，创建、管理、存储、分发和撤销证书所需要的一组硬件、软件、人力资源、相关政策和操作规范以及为 PKI 体系中的各成员提供全部的安全服务。（正确）

"Q1621、某企业应急响应预案未包含""数据出境违规""处置流程。合规检查应要求？

- A、无需包含
- B、补充跨境违规场景的阻断、报告、整改流程
- C、仅内部学习
- D、交由法务处理

答案:B"

"Q1622、根据职业标准，开展数据安全需求分析时，应优先关注（ ）。

- A、数据处理活动各环节的安全需求
- B、办公楼装修风格
- C、供应商品牌偏好
- D、数据库图标颜色

答案:A"

"Q1623、关键信息基础设施的运营者在中华人民共和国境内运营中收集和产生的重要数据的出境安全管理，适用（ ）的规定。

- A、《中华人民共和国宪法》
- B、《中华人民共和国网络安全法》
- C、《中华人民共和国国家安全法》
- D、《中华人民共和国刑法》

答案:B"

"Q1624、某业务希望长期留存日志数据“以备未来分析”，需求分析时最先应质疑的是（ ）。

- A、留存目的、必要性与保存期限是否可被证明
- B、日志服务器品牌
- C、办公网 IP 段
- D、数据库版本号

答案:A"

"Q1625、国家网信部门负责统筹协调（ ）工作和相关监督管理工作。

- A、个人信息保护
- B、个人信息搜集
- C、个人信息处理
- D、个人信息公布

答案:A"

"Q1626、根据 GB/T 43697-2024，数据分级的""动态调整""原则主要针对哪些情况？

- A、数据汇聚后敏感性升高
- B、生产数据脱敏后敏感性降低

- C、特定时效过期后数据失去敏感性
- D、更换存储介质

答案:ABC"

"Q1627、某企业在梳理数据资产时，仅统计了数据库和文件服务器中的数据，却未纳入接口数据和日志数据。该做法的主要问题是（ ）。

- A、忽略了部分重要数据资产，资产识别范围不完整
- B、日志数据不属于数据资产
- C、接口数据天然不涉安全
- D、只要数据库纳入即可满足要求

答案:A"

"Q1628、根据《个人信息保护法》，个人信息处理者违法处理个人信息，侵害众多个人权益的，人民检察院、国家网信部门确定的组织可以提起（ ）。

- A、行政诉讼
- B、公益诉讼
- C、刑事自诉
- D、仲裁申请

答案:B"

"Q1629、SSO 可以使用哪些技术实现？

- A、OAuth 2.0
- B、OpenID Connect
- C、SAML
- D、Kerberos
- E、LDAP

答案:ABCD"

"Q1630、下面哪项是属性安全控制的作用？

- A、保护重要目录和文件
- B、防止用户越权访问
- C、防止数据泄密
- D、控制用户的入网权限

E、限制网络服务器的访问

答案:AB"

Q1631、ABAC 模型允许对访问请求进行细粒度的控制。（正确）

"Q1632、相比基于角色的访问控制（RBAC），基于属性的访问控制（ABAC）支持更加灵活的策略表达能力，其主要依赖于（ ）。

- A、每个用户可绑定多个权限
- B、策略可引用任意数量和类型的属性
- C、所有策略都由系统管理员预定义
- D、角色与资源的映射关系可动态生成

答案:B"

"Q1633、根据《密码法》的规定，国家鼓励商用密码技术的研究开发、学术交流、成果转化和推广应用，健全（ ）的商用密码市场体系，鼓励和促进商用密码产业发展。

- A、统一
- B、开放
- C、竞争
- D、有序

答案:ABCD"

"Q1634、物联网安全是指什么？

- A、保护物联网设备的物理安全
- B、保护物联网设备免受未经授权的访问和攻击
- C、保护物联网设备的电源供应
- D、保护物联网设备的网络连接速度

答案:B"

"Q1635、训练人脸识别模型的人脸数据应标记为？

- A、Level 1：公共数据
- B、Level 2：匿名化数据
- C、Level 3：半敏感数据

D、Level 4：原始生物数据

答案:D"

"Q1636、物联网设备的安全性能评估应该考虑哪些方面。

- A、设备的功能性能
- B、设备的可靠性
- C、设备的易用性
- D、设备的安全性能
- E、设备的成本

答案:BD"

"Q1637、一家医疗机构需要保护患者的电子健康记录（EHR）。为了确保只有授权的医生和护士可以访问这些记录，应该采用（ ）访问控制模型。

- A、自主访问控制（DAC）
- B、强制访问控制（MAC）
- C、基于角色的访问控制（RBAC）
- D、基于任务的访问控制（TBAC）

答案:C"

"Q1638、根据《数据安全法》，国家制定政务数据开放目录，构建（ ）的政务数据开放平台，推动政务数据开放利用。

- A、统一规范
- B、互联互通
- C、安全可控
- D、便民

答案:ABCD"

"Q1639、身份认证需要建立什么？

- A、信任关系
- B、金融关系
- C、商业关系
- D、社交关系

答案:A"

"Q1640、《个人信息保护法》施行的时间是：

- A、2021-10-01
- B、2021-11-01
- C、2021-11-11
- D、2021-12-12

答案:B"

"Q1641、某 APP 通过""绑定人脸解锁""的附加服务要求用户授权人脸识别，但不授权则无法使用该 APP 的全部基本功能。该做法的法律风险在于？

- A、违反了人脸识别技术使用的必要性原则和强迫同意的禁止规定
- B、属于正常商业条款
- C、仅违反了《广告法》
- D、属于技术漏洞，不构成违规

答案:A"

Q1642、数据的价值在于其规模和质量，大规模低质量的数据集通常比小规模高质量的数据更有价值。
(错误)

"Q1643、你是一名 IT 公司的工作人员，收到 QQ 好友添加请求，显示为 IT 部门同事需要通过 QQ 远程协助对你的电脑进行升级，你应该如何处理？

- A、通过好友请求并开启远程协助
- B、通过企业微信确认真实性
- C、绝对不能在聊天中透露个人及公司信息，但可以让其远程协助处理问题
- D、拒绝并向 IT 部门反馈
- E、先通过 QQ 好友请求，向对方发起 QQ 视频通话，确认身份后方可提供远程协助

答案:BD"

"Q1644、以下哪种是生物特征欺骗攻击的示例？

- A、密码猜测/暴力破解攻击

B、中间人攻击

C、XSS 攻击

D、人脸伪造攻击 (Deepfake)

答案:D"

"Q1645、在 Hadoop 集群中，() 组件用于管理和分配计算资源。

- A、YARN
- B、HBase
- C、ZooKeeper
- D、HDFS NameNode

答案:A"

"Q1646、拒绝服务攻击可能导致的后果是 ()。

- A、信息不可用
- B、应用程序不可用
- C、系统宕机、阻止通信
- D、以上都是

答案:D"

"Q1647、下列哪项是降低社会工程学攻击风险的关键措施之一？

- A、增加网络防火墙的配置
- B、提供员工教育和培训
- C、定期进行漏洞扫描和渗透测试
- D、关闭所有对外通信功能

答案:B"

Q1648、访问者可以是用户、进程、应用程序等，也可以是文件、应用服务、数据等。(错误)

"Q1649、以下登录口令设置，安全强度最高的是？

- A、1314520
- B、Admin123
- C、root123456

D、cptbtp@77!

答案:D"

"Q1650、在单点登录（SSO）认证过程中，当请求中携带的 Cookie 或票据无效时，拦截器通常会怎么处理？

- A、放行访问请求
- B、重定向用户到统一认证服务器的登录界面
- C、向数据库写入新票据
- D、检查请求 URL 是否属于无需保护的资源
- E、清理无效 Cookie 并要求重新认证

答案:BDE"

Q1651、《个人信息出境标准合同办法》规定个人信息处理者应当在标准合同生效之日起 10 个工作日内向所在地省级网信部门备案（正确）

Q1652、对于与维护国家安全和利益、履行国际义务相关的属于管制物项的数据，国家依法实施出口管制，以防止这些数据流失造成国家安全问题。（正确）

"Q1653、某组织希望将数据安全风险评估结果真正用于治理，而不是只形成报告。最佳做法是（ ）。

- A、将风险结果映射到整改计划、责任人和时间表，并持续跟踪闭环
- B、风险评估结束即归档
- C、只保留结论，不保留依据
- D、仅向管理层口头汇报

答案:A"

"Q1654、某企业发现合作伙伴在未获授权的情况下，将其提供的脱敏数据与第三方数据集结合，成功还原了部分用户身份。应如何处置？

- A、立即要求合作伙伴停止使用并删除数据，评估法律责任，同时评估脱敏方案的有效性
- B、忽略，脱敏数据已无价值
- C、更新合同条款

D、仅发一封警告信

答案:A"

"Q1655、下列哪个是访问控制中的授权方式？

- A、访问请求审查
- B、双因素认证
- C、单一登录
- D、加密传输

答案:A"

"Q1656、以下关于模糊测试过程的说法错误的是。

- A、模拟正常用户输入行为，生成大量数据包作为测试用例
- B、数据处理点、数据通道的入口点和可信边界点往往不是测试对象
- C、监测和记录输入数据后程序正常运行的情况
- D、深入分析测试过程中产生崩溃或异常的原因，必要时需要测试人员手工重现并分析

答案:ABC"

"Q1657、（ ）以上的未成年人，以自己的劳动收入为主要生活来源的，视为完全民事行为能力人。

- A、十二周岁
- B、十四周岁
- C、十六周岁
- D、十七周岁

答案:C"

"Q1658、根据《征信业管理条例》的规定，征信机构可以采集以下哪种个人信息？

- A、个人的血型信息
- B、个人的指纹信息
- C、个人的真实身份信息
- D、个人的疾病信息

答案:C"

"Q1659、5 mod 11 的乘法逆元是 ()。

- A、2
- B、7
- C、9
- D、10

答案:C"

"Q1660、矿藏、水流、海域属于 () 所有。

- A、国家
- B、地方政府
- C、企业
- D、私人

答案:A"

"Q1661、关于数据安全治理，以下哪项说正确 () ?

- A、数据安全应当全员参与
- B、人是薄弱的环节
- C、结合信息安全管理体系是最佳实践
- D、有必要增强数据安全意识培训

答案:ABCD"

"Q1662、根据 GB/T 43697-2024《数据安全技术 数据分类分级规则》，数据分级从低到高通常对应为 ()。

- A、一般数据、重要数据、核心数据
- B、核心数据、重要数据、一般数据
- C、公开数据、内部数据、绝密数据
- D、1 级、2 级、3 级、4 级

答案:A"

Q1663、哈希函数的输出是固定长度的。(正确)

"Q1664、按 DSMM 模型，Level 3 级能力要求对分级数据的？

- A、基于角色实施静态访问控制

B、年度合规审计

C、全生命周期监测使用行为

D、双因素认证

答案:C"

Q1665、如果在机械硬盘使用场景下，将文件拖入回收站之后清空，此时不对硬盘做写入操作，有很大概率可以将删除的文件恢复回来。(正确)

Q1666、处理敏感个人信息应当取得个人的单独同意；法律、行政法规规定处理敏感个人信息应当取得书面同意的，从其规定。(正确)

"Q1667、作为定级对象的信息系统应具有如下哪些基本特征？

- A、具有确定的主要安全责任主体
- B、系组件单一
- C、承载相对独立的业务应用
- D、包含相互关联的多个资源

答案:ACD"

"Q1668、《网络数据安全管理条例》规定，互联网平台运营者收购、合并其他互联网平台的，应当在多少日内向国家网信部门报告？

- A、7 日
- B、15 日
- C、30 日
- D、60 日

答案:C"

"Q1669、下列属于智能交通实际应用的是。

- A、不停车收费系统
- B、先进的车辆控制系统
- C、探测车辆和设备
- D、先进的公共交通系统

答案:ABD"

Q1670、通过伪基站接收附近手机发送的数据，是数

据窃密者使用的一种隐蔽的窃密手段。（正确）

"Q1671、某企业安全团队需要证明某次敏感数据外泄是通过截图而非接口导出完成的。最有价值的取证方向包括哪些？

- A、终端行为审计记录
- B、剪贴板/屏幕操作相关取证线索
- C、数据导出接口日志
- D、用户角色权限记录

答案:ABCD"

"Q1672、为确保信息资产的安全，设备、信息或软件在（ ）之前不应带出公司、组织场所。

- A、使用
- B、检查合格
- C、授权
- D、识别出薄弱环节

答案:C"

"Q1673、跨站点脚本（XSS）攻击通常利用的是以下哪个安全漏洞？

- A、密码猜测漏洞
- B、输入验证漏洞
- C、会话劫持漏洞
- D、中间人攻击漏洞

答案:B"

Q1674、数据按照先行业领域分类、再业务属性分类的思路进行分类。（正确）

"Q1675、数据安全保护责任制度应当明确哪些内容？

- A、数据安全负责人和管理机构
- B、数据安全保护责任
- C、数据安全事件应急预案
- D、数据处理的具体流程

答案:ABC"

"Q1676、智能合约是一种（ ）。

- A、基于物理合同的数字化版本
- B、存储在区块链上、满足条件时自动执行的程序代码
- C、虚拟货币交易所
- D、区块链节点的身份验证机制

答案:B"

"Q1677、某项目拟建设数据防泄漏（DLP）能力，最合理的前置工作是（ ）。

- A、先明确数据类型、流转路径和敏感级别
- B、先部署任意 DLP 产品
- C、先停用所有邮件系统
- D、先删除历史日志

答案:A"

"Q1678、（ ）主管全国的保密工作。

- A、国家安全部门
- B、公安部门
- C、中央保密委员会
- D、国家保密行政管理部门

答案:D"

"Q1679、任何个人和组织不得从事下列危害关键信息基础设施的活动和行为。

- A、攻击、侵入、干扰、破坏关键信息基础设施
- B、非法获取、出售或者未经授权向他人提供可能被专门用于危害关键信息基础设施安全的技术资料等信息
- C、未经授权对关键信息基础设施开展渗透性、攻击性扫描探测
- D、明知他人从事危害关键信息基础设施安全的活动，仍然为其提供互联网接入

答案:ABCD"

"Q1680、以下哪种是中间人攻击的示例？

- A、密码猜测/暴力破解攻击
- B、跨站点脚本（XSS）攻击
- C、利用 ARP 欺骗在通信双方之间插入攻击者
- D、社会工程学攻击

答案:C"

"Q1681、某政务部门将""特定区域精确人口分布数据""定为 2 级，但安全专家认为该数据涉及国家安全。应如何处理？

- A、维持原定级
- B、依据 GB/T 43697-2024 的就高原则和国家安全影响评估，调整至 3 级或 4 级
- C、由信息化部门最终决定
- D、向公众公开后再定级

答案:B"

"Q1682、科举考生在贡院考试时，全程有兵丁在考场最高建筑""明远楼""巡视，如发现交头接耳、飞鸽传书等舞弊问题，白天摇旗，夜间举火，这在数据安全保护场景下是采用了哪种措施？（ ）

- A、加密
- B、隔离
- C、异常行为监测与告警
- D、身份认证

答案:C"

"Q1683、某企业 HR 系统收集员工生物识别信息（指纹打卡）用于考勤，但系统遭到入侵导致指纹模板泄露。责任认定时须考虑哪些因素？

- A、企业是否依法取得员工单独同意收集生物识别信息
- B、企业是否对敏感个人信息采取了与风险相适应的安全措施
- C、泄露事件发生后是否及时采取补救措施并通知监管和个人

D、员工是否签署了免责声明

答案:ABC"

"Q1684、某企业定期演练中发现，通信联络链条过长，导致升级上报延迟。最合理的改进是（ ）。

- A、精简指挥链并明确分级上报触发条件
- B、取消上报环节
- C、仅保留口头通知
- D、完全交由外部机构判断

答案:A"

"Q1685、以下做法错误的是：（ ）？

- A、严禁涉密系统一机两网
- B、涉密硬盘报废后可以格式化后废品回收
- C、用于连接互联网的 PC 不得处理涉密信息
- D、密级高的数据不得向非密系统导入

答案:B"

"Q1686、《网络安全审查办法》规定网络安全审查应重点审查评估的国家安全风险因素包括？

- A、数据出境可能带来的国家安全风险
- B、核心数据泄露风险
- C、境外上市估值合理性
- D、关键信息基础设施被控制风险

答案:ABD"

"Q1687、某直播平台发现主播在未获平台技术支持的情况下，私自安装人脸识别打赏验证模块，收集观众人脸信息。平台的合规责任是？

- A、平台负有管理责任，须及时制止并要求下架违规功能，依《人脸识别技术应用安全管理办法》履行平台主体责任
- B、主播个人行为与平台无关
- C、只要技术上可行即合规
- D、须等监管机构查处后才处理

答案:A"

"Q1688、以下关于等级保护的地位和作用的说法中正确的是。

- A、是国家信息安全保障工作的基本制度、基本国策
- B、是开展信息安全工作的基本方法
- C、是提高国家综合竞争力的主要手段
- D、是促进信息化、维护国家信息安全的根本保障

答案:ABD"

Q1689、身份认证可以对抗假冒攻击和重放攻击的威胁。(正确)

"Q1690、《促进和规范数据跨境流动规定》于何时正式施行？

- A、2023-09-01
- B、2024-03-22
- C、2024-06-01
- D、2025-01-01

答案:B"

"Q1691、如果 App 运营者将个人信息用于用户画像、个性化展示等，隐私政策中应说明其()。

- A、存储方式
- B、运行原理
- C、应用场景
- D、可能对用户产生的影响

答案:CD"

"Q1692、某企业合规审计显示，隐私政策、委托处理协议、跨境合同、共享台账彼此之间字段定义不一致。其根本问题是()。

- A、合规文档体系缺乏统一的数据定义与口径管理
- B、只影响法务部门阅读体验
- C、不会影响任何实际合规工作
- D、属于正常差异

答案:A"

"Q1693、以下哪些属于国产自主可控联盟链？

- A、Ethereum
- B、长安链
- C、Hyperledger Fabric
- D、FISCO BCOS

答案:BD"

"Q1694、在数据包转发过程中，当 TTL 值减少到 0 时，这个数据包必须()？

- A、重发
- B、无动作
- C、丢弃
- D、接收

答案:C"

"Q1695、区块链的本质是()。

- A、比特币
- B、去中心化分布式账本数据库
- C、计算机技术
- D、金融产品

答案:B"

"Q1696、某金融科技企业因业务需要，将处于欧盟的合作伙伴提供的欧盟用户数据在中国境内处理后再转移回欧盟。该场景的合规义务包括？

- A、需遵守中国《个人信息保护法》关于个人信息处理的规定
- B、需满足 GDPR 关于数据跨境传输的充分性决定或标准合同要求
- C、需向中国监管机构申报数据出境安全评估
- D、中国法律不适用于欧盟公民数据

答案:AB"

"Q1697、Oracle 数据库中，以下()命令可以删除

整个表中的数据，并且无法回滚。

- A、Drop
- B、Delete
- C、Truncate
- D、Cascade

答案:C"

"Q1698、修订后的《网络安全法》新增条款，明确网络安全工作坚持（ ）的领导。

- A、国务院
- B、国家网信部门
- C、中国共产党
- D、全国人民代表大会

答案:C"

Q1699、公钥密码学的思想最早由冯•诺依曼提出。（错误）

"Q1700、根据《个人信息保护法》，履行个人信息保护职责的部门在履行职责过程中，可以采取以下哪些措施？

- A、询问有关当事人，调查与个人信息处理活动有关的情况
- B、查阅、复制当事人与个人信息处理活动有关的合同、记录
- C、实施现场检查，对涉嫌违法的个人信息处理活动进行调查
- D、未经批准对涉嫌违法设备直接没收

答案:ABC"

"Q1701、针对数据安全事件，企业应（ ）

- A、选择性开展整改工作
- B、考量整改必要性，以危害结果为导向，采取整改措施
- C、及时制定整改措施，消除合规隐患
- D、内部处理，不对外通报

答案:C"

"Q1702、在大数据安全中，以下（ ）不是常见的数据脱敏技术。

- A、数据加密
- B、数据掩码
- C、数据删除
- D、数据混淆

答案:C"

"Q1703、智能合约是在哪个区块链平台上首次引入的（ ）。

- A、Bitcoin
- B、Ethereum
- C、Litecoin
- D、Ripple

答案:B"

"Q1704、从职业标准角度看，数据安全工程技术人员在高级阶段最能体现“评估能力”的工作是（ ）。

- A、只会填写固定检查表
- B、能够制定评估制度、组织评估活动、综合分析结果并提出整改与持续优化方案
- C、只负责收集日志
- D、只负责采购评估工具

答案:B"

"Q1705、《网络安全法》（修订后条款编号已调整）中关于数据本地化与出境安全评估的核心规定包括下列哪一项？

- A、涉及个人信息和重要数据未做区分设计
- B、自评估的具体内容
- C、监管进行安全审查的标准
- D、需境内存储，若有需要境外提供，需经安全评估

答案:D"

Q1706、零知识证明只能是交互式的。（错误）

"Q1707、如果发生大规模个人信息泄露事件，个人信息处理者应立即采取补救措施，并通知履行个人信息保护职责的部门和个人。通知应当包括下列哪些事项？

- A、个人信息泄露的信息种类、原因和可能产生的危害
- B、个人信息处理者采取的补救措施
- C、个人可以采取的缓解措施
- D、个人信息处理者的联系方式

答案:ABCD"

"Q1708、某企业在评估数据流通、交易活动时，最不应忽视的环节是（ ）。

- A、数据来源合法性和授权边界
- B、办公区座位安排
- C、合作方市场宣传内容
- D、企业 Logo 设计

答案:A"

"Q1709、大数据隐私保护的方法包括以下哪项（ ）

- A、数据脱敏
- B、安全删除
- C、数据备份
- D、数据加密

答案:ABD"

"Q1710、数据出境安全评估中，关于""境外接收方数据保护水平""的评估要点包括哪些？

- A、境外接收方所在国的数据保护法律是否达到中国法律法规的要求
- B、境外接收方是否具备保障出境数据安全的技术和管理能力
- C、境外接收方的商业信誉和盈利能力
- D、合同条款对数据权益的保障程度

答案:ABD"

Q1711、电脑中有敏感文件，所以最好不要连接到咖啡厅的 wifi。（正确）

"Q1712、民法调整平等主体的自然人、法人和法人组织之间的（ ）和（ ）。

- A、权力关系
- B、利益关系
- C、人身关系
- D、财产关系

答案:CD"

"Q1713、某企业进行数据出境评估时，仅关注“是否签署标准合同”，忽略数据链路经过哪些国家和地区。其主要缺陷是（ ）。

- A、未评估跨境通信链路本身可能带来的安全风险
- B、标准合同已经足够覆盖所有风险
- C、链路国家与风险无关
- D、只要加密传输即可不做其他评估

答案:A"

"Q1714、开展数据处理活动应当加强风险监测，什么时候应该立即采取补救措施：

- A、数据安全缺陷
- B、漏洞
- C、输错口令
- D、口令遗忘

答案:AB"

"Q1715、根据《人脸识别技术应用安全管理办法》，使用人脸识别技术处理人脸信息的，应当取得（ ）同意。

- A、个人一般同意
- B、个人书面同意
- C、个人单独同意
- D、监护人代为同意

答案:C"

"Q1716、区块链中的钱包地址是（ ）的哈希值。

- A、私钥
- B、IP 地址
- C、公钥
- D、口令

答案:C"

"Q1717、网络运营者在公开收集个人信息的过程中，应当（ ）？

- A、不与被收集者沟通
- B、取得被收集者同意
- C、自动记录个人信息并保存
- D、对收集的规则和目的进行公开

答案:BD"

"Q1718、在进行系统备份时，以下哪种做法是不安全的？

- A、定期进行备份
- B、将备份存储在安全的位置
- C、允许未经授权的用户访问备份
- D、验证备份的完整性

答案:C"

"Q1719、修订后《网络安全法》是自（ ）年该法施行以来的首次重大修订。

- A、2015 年
- B、2016 年
- C、2017 年
- D、2019 年

答案:C"

"Q1720、账号锁定策略中对超过一定次数的错误登录账号进行锁定是为了对抗以下（ ）攻击。

- A、分布式拒绝服务攻击(DDoS)

B、病毒传染

C、口令暴力破解

D、缓冲区溢出攻击

答案:C"

Q1721、访问控制产品的技术指标主要包括产品的自身安全和质量保证级别。（错误）

"Q1722、国密算法 SM4 的密钥长度是（ ）比特。

- A、64
- B、128
- C、256
- D、512

答案:B"

Q1723、根据《个人信息保护法》的规定，个人信息主体有权向信息处理者主张告知全部信息处理事项。（错误）

"Q1724、（ ）负责统筹协调个人信息保护工作和相关监督管理工作。

- A、公安部门
- B、网信部门
- C、征信部门
- D、大数据局

答案:B"

"Q1725、根据《个人信息保护法》，处理敏感个人信息，应当取得个人的（ ）同意；法律、行政法规规定须取得书面同意的，从其规定。

- A、单独同意
- B、一般同意
- C、书面同意
- D、明示同意

答案:A"

"Q1726、某系统需要把数据传输给多个外部合作方。若不同合作方可见字段不同，最合理的架构方

案是（ ）。

- A、使用统一接口返回全量数据，由合作方自行过滤
- B、基于合作方身份和权限模板做差异化接口输出
- C、将数据库直接暴露给合作方
- D、通过邮件手工发送 Excel

答案:B"

"Q1727、在中华人民共和国境外处理中华人民共和国境内自然人个人信息的活动，下列哪个情形也适用本法：

- A、以向境内自然人提供产品或者服务为目的
- B、分析、评估境内自然人的行为
- C、法律、行政法规规定的其他情形
- D、以上全部

答案:D"

"Q1728、修订后的《网络安全法》关于人工智能的新增条款，包括以下哪些内容？

- A、国家支持人工智能基础理论研究和算法等关键技术研发
- B、推进训练数据资源、算力等基础设施建设
- C、完善人工智能伦理规范，加强风险监测评估和安全监管
- D、国家支持创新网络安全管理方式，运用人工智能等新技术，提升网络安全保护水平

答案:ABCD"

"Q1729、证书颁发机构（CA）的名称是什么？

- A、PKI 公钥基础设施
- B、Kerberos 认证协议
- C、CA 数字证书认证中心
- D、公安局

答案:C"

"Q1730、某平台平均响应时间（MTTR）长期偏高，最合理的改进措施是（ ）。

- A、标准化处置剧本、明确分工并引入自动化响应
- B、减少监控项
- C、关闭高风险告警
- D、仅增加周报频率

答案:A"

"Q1731、根据《个人信息保护法》，个人信息保护影响评估报告和处理情况记录应当至少保存（ ）年。

- A、一年
- B、两年
- C、三年
- D、五年

答案:C"

"Q1732、某企业数据安全年度总结显示，全年发现数据安全风险事项 127 项，已整改完成 98 项，其中高风险事项 5 项已全部完成整改，29 项中低风险待整改。下列评价正确的是？

- A、整改率 77%属于不合格
- B、高风险事项全部整改体现了正确优先级，但中低风险待整改项须纳入持续跟踪计划，建立闭环机制
- C、整改率超 70%即满足合规要求
- D、仅关注高风险整改率即可

答案:B"

"Q1733、开展数据处理活动，下列说法正确的是：

- A、遵守法律、法规，尊重社会公德和伦理
- B、遵守商业道德和职业道德，诚实守信
- C、履行数据安全保护义务，承担社会责任
- D、不得危害国家安全、公共利益，不得损害个人、组织的合法权益

答案:ABCD"

"Q1734、常见的数据格式有哪些（ ）。

- A、结构化数据

- B、非结构化数据
- C、半结构化数据
- D、以上全是

答案:D"

"Q1735、下列哪项关于区块链的定义是错误的？

- A、区块链信息服务是基于区块链技术或系统，通过互联网站、应用程序等网络平台提供的信息服务
- B、时间戳是对时间和其他待签名数据进行签名得到的，用于表明数据时间属性的数据
- C、上链是具有特定功能的区块链组件，可独立运行的单元
- D、智能合约是存储在分布式账本中的计算机程序，由区块链用户部署并自动执行，其任何执行结果都记录在分布式账本中

答案:C"

"Q1736、采用移动互联技术的系统主要包括移动终端、移动应用和无线网络等特征要素，下列哪项定级方式是错误的？

- A、作为一个整体独立定级
- B、与相关联业务系统一起定级
- C、各要素单独定级
- D、

答案:C"

"Q1737、某企业数据安全监测发现某数据库账户异地非常规时间登录。该行为应归类为？

- A、正常运维
- B、异常访问行为，需身份复核与权限审查
- C、网络延迟导致
- D、日志系统故障

答案:B"

"Q1738、数据生命周期是指对数据进行（ ）的整个过程。

- A、采集
- B、传输
- C、存储和使用
- D、删除和销毁

答案:ABCD"

"Q1739、区块链中的跨链技术（Cross-chain）用于解决什么问题？

- A、区块链的数据隐私保护
- B、区块链节点的身份验证
- C、区块链的共识算法优化
- D、不同区块链之间的数据互通

答案:D"

"Q1740、社会工程学是一种攻击技术，利用以下哪方面的原理？

- A、数学
- B、心理学和社交工程学
- C、物理学
- D、经济学

答案:B"

"Q1741、某企业数据合规团队发现，公司向境外提供的数据包含员工绩效评级，该信息结合其他数据可推断员工健康状况。该数据出境应如何处理？

- A、绩效评级非个人敏感信息，无需特别处理
- B、评估关联风险，按最高敏感级别履行出境合规义务
- C、脱敏后无条件出境
- D、内部审批后出境

答案:B"

"Q1742、在数据安全开发阶段，若要实现“数据在传输过程中未被篡改”的能力，优先应引入（ ）。

- A、完整性校验或数字签名机制

- B、删除数据库索引
- C、关闭日志
- D、减少服务器内存

答案:A"

Q1743、数据本地化（Data Localization）要求数据在本国境内存储或处理，是国家数据主权管控的常见手段之一。（正确）

Q1744、以太坊（Ethereum）区块链上的智能合约使用的编程语言是 Solidity。（正确）

"Q1745、某金融机构依据行标将""客户生物识别信息""定为 L4，但系统未实施加密存储。合规检查应指出？

- A、分级与防护可脱节
- B、分级结果需与技术防护强度匹配
- C、生物信息无需加密
- D、仅影响内部审计

答案:B"

"Q1746、常见的数据分类方法有哪些。

- A、根据数据类型分
- B、根据数据内容分
- C、根据数据权限分
- D、根据数据全生命周期分
- E、根据数据敏感程度分

答案:ABCDE"

"Q1747、某组织建立了数据资产清单，但未设置定期复核责任。该缺陷说明（ ）。

- A、资产识别缺少持续运营机制
- B、清单一经形成就永久有效
- C、主数据管理自动完成
- D、无需再做分类分级

答案:A"

"Q1748、某互联网 APP 遭爬虫恶意抓取用户公开信息。应急响应？

- A、实施反爬策略（IP 限频、验证码、协议加密），评估影响后处置
- B、关闭所有公开页面
- C、仅发律师函
- D、忽略，公开信息可爬

答案:A"

"Q1749、某互联网平台遭撞库攻击，因未实施异常登录风控。应？

- A、部署多因素认证、设备指纹、登录行为分析与限流策略
- B、仅加强验证码
- C、关闭注册功能
- D、仅修改密码

答案:A"

Q1750、本条例所称的计算机信息系统，是指由计算机及其相关的和配套的设备、设施（含网络）构成的，按照一定的应用目标和规则对信息进行采集、加工、存储、传输、检索等处理的人机系统。（正确）

"Q1751、《中华人民共和国民法典》规定，任何组织或者个人不得以（ ）、侵扰、（ ）、公开等方式侵害他人的隐私权。

- A、刺探
- B、售卖
- C、窥视
- D、泄露

答案:AD"

"Q1752、中国公民健康数据传至境外研究机构，依据《个人信息出境标准合同》必须？

- A、删除姓名字段
- B、境内存储分级主标签，境外用映射标签

C、降低分辨率

D、采用国密算法 SM4

答案:B"

Q1753、字典攻击是指攻击者使用常见的用户名和密码组合进行尝试，以猜测用户的凭据。（正确）

"Q1754、以下哪些是访问控制的实施步骤？

A、确定资产

B、分析安全需求

C、制定访问策略

D、实施物理访问控制

E、运行和维护访问控制系统

答案:ABCE"

"Q1755、对于谁有权对违反本法规定的行为向有关主管部门投诉、举报，以下说法正确的是：

A、任何个人、组织

B、只有企事业单位工作人员有

C、只有企事业单位有

D、只有私营企业有

答案:A"

"Q1756、配置如下两条访问控制列表：access-list 1 permit 10.100.10.1 0.0.255.255，access-list 2 permit 10.100.100.100 0.0.255.255。访问控制列表 1 和 2 所控制的地址范围关系是（ ）。

A、1 和 2 的范围相同

B、1 的范围在 2 的范围内

C、2 的范围在 1 的范围内

D、1 和 2 的范围没有包含关系

答案:A"

"Q1757、在数据资产地图建设中，下列哪项不属于推荐纳入的视图维度？

A、业务系统与数据关系视图

B、数据流转视图

C、责任主体视图

D、硬件设备采购视图

答案:D"

"Q1758、下列物件中不体现物联网智能处理特征的是（ ）。

A、数据库

B、虚拟机

C、云储存

D、智能卡

答案:D"

"Q1759、某医院发现其信息系统中存在一个已知漏洞（CVE 编号公开），但供应商尚未发布补丁。安全团队应采取哪些临时缓解措施？

A、对该系统实施网络隔离，限制对外访问

B、增加异常访问监控和告警

C、部署 WAF 等补偿控制措施

D、立即关闭该系统

答案:ABC"

"Q1760、国际电信联盟（ITU）发布名为《Internet of Things》的技术报告，其中包含。

A、物联网技术支持

B、市场机遇

C、发达中国的机遇

D、面临的挑战和存在的问题

答案:ABD"

Q1761、差分隐私中，隐私预算越大，添加的噪声越小，数据可用性越高。（正确）

"Q1762、数据处理者应当采取哪些措施来加强数据安全保护？

A、随意共享数据

- B、不进行任何加密处理
- C、建立数据安全管理制度
- D、忽视数据安全风险评估

答案:C"

"Q1763、某企业上线前未对新开发的数据接口进行鉴权测试，结果接口上线后被匿名批量调用。该问题反映出（ ）。

- A、接口安全测试缺失
- B、机房环境不达标
- C、备份策略不合理
- D、数据分类分级错误

答案:A"

"Q1764、关键信息基础设施安全保护应在网络安全等级保护制度基础上，实行重点保护，应遵循以下哪些基本原则？

- A、以关键业务为核心的整体防控
- B、以整体效益为目标的制度保障
- C、以风险管理为导向的动态防护
- D、以信息共享为基础的协同联防

答案:ACD"

"Q1765、修订后的《网络安全法》自何时起施行？

- A、2025-10-28
- B、2025-12-01
- C、2026-01-01
- D、2026-06-01

答案:C"

"Q1766、网络安全事件分为？

- A、安全隐患事件
- B、网络攻击事件
- C、数据安全事件
- D、信息内容安全事件

答案:ABCD"

"Q1767、《中华人民共和国民法典》规定，个人信息的处理包括个人信息的收集、存储、使用、加工、（ ）、提供、公开等。

- A、买卖
- B、传输
- C、删除
- D、管理

答案:B"

"Q1768、违反《中华人民共和国数据安全法》关于向外国司法或者执法机构提供数据的规定，未经主管机关批准擅自提供数据并造成严重后果的，处（ ）罚款，并可以责令暂停相关业务、停业整顿、吊销相关业务许可证或者吊销营业执照，对直接负责的主管人员和其他直接责任人员处五万元以上五十万元以下罚款。

- A、十万元以上一百万元以下
- B、五十万元以上一百万元以下
- C、一百万元以上五百万元以下
- D、一百万元以上一千万元以下

答案:C"

"Q1769、运营者发现使用的网络产品（ ）应当及时采取措施消除风险隐患，涉及重大风险的应当按规定向有关部门报告。

- A、服务存在安全缺陷
- B、收益未达到运营者期望
- C、使用了最新的支付系统
- D、无法从境外网络访问

答案:A"

"Q1770、下列哪些个人信息属于敏感个人信息？

- A、生物识别信息
- B、医疗健康信息

C、金融账户信息

D、行踪轨迹信息

答案:ABCD"

Q1771、算法推荐服务提供者可以将违法和不良信息关键词作为用户标签并据以推送信息。（错误）

"Q1772、应用软件的数据存储在数据库中，为了保证数据安全，应设置良好的数据库防护策略，以下属于数据库防护策略的是？

A、安装最新的数据库软件安全补丁

B、对存储的敏感数据进行加密

C、不使用管理员权限直接连接数据库系统

D、定期对数据库服务器进行重启以确保数据库运行良好

答案:ABC"

"Q1773、下面（ ）是强制访问控制（MAC）模型中的一个重要元素。

A、主体

B、客体

C、标签

D、规则

答案:C"

"Q1774、国家积极开展数据安全治理、数据开发利用等领域的国际交流与合作，参与数据安全相关国际规则和标准的制定，下列说法正确的是（ ）。

A、数据跨境需要监管

B、为了商业利益可以出售任何数据

C、直接将数据提交给国外司法机构

D、数据在交易之前应该接受审查

答案:AD"

"Q1775、某政务系统数据迁移至新平台，未实施完整性校验导致部分数据丢失。应？

A、忽略少量丢失

B、仅备份旧系统

C、迁移前后实施校验和比对，建立回滚机制

D、仅人工核对

答案:C"

"Q1776、通过 SDK 处理个人信息过程中常见的安全风险主要有以下哪些？

A、强制申请非必要的权限

B、私自向其他应用或服务器发送、共享用户个人信息

C、APP 对 SDK 收集使用个人信息的行为进行技术检测存在困难

D、私自通过自启动、关联启动等方式收集个人信息

答案:ABCD"

Q1777、媒体欺骗是指攻击者通过伪造图像、视频或音频材料来欺骗目标或引导他们执行某些操作。（正确）

"Q1778、某银行将存量客户贷款数据共享给集团内新设的金融科技子公司用于信用评分。合规审查应重点关注哪些要素？

A、共享前是否已取得客户充分告知和同意

B、金融科技子公司是否签署数据处理委托协议并明确安全责任

C、共享数据是否经过脱敏或最小化处理

D、金融科技子公司是否具有互联网增值电信业务许可证

答案:ABC"

"Q1779、应用安全，一般是指保障应用程序使用过程和结果的安全。以下内容中不属于应用安全防护考虑的是（ ）。

A、身份鉴别，应用系统应对登陆的用户进行身份鉴别，只有通过验证的用户才能访问应用系统资源

B、安全标记，在应用系统层面对主体和客体进行标记，主体不能随意更改权限，增加访问

C、剩余信息保护，应用系统应加强硬盘、内存或缓冲区中剩余信息的保护，防止存储在硬盘、内存或缓冲区的信息被非授权的访问

D、机房与设施安全，保证应用系统处于有一个安全的环境条件，包括机房环境、机房安全等级、机房的建造和机房的装修等

答案:D"

"Q1780、在数据资产治理中，“数据 Owner”的核心职责更偏向于（ ）。

A、承担业务层面的数据归属、使用授权与责任确认

B、负责机房空调维护

C、负责全部网络设备采购

D、仅负责数据库备份执行

答案:A"

"Q1781、某企业将敏感配置存放在共享网盘中供开发团队直接下载。相比集中式密钥管理，这种做法最大的缺陷是（ ）。

A、凭据分发和访问缺乏可控性与可审计性

B、能提高协作效率，风险更低

C、可替代审计系统

D、与数据安全无关

答案:A"

Q1782、口令认证可能面临的安全风险包括中间人攻击等。（正确）

"Q1783、根据《数据安全法》，开展数据处理活动应当加强风险监测，发现数据安全缺陷、漏洞等风险时，应当立即采取（ ）；发生数据安全事件时，应当立即采取处置措施。

A、停机措施

B、补救措施

C、公告措施

D、销毁措施

答案:B"

"Q1784、以下哪些属于数字证书认证中心（CA）的主要职责？

A、制定国家商用密码算法标准

B、签发数字证书

C、撤销数字证书

D、发布证书撤销列表（CRL）

答案:BCD"

Q1785、多因素认证（MFA）比单因素认证更安全。（正确）

"Q1786、VLAN 的网络隔离是通过以下哪种方式实现的？

A、逻辑上划分子网

B、物理隔离网络设备

C、使用防火墙过滤网络流量

D、加密网络通信

答案:A"

"Q1787、某企业进行个人信息保护影响评估时，发现同一数据字段在不同业务中用途差异极大。最合理的评估思路是（ ）。

A、按不同业务场景分别评估处理目的、必要性和风险

B、只评估一次即可

C、只看字段名称，不看场景

D、统一按最低风险处理

答案:A"

Q1788、访问控制是网络信息系统的基本安全机制。（正确）

"Q1789、加密文件系统（EFS）是 Windows 操作系统的一个组件，以下说法错误的是（ ）。

A、EFS 采用加密算法实现透明的文件加密和解密，任何不拥有合适密钥的个人或者程序都不能解密数据

B、EFS 以公钥加密为基础，并利用了 Windows 系统中的 CryptoAPI 体系结构

C、EFS 加密系统适用于 NTFS 文件系统与 FAT32 文件系统（Windows 环境下）

D、EFS 加密过程对用户透明，EFS 加密的用户验证过程是在登陆 Windows 时进行的

答案:C"

"Q1790、运营者应当自行或委托网络安全服务机构对关键信息基础设施的安全性和可能存在的风险隐患每年至少进行（ ）检测评估。

A、一次

B、两次

C、三次

D、四次

答案:A"

"Q1791、在网络中传输数据，如果由于网络质量不佳或拥塞而导致丢包，此时 TCP 协议会采用哪些动作保障数据完整性？

A、网络拥塞时，TCP 协议有拥塞控制机制，调整发送数据包的速率与流量避免拥塞

B、超时重传机制，保障传输数据的完整性

C、滑动窗口机制，动态适应网络变化与数据传输要求

D、切换到 UDP 协议，尽力传输

答案:ABC"

"Q1792、《网络数据安全条例》规定，大型网络平台服务提供者每年度应当（ ）。

A、向公安机关报告数据安全情况

B、发布个人信息保护社会责任报告

C、向国家网信部门报备用户数据

D、申请数据安全认证

答案:B"

"Q1793、根据《个人信息保护法》规定，以下哪些个人信息处理的行为是合法的？

A、未经同意更改个人信息适用范围

B、处理个人信息采取对个人权益影响最小的方式

C、收集范围限于实现处理目的的最小范围

D、保存期限为实现处理目的所必须的最短时间

答案:BCD"

"Q1794、根据《数据安全法》，从事数据交易中介服务的机构提供服务，应当要求数据提供方说明数据来源，审核交易双方的身份，并留存审核、交易记录。该规定的立法目的主要是？

A、增加交易摩擦成本

B、防范违法数据流通，明确数据交易责任链条

C、保护交易中介机构的商业利益

D、限制数据市场规模

答案:B"

"Q1795、电信业务经营者、互联网信息服务提供者应尽力优化用户体验，下列哪项行为是错误的？

A、开屏和弹窗信息窗口提供清晰有效的关闭按钮，保证用户可以便捷关闭

B、使用高灵敏度""摇一摇""方式诱导用户点击广告

C、清晰明示产品功能权益及资费等内容，存在开通会员、收费等附加条件的，应当显著提示

D、未经明示，不得在提供产品服务过程中擅自添加限制性条件，并以此为由终止用户正常使用产品功能和服务，或降低服务体验

答案:B"

"Q1796、《数据安全法》规定，国家支持哪些与数据安全有关的活动？

A、数据开发利用

B、数据交易

C、数据安全技术创新

D、数据安全宣传教育

答案:ABCD"

"Q1797、() 应当与关键信息基础设施同步规划、同步建设、同步使用。

A、安全背景审查

B、安全保护措施

C、网络安全检测

D、网络安全事件应急预案

答案:B"

"Q1798、最小权限原则的核心是 ()。

A、用户拥有所有权限

B、仅授予完成任务所需的最小权限

C、权限动态调整

D、权限不可撤销

答案:B"

"Q1799、MFA 洪水攻击的目的是什么？

A、窃取用户的个人信息

B、拦截用户的登录凭据

C、使用户对不断的推送通知感到沮丧和疲惫，从而误点同意

D、发送大量垃圾邮件给用户

答案:C"

"Q1800、基于风险的访问控制 (RAdAC, Risk-Adaptive Access Control) 主要根据什么动态调整用户访问权限？

A、用户的固定角色

B、实时风险评估结果 (含用户行为、环境、资源敏感度等)

C、系统管理员的手动配置

D、网络带宽占用情况

答案:B"

"Q1801、某企业分类分级项目预算有限，需优先覆盖高风险业务。实施顺序应为？

A、先边缘测试系统

B、先核心业务、含敏感/重要数据、对外交互频繁的系统

C、随机选择

D、仅处理历史数据

答案:B"

"Q1802、单点登录 (SSO) 是什么？

A、允许用户一次登录即可访问多个应用程序或系统的身份验证方法

B、只需要用户名即可登录的身份验证方法

C、只需要密码即可登录的身份验证方法

D、只需要生物识别即可登录的身份验证方法

答案:A"

"Q1803、在上线门禁策略中，如果所有高风险例外都走口头审批，没有留痕，最主要问题是 ()。

A、无法证明例外放行的合法性、必要性和责任归属

B、会提升系统吞吐量

C、会自动补全日志

D、会降低备份需求

答案:A"

Q1804、分析识别指为检验安全防护措施的有效性，发现网络安全风险隐患，应建立相应的检测评估制度。(错误)

"Q1805、51% 攻击能做什么？

A、修改自己的交易记录，使攻击者可以进行双重支付

B、改变每个区块产生的比特币数量

C、阻止区块确认部分或全部交易

D、把不属于他的比特币发送给自己或其他人

答案:AC"

Q1806、关键信息基础设施的运营者在中华人民共和国境内运营中收集和产生的重要数据的出境安全管理，适用《中华人民共和国网络安全法》的规定。

（正确）